

CISM: THE LAST MILE

YOUR GUIDE TO THE FINISH LINE

Coverage of the **2022–2027** edition of the **ISACA CISM exam**

A **consolidated study reference** to help you get further, faster in your CISM exam preparation

High probability exam topics, exam mindset, and key knowledge for every line item on the exam syllabus

Pete Zerger, CISSP, vCISO, MVP
creator of the popular YouTube study series

INSIDE CLOUD
AND SECURITY

CISM: The Last Mile

Your guide to the finish line

Pete Zerger

This book is available at <https://leanpub.com/cismlastmile>

This version was published on 2025-04-06



This is a [Leanpub](#) book. Leanpub empowers authors and publishers with the Lean Publishing process. [Lean Publishing](#) is the act of publishing an in-progress ebook using lightweight tools and many iterations to get reader feedback, pivot until you have the right book and build traction once you do.

© 2025 Pete Zerger

Contents

List of Figures	i
Preface (<i>Read this first!</i>)	iii
Legend	iii
CISM vs CISSP: What's the difference?	iv
Technology Perspective of the CISM Exam	v
Industry Guidance from ISACA	vi
Exam Format	vi
Exam Mindset	vii
CISM Exam Syllabus	ix
Questions and Errata	xi
Chapter 1: Domain 1A: Enterprise Governance	1
Syllabus	1
Supporting Tasks	1
Important Terms and Definitions	1
Planning Horizons	3
1A1. Organizational Culture	4
Information Security Governance	4
Enterprise Governance vs. Information Security Governance	5
Alignment with Business Objectives	6
Security Governance Principles	6
ISACA Code of Professional Ethics	8
Importance of Information Security Governance	8
Outcomes of Information Security Governance	9
Scope and Charter of Information Security Governance	10
Relationship of Information Security, IT Security, and Cybersecurity	11
Organizational Culture	11
Acceptable Use Policy (AUP)	12
Ethics	13
1A2. Legal, Regulatory, and Contractual Requirements	14
Compliance Requirements	14
Identifying Applicable Compliance Standards	15
Requirements for Business Record Retention	17
1A3. Organizational Structures, Roles, and Responsibilities	18
Board of Directors	18

CONTENTS

Senior Management	18
Chief Executive Officer (CEO)	19
Chief Information Security Officer (CISO)	19
Chief Privacy Officer (CPO)	19
Chief Risk Officer (CRO)	19
Risk Management Roles and Responsibilities	19
Security Steering Committee	20
Business Process/Asset Owners	20
Internal Audit	21
RACI Matrix	21
Keys to successful RACI implementation	22
Chapter 2: Domain 1B. Information Security Strategy	25
Syllabus	25
Supporting Tasks	25
1B1. Information Security Strategy Development	25
Three flavors of governance	25
Information Security Strategy Development	26
Business Goals and Objectives	26
Information Security Strategy Objectives	27
Ensuring Objective and Business Integration	27
Avoiding Common Pitfalls and Bias	28
The Desired State	29
COBIT	29
Business Model for Information Security (BMIS)	30
Strategy Development	32
Elements of a Strategy	33
1B2. Information Governance Frameworks and Standards	33
Balanced Scorecard	34
Architectural Approaches	35
Enterprise Risk Management (ERM) Frameworks	35
Information Security/Cybersecurity Management Frameworks and Models	36
1B3. Strategic Planning	37
Workforce Composition and Skills	37
Assurance Provisions	38
Risk Assessment and Management	44
Action Plan to Implement Strategy	46
Creating SMART Goals	48
SWOT	49
Capability maturity models	50
Information Security Program Objectives	51
Chapter 3: Domain 2A: Information Security Risk Assessment	53
Syllabus	53
Supporting Tasks	53
Governance, Risk, and Compliance	53

CONTENTS

Important terms related to risk	54
2A1. Emerging Risk and Threat Landscape	56
Risk Identification	56
Risk Categories (Risk Types)	57
Threats	59
Defining a Risk Management Framework	62
Emerging Threats	63
Risk Likelihood and Impact	66
Risk Register	67
2A2. Vulnerability and Control Deficiency Analysis	67
Methods for Identifying and Assessing Vulnerabilities	68
The Role of Controls and Deficiencies	68
Common Vulnerabilities	68
Key Resources and Vulnerability Categories	69
Vulnerability Management and Penetration Testing	69
Security Control Baselines	71
Events Affecting Security Baselines	73
2A3. Risk Assessment and Analysis	74
Determining the Risk Management Context	77
Operational Risk Management	79
Risk Management Integration with IT Life Cycle Management Processes	79
Risk Scenarios	83
Understanding Risk: A Breakdown	85
Risk Assessment Process	86
Risk Assessment and Analysis Methodologies	89
Other Risk Assessment Approaches	93
Risk Analysis	94
Formulas and Methods	95
Analysis Techniques	95
Gap Analysis	95
Qualitative Analysis	96
Semi-quantitative (Hybrid) Analysis	96
Quantitative Analysis	97
Value at Risk (VaR)	102
Other Risk Analysis Methods	103
Risk Evaluation	104
Deciding on Risk Treatment Options	105
Risk Ranking	106
Chapter 4: Domain 2B: Information Security Risk Response	107
Syllabus	107
Supporting Tasks	107
2B1. Risk Treatment/Risk Response Options	107
Determining Risk Capacity and Acceptable Risk (Risk Appetite)	108
Risk Response Options	109
Risk Acceptance Framework	110

CONTENTS

Inherent and Residual Risk	111
Impact	111
Controls	113
Legal and Regulatory Requirements	114
Compliance as a Business Decision	114
Cost-Benefit Analysis	114
2B2. Risk and Control Ownership	115
Risk Ownership and Accountability	116
Risk Owner	116
Control Owner	117
2B3. Risk Monitoring and Reporting	118
Risk Monitoring	118
Key Risk Indicators (KRIs)	118
Reporting Changes in Risk	120
Risk Communication, Awareness, and Consulting	121
Documentation	122
Chapter 5: Domain 3A: Information Security Program Development	124
Syllabus	124
Supporting Tasks	124
3A1. Information Security Program Resources	124
Information Security Program Overview	125
Information Security Management Trends	125
Essential Elements of an Information Security Program	126
Importance of the Information Security Program	126
Applying the Security Program Business Case	127
Outcomes of Information Security Program Management	127
Information Security Program Resources	130
Information Security Program Objectives	130
Information Security Program Concepts	131
Scope and Charter of an Information Security Program	132
Common Information Security Program Challenges	133
Common Information Security Program Constraints	134
Defining an Information Security Program Roadmap	136
Create a Program Roadmap Using Frameworks and Architectures	136
Developing an Information Security Program Roadmap	138
Benefits	139
Life Cycle Principles Supporting the Roadmap	140
3A2. Information Asset Identification and Classification	141
The Information Lifecycle	142
Information Asset Identification and Classification	143
Information Asset Identification and Valuation	144
Information Asset Valuation Strategies	144
Integrating Asset Classification with Risk Structures	146
Data Protection Technologies	148
Determine Criticality of Assets, Impact of Adverse Events	151

CONTENTS

3A3. Industry Standards and Frameworks for Information Security	152
Framework Types	153
Enterprise Information Security Architectures	154
Information Security Management Frameworks	156
Information Security Framework Components	160
Technical Components	161
Operational Components	161
Management Components	161
Administrative Components	162
Educational and Informational Components	162
3A4. Information Security Policies, Procedures, and Guidelines	163
Security Policy	163
Security Standard	164
Security Procedure	165
Security Guideline	166
3A5. Information Security Program Metrics	167
Effective Security Metrics	168
Security Program Metrics and Monitoring	169
Metrics Tailored to Enterprise Needs	170
Chapter 6: Domain 3B: Information Security Program Management	172
Syllabus	172
Supporting Tasks	172
3B1. Information Security Control Design and Selection	172
People, Process, Technology	172
Managing Risk Through Controls	174
Control Design Considerations	174
Foundational Technologies	178
3B2. Information Security Control Implementation and Integration	184
Control Categories	184
Baseline Controls	188
Integration of the Security Program with IT Operations	189
Personnel, Roles, Skills, and Culture	189
Information Security Liaison Responsibilities	191
Cross-Organizational Responsibilities	192
Issue Resolution Through the Information Security Program	192
Integration with IT Processes	193
Public Cloud	194
Network Security	200
3B3. Information Security Control Testing and Evaluation	203
Control Strength	204
Control Recommendations	206
Control Testing and Modification	207
3B4. Information Security Awareness and Training	209
Security Awareness Training and Education	209
Developing an Information Security Awareness Program	210

CONTENTS

Role-Based Training	211
Training and Education Metrics	212
3B5. Management of External Services	213
Governance of Third-Party Relationships	213
Third-Party Service Providers	214
Outsourcing Challenges	215
Outsourcing Contracts	216
Third-Party Access	217
3B6. Information Security Program Communications and Reporting	218
Program Management Evaluation	218
The Plan-Do-Check-Act (PDCA) Cycle	222
Security Reviews and Audits	223
Compliance Monitoring and Enforcement	224
Monitoring Approaches	225
Measuring Information Security Management Performance	225
Ongoing Monitoring and Communication	226
Chapter 7: Domain 4A: Incident Management Readiness	228
Syllabus	228
Supporting Tasks	228
4A1. Incident Response Plan	228
The Relationship Between Incident Management and Incident Response	229
Goals of Incident Management and Incident Response	230
Incident Handling and the Incident Management Life Cycle	231
Incident Management vs Incident Response	232
Incident Management and Incident Response Plans	233
Importance of Incident Management	233
Outcomes of Incident Management	234
Incident Management Resources	235
Policies and Standards	235
Incident Management Objectives	236
Strategic Alignment	236
Response and Recovery Plan	237
The Role of the Information Security Manager in Incident Management	237
Risk Management	238
Assurance Process Integration	238
Value Delivery	239
Resource Management	239
Defining Incident Management Procedures	240
Plan of Action for Incident Management	241
Current State of Incident Response Capability	244
Incident Response Life Cycle	244
Incident Management and Response Teams	246
Organizing, Training, and Equipping the Response Staff	246
Incident Notification Process	246
Challenges in Developing an Incident Management Plan	247

CONTENTS

4A2. Business Impact Analysis (BIA)	247
The Three Primary Goals of a BIA	248
Key Considerations in a BIA	248
Elements of a Business Impact Analysis	249
Typical BIA Information Collected	250
Benefits of Conducting a Business Impact Analysis	251
4A3. Business Continuity Plan (BCP)	252
Integrating Incident Response with Business Continuity	252
Methods for Providing Continuity of Network Services	253
High-Availability Considerations	253
Insurance	255
Cyber Insurance	256
4A4. Disaster Recovery Plan (DRP)	258
Business Continuity and Disaster Recovery Procedures	259
Recovery Operations	259
Evaluating Recovery Strategies	259
Addressing Threats	260
Recovery site strategies	260
Types of recovery sites	261
Basis for Recovery Site Selections	263
Response and Recovery Strategy Implementation	264
4A5. Incident Classification/Categorization	266
Escalation Process for Effective Incident Management	267
Help/Service Desk Processes for Identifying Security Incidents	268
4A6. Incident Management Training, Testing, and Evaluation	269
Incident Management Metrics and Indicators	270
Performance Measurement	271
Updating Recovery Plans	271
Testing Incident Response and BC/DR Recovery Plans	273
Periodic Testing of the Response and Recovery Plans	273
Testing for Infrastructure and Critical Business Applications	274
Types of Tests	275
Test Results	277
Recovery Test Metrics	277
Incident Management Metrics and Indicators	278
Updating Recovery Plans	279
Chapter 8: DOMAIN 4B: Incident Management Operations	280
Syllabus	280
Supporting Tasks	280
4B1. Incident Management Tools and Techniques	280
Incident Management Systems	281
Incident Response Technology Foundations	283
Personnel (IRT Structure)	284
Skills	286
Awareness and Education	286

Audits	287
Outsourced Security Providers	287
4B2. Incident Investigation and Evaluation	288
Executing Response and Recovery Plans	288
Foundational Concepts	289
4B3. Incident Containment Methods	295
Decision to Initiate Containment	297
4B4. Incident Response Communications (e.g., reporting, notification, escalation) . . .	297
Notification Requirements	298
Communication Networks	300
4B5. Incident Eradication and Recovery	301
Eradication Phase	302
Recovery Phase	303
4B6. Post-Incident Review Practices	304
Identifying Causes and Corrective Actions	305
Documenting Events	306
Establishing Legal Procedures to Assist in Post-Incident Activities	306
Requirements for Evidence	307
Legal Aspects of Forensic Evidence	307
What's Next?	309
Appendix A - Glossary (ISACA CISM Official)	311
1. Governance and Management	311
2. Risk Management	314
3. Security Program and Controls	316
4. Incident Management and Recovery	317
5. Technical Security Mechanisms	319
6. Network and Infrastructure Security	321
7. Threats and Vulnerabilities	324
8. Data and Asset Management	325
Appendix B - Acronyms (ISACA CISM Official)	328
Appendix C - Frameworks Reference	336
Index	338

List of Figures

Figure 1.	CISM vs CISSP Exam Focus	v
Figure 1.1.	Security Planning Horizons	4
Figure 1.2.	Information Security and Cybersecurity, Compared	11
Figure 1.3.	Sample RACI Matrix	22
Figure 2.1.	3 Levels of Governance	26
Figure 2.2.	BMIS Model	31
Figure 2.3.	Balanced Scorecard	35
Figure 2.4.	Popular Frameworks	36
Figure 2.5.	Centralized vs Decentralized Security	38
Figure 2.6.	Audit vs Assessment	39
Figure 2.7.	Audit Types Comparison	40
Figure 2.8.	Relationship of CSFs, KPIs, KRIs, and KGIs	47
Figure 2.9.	SWOT Matrix	50
Figure 2.10.	CMMI Levels	51
Figure 3.1.	Risk Boundaries	55
Figure 3.2.	Threat Actors, Attributes, and Motivations	61
Figure 3.3.	TAXII/STIX Process and Components	65
Figure 3.4.	Basic Risk Formula	66
Figure 3.5.	Vulnerability Management	70
Figure 3.6.	Risk Management, Assessment, and Analysis	76
Figure 3.7.	IT Risk Management Lifecycle	80
Figure 3.8.	Risk Heat Map	96
Figure 3.9.	Quantitative Risk Analysis Formulas	101
Figure 4.1.	Cost vs Level of Control	108
Figure 4.2.	Risk/Control Relationship	116
Figure 5.1.	SDLC (ISACA perspective)	141
Figure 5.2.	Functional perspective of the Information Lifecycle	143
Figure 5.3.	Mapping Business Functions to Risks	147
Figure 5.4.	Policy, Standards, Procedures, Guidelines	163
Figure 6.1.	Symmetric Encryption and Decryption	182
Figure 6.2.	Asymmetric Encryption and Decryption	182
Figure 6.3.	Hash Function (example)	183
Figure 6.4.	How Digital Signatures Work	184
Figure 6.5.	Cloud Shared Responsibility Model	196
Figure 6.6.	Cloud Deployment Models	198
Figure 6.7.	Virtual Local Area Network (VLAN) example	200

Figure 6.8.	Segmentation via Three-Legged Firewall Configuration	201
Figure 6.9.	IPSec Modes	203
Figure 6.10.	PDCA Cyle (for Info Security Program)	223
Figure 7.1.	NIST SP 800-61 Incident Response Process	245
Figure 7.2.	Types of Disasters	259
Figure 7.3.	RPO/RTO and Recovery Methods	261
Figure 7.4.	Relationship between BCM, BIA, BCP, and DRP	264

Preface (*Read this first!*)

When I created my various exam prep series on YouTube, my goal was to create resources full of valuable information, and at the same time, as concise and easy to understand as possible - without the fluff. My goal is the same for “CISM: The Last Mile”.

In this volume, we'll dig into the topics you need to know for exam day from ISACA's perspective, and the details you should commit to memory, without the distractions. And because it's on LeanPub, it's a *living book*. I'll make updates as necessary, and you'll always have access to the latest edition. This is one of many reasons this book is available *only on LeanPub*.

The intent is to provide you not only with the key CISM exam topics in a digestible format, but details of the applicable standards, policies, processes, and technologies. Then, I'll layer in context to ensure you understand the considerations and can apply these elements to solve problems presented in exam scenarios.

- Legend
- CISM vs CISSP: What's the difference?
- Technology Perspective of the CISM Exam
- Industry Guidance from ISACA
- Exam Format
- Exam Mindset
- CISM Exam Syllabus

Legend

Here's a quick legend detailing visual indicators and formatting you'll see throughout the book, designed to provide context and call your attention to important information.

This item is for **key takeaways**, **important notes**, **examples**, or **exam tips** related to essential exam topics.



This is an **exam tip** calling attention to shorter, important, or strategic considerations for exam day you should be aware of.



This is a note, additional reading, or other general information.



This is a **real-world tip**, referencing how a concept plays out in organizations around the world.



This is a **video link** to a topic in the CISM Exam Prep series (YouTube) or other related video resource.

NOTE ON CHAPTER HEADINGS: Headings from the exam syllabus are identical to the chapter and sections in this book. I've added a few sub-sections to ensure you see certain key exam concepts. For headings I've added, you'll notice they are in *camel case* (where Words in Heading are Capitalized). This is simply my preference but does not negatively impact the content in any way.

CISM vs CISSP: What's the difference?

I think ISC2 provides a great answer to this question:

Both the ISC2 Certified Information Systems Security Professional (CISSP) and ISACA Certified Information Security Manager (CISM) are highly sought-after IT security certifications.

What do they have in common?

- Each provides a common body of knowledge for information security professionals and managers around the globe.
- Both are vendor-neutral, require 5 years of experience in information security management to achieve, and mandate completion of continuing education to maintain.

How are they different?

From a competitive perspective, the CISSP and CISM complement rather than directly compete with one other.

- The CISM certification is almost solely management focused.
- The CISSP is both technical and managerial and designed for security leaders who design, engineer, implement and manage the overall security posture of an organization.
- CISSP is more widely known than CISM, with 136,428 CISSPs globally, compared with 28,000 CISM as of 2019, according to [an ISC2 article](#).

If I were to summarize, both certifications require a leadership mindset, but the nature of that leadership focus differs:

- **CISM:** More focused on *strategic leadership*, governance, and risk management. It assumes you have substantial foundational technical knowledge, but will not test you on it directly.
- **CISSP:** More focused on *technical leadership*, influencing others, and problem-solving. This exam covers a broad range of security technologies and will test you on the details of its application in solving problems.

Essentially, the CISSP exam trends more technical, and tests your technical knowledge more directly than it's true of the CISM exam. If you have passed the CISSP exam recently you likely have the technical knowledge you need and it's the process you need to focus on. If you haven't passed the CISSP, I have layered in the underlying technology that will help you on this exam throughout the book.

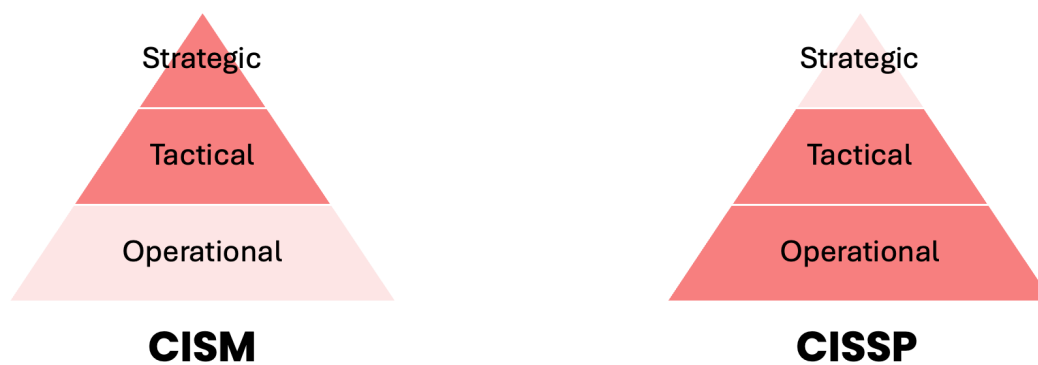


Figure 1. CISM vs CISSP Exam Focus

Technology Perspective of the CISM Exam

A CISM certification holder is primarily a leader of people and processes, whereas a CISSP certification holder is often a technical leader, influencing and guiding teams to achieve security objectives. As such, the CISM exam will be heavier on process and lighter on technology vs CISSP.

The CISM exam covers a wide range of technical topics, spanning everything from cryptography and network security to cloud and code security—to ensure you're familiar with key cybersecurity technologies. However, it's important to understand that the exam is fundamentally a **management** exam rather than a technical one.

Most of the technical content will likely surface within two sections within in Domain 3, which accounts for 33 percent of the exam. This means you can expect roughly 50 questions related

to Domain 3. HOWEVER, in practical terms, you'll likely encounter only a handful questions that focus directly on the technical material relating to Domain 3. You'll be tested on how to select and apply security controls, not on the specific details of how those controls operate or are configured.

So, while you should have a good grasp of these technical topics as part of your overall preparation, your focus should be on understanding them from a managerial perspective; integrating them with risk management and program design, rather than diving too deeply into the operational details.

Much like the CISSP exam, you need to approach CISM questions from the perspective of a security leader (manager, director, executive) rather than that of a technician.

NOTE ON ISACA EXAM PREP MATERIALS: ISACA says that when using the official CISM review material to prepare for the exam that candidate should not assume that reading their manual and answering the review questions will fully prepare them for the exam. The actual exam questions often relate to practical experience, technologies that employees would encounter on the job, and that exam candidates should draw on that real world experience.

Industry Guidance from ISACA

ISACA has developed and published several frameworks that are widely used in the IT security industry, most notably COBIT (Control Objectives for Information and related Technology).

In 2016, ISACA acquired the CMMI Institute, which is the steward of the Capability Maturity Model Integration (CMMI) model. Since then, ISACA has been responsible for maintaining, evolving, and promoting the use of CMMI.



For the exam, it's safe to assume that frameworks developed or managed by ISACA might be more likely to be included in exam questions.

Exam Format

Here's an overview of the key elements of the CISM exam:

Exam Costs & Format

- Member Price: \$575

- Non-member Price: \$760
- Duration: 4 hours
- Questions: 150
- Scoring Scale: 200-800
- Passing Score: 450

Testing Options

1. In-Person Testing

- Available at PSI Exams testing centers
- Requires government ID matching registration name
- No personal items allowed (notes, electronics, watches)
- Schedule through PSI website: <https://isacaavailability.psiexams.com>

2. Remote Testing

- Take exam from home/office
- Proctored via webcam
- Check ISACA website for current policies and requirements

Experience Requirements

- Total Information Security Experience: 5 years
- Information Security Management Experience: 3 years
 - Must cover at least 3 of 4 CISM domains

For complete exam details and registration, visit: www.isaca.org/credentialing/cism

Exam Mindset

It's important to adopt the appropriate mindset for this exam, which at the highest level is one of a security leader. If you've taken the CISSP exam some elements of what you'll see here will look very familiar. However, you'll find some subtle differences based on the less technical focus of the CISM exam versus the CISSP exam.

1. HUMAN SAFETY is the #1 priority of the security leader.
2. Security must MEET BUSINESS NEEDS.
3. Security must be COST EFFECTIVE.
4. MANAGEMENT BUY-IN is critical to program success.

5. POLICY is critical to program success.
6. Users must be TRAINED to follow policy.
7. Know the *flow* of the INCIDENT MANAGEMENT PROCESS.
8. Choose PROCESS OVER TECHNOLOGY.
9. Choose answers that meet PRIORITIES of the *security leader*.
10. EVERYONE in the organization is responsible for security.



You can leverage my READ strategy for difficult question evaluation I developed for CISSP exam candidates. However, do remember this exam is less technical, and that is reflected in the 10 tenets of CISM exam mindset listed here. You can find a video explaining that strategy on YouTube in “[CISSP EXAM PREP: Ultimate Guide to Answering Difficult Questions](#)”.

1. HUMAN SAFETY is the #1 priority of the security leader.

Human safety supersedes any business-related priorities. In situations where human safety is at substantial risk, choose the answer that protects people first.

2. Security must MEET BUSINESS NEEDS.

Security controls are not implemented for their own sake; they must serve the needs of the business. If a solution impedes the execution of normal business operations, it should be avoided.

3. Security must be COST EFFECTIVE.

When managing risk, security controls used to mitigate risk must cost less than the risk they’re defending against. It does not make sense to spend \$10,000 protecting against a \$5000 risk.

4. MANAGEMENT BUY-IN is critical to program success.

Any information security program that does not have the express support of management up to the executive level is doomed to fail.

5. POLICY is critical to program success.

Policies capture goals and objectives of the organization’s management. These goals then have to be passed on to employees who follow these policies and related procedures.

6. Users must be TRAINED to follow policy.

Users must be aware of policies in order to follow them. This often takes the form of security awareness training. And in some cases, such as with an acceptable use policy (AUP), users may be asked to sign the policy indicating they are aware of and accept the terms of that policy as a condition of access to company resources.

So, if you were to see a question that asked you what to do FIRST or NEXT, policy creation would always come before awareness training.

7. Know the *flow* of the INCIDENT MANAGEMENT PROCESS.

You have to IDENTIFY an incident... at which point you can DECLARE an incident... and then CONTAIN, ERADICATE, and RECOVER from an incident.

This exam roughly maps to the NIST incident management process. Focus on understanding the sense process flow and recognizing where you are in the process when confronted with a scenario-based question. That means you should know the difference between containment, eradication, and recovery.

8. Choose PROCESS OVER TECHNOLOGY.

Your role in this exam is one of a security leader. And the CISM exam is much more tactical and strategic than the CISSP exam and focuses much less on technology. Be very wary of any answer that involves a technical solution. Technical solutions or solutions with an operational focus will almost always be the wrong answer on this exam.

9. Identify focus within the CIA Triad

You may encounter questions that focus on confidentiality, integrity, or availability. If you can identify the focus of the question, you can rule out some wrong answers.

10. EVERYONE in the organization is responsible for security.

Everyone in the organization is responsible for security, from following company policies to protecting the safety of colleagues. The CISM champions a “shift left” approach to security, where risks are identified and mitigated earlier in the process.

CISM Exam Syllabus

The CISM exam consist of four domains. Each of those four domains can be divided into two parts, part A and part B. The full syllabus is shown below with some descriptive text explaining the focus of each domain.

DOMAIN 1. Information Security Governance (17%)

This domain focuses on *aligning information security strategies with overall business goals and objectives*. It covers the development and maintenance of security policies, accountability structures, and processes to ensure that senior leadership and stakeholders support and understand security initiatives.

- **A. Enterprise Governance** (Chapter 1)
 - 1A1. Organizational Culture
 - 1A2. Legal, Regulatory, and Contractual Requirements
 - 1A3. Organizational Structures, Roles, and Responsibilities
- **B. Information Security Strategy** (Chapter 2)
 - 1B1. Information Security Strategy Development
 - 1B2. Information Governance Frameworks and Standards
 - 1B3. Strategic Planning (e.g., budgets, resources, business case)

DOMAIN 2. Information Risk Management & Compliance (20%)

This area deals with *identifying and assessing information security risks*, and then *determining appropriate controls to mitigate these risks*. It also encompasses ensuring compliance with relevant legal and regulatory requirements, as well as establishing ongoing risk monitoring and reporting mechanisms.

- **A. Information Security Risk Assessment** (Chapter 3)
 - 2A1. Emerging Risk and Threat Landscape
 - 2A2. Vulnerability and Control Deficiency Analysis
 - 2A3. Risk Assessment and Analysis
- **B. Information Security Risk Response** (Chapter 4)
 - 2B1. Risk Treatment/Risk Response Options
 - 2B2. Risk and Control Ownership
 - 2B3. Risk Monitoring and Reporting

DOMAIN 3. Information Security Program Development & Management (33%)

In this domain, candidates learn how to *design, implement, and manage a comprehensive information security program*. It includes defining security objectives, allocating resources effectively, developing supporting processes and technologies, and measuring the program's effectiveness over time. In short, this is where *the plan is put into action*.

- **A. Information Security Program Development** (Chapter 5)
 - 3A1. Information Security Program Resources (e.g., people, tools, technologies)
 - 3A2. Information Asset Identification and Classification

- 3A3. Industry Standards and Frameworks for Information Security
- 3A4. Information Security Policies, Procedures, and Guidelines
- 3A5. Information Security Program Metrics
- **B. Information Security Program *Management*** (Chapter 6)
 - 3B1. Information Security Control Design and Selection
 - 3B2. Information Security Control Implementation and Integrations
 - 3B3. Information Security Control Testing and Evaluation
 - 3B4. Information Security Awareness and Training
 - 3B5. Management of External Services (e.g., providers, suppliers, third parties, fourth parties)
 - 3B6. Information Security Program Communications and Reporting

DOMAIN 4. Information Security Incident Management (30%)

This domain emphasizes *preparing for and responding to security incidents*, including detection and escalation procedures, incident response coordination, and post-incident investigation. It also addresses the critical role of business continuity (BC) and disaster recovery (DR), ensuring that incident management processes effectively align with or support the organization's BC/DR strategies to facilitate swift restoration of operations and minimize disruption.

- **A. Incident Management *Readiness*** (Chapter 7)
 - 4A1. Incident Response Plan
 - 4A2. Business Impact Analysis (BIA)
 - 4A3. Business Continuity Plan (BCP)
 - 4A4. Disaster Recovery Plan (DRP)
 - 4A5. Incident Classification/Categorization
 - 4A6. Incident Management Training, Testing, and Evaluation
- **B. Incident Management *Operations*** (Chapter 8)
 - 4B1. Incident Management Tools and Techniques
 - 4B2. Incident Investigation and Evaluation
 - 4B3. Incident Containment Methods
 - 4B4. Incident Response Communications (e.g., reporting, notification, escalation)
 - 4B5. Incident Eradication and Recovery
 - 4B6. Post-incident Review Practices

Questions and Errata

Have a question? Errata you'd like to report? Find a topic you think really belongs in the book? Contact me at lastmilebooks@outlook.com and let me know!

Now, let's get started with Domain 1.

Domain 1A: Enterprise Governance

Syllabus

1A. Enterprise Governance

- 1A1. Organizational Culture
- 1A2. Legal, Regulatory, and Contractual Requirements
- 1A3. Organizational Structures, Roles, and Responsibilities

Supporting Tasks

- 4. Integrate information security governance into corporate governance.
- 8. Define, communicate, and monitor information security responsibilities throughout the organization and lines of authority
- 21. Identify legal, regulatory, organizational, and other applicable compliance requirements.

I want to start with some foundational material that will support Domain 1A and indeed all that follow.

- Important Terms and Definitions
- Planning Horizons

Important Terms and Definitions

As we discuss organizational responsibilities, structure, and governance activities, a few terms will come up repeatedly that you should be familiar with. In particular, knowing the difference between *governance*, *strategy*, and *management* right from the start will pay dividends as you prepare:

- **Governance:** Ensures the needs of various stakeholders are evaluated to determine balanced, agreed-upon enterprise objectives. Those objectives are then used to set direction (through prioritization and decision-making) and to monitor performance and compliance

- **Strategy:** Defines the desired state of security for an organization, aligning with its business objectives. It outlines a roadmap for achieving this desired state by addressing identified risks and vulnerabilities.
- **Management:** Implements direction set by governance. Includes planning, building, operation, and monitoring activities, as well as managing operational risk tolerance

If you're a cybersecurity professional and somewhat technical in your focus, all this talk of governance and management can be confusing. *What's the difference?* Let's go a bit deeper than the definitions above.

- **Governance (C-level, strategic responsibility)**
 - Sets the “why” and “what”
 - Establishes the overall security vision and risk appetite.
 - Defines policies, standards, and frameworks.
 - Ensures alignment with business objectives and regulatory requirements.
 - Oversees the allocation of resources and prioritization of initiatives.
 - Monitors the effectiveness of the security program and ensures compliance.
- **Strategy (Bridging the Gap)**
 - Defines the “how” at a high level.
 - Translates governance directives into actionable plans.
 - Defines the roadmap for achieving the desired security state.
 - Identifies and prioritizes key security initiatives.
 - Develops and maintains security architectures and roadmaps.
 - Provides the framework for management to implement and operate effectively.
 - Focuses on broad objectives and high-level initiatives.
 - Defines “what” needs to be achieved and “why” it's important.
 - Outlines general approaches and key milestones.
- **Management (Operational responsibility)**
 - Executes the “how”.
 - Implements and maintains security controls.
 - Manages day-to-day security operations, including incident response and threat hunting.
 - Conducts risk assessments and vulnerability scans.
 - Ensures the proper functioning of security technologies.
 - Provides technical guidance and support to the organization.

In short:

- **Governance** provides the high-level direction and oversight.
- **Strategy** bridges the gap between governance and management by translating strategic objectives into actionable plans and roadmaps.
- **Management** executes the operational activities to implement governance and strategic objectives.

Planning Horizons

Planning horizons define the time frame for which an organization establishes its goals and strategies. Different planning horizons offer varying levels of detail and focus.

- **Strategic (3-5 year horizon, annual updates):**
 - **Long-term**, stable plan outlining the organization's overall direction.
 - Includes a comprehensive risk assessment to identify and mitigate potential threats.
 - Focuses on broad goals and objectives.
 - Executives (security leaders) focus is strategic.
- **Tactical (usually ~1 year):**
 - **Mid-term** plan that translates the strategic plan into specific actions.
 - Provides more detail on how to achieve the strategic goals.
 - Defines key milestones and resource allocation.
 - Managers and directors focus is most often tactical.
- **Operational (monthly, quarterly):**
 - **Short-term**, highly detailed plan based on the strategic and tactical plans.
 - Focuses on day-to-day activities and tasks needed to achieve tactical objectives.
 - Regularly monitored and adjusted to ensure alignment with broader goals.
 - Security and IT staff, as well as end users operate here.

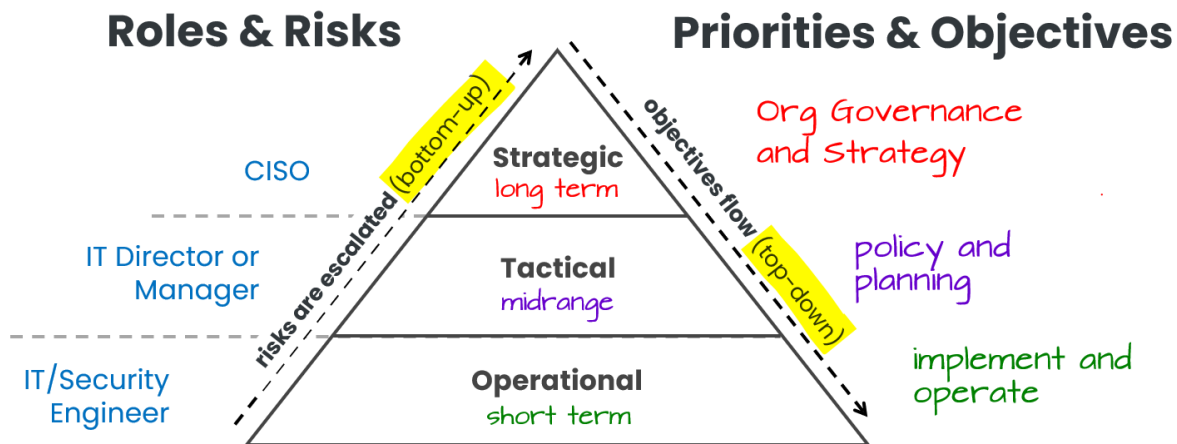


Figure 1.1. Security Planning Horizons



As a security leader (your role for the CISM exam), your focus will tend to be largely on the tactical and strategic.

1A1. Organizational Culture

Here are a couple of important terms and concepts that we'll dig into in this section:

- **Accountability:** The obligation to answer for one's actions, decisions, or results. Accountability cannot be delegated; it rests with the person who originally assigned the task.
- **Responsibility:** The duty or obligation to complete a task or achieve a specific goal. Responsibility can be delegated to others, but the delegator remains accountable for the overall outcome.
- **Span of Control:** The number of subordinates that report to a manager or that a manager can effectively supervise. By most accounts, and appropriate number of direct reports is less than 10.

Information Security Governance

Information security governance is a set of established top-down activities that helps management understand and control the organization's security program, current risks, and initiatives, while ensuring they align with and support business objectives. It operates through formal structures and processes that translate strategic objectives into actionable policies, controls, and metrics across all organizational levels.



The most important objective of an information security governance program is to ensure that the information security strategy is in alignment with the strategic goals and objectives of the business.

Enterprise Governance vs. Information Security Governance

Enterprise Governance is the overall framework of rules, policies, standards, and procedures that direct, monitor, and control all activities across an organization. It covers the organization's objectives, vision, mission, organizational structure, and leadership, ensuring that every part of the business aligns with its strategic goals.

Information Security Governance is a specialized subset of enterprise governance focused specifically on protecting the organization's information assets. While enterprise governance sets the broader direction, information security governance ensures that security policies and practices are integrated into business processes.

It is primarily the responsibility of the board of directors and senior management, often supported by an information security steering committee comprised of senior officials from various departments.

Key Takeaway: Information security governance is not a standalone effort but a subset of enterprise governance. It leverages the overall governance structure to embed security into every aspect of the organization, ensuring that both security risks and business risks are managed cohesively.

Three Steps for Establishing Governance

1. Define Objectives:

Determine the goals of the information security program, which are usually derived from risk management and the organization's acceptable level of risk.

Example: A bank might require its systems to be available 24/7. These security objectives must align with the organization's overall business objectives.

2. Develop Strategy and Requirements:

Conduct a gap analysis to assess the difference between the current state of security and the desired security objectives. Based on this analysis, the information security manager develops a strategy and sets requirements to move from the current state to the desired state.

3. Create a Roadmap for Implementation:

Outline a detailed plan with specific, actionable steps to achieve the security objectives. This roadmap should consider factors such as time constraints, resource availability, budget, and compliance with laws and regulations. The actionable steps are then implemented through appropriate security policies, standards, and procedures.

Alignment with Business Objectives

Business alignment means ensuring that an organization's information security program integrates seamlessly with the overall organization. This alignment requires understanding *two key areas*:

- **Organizational Foundation:**

- The organization's mission (purpose and who it serves)
- Established goals and objectives (what needs to be achieved and when)
- Strategic approach (specific activities needed to meet these goals)

- **Key Business Factors:**

- Organizational culture (how employees work and interact)
- Value of information assets (intellectual property, customer data, infrastructure)
- Risk tolerance levels
- Regulatory and legal requirements (GDPR, HIPAA, PCI DSS, etc.)
- Competitive position in the market

BOTTOM LINE: It's all about the business! The security program must understand and support these elements to effectively protect the organization while enabling its business objectives. This ensures security measures enhance rather than hinder the organization's operations and growth.

Security Governance Principles

Here are key principles providing input to security governance, along with questions to identify each principle for the organization, and some real-world examples

Values

What are our values? Ethics, Principles, Beliefs.

The fundamental standards and moral principles that guide decision-making and behavior within an organization's security framework.

Example: Microsoft lists diversity and inclusion, respect, integrity, and accountability amongst their corporate values.

Vision

What does the organization aspire to deliver?

A clear, aspirational statement of the desired future state of the organization's security posture and capabilities.

Example: Microsoft lists the following vision statement: "To democratize AI, making it accessible and beneficial for everyone."

Mission

What do we do what we do? What is our core purpose

A concise declaration of the organization's core purpose in implementing and maintaining security measures, and identification of key stakeholders being served.

Example: Microsoft's lists their mission as "To empower every person and every organization on the planet to achieve more".

Strategic Objectives

How are we going to progress? Plans, Goals, Sequencing.

Specific, measurable, and time-bound goals that outline the path toward achieving the security vision while aligning with organizational priorities.

Implementation and Key Performance Indicators

What do we need to do and how do we know when we achieved it? Actions, Resources, Outcomes, Owners, and Timeframes.

The tactical implementation plan consisting of specific tasks, assigned responsibilities, and measurable metrics that demonstrate progress toward strategic security objectives.

Core Purpose of Security Governance:

- Aligns security programs with business needs through strategic top-down control
- Ensures information security supports overall business objectives



A *top-down approach to governance and management* is considered critical, because it means the necessary executive-level insight and support is present.

ISACA Code of Professional Ethics

The Information Systems Audit and Control Association (ISACA) sets forth this Code of Professional Ethics, including standards, guidelines, and procedures, to guide the professional and personal conduct of members of the Association and/or its certification holders.



Adherence to the ISACA Code of Professional Ethics is testable on the CISM exam.

Members and ISACA Certification holders shall:

1. Support the implementation of, and encourage compliance with, appropriate **standards and procedures** for the effective governance and management of enterprise information systems and technology, including audit, control, security, and risk management.
2. Perform their duties with **due diligence and professional care**, in accordance with professional standards.
3. Serve in the **interest of stakeholders** in a lawful and honest manner, while maintaining high standards of conduct and character, and not discrediting the profession or the Association.
4. Maintain the **privacy and confidentiality** of information obtained in the course of their duties unless disclosure is required by legal authority. Such information shall not be used for personal benefit or released to inappropriate parties.
5. Maintain **competency** in their respective fields and agree to undertake only those activities that they can reasonably expect to complete with professional competence.
6. Inform appropriate parties of the results of work performed; revealing all significant facts known to them.
7. Support the **professional education of stakeholders** in enhancing their understanding of the governance and management of enterprise information systems and technology, including: audit, control, security, and risk management.

Importance of Information Security Governance

Think of this section as the “why” behind information security governance. The CISM exam will expect you to understand that it’s not just about technology, but a critical element of overall business success.

Information is a vital asset, and its security is paramount. Information security governance is no longer optional but essential for survival.

- **Key Benefits:**

- **Reduces Liability:** Protects the organization and its leadership from legal and civil repercussions due to data breaches or non-compliance.
- **Ensures Compliance:** Helps the organization adhere to policies and regulatory requirements.
- **Manages Risk:** Lowers operational uncertainties by identifying and mitigating risks to acceptable levels.
- **Optimizes Resources:** Provides a framework to allocate security resources effectively.

Outcomes of Information Security Governance

This is the “what” of information security governance. It defines the tangible results a successful governance program should deliver. A structured approach to security governance provides assurance to senior management that the organization’s security posture aligns with its strategic direction.

- **Six Basic Outcomes:** These are the expected benefits of information security governance:

1. **Strategic Alignment:**

- Security strategy supports business objectives.
- Security solutions are tailored to the enterprise’s specific context.
- Security investments align with the overall business strategy.
- **Exam Tip:** Understand that security requirements should always be driven by business needs. The CISM exam loves to test this.

2. **Risk Management:**

- Shared understanding of the organization’s risk profile.
- Proactive identification of risk exposure and potential consequences.
- Risk mitigation strategies to achieve acceptable residual risk.
- **Exam Tip:** Emphasis on a holistic understanding of risk, not just technical vulnerabilities.

3. **Value Delivery:**

- Security practices are standardized and proportionate to risk.

- Security overhead is minimized.
- Resources are prioritized based on risk and business impact.
- Cost-effective security solutions are implemented.
- Continuous improvement is embedded in the security program.
- **Exam Tip:** Focus on how security investments contribute to the bottom line.

4. Resource Optimization:

- Knowledge is effectively captured and disseminated.
- Processes are formalized in IT policies and procedures.
- Security architectures are developed to make efficient use of security resources.
- **Exam Tip:** CISM wants you to know that security resources (people, processes, technology) must be used efficiently.

5. Performance Measurement:

- Well-defined metrics aligned with strategic objectives.
- Processes to identify shortcomings and track progress.
- Independent assurance through audits and assessments.
- Criteria for selecting the most relevant metrics.
- **Exam Tip:** You can't manage what you can't measure. CISM emphasizes the importance of *relevant, measurable metrics*.

6. Assurance Process Integration:

- Coordination of all assurance functions within the organization.
- Clear roles and responsibilities to avoid gaps or overlaps.
- A holistic, systems approach to security management.
- **Exam Tip:** Security is not a siloed function. It must be integrated with other assurance activities.

What are “assurance processes”?

Assurance processes are the systematic methods and activities that provide confidence to an organization's leadership and stakeholders that security controls and policies are:

- effectively implemented
- operating as intended
- aligned with the organization's overall risk management and compliance goals.

Examples: Risk assessments, security audits, vulnerability scans, penetration testing, compliance reviews.

Scope and Charter of Information Security Governance

Official resources mention the scope and charter briefly in domain 1, so let's touch on the basic function of each:

- **Charter → Authority & Objectives:** Specifies *who* has the power to act, *what* they are responsible for, and *why* the information security program exists.
- **Scope → Coverage & Boundaries:** Defines *where*, *to whom*, and *to what extent* the information security program applies.

Typical Approach: Most organizations have a single security charter that includes both governance and operational aspects, alongside a clearly defined scope.

Relationship of Information Security, IT Security, and Cybersecurity

The CISM exam may assess your understanding of the differences and relationships between information security, IT security, and cybersecurity. This section explains the scope.

- **Information Security:** The broadest term. Covers all forms of information, regardless of location or format (digital or physical).
- **Cybersecurity:** A sub-discipline of information security. Focuses on threats in the interconnected digital world (e.g., malware, phishing, APTs).
- **IT Security:** A subset of information security, focusing specifically on protecting information within IT systems. It's a custodial function, meaning IT manages the systems but doesn't own the data.

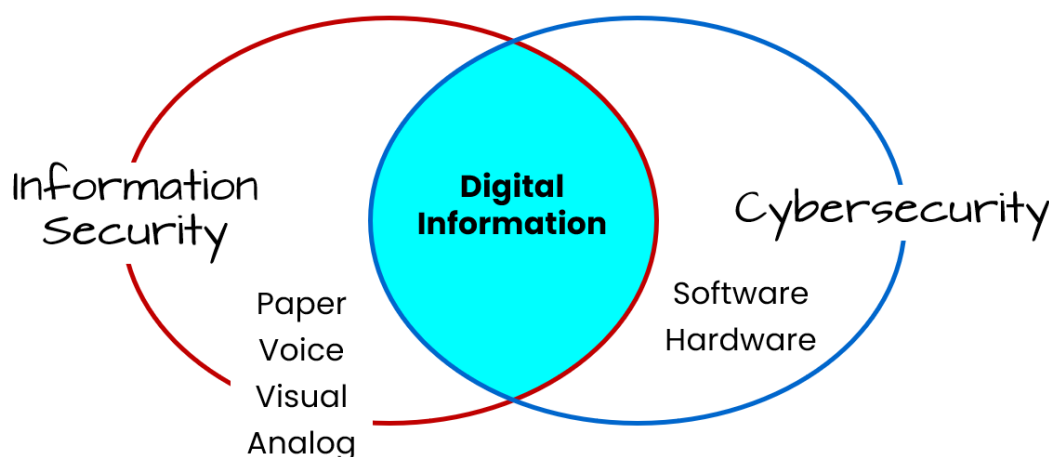


Figure 1.2. Information Security and Cybersecurity, Compared

Organizational Culture

Organization culture refers to how employees work and interact. Security isn't just about technology; it is about people and how they behave. A security-aware culture is essential for success. It is influenced by the behaviors, attitudes, and values of everyone in the organization.

- **Key Influences on Culture:**

- Transparency and accountability
- Formal and informal structures
- Attitudes and norms of behavior
- Level of teamwork
- Individual backgrounds and work ethics

- **Security Manager's Role:**

- Requires both technical and interpersonal skills.
- Must be able to build relationships and influence behavior.
- Should tailor communication to address individual needs and concerns ("What's in it for me?").

- **Indicators of a Positive Security Culture:**

- Security is integrated into projects early on.
- Employees know how to report incidents.
- Everyone understands their role in protecting information.

Exam Tip: Be prepared for questions that test your understanding of how organizational culture impacts security effectiveness. Remember that culture change takes *time* and consistent *effort*.

Acceptable Use Policy (AUP)

An **Acceptable Use Policy** is a formal document that outlines permissible activities and prohibited behaviors for all individuals interacting with an organization's information systems and data.

Scope

- Applies to anyone who uses or handles the organization's information assets (employees, contractors, third parties).

- Covers aspects such as access control, data classification and handling, reporting incidents, disclosure constraints, and mobile device usage.

Key Elements

A well-written AUP should include:

1. Permitted and Prohibited Activities

- Defines how resources (e.g., email, internet) may be used; includes expectations for data handling and storage.

2. Consequences of Violations

- Outlines disciplinary or legal actions for policy breaches.

3. Roles and Responsibilities

- Clarifies user accountability (e.g., safeguarding passwords, reporting suspicious activities).

4. Communication and Awareness

- Must be distributed, read, and acknowledged by all relevant parties.
- Ongoing training ensures continued compliance and alignment with organizational security practices.



Understand that AUPs need to be periodically reviewed and updated to remain current with changing technologies, threats, and legal requirements.

Exam Tip: The exam might present a scenario where the root cause of a breach is poor AUP adherence. Recognize that cultural and behavioral factors often underlie these failures.

Ethics

Ethics in the context of information security involves promoting and practicing behavior that respects laws, regulations, and the rights and welfare of others. Ethical conduct underpins trust in the organization's practices and is often integrated into the security code of conduct or broader professional code of ethics (e.g., ISACA Code of Professional Ethics).

The board of directors and senior management should model ethical behavior to shape the overall ethical climate. Ethical guidelines should align with the organization's mission, vision, and values.

CISM is management-focused; you won't be asked about philosophical ethics. Instead, expect scenario-based questions (e.g., handling data breaches, whistleblowing, etc.) where ethical obligations guide your next steps.

Exam Tip: Be prepared for exam questions asking how to handle ethical dilemmas (e.g., discovering wrongdoing, conflicts of interest). The CISM perspective emphasizes escalation, compliance, and organizational processes rather than acting unilaterally.

1A2. Legal, Regulatory, and Contractual Requirements

The section focuses on the influence legal, regulatory, and contractual requirements on the organization's information security governance

- Requirements for Content and Retention of Business Records
- Specific Laws and Regulations (e.g., GDPR, CCPA, HIPAA)

Due diligence refers to the reasonable steps an organization takes to identify, assess, and address cybersecurity risks. It involves proactively evaluating an organization's networks, systems, and data to uncover vulnerabilities and implement controls that protect against threats.

Examples of due diligence:

- Auditing IT infrastructure
- Testing incident response plans
- Providing cybersecurity awareness training
- Staying up to date on the latest threats

Due diligence provides information and insights that guide actions taken as part of the due care effort.



Due diligence is a key element of the leadership mindset you should understand for a successful CISM exam result. Due diligence will almost certainly appear on the CISM exam.

Compliance Requirements

Compliance speaks to an organization's adherence to the laws, regulations, standards, and contractual obligations that govern its operations. Supporting task 21 mentions identification of the following types of compliance obligations:

- Legal
- Regulatory
- Contractual

And there is a fourth type of compliance worth mentioning to complete the picture:

- Organizational

It's important you know the difference for exam day, so here are simplified definitions for legal, regulatory, and contractual requirements, with examples of each:

Legal Requirements:

- **Source:** Imposed by laws passed by government bodies
- **Scope:** Apply broadly to all organizations within the jurisdiction
- **Enforcement:** Mandatory compliance enforced by courts and government agencies
- **Example:** Data protection laws like GDPR

Regulatory Requirements:

- **Source:** Imposed by regulatory bodies or agencies to implement and enforce laws
- **Scope:** Apply to specific industries or sectors
- **Enforcement:** Compliance enforced by regulatory agencies through audits, fines, etc.
- **Example:** HIPAA for the healthcare industry

Contractual Requirements:

- **Source:** Imposed through legally binding agreements between organizations
- **Scope:** Apply only to the parties involved in the contract
- **Enforcement:** Compliance enforced through contract terms and potential legal action
- **Example:** Security and data protection clauses in vendor agreements.

Organizational Requirements

- These are internal policies and procedures established by an organization to ensure cybersecurity best practices.
- **Examples:**
 - **Access Control Policies:** Policies that define who can access specific systems and data.
 - **Incident Response Plans:** Plans for responding to security incidents, such as data breaches.
 - **Data Classification Policies:** Policies that categorize data based on its sensitivity.

Identifying Applicable Compliance Standards

Identifying the specific compliance standards your organization must adhere to requires a multi-faceted approach. Here are a few key steps in identifying compliance requirements and then effectively addressing them:

1. **Industry and Geographic Location:** There are compliance requirements that applied to specific industries, such as:
 - **Industry-Specific Regulations:**
 - **Healthcare:** HIPAA, HITECH
 - **Finance:** PCI DSS, SOX
 - **Education:** FERPA
 - **Geographic Regulations:**
 - **EU:** GDPR
 - **California:** CCPA, CPRA
2. **Data Processing Activities:** Handling of sensitive data, such as personally identifiable information (PII) and protected health information (PHI) necessitate compliance with certain laws and regulations.
 - **Personal Data:** GDPR, CCPA, HIPAA
 - **Payment Card Data:** PCI DSS
 - **Health Information:** HIPAA, HITECH
3. **Customer Contracts and Agreements:**
 - **Specific Requirements:** Some contracts may mandate compliance with certain standards. PCI DSS is an example of a compliance standard that is contractually enforced.
4. **Consult with Legal and Compliance Experts:**
 - **In-house Counsel:** If your organization has in-house legal counsel, they can provide guidance.
 - **External Counsel:** Consider hiring external legal counsel for complex compliance matters.
5. **Utilize Compliance Frameworks:** These compliance frameworks provide guidance on implementation of a secure information security program in various respects:
 - **NIST Cybersecurity Framework:** Provides a comprehensive approach to managing cybersecurity risk. Note this is purely optional guidance NIST provides for non-government entities.
 - **ISO 27001:** An international standard for information security management systems.

6. **Stay Updated on Regulatory Changes:** Regulations change over time, so responsible roles within the organization must remain a breath of any changes in regulatory obligations the organizations must adhere to.

- **Monitor Regulatory News:** Keep track of changes in regulations and standards.
- **Engage with Industry Associations:** Join industry associations to stay informed about regulatory developments.

7. **Conduct Regular Compliance Assessments:**

- **Gap Analysis:** Identify areas where your organization may not be fully compliant.
- **Risk Assessments:** Assess the potential impact of non-compliance.

Important activities that support the organization's compliance include:

- **Document Your Compliance Program:** Create a comprehensive compliance program that outlines policies, procedures, and responsibilities.
- **Train Employees:** Ensure that employees understand their compliance obligations.
- **Implement Strong Security Controls:** Protect sensitive data and systems.
- **Regular Monitoring, Auditing, and Testing:** Monitor and conduct periodic security assessments and penetration testing.
- **Respond to Incidents Promptly:** Have a plan in place to respond to security incidents.

By following these steps and working with legal and compliance experts, your organization can effectively identify and adhere to the appropriate compliance standards.

By understanding and adhering to these compliance requirements, organizations can protect their sensitive information, mitigate cyber risks, and maintain a strong security posture.

Requirements for Business Record Retention

Business record requirements refer to the legal and regulatory mandates for the creation, storage, retrieval, retention, and disposal of records relevant to the organization (e.g., email communications, financial documents, employee records). Different jurisdictions have specific regulations (e.g., GDPR in the EU, HIPAA in the U.S. healthcare sector) that dictate how long records must be kept and under what conditions they can be destroyed or released.

Some key considerations in determining retention requirements include:

1. **Applicability:** Recognize that the type of industry, region, and data involved will determine the specific retention requirements.
2. **Risk Management Ties:** Non-compliance can lead to legal, financial, and reputational risks. Hence, exam questions often focus on how security managers ensure compliance through policies, controls, and audits.

3. **Legal Issues:** A **legal hold** is a process where a company or individual preserves documents, emails, and other data that may be relevant to a lawsuit or investigation. Consider legal holds during litigation and how they affect record retention and incident response.

You won't need to memorize specific laws for the exam, but you should understand general principles, especially including how retention obligations shape an organization's security program.



Legal and regulatory requirements are the most important determinants of record retention. Records should be kept for the *longest required period*.

1A3. Organizational Structures, Roles, and Responsibilities

This section focuses on key organizational roles, both business and security focused, and their responsibilities in the envisioning, development, implementation, and operation of an information security program.

- Roles and Responsibilities
 - Board of Directors
 - Senior Management
 - Chief Executive Officer (CEO)
 - Chief Information Security Officer (CISO)
 - Chief Privacy Officer (CPO)
 - Chief Risk Officer (CRO)
 - Risk Management Roles and Responsibilities
 - Business Process Owners
 - Steering Committee

Here are the key governance roles and their respective duties:

Board of Directors

The highest governing body that oversees all organizational activities and holds ultimate responsibility for the organization's success. Their duties include selecting the CEO, implementing governance models, setting risk appetite, forming oversight committees, providing strategic guidance, and approving major organizational decisions.

Like executives, many boards have a **fiduciary duty**, meaning they are accountable to shareholders or constituents to act in the organization's best interests. Increasingly, information security and data privacy are being classified as part of this responsibility.

Senior Management

Senior management ensures that the board's intentions and requirements are implemented effectively and efficiently. They provide continuous support for information security projects by allocating budgets, resources, and necessary infrastructure. When conflicts arise between IT and security, senior management weighs performance, cost, and security factors to reach balanced decisions. Ultimately, they align security objectives with overall business goals.

Chief Executive Officer (CEO)

The top executive responsible for running all aspects of the organization who reports directly to the Board of Directors. Their duties include developing governance functions, managing organizational assets/budgets/personnel, implementing processes, overseeing risk management, and executing board directives.

Chief Information Security Officer (CISO)

The senior executive responsible for the organization's information security program and strategy. Their duties include developing and implementing security policies, managing risk programs, overseeing security operations (including incident management and vulnerability management), and ensuring security aligns with business objectives.

Chief Privacy Officer (CPO)

The executive responsible for overseeing the organization's privacy program and protection of sensitive information. Their duties include ensuring proper use of personally identifiable information (PII), advocating for customer privacy, establishing privacy controls, and coordinating with the CISO on information protection.

Chief Risk Officer (CRO)

The CRO is typically charged with overall enterprise risk management, which often includes information security. This role generally includes responsibility for mitigating business-related risk. Managing business related risk will often rely on information security to some degree, such as minimizing fraud in banking transactions Through the use of AI and machine learning.

Risk Management Roles and Responsibilities

Risk management involves identifying, assessing, and controlling risks that could impact the organization's objectives. While senior management is ultimately accountable for managing risk, everyone in an organization has some role to play in managing risk in with the circle of influence of the job role. For individual risks, two roles will be assumed by various members of the organization.

- **Risk Owners:** Individuals formally accountable for managing risks within their sphere.
- **Control Owners:** Those responsible for deploying and maintaining controls.

Example: In an ecommerce company, the CIO is the risk owner for data breaches, ultimately accountable for their prevention and mitigation. Meanwhile, the Network Administrator serves as the control owner, responsible for implementing and maintaining intrusion detection tools.

Security Steering Committee

The **Steering Committee** is a group formed within an enterprise that includes senior representatives of affected groups to ensure that all stakeholders impacted by security considerations are involved. It serves as an **effective communication channel** to align the security program with business objectives.

Responsibilities of the steering committee include:

1. Achieving Consensus on Priorities and Trade-offs

- Helps affected groups come to agreements on security priorities.
- Balances security needs with business objectives.

2. Aligning Security with Business Objectives

- Ensures that security initiatives support overall business goals.

3. Modifying Organizational Behavior

- Helps create a security-conscious culture within the enterprise.

4. Providing Oversight on Security Strategy

- Discusses and monitors security strategy and integration with business activities.

5. Tracking Progress of Security Implementation

- Reviews action plans and progress of security programs.

6. Addressing Emerging Risks and Compliance Issues

- Ensures awareness and response to new security threats, business risks, and compliance regulations.

Business Process/Asset Owners

These are management-level personnel who, while not necessarily technical experts, oversee business processes that often rely on IT systems. They make key business decisions that affect IT usage and security since they best understand their operational needs.

Core responsibilities might include:

- **Access Management**
 - Determine who gets access to assets and at what level (read, write, create, delete)
 - Decide when to revoke access rights
 - Conduct periodic access reviews to verify continued need
- **Asset Control**
 - Define required configurations for assets and applications
 - Determine physical location of assets based on security needs, operational efficiency, and legal requirements
 - Specify application functions and how they support business processes
- **Process Leadership**
 - Design and define business process workflows
 - Establish roles and responsibilities within processes
 - Determine process steps and sequences

Key Takeaway: While IT and security teams implement these decisions technically, the business owners make the fundamental decisions about their processes and assets based on operational requirements.

Internal Audit

An independent group that provides objective assurance on organizational controls and processes. Their duties include examining process designs, verifying control effectiveness, reporting to the audit committee, and maintaining independence from areas under review.

RACI Matrix

The **RACI matrix** is a management tool that clearly defines how responsibilities are shared across an organization. It prevents task overlap, ensures proper stakeholder involvement, and helps track who does what.

- **Responsible (R)** refers to roles that carry out the actual work involved. Each responsibility must have at least one responsible role, though multiple roles can be responsible. *Who drives outcomes, who is getting the task done?*
- **Accountable (A)** refers to roles with ultimate responsibility for achieving the objective - where “the buck stops”. Each responsibility must have exactly one accountable role. *Who accounts for the achievement of the task?*
- **Consulted (C)** refers to roles that provide subject matter expertise and input that affects the responsibility. *Who is providing input?*
- **Informed (I)** refers to roles that receive regular status updates but don’t provide input, unlike consulted roles. *Who is receiving information?*

Example: In cybersecurity incident response, the CISO might be accountable, while the incident response team is responsible, legal counsel is consulted, and the CEO is kept informed.



For the exam, remember that responsibility can be delegated, but accountability cannot. There may be multiple parties responsible (R), but only one party will be accountable (A).

Task/Activity	CISO	IR Team	Legal	CEO
Incident Response Management	A	R	C	I
Technical Investigation	A	R	C	I
Legal Compliance	C	I	R	A
Status Updates	R	C	I	A
Remediation Planning	A	R	C	I

Figure 1.3. Sample RACI Matrix

Keys to successful RACI implementation

Understanding the important considerations and steps in RACI development will be important on exam day. Here are the key concepts and considerations you should understand.

1. Define Roles and Responsibilities Clearly

- **Roles:** These are high-level positions or job titles (e.g., Project Manager, Developer, Designer, Marketing Manager).
- **Responsibilities:** These are specific duties and tasks associated with each role. For example, a developer's responsibilities might include coding, testing, and debugging.

2. Identify Key Tasks and Deliverables

- Break down the project into smaller, manageable tasks.
- Define the specific deliverables expected for each task.

3. Assign RACI Responsibilities

- **Responsible (R):** The person(s) primarily responsible for completing the task. There can be multiple (R)s for a task.
- **Accountable (A):** The person ultimately responsible for the successful completion of the task. There should only be ONE (A) per task.
- **Consulted (C):** People who need to be consulted or whose input is required before a decision is made or action is taken.
- **Informed (I):** People who need to be kept informed of the progress or outcome of the task.

4. Consider Skills and Expertise

- **Match skills to tasks:** When assigning (R)s, consider the specific skills and expertise required for each task. For example, if a task requires advanced coding skills, assign an experienced developer with those skills.
- **Allocate responsibilities based on expertise:** Ensure that individuals with the necessary skills and experience are assigned to tasks that align with their expertise.

5. Communicate and Review

- **Communicate the RACI matrix:** Share the completed matrix with the entire team to ensure everyone understands their roles and responsibilities.
- **Review and update regularly:** The RACI matrix should be a living document. Review and update it as needed throughout the project to reflect any changes in scope, team composition, or individual responsibilities.

Example:

Let's say you're creating a website:

- **Task:** Design the website's homepage.
- **R:** UI/UX Designer, Web Developer
- **A:** Project Manager
- **C:** Marketing Manager (for brand consistency)
- **I:** CEO, Client

Key Considerations:

- **Avoid ambiguity:** Make sure the RACI matrix is clear and unambiguous. There should be no confusion about who is responsible for what.
- **Minimize overlap:** Avoid assigning multiple (R)s or (A)s to the same task whenever possible. Overlapping responsibilities can lead to confusion and inefficiency.
- **Empower team members:** The RACI matrix should empower team members by clearly defining their roles and responsibilities.
- **Use the RACI matrix for effective communication:** The RACI matrix can be used as a communication tool to ensure that everyone is informed and aligned on project goals and objectives.

By carefully considering skills, roles, and responsibilities, you can create an effective RACI matrix that will help your team work more efficiently and effectively.

Domain 1B. Information Security Strategy

Syllabus

1B. Information Security Strategy

- 1B1. Strategy Development
- 1B2. Governance Frameworks and Standards
- 1B3. Strategic Planning

Supporting Tasks

- 1. Identify internal and external influences on the organization that impact the information security strategy.
- 2. Establish and/or maintain an information security strategy in alignment with organizational goals and objectives.
- 3. Establish and/or maintain an information security governance framework.
- 6. Develop business cases to support investments in information security.
- 7. Gain ongoing commitment from senior leadership and other stakeholders to support the successful implementation of the information security strategy.

1B1. Information Security Strategy Development

These topics cover development of the information security strategy, which covers objectives, resources, participants, and key constraints when formulating an information security strategy.

Three flavors of governance

Ahead of the sections that follow in this chapter, it will be helpful to understand the different elements of governance and their relationship.

Corporate governance is the exercise of a set of responsibilities and practices by the board and senior management with the goals of providing strategic direction, ensuring the business objectives are achieved, ascertaining that risk is managed appropriately, and verify that the enterprises resources are used responsibly.

Information security governance is a subset of corporate governance. It provides strategic direction for security activities and ensures that objectives are achieved. It ensures the information security risk is appropriately managed and the enterprise information resources are used effectively and efficiently.

Cybersecurity governance is a subset of information security governance. It focuses specifically on the governance of cybersecurity risks and controls.

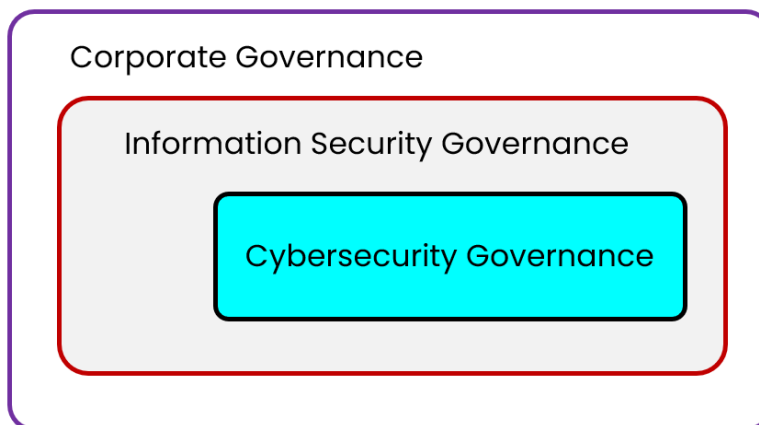


Figure 2.1. 3 Levels of Governance

Information Security Strategy Development

Information security governance is the board's and senior management's responsibility, though security leaders, business leaders, and outside experts may provide input to the process. It must be seamlessly integrated into overall enterprise and IT governance so that complex security challenges are met with transparent monitoring and effective compliance.

The strategy outlines how the information security manager will balance risk with resource optimization, providing a repeatable, mature approach (such as that defined by CMMI) that promotes collaboration across business areas.

Business Goals and Objectives

Corporate governance sets the strategic direction by ensuring objectives are met, risks are managed, and resources are used responsibly. *An effective security strategy must support this business direction by:*

- **Aligning with business objectives:** Security measures must enable and protect business processes.
- **Communicating purpose and protection:** Organizations must not only define what success means but also how they will protect their existence.

- **Integrating with IT architecture:** Once security requirements and outcomes are defined, a high-level security architecture (ideally developed alongside enterprise architecture) guides the implementation of controls.

Information Security Strategy Objectives

According to ISACA, the first question that must be entered when an organization is developing an information security strategy is:

What is the goal of the strategy and the program it enables?

A clear security strategy defines specific objectives and metrics. The **six key outcomes** to address are:

- **Strategic Alignment:** Linking security objectives and controls to the organization's strategic plan and goals.
- **Risk Management:** Embedding robust processes to identify, assess, and address threats to data's confidentiality, integrity, and availability.
- **Value Delivery:** Ensuring security investments optimize resources and produce measurable benefits (not just costs).
- **Resource Management:** Allocating people, budget, and tools efficiently to support the security program.
- **Performance Measurement:** Using KPIs, KRIs, and metrics to track and demonstrate the program's effectiveness.
- **Assurance Process Integration:** Coordinating internal/external audits and compliance activities within the security program.

Information security strategy assumes:

- Information assets are known
- Risks, threats, and security controls currently in place
- A data life cycle management process is in place

Because many enterprises lack a complete inventory of information assets, it is essential to:

- **Identify and value assets:** Understand what information exists and its importance.
- **Classify assets by sensitivity and criticality:** Ensure that protection efforts are proportional and cost-effective.
- **Assign clear ownership:** Every asset must have a defined owner and accountability.

Without these steps, it is *nearly impossible* to align security initiatives with business needs.

Ensuring Objective and Business Integration

A robust security strategy begins with long-term, well-defined objectives aligned to business goals. This prevents reliance on ad hoc solutions and ensures that:

- **Risk mitigation supports business activities:** For example, PKI may enable secure transactions or VPNs may support remote work.
- **Direct business linkages are established:** By mapping specific business processes (like manufacturing operations), security initiatives can reduce errors, prevent disruptions, and add tangible value.
- **Regular dialogue with business owners occurs:** Involving high-level representatives fosters ongoing integration and helps tailor security measures to real business needs.

Analogy: Imagine a road trip.

- **Long-Term Objectives:** Like setting a clear destination and stops, a solid strategy aligns security with business goals.
- **Risk Mitigation:** Planning alternate routes for potential roadblocks mirrors using PKI and VPNs to keep operations moving smoothly.
- **Business Linkages:** Choosing essential stops ensures every part of your journey adds value, just as linking security to specific business processes reduces errors.
- **Regular Dialogue:** Constant check-ins with travel companions reflect the need for ongoing discussions with business leaders to adjust plans as needed.

Avoiding Common Pitfalls and Bias

Effective strategy development requires awareness of decision-making biases that can distort planning. *Common pitfalls include:*

- **Overconfidence:**
Individuals often overestimate their ability to predict outcomes, resulting in overly precise estimates that may not be accurate. *This bias is especially harmful when evaluating an organization's core capabilities.*
- **Optimism:**
A natural tendency to forecast positive outcomes can lead to underestimating challenges and risks. *When combined with overconfidence, it creates unrealistic projections that can derail strategic planning.*

- **Anchoring:**
Initial figures or data can unduly influence subsequent judgments, causing later estimates to be based on outdated or irrelevant information. *This bias may lead to misaligned forecasts that fail to incorporate new variables.*
- **The Status Quo Bias:**
People tend to stick with familiar methods even when they are inadequate, due to a reluctance to change and fear of loss. *This bias discourages innovation and necessary shifts in strategy.*
- **Mental Accounting:**
Decision-makers often compartmentalize funds based on their source or purpose, leading to inconsistent and distorted financial decisions. *This can result in spending practices that do not reflect the true financial picture.*
- **The Herding Instinct:**
The desire for social validation may drive groups to conform to popular trends rather than making independent assessments. As a result, *strategies might be adopted simply because they are widely accepted, not because they are the best option.*
- **False Consensus:**
People frequently assume that others share their opinions and views, which can lead to overlooking critical risks or weaknesses. *This bias may cause strategic plans to persist even when they are fundamentally flawed.*

Additional cognitive biases such as confirmation bias, selective recall, biased assimilation, biased evaluation, and groupthink can further impair objective strategy development. Recognizing these biases helps ensure that decisions are based on balanced, accurate assessments.

The Desired State

The “desired state” is a complete, future snapshot of security that encompasses:

- Principles, policies, and frameworks
- Processes and organizational structures
- Culture, ethics, and behavior
- Information and technology
- People, skills, and competencies

Because security cannot be defined solely in quantitative terms, the desired state must include qualitative attributes and outcomes. Two common frameworks that provide guidance are COBIT and BMIS.

COBIT

- **What It Is:** An enterprise IT governance and management framework addressing IT risk, governance, and information security.
- **Focus Areas:** Covers topics such as cloud computing, DevOps, privacy, etc., each with relevant governance and management objectives.
- **Purpose:** Helps define and achieve the “desired state” for information security within broader IT governance.

COBIT is based on two sets of principles:

- Principles for a Governance System
- COBIT’s Principles for a Governance Framework

Governance System? Governance Framework? What’s the difference?

A **governance system** is the actual “operational” set of structures, processes, and organizational resources that an enterprise uses to govern IT and information security. A **governance framework** is the conceptual structure or “blueprint” that informs how to build and operate that system.

COBIT’s Principles for a Governance System

COBIT includes six principles that describe the **core requirements** a governance system.

1. **Provide Stakeholder Value** – Align security and IT with stakeholder needs.
2. **Holistic Approach** – View processes, structures, and information as an integrated system.
3. **Dynamic Governance System** – Adapt to changes in technology, threats, and business.
4. **Governance Distinct from Management** – Separate strategic oversight from day-to-day operations.
5. **Tailored to Enterprise Needs** – Customize to the organization’s size, culture, and risk appetite.
6. **End-to-End Governance System** – Encompass the entire enterprise, not just the IT function.

COBIT’s Principles for a Governance Framework

COBIT includes three principles that describe desirable characteristics *when building a governance framework*. It conveys that governance frameworks should be:

1. **Based on a Conceptual Model** – Identify key relationships among components for consistency/automation.
2. **Open and Flexible** – Incorporate new issues and content without losing integrity.
3. **Aligned to Major Standards** – Conform to recognized frameworks, regulations, and best practices.

Business Model for Information Security (BMIS)

BMIS emphasizes that security is not just the sum of parts (people, processes, technology) but how those parts interact within the organization. BMIS provides a holistic and dynamic approach to information security in the context of business.

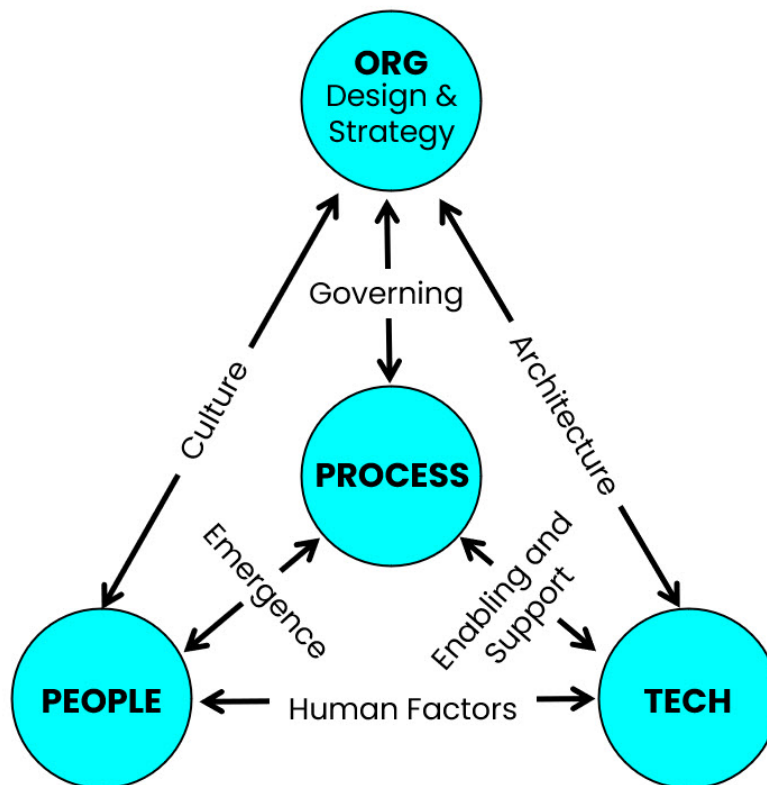


Figure 2.2. BMIS Model

- **Holistic View:** Defines an information security program is structured and how it responds to internal and external changes.
- **Four Core Elements** of the model (forming the 3D “pyramid”):
 1. **Organization Design and Strategy**
 - Defines business goals, missions, and how resources/roles interact.
 - Must adapt to internal/external factors.
 2. **People**
 - Human element of strategy (HR/security issues, roles, responsibilities).
 - Must account for behaviors, biases, and training.
 3. **Process**

- Formal/informal mechanisms to get work done, including risk and compliance processes.
- Must align with business requirements and adapt to changing needs.

4. Technology

- Tools, infrastructure, and applications that enhance processes.
- Always changing; introduces its own risks and cultural acceptance issues.

- **Dynamic Interconnections:** Six key “tensions” that push/pull on these elements, affecting security equilibrium:

1. Governance

- Strategic leadership, defining limits, monitoring performance, ensuring compliance, and adapting to change.

2. Culture

- Shared attitudes, beliefs, behaviors that influence how information is used and managed.

3. Enablement & Support

- Linking technology to processes via user-friendly security measures, policies, and procedures.

4. Emergence

- Unpredictable changes or new developments (feedback loops, process improvements, unexpected threats).

5. Human Factors

- Interplay between people and technology; includes training, cultural differences, and generational perspectives.

6. Architecture

- Formal encapsulation of how people, processes, policies, and technology fit together.
- Enables defense in depth and strategic security alignment.

Strategy Development

Development of an information security strategy starts with a **current state assessment**. It involves a comprehensive evaluation of the organization’s current security posture, including its assets, vulnerabilities, threats, and existing security controls. This assessment helps identify gaps in the organization’s security measures and provides a baseline for developing an effective information security strategy.

With the current state understood and the desired state defined, the security strategy outlines the path forward. It must:

- **Address risk and compliance:** Ensure risks are mitigated to acceptable levels while meeting legal and regulatory requirements.
- **Support business objectives:** Align security measures to *protect and enable business processes*.
- **Incorporate a range of solutions:** Use controls, process reengineering, and architectural modifications to achieve a *balance between security and operational efficiency*.
- **Include measurable checkpoints:** Regular reviews and metrics allow for mid-course corrections, ensuring that the strategy remains on track.



The exam might ask how to secure buy-in from key stakeholders outside IT (e.g., finance, HR) to ensure broad coverage and alignment.

Elements of a Strategy

A comprehensive security strategy is built upon a clear roadmap, an understanding of resources, and an awareness of constraints.

Roadmap: *The path to desired state.* A roadmap provides a guide to achieve desired state including people, processes, resources, such as tools and technologies. Key elements of a roadmap:

- Includes the steps required to achieve strategic objective(s).
- Outlines the short-term and long-term projects (involving people, processes, and technologies) needed to transition from the current to the desired state.
- Breaks down the overall goal into achievable, checkpoint-driven initiatives that allow for adjustments as conditions change.

Resources: *What you have to work with.* These are the tools, frameworks, and organizational elements you can leverage to build and maintain your security posture.

- Include policies, standards, procedures, guidelines, architectures, and controls (physical, technical, and procedural).
- Extend to personnel (skills, training, awareness), organizational structures, audits, compliance mechanisms, and technological tools.

Constraints: *What limits your actions.* These are the factors that restrict or influence how you can implement and maintain your security program. They can be

- Internal, like budget, company culture, personnel resistance, organizational structure, and risk appetite.
- External, such as legal and regulatory requirements.

By maximizing the use of existing assets and recognizing potential limitations, the strategy remains both effective and realistic.

1B2. Information Governance Frameworks and Standards

Effective information security governance requires management to define, implement, monitor, measure, and continually improve security practices. *A well-structured governance framework typically includes:*

1. **Alignment with Business Objectives**

A comprehensive security strategy that directly supports and advances the organization's overall goals.

2. **Clear Governance Structures**

Defined roles and responsibilities for every facet of security implementation and maintenance, ensuring accountability at all levels.

3. **Policies, Standards, Procedures, and Guidelines**

Consistent and uniform standards to support each policy, supplemented by detailed procedures and guidelines that enable practical application.

4. **Risk Management and Cost-Effectiveness**

A focus on identifying and mitigating risks through cost-justified controls and solutions, balancing security needs with financial considerations.

5. **Compliance and Continuous Improvement**

Ongoing monitoring to confirm adherence to policies and standards, alongside regular reviews and updates to address evolving threats and requirements.

Balanced Scorecard

The balanced scorecard is a strategic planning and management tool used to align organizational strategy and measure performance. It helps communicate priorities and monitor progress across four key perspectives:

- **Learning and Growth:** Employee skills, training, and organizational culture.
- **Business Process:** Efficiency and effectiveness of internal operations.
- **Customer:** Customer satisfaction and retention.
- **Financial:** Profitability, revenue growth, and shareholder value.

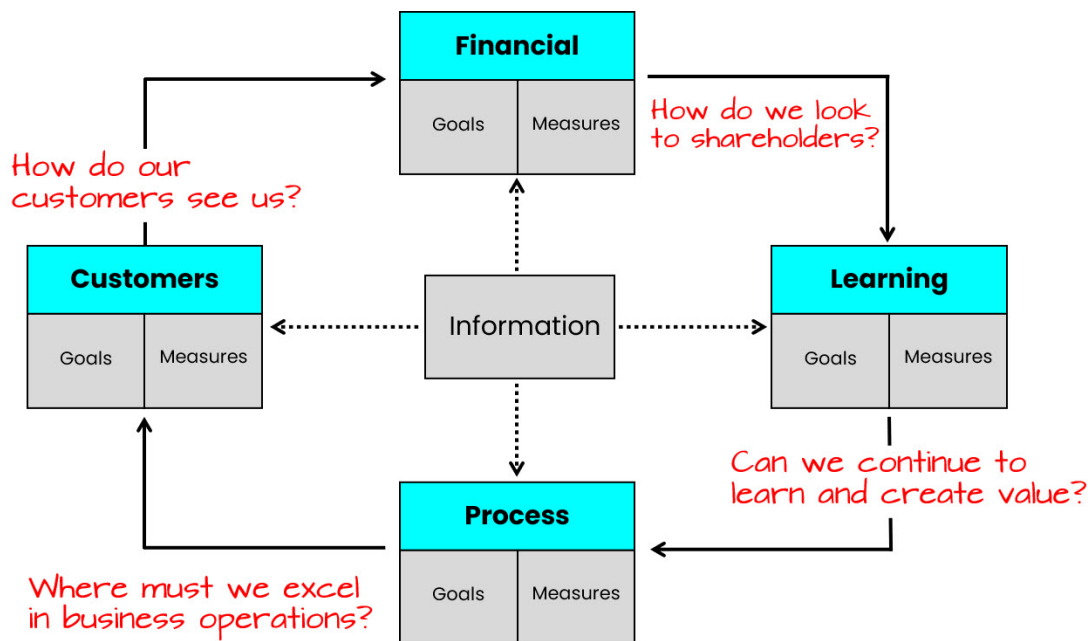


Figure 2.3. Balanced Scorecard

This approach helps in steering the organization towards strategic goals by balancing different perspectives.

Analogy: Think of the balanced scorecard as a car's dashboard; it displays different gauges (metrics) that together tell you how well the vehicle (organization) is performing.

Architectural Approaches

Enterprise Information Security Architecture (EISA) is part of the broader enterprise architecture. An architectural framework is like a set of blueprints; it provides the structure needed to develop various architectures, including business process, conceptual, logical, physical, functional, and operational.

Early methods focused only on IT, but modern approaches integrate business design and security requirements. Frameworks such as COBIT, TOGAF, the Zachman Framework, and the Extended Enterprise Architecture Framework (E2AF) link business processes with security needs.

The architecture should define a target or “desired state” (reference architecture). Frameworks provide with building blocks (policies, technologies) that make up the architecture, ensuring they work together towards common goals.

Enterprise Risk Management (ERM) Frameworks

ERM frameworks help organizations systematically plan and manage risks that could affect business objectives. *Key frameworks include:*

- **COSO ERM Integrated Framework:** Defines key risk management components and principles while promoting a common risk language.
- **ISO 31000:2018:** Outlines principles, a framework, and a process for managing risk, helping identify opportunities and threats.
- **British Standard (BS) 31100:** Provides a practical process aligned with ISO 31000 for identifying, assessing, responding, reporting, and reviewing risks.



Figure 2.4. Popular Frameworks

Information Security/Cybersecurity Management Frameworks and Models

In addition to broad ERM practices, there are specialized frameworks for managing information security risk:

ISO/IEC 27000 Series: Like a comprehensive medical textbook, it covers all aspects of information security management with 14 control areas. ISO 27001 is the certification standard, while 27002 provides the practical guidelines for achieving ISO 27001 certification. ISO 27002 provides a menu of potential controls, which are not mandatory. Organizations select controls tailored to their environment based on risk assessment.

NIST Cybersecurity Framework (CSF): Acts as a roadmap for improving cybersecurity, focusing on identifying gaps and aligning security practices with business needs. NIST CSF was designed for commercial (non-government) businesses, and is free, optional guidance for all organizations.

NIST Risk Management Framework (RMF): A systematic approach to integrating security into every phase of system development, ensuring that security evolves with the system. NIST

RMF was designed for U.S. government agencies and is mandatory for the agencies to which it applies.

Other Approaches: Various methodologies like ISO 9001 for quality management or Six Sigma can complement security strategies, much like different medical specialties contributing to overall health.

Combining these methods can enable development of a security strategy that leaves no risk unaddressed. Remember, while these frameworks provide structure, they should be scoped and tailored to fit the unique needs of the organization. While seemingly complex, this approach is often necessary for effective security program development in an enterprise.

1B3. Strategic Planning

Strategic planning is the final step in creating an effective information security strategy. These plans should mirror the enterprise strategy, including workforce and organizational structure, compliance with requirements, and activities to protect enterprise value.

Workforce Composition and Skills

Personnel are your first line of defense. Since insider actions (whether malicious or accidental) can cause the most damage, ensuring that both new and existing staff (including external service providers) are trustworthy and skilled is essential. Your security strategy should include clear requirements and plans for maintaining a reliable workforce.

Organizational Structure: A flexible structure facilitates security strategy development. Constrained structures can perceive security efforts as a threat. Information security's reporting structure has evolved from the CIO to C-level (CFO, CEO, Board) due to increased risks, losses, attacker sophistication, and inherent conflicts of interest between security and IT operations. Security needs to be aligned with the business, not just technology.

Centralized vs. Decentralized Security: The enterprise's culture influences the choice. Centralized approaches offer standardization but may not suit all organizational structures (e.g., multinational companies with varying legal requirements, acquired companies operating independently). Decentralized security allows for local responsiveness but can lead to inconsistent service quality.

Characteristic	Centralized Security	Decentralized Security
Consistency & Standardization	Higher	Lower
Adaptability to Local Requirements	Lower	Higher
Resource Efficiency	Higher	Lower
Response Time to Local Issues	Slower	Faster
Service Quality	Consistent	Inconsistent

Figure 2.5. Centralized vs Decentralized Security

Regardless of approach, all security programs must:

- Align with business goals
- Have senior management support
- Include monitoring and reporting
- Have crisis management procedures
- Maintain risk management
- Provide security awareness training

Employee Roles and Responsibilities: The strategy must define security roles and responsibilities, incorporated into job descriptions and linked to performance evaluations. HR and the information security manager should collaborate on defining roles, responsibilities, and required competencies.

Skills: A skills inventory is essential. The strategy should leverage existing skills where possible but also plan for developing new skills or procuring them externally. Performance testing can validate skill availability.

Awareness and Education: Periodic awareness training is important reduce end user vulnerabilities. Recurring awareness programs are essential and sometimes legally mandated. Training should be customized to the target audience and integrated with existing initiatives. Avoid overqualified hires who may become dissatisfied. Continuous training and career development are more economical and effective.

Assurance Provisions

Your strategy must include methods for oversight to ensure that the security plan is effectively implemented and maintained. These assurance provisions enable ongoing communication and reporting, confirming that compliance and security objectives are met.

Audit vs Assessment

As we dive into compliance, the terms **audit** and **assessment** will come up. It's important to understand the differences between them.

Audits are systematic evaluations of an organization's information system security against a set of established criteria or standards. Audits are a key tool for identifying deficiencies in controls and compliance.

Generally, an audit must be conducted by independent, certified auditors.

Assessments are informal security control reviews initiated by the security organization to improve processes.

- A security assessment is an evaluation of an organization's security posture, aimed at identifying vulnerabilities, threats, and risks to the organization's information assets.
- Unlike audits, they rely on employee interviews rather than independent testing to gather information.
- An assessment is focused on identifying and prioritizing risks so the organization can remediate where warranted.

Feature	Security AUDIT	Security ASSESSMENT
Focus	Compliance with standards/regulations	Identifying and prioritizing risks
Purpose	Verification	Evaluation and analysis
Formality	Formal, often by external auditors	Formal or informal
Outcome	Report on compliance gaps	Report on identified risks, gaps, and recommendations

Figure 2.6. Audit vs Assessment

Audit Types

- **Internal audits** are formal examinations of security controls and processes by the organization's internal audit team.
 - They provide a deeper understanding of the organization's current security posture from an insider's perspective.
 - Help ensure compliance with internal policies and external regulations.

- **External audits** are formal examinations conducted by third-party entities not directly affiliated with the organization. They provide an independent, objective evaluation of the organization's security posture. However, an important distinction is that external audits or assessments are **ordered by and under the control of the organization itself**.
- **Third-party audits** are *controlled by an external organization*. This could be a regulatory body, a customer, or another entity. The auditors are selected by the initiating organization (often a regulatory body or customer), and the organization being audited has little control over the process. Third-party audits are often conducted for regulatory compliance or contractual obligations.

NOTE: ISACA does not specifically define third-party audits as distinct from external audits. For the exam, you can file the third-party audit into the external category. However, it is still helpful to understand the distinction.

Third-party audits are performed by completely independent organizations with no ties to the organization. These could be specialized security firms, accounting firms with security practices (like Big 4 consultancies), or certified auditors. They bring complete independence and often additional specialized expertise or certifications (like PCI DSS assessors or SOC 2 auditors).



While not generally the case, in certain scenarios a third-party audit could be ordered by the organization itself, such as when a CSP (e.g., AWS, Amazon, GCP) wants a SOC 2 audit to provide assurance to customers on-demand for specific systems and services. *You'll find more info on SOC audits below.*

	Internal Audit	External Audit	Third-Party Audit
Who Initiates?	Organization itself	Organization or external stakeholder	Regulatory body, certification agency, or customer
Who Controls Scope?	Organization	Organization or external stakeholder	Regulatory body, certification agency, or customer
Who Performs?	Organization's employees (internal audit team)	External auditors (often professional firms or consulting companies)	Independent third-party auditors (certified professionals)

Figure 2.7. Audit Types Comparison

System and Organization Controls (SOC) Audits

To reduce the burden of multiple audits for organizations with large numbers of clients, like public cloud service providers (CSPs), standards like **Statement on Standards for Attestation Engagements (SSAE) 18** were developed by the American Institute of Certified Public Accountants (AICPA). For SOC audits specifically, they must be performed by a licensed CPA firm.

SSAE audits are known as **System and Organization Controls (SOC) audits**:

1. **SOC 1**: Assesses controls impacting financial reporting accuracy.
2. **SOC 2**: Evaluates security and privacy controls. Results are confidential. *Typically, the organization audited requires customers to sign an NDA to receive a copy.*
3. **SOC 3**: Similar to SOC 2, but results are for public disclosure.

Types of SOC 2 Reports:

You'll see two variations of the SOC 2 report mentioned:

- **Type I**: Auditor's opinion on management's control description and design suitability at a specific point in time.
- **Type II**: Includes Type I content plus assessment of control effectiveness over an extended period, usually six months or longer.

Type II reports are considered more reliable as they involve actual testing of controls.



The SOC 2 Type II report has become a de facto global standard for evaluation of security and privacy controls. This is the report most likely to appear on the CISM exam.

Audit Purpose, Characteristics, and Dynamics

The purpose, scope, and characteristics of an audit will vary, and internal and external audits are different in more respects than just by who conducts the audit. Below is a discussion of each aspect of an audit, including objectives, scope, qualifications of auditors, and audit methodologies, as well as audit assurance and objectivity from the perspective of both internal and external audits.

1. Objective

Internal Audits

- **Purpose**: Often focused on internal controls, operational efficiency, and continuous improvement.

- **Drivers:** May be initiated as part of organizational policy, management requests, or internal risk assessments.

Example: A cybersecurity team might audit password management policies to ensure employees are following requirements and to identify gaps before issues escalate.

External Audits

- **Purpose:** Primarily to satisfy regulatory requirements, contractual obligations, or industry standards (e.g., PCI DSS, HIPAA, ISO 27001).
- **Drivers:** Often mandated by external regulators, customers, or certification bodies; sometimes performed as part of due diligence for partners or investors.

Example: An external auditor might examine the same password management policies but with the main objective of demonstrating compliance to a third-party standard.

2. Scope

Internal Audits

- Determined by internal stakeholders (e.g., management, internal audit committee) based on organizational needs and risk priorities.
- **Flexibility:** Tends to be more flexible; internal auditors can adjust the scope as they discover new risks or areas needing attention.

Example: An internal audit may focus solely on a specific department's IT processes, or it can be broad, reviewing policies across multiple departments if needed.

External Audits

- Often defined by the requirements of a regulatory body, customer, or standard.
- **Boundaries:** Typically, more rigid, as external auditors must follow strict guidelines and predefined criteria for compliance or certification.

Example: An external audit might include only systems in-scope for a particular regulation (e.g., systems storing customer payment data), strictly following that regulation's defined boundaries.

3. Qualifications of Auditors

Internal Audits

- **Skills and Experience:** Internal auditors often have deep knowledge of the organization's processes, culture, and technology stack.
- **Independence:** While internal auditors strive for objectivity, there can be potential conflicts of interest if they are auditing areas in which they have direct involvement.

Example: An internal audit team might include IT professionals from elsewhere in the company who understand the internal network architecture intimately.

External Audits

- **Skills and Experience:** External auditors typically bring broad industry experience and might hold specialized certifications (e.g., CISA, CISSP).
- **Independence:** Strong independence and objectivity, because they are not employees of the organization they audit.

Example: A large accounting or consulting firm may provide specialized IT security auditors who follow formalized methodologies and best practices for external reviews.

4. Audit Methodologies

Internal Audits

- **Approach:** Can use a mix of formal and informal methods (e.g., interviews, policy reviews, automated scans) depending on the organization's standard procedures.
- **Sampling and Testing:** May be more flexible, focusing on areas where internal knowledge suggests the highest risk.

- **Adjustment and Iteration:** More likely to adjust methodologies mid-audit based on interim findings, since internal audits are often iterative and ongoing.

External Audits

- **Approach:** Generally, follows a prescribed framework or standard (e.g., ISO, NIST, COBIT), as these audits must demonstrate specific compliance outcomes.
- **Sampling and Testing:** Typically well-documented, with clear rules around sample size, selection criteria, and evidence gathering.
- **Reporting:** Must adhere to formal reporting standards; findings are often presented in an official report to regulators, customers, or certification bodies.

5. Assurance and Objectivity

Assurance in audits involves verifying accuracy and fairness, while objectivity ensures unbiased, credible results. Different types of audits carry varying independence levels and assurance guarantees.

- **Assurance** in the context of an audit refers to the level of confidence that stakeholders, such as management, regulators, or shareholders, can place in the audit findings.
- **Objectivity** in an audit is about ensuring that the audit process and its findings are free from bias, conflict of interest, or undue influence. An auditor's ability to remain independent and unbiased is crucial to maintaining the credibility of the audit report.

While assurance and objectivity will tend to be higher in external audits, organizations can take steps to ensure acceptable levels of assurance and objectivity are present in internal audits by ensuring staff conducting audits possess the proper skills and potential conflicts and bias are addressed through policy and leadership support.

Compliance Enforcement

Procedures for handling security violations are essential, with senior management support. Enforcement works best in organizations where security is viewed as *everyone's responsibility*, not just a set of rules to follow. Self-reporting and voluntary compliance are ideal in trusting environments. Prioritize compliance requirements based on risk and impact, as 100% compliance across everything may not be feasible.

Develop procedures to handle security violations, with strong backing from senior management. While a culture of trust and voluntary reporting is ideal, enforcement mechanisms must prioritize high-risk areas (for instance, where 100% compliance is non-negotiable, such as in nuclear operations). Keep in mind that leadership's commitment to compliance often sets the tone for the entire organization.

Risk Assessment and Management

A thorough risk management plan is essential. This plan should detail how the organization will:

- Identify, assess, and treat risks to enterprise assets
- Define risk tolerance, identification methodologies, and response strategies
- Continuously monitor risks over time

The plan must account for both external and internal threats, known and emerging threats, as well as the vulnerabilities that might be exploited.

The strategy should include a comprehensive risk management plan, addressing threats, vulnerabilities, and risk tolerance.

- **Business Impact Analysis (BIA):** Determines the consequences of losing confidentiality, integrity, or availability, often expressed financially. It informs information classification and business continuity planning.
- **Resource Dependency Analysis:** Similar to business dependency analysis but less granular, focusing on systems and resources critical to operations.
- **Outsourced Services:** Introduce risks due to differing standards and control levels. The strategy should address single points of failure and ensure backup plans. Cloud services and mergers/acquisitions present unique challenges.
- **Risk Assessment Process:** Involves identifying threats (physical, environmental, technological), assessing their likelihood and magnitude, and determining organizational vulnerabilities. Calculate probable annual loss expectancy to determine acceptable risk.
- **Threat Assessment:** Essential for cost-effective risk treatment. Consider threats proactively, even without known vulnerabilities. Policies should map to a threat profile.
- **Vulnerability Assessment:** Goes beyond technical scans to include physical elements, procedures, practices, and legal requirements. Address systemic weaknesses proactively.
- **Insurance:** Suitable for rare, high-impact events (floods, fire, embezzlement). Types include first-party (enterprise coverage), third-party (liability), and fidelity bonds (employee theft).

To ensure these types are clear, let's look at each type of insurance with examples:

- **1. First-Party (Enterprise Coverage):** This type of insurance protects *your* business or assets directly. It covers damage or loss to things *you* own.

Example: A fire damages your company's warehouse and destroys inventory.

Your first-party property insurance would cover the cost of repairing the warehouse and replacing the lost inventory.

- **2. Third-Party (Liability):** This type of insurance protects *you* from claims made by *others* who have been harmed (or claim to have been harmed) by your business operations. It covers your legal defense and potential payouts if you are found liable.

Example: When customers experience harm due to a data breach that your company is responsible for, they may file lawsuits to recover damages (e.g., credit score, loss of privacy). This would help cover the costs associated with these lawsuits.

- **3. Fidelity Bonds (Employee Theft):** These are not strictly insurance, but a type of surety bond. They protect *your* business from losses caused by the dishonest acts of *your* employees.

Example: An employee in your accounting department embezzles funds from the company's bank accounts. A fidelity bond would reimburse your business for the stolen money (up to the bond's limit).



NIST SP 800-37 rev. 2 [Risk Management Framework for Info Systems and Organizations](#) provides guidance on risk management strategy.

Action Plan to Implement Strategy

Implementation requires projects and initiatives. Gap analysis identifies the steps to move from the *current state* to the *desired state*. This plan should be reviewed and updated regularly to stay aligned with evolving business needs. *Key components in this conversation:*

Gap Analysis: Performed for various strategy components (maturity levels, control objectives, risk). Repeated regularly for performance metrics and mid-course corrections. Work backward from the endpoint (desired state) to the current state.

Action Plan Metrics: Monitor progress and costs. Use methods like balanced scorecards or CMMI for ongoing gap analysis. These metrics will include KPIs, CSFs, and KGIs.

- **Critical Success Factors (CSFs):** Essential elements required to achieve effective information security management outcomes aligned with business goals. CSFs are monitored through Key Performance Indicators (KPIs), which quantitatively measure progress.
- **Key Goal Indicators (KGIs):** Define clear, measurable objectives that describe what success looks like (e.g., achieving Sarbanes-Oxley compliance).
- **Key Performance Indicators (KPIs):** Measure progress towards KGIs (e.g., control effectiveness testing plans).

Also helpful are **Key Risk Indicators (KRIs):**

These are metrics used to identify potential risks that could negatively impact progress. KRIs provide early warning signals of potential problems. They are the “*what could go wrong*”.

When choosing metrics, consider what is important to manage information security operations, IT security management requirements, business process owner needs, and senior management needs.

- Focus on relevant metrics that inform decision-making.
- Categorize as strategic, tactical, or operational.
- Define near-term goals aligned with the overall strategy.
- Ensure integration of tactical activities with long-term goals.
- Distill technical data into useful management information.

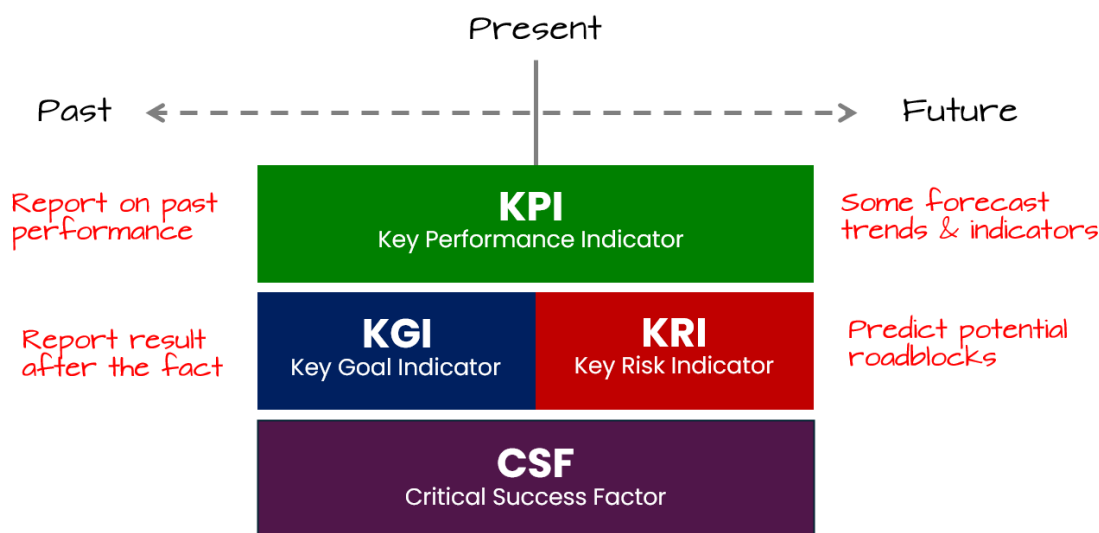


Figure 2.8. Relationship of CSFs, KPIs, KRIs, and KGIs

What visibility does each provide? Which are forward-looking or backward-looking?

- **Key Risk Indicators (KRIs)** are primarily *forward-looking*. Their purpose is to predict potential future risks and provide early warning signals. They aim to anticipate problems before they occur.
- **Key Performance Indicators (KPIs)** can be both *backward-looking* and *forward-looking*.
 - Many traditional KPIs are *backward-looking*, reporting on past performance (e.g., sales figures from the previous quarter).
 - However, some KPIs can be designed to be *forward-looking*, such as those that track trends or leading indicators (e.g., customer satisfaction surveys, which can predict future customer retention).
- **Key Goal Indicators (KGIs)** are primarily *backward looking*. They measure if a goal was achieved *after the fact*.
- **Critical Success Factors (CSFs)** are more of a foundation. They define what is necessary for success, so they are not strictly forward or backward looking. They are the present conditions that need to be maintained for future success. However, their application is for the future.

In summary, KRIs are strongly forward-looking, KPIs can be both, and KGI's are strongly backward looking.

- **CSFs** provide the *strategic direction*.
- **KPIs** *measure progress* toward that direction.
- **KRIs** monitor potential *roadblocks*.
- **KGI's** confirm final *goal acquisition*.
- Together, they form a comprehensive framework for managing performance and risk.

In essence:

- Organizations identify their CSFs.
- They then define KPIs to track progress toward those CSFs.
- Simultaneously, they establish KRIs to monitor potential risks.
- Finally, they use KGI's to confirm goal completion.

Creating SMART Goals

Organizations should focus on creating clearly articulated and achievable goals. SMART goals bridge strategic vision with operational execution, ensuring accountability and progress tracking in governance frameworks.

The *SMART* framework ensures that each goal is:

1. **Specific** - Clearly defines the desired outcome. For example, rather than “improve our vulnerability management program,” define the exact scope or improvement target.
2. **Measurable** - Establishes how success will be measured, such as a specific reduction in the number of critical vulnerabilities within a timeframe.
3. **Achievable** - Ensures the goal is realistic, given available resources and time.
4. **Relevant** - Aligns with the organization’s broader security and business objectives, so the outcome supports the strategic mission.
5. **Time-Bound** - Includes a deadline or schedule, such as “by the end of Q2,” so the organization can track progress.

Example of SMART Goal:

- Vague: “Improve vulnerability management.”
- SMART: “Reduce critical vulnerabilities by 80% in cloud environments through weekly scans and automated patching by December 2025.”

SWOT

Performing a SWOT analysis can guide decision-making about where to invest in controls and how to align security strategy with business objectives.

- **Strengths** – What characteristics of the organization or security program give it a strong advantage over others?
- **Weaknesses** – What characteristics of the organization or security program create a disadvantage or gaps in controls?
- **Opportunities** – What external factors can be leveraged to improve or advance the security posture?
- **Threats** – What external factors could harm the organization or diminish security efforts?

SWOT typically appears as a matrix, with internal factors (Strengths, Weaknesses) on one axis and external factors (Opportunities, Threats) on the other.

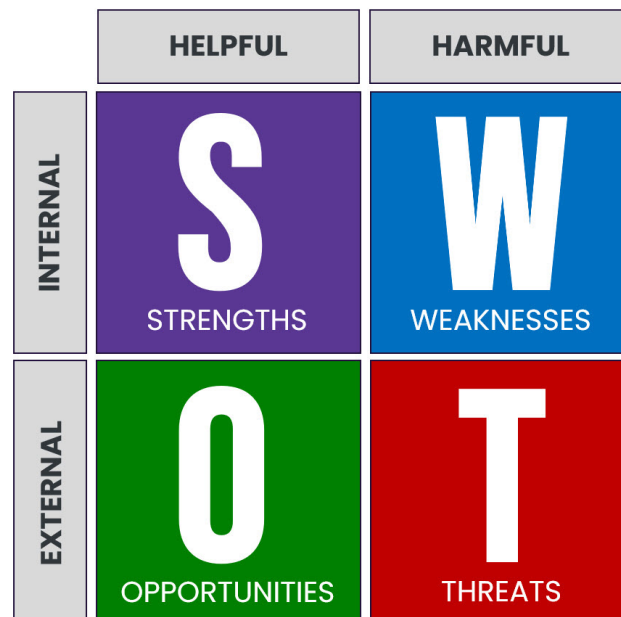


Figure 2.9. SWOT Matrix



For the CISM exam, you should remember that security leaders use SWOT to gain a comprehensive view of internal and external factors affecting the security program.

Capability maturity models

Capability maturity models are frameworks for assessing the maturity of an organization's processes. They describe how well-defined and repeatable a process is within an organization. Perhaps the most widely recognized is the **Capability Maturity Model Integration** for Development (CMMI-DEV) developed by Software Engineering Institute (SEI) at Carnegie Mellon University

Although there are variations across different frameworks, they generally follow five maturity levels:

1. Level 1: Initial

- Processes are ad hoc, inconsistent, unmeasured, and non-repeatable.

2. Level 2: Repeatable

- Processes occur consistently with predictable results; may be informally documented.

3. Level 3: Defined

- Processes are formally documented and standardized across projects or teams.

4. Level 4: Managed

- Processes are measured and controlled through metrics or KPIs.

5. Level 5: Optimizing

- Continuous improvement is embedded in the process, guided by data and metrics.

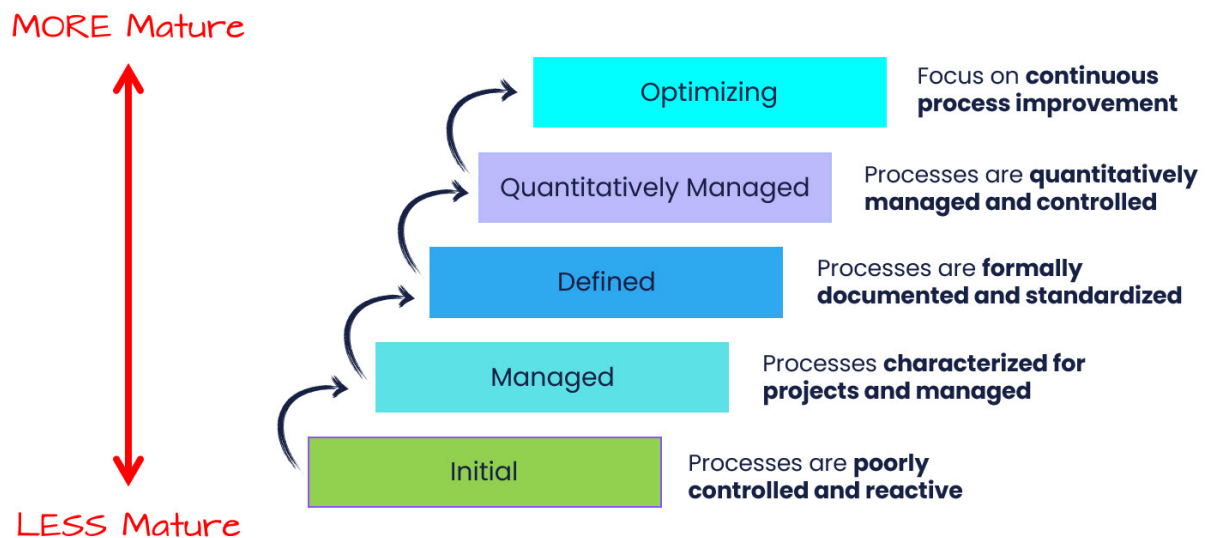


Figure 2.10. CMMI Levels

By using maturity models, security managers can systematically evaluate the current state of each process or control, define target states, and plan continuous improvements that align with organizational goals.

Note that *maturity can vary by control or process*. Each control or process should be assigned a maturity level that aligns with its importance and relevant risks.



Level 5 is not always the goal. Many organizations only require a maturity target in the range of 2.x–3.x due to cost and complexity, aligning with risk appetite and business objectives.

Information Security Program Objectives

The information security program implements the strategy. Its objective is to protect information and related processes/systems from harm (availability, confidentiality, integrity). When implemented, your security strategy evolves into an information security program; a comprehensive plan to safeguard the enterprise's information, systems, and communications.

Objectives apply to both electronic and physical systems. *The core objectives include:*

Confidentiality - Ensuring that private or sensitive information is accessible only to authorized individuals.

Example: Encrypting patient medical records so only doctors can access them.

Integrity - Safeguarding the accuracy and completeness of data to prevent unauthorized and improper modification.

Example: Using blockchain technology to create an immutable record of financial transactions.

Availability - Making sure that authorized users have timely and reliable access to information and associated assets when needed.

Example: Implementing redundancy and backup systems to minimize downtime for an e-commerce platform.

The security program meets the objective when information is available when it's needed (availability), only disclosed to authorized parties (confidentiality), and protected from unauthorized modification (integrity).

The priority of these objectives may vary by context. For example, confidentiality might be paramount in environments handling personal, financial, or sensitive proprietary information. Remember, both electronic and physical systems are at risk, and insider threats require as much attention as external threats.

Domain 2A: Information Security Risk Assessment

Syllabus

2A. Information Security Risk Assessment

- 2A1. Emerging Risk and Threat Landscape
- 2A2. Vulnerability and Control Deficiency Analysis
- 2A3. Risk Assessment and Analysis

Supporting Tasks

- 22. Participate in and/or oversee the risk identification, risk assessment, and risk treatment process.
- 23. Participate in and/or oversee the vulnerability assessment and threat analysis process.
- 26. Facilitate the integration of information risk management into business and IT processes.

Risk Management Program Objectives

The *main objective of a risk management program* is to identify, assess, and manage potential threats that could impede an organization's ability to achieve its goals. By systematically addressing uncertainties, whether operational, financial, or strategic, a risk management program helps ensure business continuity, protect assets, and maintain stakeholder confidence, all while aligning risks with the organization's defined risk appetite and tolerance.

Governance, Risk, and Compliance

Governance, Risk Management, and Compliance (GRC) is an integrated approach that combines governance, risk management, and compliance. It's a multifaceted system designed to ensure an organization follows established processes, policies, and regulatory requirements.

The three components of GRC are:

- **Governance:** The oversight provided by senior management and the board of directors. It establishes mechanisms to ensure personnel adhere to policies and procedures.

- **Risk Management:** The process of identifying, assessing, and mitigating potential risks to an organization. This involves:
 - Identifying potential risks and their impact.
 - Prioritizing risk mitigation based on business objectives.
 - Developing and implementing internal controls to manage risks.
- **Compliance:** The process of documenting, monitoring, and enforcing policies, procedures, and controls to ensure adherence to standards and regulations.

Important Considerations:

- Effective GRC requires establishing strong governance before addressing risk management and compliance.
- GRC software solutions are available to help organizations implement and manage GRC processes.
- GRC is commonly applied to financial, IT, and legal areas to ensure operational efficiency and regulatory compliance.

In essence, GRC provides a holistic framework for organizations to manage risk, ensure compliance, and achieve their business objectives.

Important terms related to risk

To ensure you fully understand the context as we go through risk, I want to preface your reading with some important foundational terms related to risk:

- **Risk appetite** is the total amount of risk that an organization is willing to take on in aggregate across all assets. Organization use its risk appetite to determine its **risk threshold**. This is level of risk that a situation must rise to *before* the organization chooses to take action to manage that risk. *It's the amount of risk an organization is willing to accept in pursuit of its goals.*
- **Risk tolerance** is the amount of risk that an organization will accept for a specific individual asset/threat pair, sometimes described as a specific business activity or pursuit. Tolerance is often aligned to a **risk target**, which is the preferred level of risk for a specific asset-threat pairing. *It's the acceptable range of variation around the expected level of risk for a specific activity.*
- **Risk Capacity** is the maximum amount of loss an organization can absorb before its survival is threatened. *This is the outermost boundary of risk.*

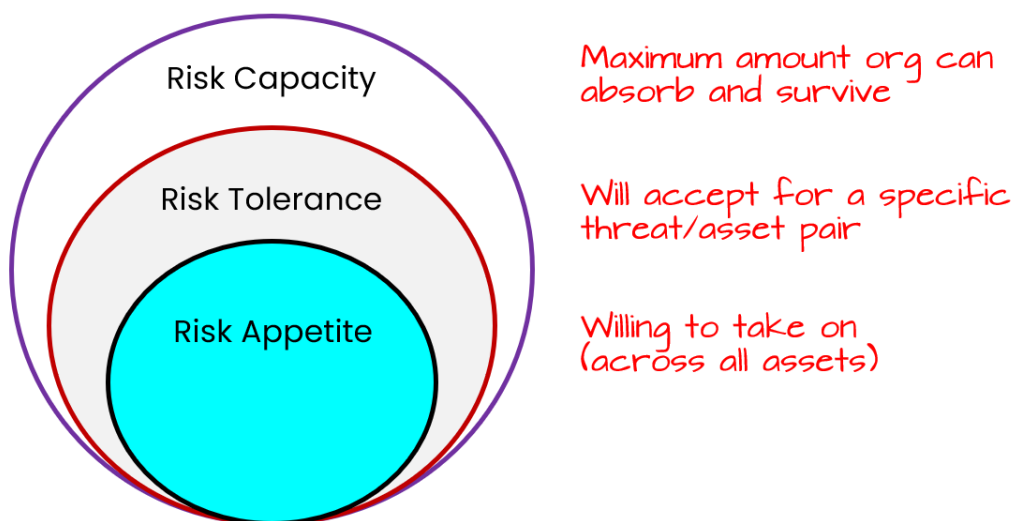


Figure 3.1. Risk Boundaries

Real-World Example: Imagine a small bakery.

Risk Appetite: The bakery's overall risk appetite is moderate. They're willing to take some risks to grow, like trying new recipes or investing in a new oven, but they're not willing to gamble the entire business. They've set a risk threshold: any single potential loss exceeding \$5,000 requires immediate management action.

Risk Tolerance: The bakery is considering a new delivery service. They've identified a risk: late deliveries leading to customer dissatisfaction. Their risk tolerance for this *specific* risk is low. They aim for a risk target: no more than 5% of deliveries being late. They are willing to accept a small variation (e.g., up to 7% late deliveries occasionally) but anything beyond that triggers action (e.g., changing delivery routes, hiring another driver).

Risk Capacity: The bakery's risk capacity is \$20,000. If a single event (e.g., a fire) or multiple simultaneous events were to cause losses exceeding this amount, the bakery would likely have to close permanently. *This is their absolute limit of acceptable loss.*

You should also be familiar with **inherent risk** and **residual risk**.

- **Inherent Risk** - The risk level or exposure arising from a specific risk before any action has been taken to manage it. Represents the worst-case scenario if no controls or other mitigating factors were in place. For example, the inherent risk of a cyberattack disabling critical infrastructure before any cybersecurity measures are implemented.
- **Residual Risk:** The risk remaining after management has taken action to mitigate inherent risk. Represents the remaining exposure after controls and risk response strategies

have been applied.

2A1. Emerging Risk and Threat Landscape

Enterprises operate in rapidly changing environments—business conditions, regulatory requirements, geopolitical events, and technology all evolve. A clear example is how the COVID-19 pandemic drove a sudden shift to remote work, creating new exposures in areas such as access management, data privacy, and regulatory compliance.

An information security manager must regularly assess how such changes affect:

- The organization's information assets
- Core business processes
- Compliance obligations (e.g., privacy, security, regulatory)

Because the overall risk profile can shift quickly, organizations should anticipate new threats, plan for various scenarios, and be ready to adapt security controls to evolving circumstances.

Risk Identification

Before an enterprise evaluates potential and emerging risks, it must determine how to *identify risk*. This involves:

1. **Identifying Potential Threats:** Determine all possible threats (whether technical, physical, or operational) that could exploit the enterprise's vulnerabilities.
2. **Examining Vulnerabilities:** Identify weak points in systems, processes, and personnel that, if targeted by a threat, would result in risk.
3. **Recognizing Assets (Including Third Parties):** Consider assets beyond the organization's direct control (e.g., data or services hosted by vendors, contractors, or cloud providers).

Only once a threat–vulnerability pair is identified can that risk be **assessed** (in terms of likelihood and impact) and effectively **treated** (through mitigation, transfer, or acceptance).

Risk identification is typically carried out by a knowledgeable, cross-functional group using methods such as:

- **Workshops:** Gather diverse stakeholders for brainstorming, building consensus, and leveraging multiple viewpoints.
- **Structured Techniques:** Use tools like flowcharts, system design reviews, systems analysis, hazard and operability studies, and operational modeling to systematically uncover vulnerabilities.
- **What-If and Scenario Analysis:** Examine less defined or emerging situations (e.g., strategic risks or changes in technology) and project potential outcomes and impacts.

- **Threat Mapping:** Correlate internal and external threats with known or suspected vulnerabilities to see where the organization is most at risk.

Because attackers' methods are continuously evolving, and organizations can overlook certain vulnerabilities, it is challenging to identify all risks perfectly. However, ongoing awareness, periodic re-evaluation of assets and controls, and collaborative brainstorming can substantially reduce the chance of successful attacks.

Risk Categories (Risk Types)

The CISM exam covers a wide range of risk categories, including:

Strategic Risk

Strategic risks threaten an organization's ability to achieve its strategic objectives. They can arise from factors such as poor decision-making, changes in the competitive landscape, or emerging technologies. Strategic risk can be categorized into two sub-categories: business risks and non-business risks.

- **Business Risks:** These risks arise from internal factors within the organization, such as poor management decisions or ineffective strategies. For example, a company might make a poor decision to expand into a new market without conducting proper due diligence, leading to financial losses.
- **Non-Business Risks:** These risks arise from external factors outside the organization's control, such as changes in the economic or political landscape. For example, a change in government regulations could negatively impact a company's ability to operate in a particular market.

Operational Risk

Operational risks relate to the day-to-day operations of an organization and can result from inadequate or failed internal processes, people, and systems. Operational risks can originate from a variety of sources, including:

- **Human Error:** Mistakes made by employees, such as data entry errors or negligence in following procedures, can lead to operational disruptions.
- **Third Parties:** Vendors, suppliers, and other external partners can introduce risks into an organization's operations. For example, a supplier might fail to deliver goods on time, disrupting production.
- **Cybersecurity Threats:** Cyberattacks, such as data breaches or ransomware attacks, can disrupt operations and cause financial losses.
- **External Events:** Natural disasters, political turmoil, and other external events can disrupt operations and damage infrastructure.

Compliance Risk

Compliance risks arise from non-compliance with laws, regulations, or industry standards. They can result in fines, penalties, and reputational damage.

Compliance risk can have the following implications:

- **Reputational:** Non-compliance can damage an organization's reputation and erode stakeholder trust. For example, a company that violates environmental regulations might face negative publicity and consumer backlash.
- **Business:** Non-compliance can disrupt business operations. For example, a company that fails to comply with data privacy regulations might be prohibited from processing personal data, impacting its ability to conduct business.
- **Financial:** Non-compliance can lead to financial losses, such as fines, penalties, and legal fees. For example, a company that violates GDPR regulations might face millions of dollars in fines and penalties.
- **Legal:** Non-compliance can result in legal action, such as lawsuits or criminal charges. For example, a company that violates labor laws might face lawsuits from employees.

Reputational Risk

Reputational risks can damage an organization's reputation and erode stakeholder trust. They can arise from data breaches, negative publicity, or unethical behavior. Reputational risk can be immediate, severe, and long-lasting. For example, a company that experiences a data breach might face negative media coverage, customer churn, and a decline in stock price.

Technology Risk

Technology risks are associated with the use of technology and can include cybersecurity threats, system failures, and data breaches. Technology risk can lead to:

- Unplanned downtime, significantly disrupting operations.
- Increased costs due to emergency repairs.

Data Risk

Data risks relate to the collection, use, and disclosure of data and can include data breaches, data loss, and privacy violations. *Data risk can lead to:*

- **Financial loss**, including regulatory fines and compensation to affected individuals.
- **Reputational loss**, with a decline in customer trust and brand value.
- **Loss of trade**, as customers move to competitors with better data security practices.
- **Disruption to business operations**, with potential downtime and recovery costs.
- **Identity theft**, with unauthorized access to personal information.
- **Legal consequences**, including lawsuits and regulatory penalties.

Human Resources Risk

Human resources risks arise from the actions or inactions of employees, contractors, or other personnel. They can include issues such as employee misconduct, negligence, or lack of training. *Human resources risk can lead to:*

- **Legal disputes**, such as wrongful termination lawsuits or discrimination claims.
- **Financial losses**, such as those arising from employee theft or fraud.
- **Reputational damage**, such as negative publicity from employee misconduct.
- **Operational disruptions**, such as those caused by employee absenteeism or low morale.

Threats

Cyber threats pose a significant risk to organizations of all sizes. These threats can originate from various sources, both internal and external, and can be intentional or accidental. Understanding the different types of threats and their potential impact is crucial for developing effective security measures.

A few key points to consider:

- **Threats are diverse:** They can range from accidental actions and natural events to deliberate attacks by malicious actors.

Examples: physical damage, natural disasters, data breaches, technical failures, and compromised functions.

- **Threat actors vary:** Threats can come from insiders (employees, contractors), outsiders (hackers, criminals), or even state-sponsored groups. Their motivations can range from financial gain and disruption to political or ideological goals.
- **Advanced Persistent Threats (APTs):** These are sophisticated, long-term attacks, often targeting valuable data or infrastructure. APT actors are highly skilled, well-resourced, and persistent in their efforts. They often use multiple attack vectors (cyber, physical, and deception) to achieve their objectives.
- **The APT lifecycle:** APT attacks typically involve several stages:
 - **Initial compromise:** Gaining initial access through methods like social engineering, phishing, or exploiting vulnerabilities.
 - **Establishing a foothold:** Deploying malware, creating backdoors, and gaining control of systems.

- **Escalating privileges:** Obtaining higher levels of access, potentially including administrator rights.
- **Internal reconnaissance:** Mapping the network, identifying valuable data, and understanding trust relationships.
- **Lateral movement:** Expanding control to other systems and infrastructure elements.
- **Maintaining presence:** Ensuring continued access through established channels.
- **Completing the mission:** Exfiltrating data or achieving other objectives.

- **Classifying Cybersecurity Threats**

- **Internal vs. External** - Distinguishes between threats originating from within an organization (like employees) versus those coming from outside the organization (like competitors or criminals).
- **Level of Sophistication/Capability** - Describes the technical skill level and expertise of threat actors, ranging from basic script users to advanced researchers discovering new vulnerabilities.
- **Resources/Funding** - Indicates the financial and operational resources available to threat actors, from hobbyists with limited means to state-sponsored groups with virtually unlimited resources.
- **Intent/Motivation** - Defines what drives the threat actor, such as financial gain, political objectives, corporate espionage, or personal thrill.

- **Types of Threat Actors**

- **White-hat hackers** - *Authorized security professionals* who act with permission to discover and help fix vulnerabilities in systems and networks.
- **Black-hat hackers** - *Malicious actors* who exploit vulnerabilities for unauthorized purposes and personal gain.
- **Gray-hat hackers** - *Unauthorized actors* who discover vulnerabilities but report them to the organization rather than exploiting them maliciously.

- **Specific Threat Actors**

- **Script Kiddies** - Inexperienced attackers who use pre-written tools and scripts without understanding how they work, primarily seeking to prove their skills.
- **Hacktivists** - Individuals or groups who use hacking techniques to promote social or political causes, often believing they're serving a greater good.
- **Criminal Syndicates** - Organized crime groups that conduct cybercrime for financial gain, often with significant resources and sophisticated capabilities.
- **Advanced Persistent Threats (APTs)** - Typically state-sponsored groups using advanced techniques over long periods to achieve political or economic objectives.
- **Insiders** - Authorized users who abuse their legitimate access to harm the organization, whether motivated by activism, financial gain, or personal grievances.
- **Competitors** - Organizations engaging in corporate espionage to steal sensitive information for business advantage.

So, while it's useful to look at actors by their skills, it's also helpful to examine their mission and motives. The following graphic shows these two elements considered together.

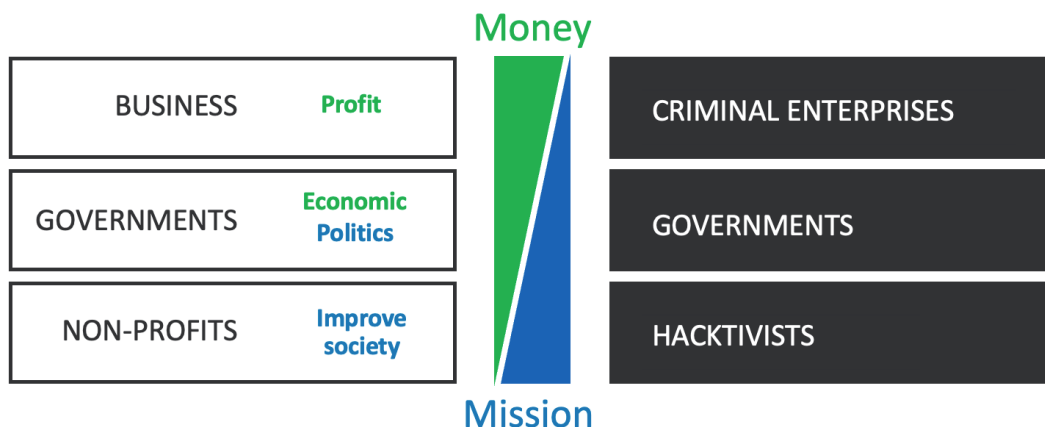


Figure 3.2. Threat Actors, Attributes, and Motivations

- **Threat Vectors.** These are methods or pathways that threat actors use to gain access to an organization's information or systems.
 - **Email and Social Media** - Common entry points for phishing attacks, spam, and social engineering attempts that can compromise user credentials or spread malware.
 - **Direct Access** - Physical access to facilities or systems, often achieved through unauthorized entry or social engineering of building access controls.
 - **Wireless Networks** - Networks that can be accessed remotely, potentially allowing attackers to connect from nearby locations without physical access.
 - **Removable Media** - Physical devices like USB drives that can be used to spread malware or exfiltrate data.
 - **Cloud** - Cloud services that may have misconfigured access controls or security vulnerabilities that attackers can exploit.
 - **Third-Party Risks** - Vulnerabilities introduced through the supply chain, vendors, or other business partners who have access to systems or data.



Supply chain risk management: The process of identifying, assessing, and mitigating risks associated with third-party vendors and service providers. This is crucial because modern organizations often rely heavily on external partners who may introduce significant security risks.

- **Threat Data and Intelligence.** Activities and resources that help organizations learn about and stay current with changes in the threat environment.

- **Open-Source Intelligence (OSINT)** - Publicly available threat information from sources like government agencies, security blogs, and community forums.
- **Proprietary and Closed Source Intelligence** - Commercial or private threat information services that provide exclusive or paid access to threat data.
- **Vulnerability Databases** - Centralized repositories of known security weaknesses and flaws in software, hardware, and systems that help organizations prioritize patching and understand emerging exploit trends.
- **Indicators of Compromise (IoCs)** - Forensic data that indicates a potential security incident has occurred, such as unusual file signatures, suspicious log patterns, or other digital evidence of malicious activity.
- **Threat Indicator Management and Exchange** - Standardized systems and protocols for sharing threat information between organizations and systems.
- **Public and Private Information Sharing Centers** - Organized communities and centers (like ISACs) that facilitate threat information sharing within specific sectors.
- **Assessing Threat Intelligence**
 - **Timeliness** - How current and relevant the threat information is relative to when it's needed for decision-making.
 - **Accuracy** - The reliability and truthfulness of the threat information based on verified sources and evidence.
 - **Relevance** - How applicable the threat information is to your specific organization, industry, or systems.
 - **Confidence Scoring** - A standardized rating system to evaluate the trustworthiness and reliability of threat intelligence.

To remain abreast of and identify presence of the latest threats:

- **Subscribing to and integrating** threat intelligence feeds from reputable sources, such as industry groups, government agencies, and commercial providers
- **Conducting threat hunting activities** to proactively identify and investigate potential threats and vulnerabilities
- **Sharing threat intelligence** information with relevant stakeholders, such as incident response teams, security vendors, and industry peers
- **Continuously updating and refining** threat intelligence processes and sources to ensure relevance and effectiveness

Defining a Risk Management Framework

Risk is the potential for loss or damage. It's crucial to understand the interconnectedness of threats, vulnerabilities, and the potential impact on assets to effectively manage risk.

A **risk management framework** provides a structured approach to identify, assess, respond to, and monitor risks related to information security. *Two major benefits are:*

- **Repeatability** It provides a consistent, repeatable structure for addressing risk at all levels of the organization.
- **Common Language:** Frameworks also help unify terminology so that different teams (IT, legal, finance) can communicate about risk coherently.



Common frameworks for risk management in the enterprise include NIST RMF, ISO 31000, and COBIT.

Here's a breakdown of key concepts for the exam:

1. Foundational Elements:

- **Reference Model:** A chosen framework (e.g., NIST 800-39, COBIT) should be adapted to the organization's specific needs and context. This model serves as the blueprint for your risk management program.
- **Desired State:** The framework should reflect the organization's target risk posture and objectives, outlining how risk management will support business goals.

2. Core Components of a Risk Management Framework:

- **Policy:** Executive-level commitment is essential. A documented risk management policy defines objectives, scope, responsibilities, and the organization's risk appetite.
- **Planning & Resourcing:** Define roles, responsibilities, and allocate necessary resources (budget, personnel, tools) for effective implementation.
- **Implementation:** Establish a clear, step-by-step process for managing risk, including risk identification, assessment, response, and monitoring.
- **Management Review:** Regular reviews by executive management ensure the framework's effectiveness, relevance, and alignment with business objectives.
- **Risk Management Process:** Apply the risk management process at all levels (strategic, tactical, operational) across the organization. Prioritize risk treatment based on business impact, risk appetite, and regulatory requirements.
- **Documentation:** Maintain thorough records of all risk-related activities, including risk assessments, treatment plans, and review findings. This documentation is crucial for audits and continuous improvement.

3. Key Considerations for Defining the Framework:

- **External Environment:** Analyze external factors like market conditions, industry trends, legal/regulatory landscape, social/cultural factors, and stakeholder expectations.
- **Internal Environment:** Assess internal factors such as business drivers, strengths/weaknesses, organizational culture, resources, strategic goals, and risk tolerance.
- **Emerging Threats:** Stay informed about evolving threats and their potential impact on the organization. Proactively adapt the framework to address these threats.
- **Control Objectives:** Ensure that risk management activities align with control objectives and other relevant requirements (e.g., efficiency, user acceptance, compliance).

Emerging Threats

Emerging threats include newly discovered vulnerabilities, zero-day exploits, advanced social engineering attacks (deepfakes, spear phishing), and changes in the threat landscape (e.g., widespread remote work). Keeping abreast of emerging threats is key for proactive defense.



Ransomware, supply-chain attacks, and IoT exploitation are frequent examples in current threat intelligence.

To remain abreast of the emerging threats, information security manager and their security personnel can subscribe to various sources of threat intelligence, such as threat feeds.

Useful foundational knowledge to enhance like your understanding of threat intelligence is included below.

Technical concepts related to threat intelligence

While you're not expected to be tested directly on this information, understanding of the technical basics of threat intelligence may help your application of knowledge in real-world scenarios.

A **threat intelligence feed (threat feed)** is a continuous stream of data about potential cyber threats. This data is collected from various sources and formatted to provide security professionals with actionable intelligence. Think of it like a real-time news feed, but instead of news articles, it delivers updates on the latest cyber threats

What's included in a threat feed?

It varies by provider, but can include indicators of compromise (IoCs), threat actor information, and emerging threats.

How are these feeds consumed?

Some are machine readable, often in STIX/TAXII format, consumable by a SIEM. Others are human readable feeds, delivered via e-mail, dashboards, or reports.



Threat feeds can help organizations stay ahead of the latest cyber threats providing early warning, informed decision-making, and improved detection. Today, detection often comes through AI/ML-driven investigation leveraging information from threat intelligence feeds, sometimes even in near real-time.

- **Automated Indicator Sharing (AIS).** A Cybersecurity and Infrastructure Security Agency (CISA) capability, enables the real-time exchange of machine-readable cyber threat indicators and defensive measures. It's provided free to help protect participants of the AIS community and ultimately reduce the prevalence of cyberattacks. Find it at <https://www.cisa.gov/ais>.

- **Trusted Automated eXchange of Intelligence Information (TAXII).** Short for Trusted Automated eXchange of Intelligence Information, defines how real-time cyber threat information can be shared via services and message exchanges.
- **Structured Threat Information eXpression (STIX).** Defines a common language for expressing cyber threat information. TAXII is designed specifically to support transfer of STIX information.

STIX defines “what” is shared, and TAXII is the “how” STIX formatted messages are securely transferred between systems. Trust groups represent how organizations are subscribed to a threat feed on the TAXII server, controlling feed access.

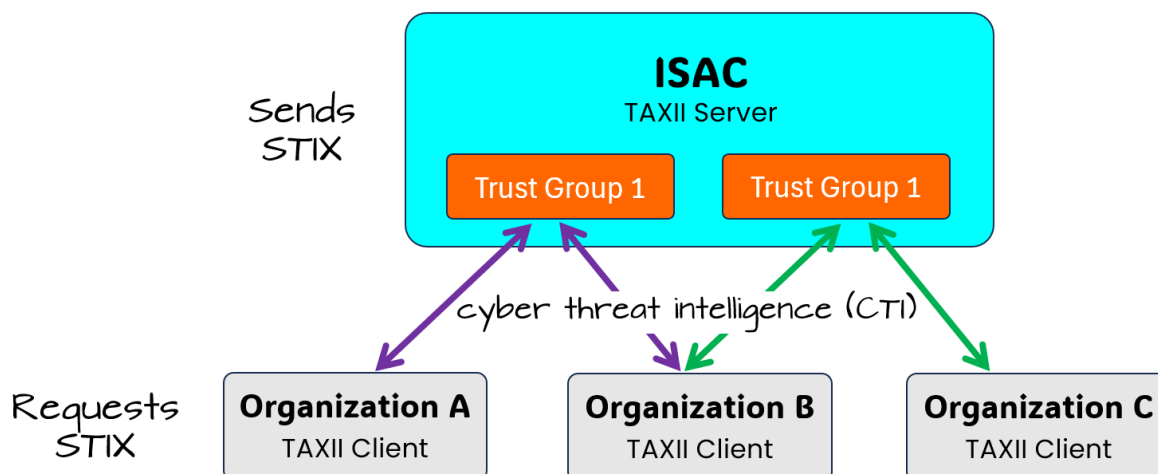


Figure 3.3. TAXII/STIX Process and Components

- **Open Indicators of Compromise (OpenIOC)** is an XML-based framework developed by Mandiant to standardize the sharing and detection of indicators of compromise (IOCs). IOCs are artifacts or behaviors associated with malicious activity, such as specific file hashes, registry keys, or network traffic patterns.



OpenIOC provides a structured way to describe these IOCs, providing standardization to facilitate easier exchange of threat intelligence between security teams, allowing for faster detection and response to cyber threats.

Exam Tip: CISM emphasizes that security programs must adapt to evolving threats (e.g., new compliance challenges from IoT or cloud computing). You may see questions on budgeting or resource allocation for new and unexpected threats, highlighting the importance of flexibility.

Risk Likelihood and Impact

There are two terms that refer to the possibility of a risk event occurring:

- **Probability.** Refers to the chance of an event happening, often expressed as a numerical value between 0 (impossible) and 1 (certain). It represents a 'quantitative' approach.
- **Likelihood.** Expresses the chance of a risk occurring using descriptive terms such as "high," "medium", "low", or "rare". It represents a 'qualitative' approach.

Risk is a function of likelihood (probability of an event) and impact (magnitude of the loss or harm). Exam questions may reference the basic risk formula: Risk = Likelihood × Impact, because they are used in determining annual loss expectancy.



Figure 3.4. Basic Risk Formula

We'll get into quantitative risk analysis formulas a bit later in Domain 2. Understanding both probability and potential consequences helps prioritize which risks need immediate attention and resources.

There are several factors that can be helpful when determining the likelihood of a risk:

1. **Volatility:** The probability of a risk can fluctuate depending on the stability of the situation. If conditions are unstable or rapidly changing, the likelihood of certain risks may be higher.
2. **Velocity:** This refers to the speed with which a risk event could occur and its impact could be felt. A high-velocity risk, with little warning time, would generally have a higher likelihood of causing damage or disruption.

3. Proximity: Related to velocity, proximity indicates the time between an event and its impact. A shorter time frame (closer proximity) suggests a higher likelihood of negative consequences.

4. Interdependency: Risks don't exist in isolation. The likelihood of one risk materializing can be influenced by other risks or events within the organization.

5. Motivation: The motives of potential attackers can influence the likelihood of a risk. Highly motivated attackers are more likely to persist and potentially succeed.

6. Skill: The skill level of potential attackers can impact the likelihood of a successful attack, especially for complex or sophisticated threats.

7. Visibility: High-visibility targets are more likely to attract attention and attacks. This could include systems with valuable data, critical infrastructure, or prominent online presence.

By considering these factors together with other risk assessment information, you can gain a more comprehensive understanding of the likelihood of various risks and prioritize your risk management efforts accordingly.

Risk Register

A **risk register** is a living document (often a spreadsheet or database) that records identified risks, their potential impacts, treatments, ownership, and status. It serves as a central repository for all information security risks, including details about threats, vulnerabilities, impacts, and assigned risk owners. It is used for tracking risk mitigation efforts and ensuring accountability.



Risk ownership and accountability are often essential in CISM scenarios, and questions may highlight the importance of continuous maintenance.



Risk registers may integrate with project management tools or GRC platforms for broader visibility.

2A2. Vulnerability and Control Deficiency Analysis

Understanding the fundamental nature of vulnerabilities is the first step.

- A **vulnerability** is essentially a weakness. This weakness can exist in a system, a process, or even a policy.
- **It's not always a simple yes or no.** Vulnerabilities often exist on a spectrum, with some being more severe than others.

- **The degree of exposure** directly influences the probability that a vulnerability will be exploited. A highly exposed, severe vulnerability is a significant risk.
- **Proactive identification** is critical. The goal is to find and address vulnerabilities *before* they are exploited by malicious actors.

Methods for Identifying and Assessing Vulnerabilities

To effectively manage vulnerabilities, you must first know how to find them.

- **Vulnerability scans** are automated tools that check systems for known weaknesses.
- **Penetration tests** simulate real-world attacks to identify exploitable vulnerabilities.
- **Security reviews** involve a thorough examination of policies, procedures, and configurations.
- **Audits** assess compliance with security standards and regulations.
- **Consider all aspects:** Assessments must include process, procedural, physical, and technical vulnerabilities.
- **Estimates can be quantitative (numbers) or qualitative (descriptions).** Use both where appropriate.
- **Subject matter experts** provide valuable insights and context.

The Role of Controls and Deficiencies

Controls are your safeguards, and understanding their weaknesses is of critical importance.

- **Controls** are safeguards designed to mitigate risks and vulnerabilities.
- **Control deficiencies** occur when controls are weak, ineffective, or missing.
- **Evaluate controls in context:** The impact of a single weak control depends on the effectiveness of other controls in a layered defense.
- **Lack of training and awareness** is a critical control deficiency. Users unaware of security best practices are more likely to make mistakes.

Common Vulnerabilities

Recognizing typical vulnerabilities is essential to effective risk management.

- **Defective Software:** Software bugs or flaws that can be exploited.
- **Misconfigurations:** Incorrect settings in hardware or software that create security gaps.
- **Inadequate Compliance:** Failure to adhere to security standards or regulations.

- **Poor Network Design:** Flat networks or other design flaws that increase the attack surface.
- **Lack of Redundancy:** Single points of failure that can cause disruptions or data loss.
- **Poor Password Choice:** Weak or easily guessed passwords.
- **Unprotected Communications:** Transmitting sensitive data without encryption.
- **Insufficient Staffing:** Lack of qualified personnel to manage security.
- **Lack of Proper Hygiene and Maintenance:** Not keeping systems up to date with patches and not having proper cleaning procedures for physical systems.

Key Resources and Vulnerability Categories

Staying informed requires knowing where to find relevant information. Here are a few authoritative sources:

- **NIST National Vulnerability Database (NVD):** A comprehensive source of vulnerability information.
- **Common Weakness Enumeration (CWE):** A list of software and hardware weakness types.
- **Common Vulnerabilities and Exposures (CVE):** A dictionary of publicly known information security vulnerabilities and exposures.
- **OWASP (Open Web Application Security Project):** Focuses on web application security.
- **Vulnerability Categories:** Network, Physical Access, Applications, Utilities, Supply Chain, Processes, Equipment, Cloud, IoT, BYOD.

Vulnerability Management and Penetration Testing

Two areas that can be helpful both in assessing vulnerabilities in the current state of the organization's security posture and in ongoing operations and maintenance are **vulnerability management** and **penetration testing**.

Knowledge of the basics of vulnerability management, its components, and objectives will be helpful to your decision making in the CISM exam.

Vulnerability Management

The core components and objectives of vulnerability management include:

- **Vulnerability Management** includes routine vulnerability scans and periodic vulnerability assessments but encompasses a larger set of processes that support the risk management process. *This is the overarching process/practice for identifying, tracking, and remediating vulnerabilities on an ongoing basis.*

- **Vulnerability Assessments** extend beyond just technical scans and can include configuration and process reviews and audits to detect vulnerabilities. *This is the process of human assessment of vulnerability scans and the organization's security posture.*
- **Vulnerability Scans** can detect known security vulnerabilities and weaknesses, absence of patches or weak passwords. Vulnerability scanners are used in performing vulnerability scans, which serve as inputs to the assessment process.
- **Vulnerability Analysis** involves confirming the individual vulnerability, prioritizing it using CVSS and CVE numbers (many produced in the vulnerability scan report), and considering organization-specific factors.

Vulnerability scans come in many types, and may be anonymous or with credentials, non-intrusive or intrusive, or may be specialized to focus on network, applications, or web applications.

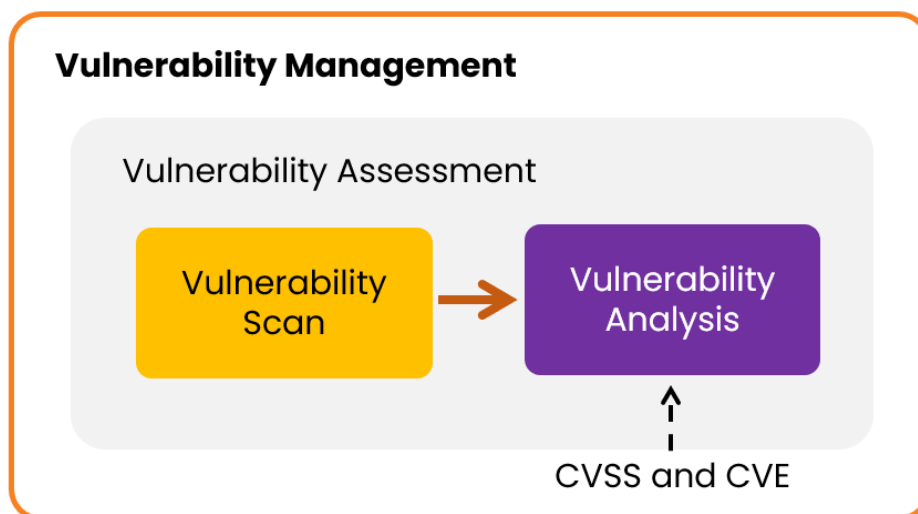


Figure 3.5. Vulnerability Management

Objectives:

- The primary goal of a vulnerability assessment is to proactively identify and analyze security weaknesses within an organization's IT infrastructure.
- The overarching goal of vulnerability management is to reduce an organization's exposure to cyber threats by systematically identifying, assessing, prioritizing, and remediating security weaknesses.

Penetration Testing

A penetration test is a simulated cyberattack against a computer system to evaluate its security. *Types of penetration tests include:*

- **Known environment (*white box test*):** The penetration tester is given a map of target systems and networks. They go into the test with substantial/full information of the target systems and networks.
- **Unknown environment (*black box test*):** The penetration tester knows nothing about target systems and networks. They go into the test completely blind and build out the database of everything they find as they go.
- **Partially known environment (*grey box test*):** Limited information is shared with the tester, sometimes in the form of login credentials. Simulate the level of knowledge that a hacker with long-term access to a system would achieve through research and system footprinting.



Because it involves a simulated cyber attack, a penetration test can be disruptive to business services. Therefore, it must be carefully scoped and coordinated with the business to avoid unintentional impacts.

Objectives:

- The goal is to identify vulnerabilities that could be exploited by malicious actors, and to provide recommendations for improving the system's security posture.
- The output is a report of ranked security concerns helps organizations understand their security posture and prioritize their efforts to improve their defenses.

Security Control Baselines

A **security control baseline** is a predefined set of security controls aligned with the organization's risk tolerance and compliance requirements. It represents the minimum security requirements an organization must maintain to manage risk to an acceptable level.

Baselines are often developed using guidance from frameworks like NIST 800-53, ISO/IEC 27001 Annex A, CIS benchmarks, or organizational policy. A baseline can help compare "where you should be" vs. "where you actually are" in terms of security control maturity. They provide the essential building blocks for an effective risk management program. They give structure, measurability, and consistency to the entire process.



Annex A in ISO/IEC 27001 is a part of the standard that lists a set of classified security controls that organizations can use to demonstrate compliance with ISO 27001 6.1.3 (Information security risk treatment)

Here's a breakdown of key concepts:

- **Controls:** Actions or mechanisms (practices, procedures, processes, or technology) implemented to reduce risk and protect assets. They can be proactive (preventative) or reactive (countermeasures).

- **Baselines:** A set of minimum security controls established for an organization or a specific security domain. They ensure a consistent level of security across the enterprise. Different baselines may be required for different data classifications (e.g., confidential, public).

Considerations in Developing Control Baselines:

A few key considerations in developing security control baselines include:

- **Context Matters:** Baselines must be tailored to the organization's specific needs, risk appetite, culture, structure, and available resources. Generic standards (NIST, ISO, COBIT) offer valuable guidance but require customization.
- **People and Processes:** Consider people and processes in addition to technology when defining baselines. Procedural and physical security baselines are crucial.
- **Classification Scheme:** A clear data classification scheme is essential for establishing appropriate baselines. Higher classification levels require more stringent controls.
- **Effectiveness and Efficiency:** Baselines are not based on a single test but on the overall capacity of controls to mitigate risk. Regular testing and evaluation are necessary to ensure the baseline remains effective in mitigating risks.
- **Collaboration and Approval:** Developing and implementing baselines often requires collaboration across departments and should be approved by a steering committee or similar governing body. Internal audits and reviews can ensure compliance.

Benefits of Baselines:

There are several tangible benefits to the risk management program and security operations, including:

- **Standardization:** Ensure consistent security measures across the enterprise.
- **Risk Management:** Provide a structured and measurable foundation for effective risk management.
- **Operational Efficiency:** Baselines can simplify security operations and management. Application Of security control baselines is often automated, monitored for configuration drift and automatically corrected as needed.
- **Measurable Security:** Facilitates the measurement and evaluation of security effectiveness, which can be helpful in security assessments and audits.

Key Considerations:

There are a few key considerations that ensure your security control baselines meet business needs and continue to do so over time:

- **Risk Appetite and Tolerance:** Baselines should align with the organization's risk appetite and tolerance.
- **Continuous Improvement:** Baselines must be regularly reviewed and updated to address changing threats, vulnerabilities, and business needs.
- **Metrics:** Use relevant metrics to measure the effectiveness and efficiency of controls and baselines. Metrics should be specific, measurable, attainable, relevant, and timely (SMART).

Exam Tip: The exam may highlight tailoring the baseline to your organizational context (e.g., risk profile, compliance).

Events Affecting Security Baselines

Security baselines are not static; they must be dynamic and adapt to changes in the environment. Several factors can trigger the need to modify existing baselines:

- **Incidents:** Any security incident, whether due to a control failure or a lack of a control, necessitates a reassessment of risk and may require adjustments to the baseline. Root cause analysis is crucial to identify weaknesses.
- **Organization changes** like mergers/acquisitions or a decision to migrate to the public cloud.
- **Monitoring and Assessment:** Continuous monitoring and assessment of security controls can reveal degradation over time or identify areas where controls are no longer effective. This triggers the need to update baselines.
- **Vendor Updates:** Vendors may identify vulnerabilities or necessary changes in their products, requiring modifications to related security baselines.
- **External Events:** Events outside the organization, such as protests, civil unrest, or natural disasters, can necessitate temporary or permanent adjustments to physical security baselines.
- **Legal and Regulatory Changes:** New or updated laws and regulations may mandate changes to security controls, impacting baselines.
- **Changing Risk Appetite:** If an organization's risk appetite shifts, it may need to adjust its security baselines accordingly.

- **New Threats and Vulnerabilities:** The emergence of new threats and vulnerabilities requires a reassessment of risk and may lead to changes in baselines.
- **System Changes:** Any changes to systems, applications, or infrastructure can introduce new vulnerabilities and require baseline adjustments.

Security baselines must be regularly reviewed and updated to remain effective in the face of evolving threats, vulnerabilities, and business requirements. Maintaining an appropriate level of security is a continuous process, not an occasional or one-time effort.

Exam Tips:

- CISM exam questions may test your understanding of integrating security changes into a formal change management process.
- The exam may include scenario questions where a significant organizational event forces an immediate re-assessment of baseline controls.

2A3. Risk Assessment and Analysis

A core responsibility of the information security manager (ISM) is managing risk to an acceptable level. This involves a continuous, cyclical process, not a one-time event. The CISM exam will heavily test your understanding of this process, particularly the analysis, evaluation, and assessment phases. This section will present information on these key areas of information security risk management:

- **The Continuous Risk Management Cycle:** Think of risk management as a *constant loop*, not a linear path, including:
 1. **Identify and Assess Risk:** Determine what could go wrong.
 2. **Develop Risk Management Plan:** Figure out how to address the risks.
 3. **Implement Risk Management Plan:** Put the plan into action.
 4. **Proactive Monitoring:** Continuously check if the plan is working and if new risks have emerged.

Key Takeaway: The cycle is driven by the organization's *risk appetite* – the level of risk the organization is willing to accept.

- **Risk Management Drivers:** Changes requiring risk management modification can be internal, external, business or technically driven.
- **The Importance of Baselines:** Security baselines (minimum security levels) are crucial. The information security manager must monitor events that impact these baselines, potentially triggering a reassessment of the security posture and strategy.
 - **Examples:**
 - * Vendor-identified vulnerabilities
 - * New laws and regulations
 - * Emerging threats
 - * Degradation of existing controls
 - * Significant incidents
- **The Risk Management Process (Detailed):**
 - **Establish Scope and Boundaries:** Define the parameters for the risk management process. This includes internal and external factors that help establish context.
 - **Identify Assets and Valuation:** Know what you're protecting and its value. This is foundational.
 - **Perform Risk Assessment:** This is the core, and it has *three distinct phases* (critical for the exam):
 1. **Risk Identification:** Identify potential threats, vulnerabilities, and exposures. This involves threat modeling. A threat, combined with a vulnerability creates an exposure.
 2. **Risk Analysis:** Analyze the *likelihood* and *impact* of identified risks. Quantify or qualify the risk (e.g., high, medium, low).
 3. **Risk Evaluation:** Compare the analyzed risk against the organization's acceptance criteria (risk appetite). Determine if the risk is acceptable or requires treatment.
 - **Recommend Risk Treatment/Response:** If a risk is unacceptable, choose a strategy:
 - * **Avoid:** Stop the risky activity.
 - * **Mitigate:** Implement controls to reduce risk.
 - * **Transfer:** Shift risk to a third party (e.g., insurance).
 - * **Accept:** Acknowledge and accept the risk (only if within appetite).
 - * **Accept Residual Risk:** Management formally accepts the remaining risk after treatment.
 - **Communicate About and Monitor Risk:** Constant communication and review are essential. This keeps the process relevant and effective.

Risk Assessment vs Risk Analysis: What's the difference?

These terms sometimes get thrown about as equivalent (they're not), and it's important to know the difference.

- **Risk Assessment:** This is the broader process of identifying, analyzing, evaluating, and prioritizing potential risks. It encompasses the entire lifecycle, from initial identification to developing mitigation strategies.
- **Risk Analysis.** Specific step within risk assessment focused on analyzing identified risks, such as evaluating likelihood and impact of identified risks, and detailed examination of risk characteristics.

The figure below visualizes the relationship between risk assessment and risk analysis.

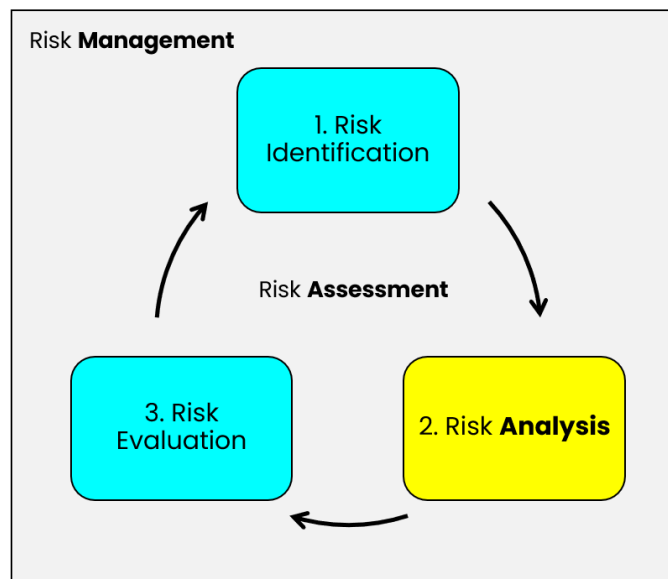


Figure 3.6. Risk Management, Assessment, and Analysis

The Three Phases of Risk Assessment (Exam Focus):

The CISM exam *will* test your understanding of these phases. Be able to differentiate them:

1. **Risk Identification:** *What could go wrong?* This involves:

- Identifying assets.
- Identifying threats (intentional, accidental, natural).

- Identifying vulnerabilities (weaknesses).
- Identifying existing controls.
- Determining potential consequences/impacts.

2. **Risk Analysis:** *How likely is it to go wrong, and how bad would it be?* This involves:

- Assessing the *probability* of the threat exploiting the vulnerability.
- Assessing the *impact* (financial, reputational, operational, legal, etc.) if the threat were realized.
- Often involves *qualitative* (high/medium/low) or *quantitative* (dollar values, probabilities) analysis.

3. **Risk Evaluation:** *Is the risk acceptable?* This involves:

- Comparing the analyzed risk level to the organization's risk appetite.
- Determining if the risk is within acceptable tolerance levels.
- Making a decision: accept, mitigate, transfer, or avoid.
- **Continuous Monitoring and Metrics:** The information security manager must establish relevant metrics to measure the effectiveness of security controls and the overall risk management program. Regular reporting and review are critical.
- **Risk Frameworks:** Remember that frameworks like COBIT and ISO/IEC 27005 can help you perform a risk assessment.

Determining the Risk Management Context

Context involves understanding the organization's strategic objectives, regulatory environment, and risk appetite, which sets the boundaries for risk management.

Risk management context refers to the overarching environment in which an organization's risk management program operates. It sets the stage for how risks are identified, analyzed, and addressed by defining:

1. Strategic Goals and Objectives

- What the organization is trying to achieve, and how risk management can support those aims.

2. Regulatory Environment

- The laws, regulations, and standards the organization must follow, which help determine acceptable actions and constraints.

3. Risk Appetite and Tolerance

- How much risk the organization is willing to accept while still pursuing its objectives.

4. Scope and Boundaries

- Which parts of the business are covered by the risk program (e.g., regions, business units), who the stakeholders are, and how responsibilities are assigned.

By laying out these factors, the risk management context ensures that any security measures or risk controls align with the organization's broader mission, legal or regulatory requirements, and within acceptable risk thresholds.

Influence will come from inside and outside the organization. Common influences are listed here.

- **Internal Environment:** mission, goals, and objectives, existing business strategies, financial health, current risk practices, organizational maturity, communication protocols and relationships, culture.
- **External Environment:** market conditions, economic conditions, applicable laws and regulations, social and political environments, external stakeholders (regulators, partners, suppliers, customers), external threats and threat actors, geopolitical factors.

Ensuring Alignment

A well-defined context ensures that **business goals** and **risk mitigation efforts** reinforce each other. In global organizations, context may differ by region (due to unique legal, cultural, or market factors). Tailoring the risk management program to these nuances helps maintain compliance and supports strategic objectives.

Key considerations for the exam:

1. Regulatory Constraints

CISM questions often test understanding of how industry laws (GDPR, HIPAA, etc.) shape risk context and influence priorities. Remember, since compliance with these elements is mandatory, these will often take priority over other considerations.

2. Risk Appetite Statement

Leadership's definition of acceptable risk is central to decision-making. Expect questions on balancing risk-taking with risk-avoidance.

3. Documentation and Communication

Be prepared for questions on the importance of clearly documenting the risk context, so stakeholders understand its boundaries and rationale. This means distilling technical concepts into non-technical language for business leaders.

BOTTOM LINE: Determining the risk management context is about understanding both the internal and external conditions that shape an organization's threat landscape. By establishing clear boundaries, aligned with strategic objectives,

regulatory requirements, and defined risk appetites, information security leaders can design risk processes that effectively support the business.

Operational Risk Management

Operational risk management is the proactive identification, assessment, and mitigation of potential losses arising from ineffective, inefficient, inadequate, or failed processes, people, and systems (including external events), with the aim of ensuring business continuity and minimizing disruptions.

It involves the day-to-day activities of identifying, assessing, and mitigating operational-level risks, such as:

- technology failures
- human errors or omissions
- internal or external fraud
- supply chain disruptions
- data breaches or cybersecurity incidents
- process breakdowns
- issues stemming from inadequate or failed internal controls.

Real-world scenarios often revolve around how security influences operational workflows without causing excessive friction. It requires collaborating closely with stakeholders to:

- tailor security measures to operational realities
- providing clear and concise guidelines
- leveraging user-friendly tools and training.

Risk Management Integration with IT Life Cycle Management Processes

Risk management shouldn't be a standalone practice; it must be woven into IT project life-cycles, from requirements gathering, design, and development, through deployment and decommission. This approach ensures security considerations are addressed early (shift-left approach).

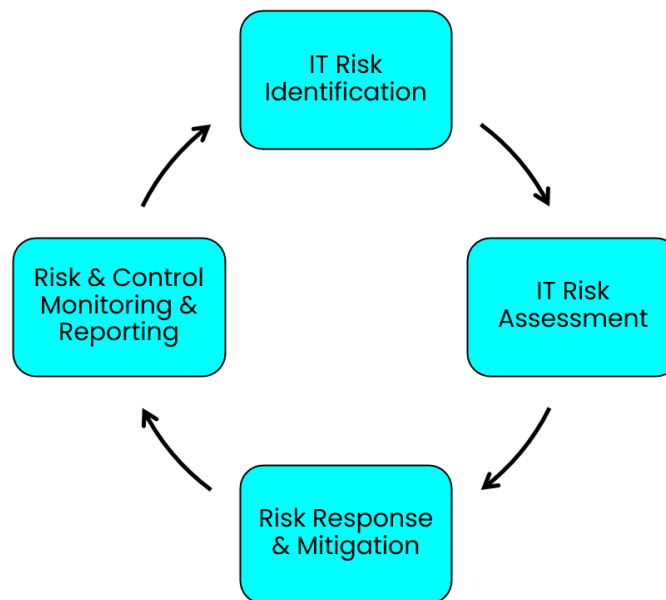


Figure 3.7. IT Risk Management Lifecycle

Why Integrate Risk Management into the IT Life Cycle?

This approach minimizes negative impact on the enterprise and ensure informed decision-making. Risk management should be embedded throughout the entire system development life cycle (SDLC) rather than treated as a one-time activity.

Benefits of this approach include:

- Proactive identification and handling of potential vulnerabilities.
- Alignment of risk priorities with enterprise goals and regulatory requirements.

Phases of the IT System Development Life Cycle (SDLC)

An IT system typically moves through five distinct phases:

1. **Initiation**
2. **Development or Acquisition**
3. **Implementation**
4. **Operation or Maintenance**
5. **Disposal**

Exam Tip: Risk management activities remain the same regardless of phase, but the specific concerns and controls in each phase will differ.



SDLC is covered in greater depth in “Life Cycle Principles Supporting the Roadmap” in Chapter 5.

Core Risk Management Processes

- **Identification:** Recognize potential threats and vulnerabilities.
- **Assessment (Analysis & Evaluation):** Determine the likelihood and impact of each threat.
- **Response (Treatment or Mitigation):** Decide on actions—avoid, reduce, share/transfer, or accept the risk.
- **Monitoring & Reporting:** Continuously track and report on risks, controls, and any shifts in the environment.



Because risk is ongoing, the CISM perspective is that risk management should be viewed as a *continuous, adaptive loop*.

The Importance of Change Management

- **Rationale:** Any change to hardware, software, facilities, or processes can introduce new vulnerabilities.
- **Role of Security Manager:**
 - Participate in the change management committee to ensure all changes receive appropriate security review.
 - Document and analyze any deviation from security policies and standards before final approval.
- **Enterprise Impact:**
 - Extends beyond IT owners to facilities management, business continuity, and outsourced services.
 - Aligns security requirements with normal operational changes (e.g., system upgrades, data center blueprint changes).

Exam Tip: Remember that formalized change management processes can reduce unintended security gaps.

Physical Security and Facilities Management

- **Vulnerabilities:**
 - Physical security systems (e.g., CCTV, access controls) increasingly integrate with IT networks, creating potential attack vectors.
 - Lack of standardized hardware/software across dispersed sites can make consistent security controls difficult.
- **Facilities Concerns:**
 - Contracts for facility services should include adequate SLAs (service level agreements) and emergency response clauses.
 - Undocumented or unreviewed changes in facilities infrastructure can impact business continuity.
 - Human factors (internal staff or external maintenance teams) represent a critical risk source.

Key Takeaway: Inadequate oversight of facility changes, or outsourced management can undermine security posture and business continuity.

Third-Party and Outsourcing Considerations

Enterprises may outsource facility operations or other business functions, not just IT. This expands the risk management scope to third-party compliance and performance.

Organizations must exercise due diligence in selecting suppliers, drafting contracts, and monitoring performance. This includes periodically confirming that third parties adhere to your organization's security standards.

Exam Tip: Always remember risk acceptance/tolerance thresholds must not be exceeded by any vendor or third-party partner.

Best Practices for Continuous Risk Management

Risk management should be treated as a continuous process. Best practices include:

1. **Integrate With Change Management:** Incorporate risk assessments and mitigation steps at each stage where changes occur.
2. **Maintain Updated Documentation:** Keep records of changes—both IT and facilities—and communicate them across the enterprise.
3. **Assess Human Factors:** Include background screenings, contractual terms, and role-based access for internal and external personnel.
4. **Conduct Incremental Updates:** Rather than waiting for periodic major assessments, update risk analyses continuously or whenever a significant change is proposed.
5. **Align With Business Goals:** Keep security controls and risk decisions in sync with the organization's objectives and regulatory landscape.

In the context of these, it is important to remember:

- Each SDLC phase requires consistent attention to risk.
- Managing changes is crucial for maintaining a strong security posture, and should be implemented through a structured change management process.
- Prevention and early detection should be pervasive, involving security throughout all organizational processes, not just during audits or after incidents.

Exam Tip: Exam questions may highlight the cost savings of identifying security risks in early project stages vs. post-deployment fixes.

Role of the Information Security Manager

Remember, the information security manager is a strategic leader who ensures that risk management processes are interwoven into every phase of the system life cycle, from design through disposal. By guiding policy compliance, evaluating the security implications of changes, and collaborating with both internal stakeholders and external service providers, the information security manager helps maintain a robust security posture throughout the enterprise.

Risk Scenarios

Risk analysis consist of thorough analysis of any likely risk scenarios, and can be performed using a variety of techniques or frameworks, such as FAIR (Factor Analysis of Information Risk).

- Risk scenarios are hypothetical situations that help visualize how a risk might materialize (e.g., “Malware infects payment systems, causing operational downtime and financial loss”).
- They aid in prioritizing risks and determining appropriate response strategies.
- **Key takeaway:** Scenarios can also test organizational resilience (incident response, business continuity).

Exam Tips:

- **Real-World Context:** The CISM exam often tests your ability to translate general threats into specific business-impact scenarios.
- **Scenario Planning:** Know how to qualitatively or quantitatively assess each scenario's potential outcome.
- **Key takeaway:** You might be asked how to present scenario outcomes (e.g., cost projections, downtime estimates) to non-technical stakeholders.

Key Issues and Focus Areas for Risk Scenario Analysis:

Official ISACA exam review resources cover the primary risk scenario techniques and focus areas. I have attempted to distill these into a clear, actionable list that's easier for you to onboard into your thought processes for exam day.

1. Involve Stakeholders:

- **Issue:** Scenario analysis should not be confined to risk analysts and senior management.
- **Solution:** Include staff from all levels, particularly those in the first line of defense who are directly involved in daily operations. Their insights into vulnerabilities and potential risks are invaluable.

2. Focus on a Range of Scenarios:

- **Issue:** Over-focusing on extreme, low-probability events can lead to neglecting more frequent, less severe incidents that can have a significant impact.

- **Solution:** Consider a range of scenarios with varying severity levels. Analyze how less severe incidents can cascade or combine with other events to create more complex and impactful outcomes.

3. Build Complexity Gradually:

- **Issue:** Complex scenarios can be challenging to analyze and visualize.
- **Solution:** Start with simple scenarios and gradually increase complexity by showing how cascading events and dependencies can lead to more severe consequences.

4. Account for Systemic and Contagious Risks:

- **Issue:** Systemic and contagious risks can have a significant impact on the enterprise.
- **Solution:** Pay attention to scenarios where a single event affects a large group of enterprises (systemic risk) or multiple business partners within a short time frame (contagious risk).

5. Leverage Scenario Building for Risk Detection:

- **Issue:** Enterprises may not be aware of all potential risks.
- **Solution:** Scenario building can help identify risks that the enterprise might not have otherwise recognized. This improves risk detection capabilities. Focus on detectability: can the enterprise observe and recognize something has gone wrong?

6. Ensure Currency and Relevance:

- **Issue:** Risk factors and the enterprise environment change over time, affecting the validity of existing risk scenarios.
- **Solution:** Regularly review and update risk scenarios to reflect changes in the business environment and risk landscape. Frequency depends on the risk profile, but at least annual reviews are recommended.

7. Manage the Number of Scenarios:

- **Issue:** Managing a large number of detailed risk scenarios can be overwhelming and resource intensive.
- **Solution:** Aim for a manageable number of scenarios that accurately represent the business environment and its complexity. Use generic risk scenarios as a starting point and create more specific ones only when necessary.

8. Utilize Methodologies and Tools:

- **Issue:** Structured approaches can enhance the effectiveness of risk scenario analysis.
- **Solution:** Consider using methodologies like FAIR and HARM for risk analysis and brainstorming workshops to generate a wider range of scenarios and ensure buy-in from stakeholders.

9. Focus on Response and Recovery:

- **Issue:** Scenario building should not just identify risks but also inform response and recovery strategies.
- **Solution:** Analyze how the enterprise would respond to different scenarios and identify areas for improvement in its resilience capabilities.

Understanding Risk: A Breakdown

This list provides a framework for characterizing and analyzing risks that aligns with ISACA guidance. By understanding these components, you can better identify, assess, and mitigate potential threats.

Key Characteristics of a Risk

1. **Asset/Resource:** *What is at stake?* This could be tangible (equipment, data) or intangible (reputation, brand value).
2. **Threat Actor:** *Who or what poses the threat?* This could be internal (employees, systems) or external (competitors, natural disasters).
3. **Threat Type:** *What is the nature of the threat?* Is it intentional (malicious) or unintentional (accidental)? What is the motivation behind the threat?
4. **Exposure:** *Where and how is the asset vulnerable?* Are there weaknesses in security controls, physical locations, or operational processes?
5. **Frequency:** *How likely is the threat to occur?* This involves estimating the probability and potential timing of the event.
6. **Resulting Event:** *What specific event could occur due to the threat?* This could be data breaches, system failures, or business disruptions.
7. **Consequences:** *What are the potential impacts of the event?* This could include financial losses, reputational damage, or operational inefficiencies.
8. **Protective Mechanisms:** *What measures are in place to mitigate the risk?* This could include security controls, policies, and procedures.

By considering these factors, you can gain a comprehensive understanding of the risks facing your organization and develop effective strategies to manage them.

Risk Assessment Process

ISACA details a four-phase risk assessment process. More important than memorizing phases is understanding the assessment process and considerations in security control selection.

Risk Scenario Components

A **risk scenario** describes a potential threat to a specific asset or resource, detailing what may occur, how it happens, and its potential impact on an enterprise. The building blocks of these scenarios:

- **Threat Type** - Malicious, Accidental, Error, Failure, Flood, External Requirement
- **Actor** - Internal (staff, contractor), External (competitor, hacktivist, criminal, market), Regulator, Vendor, Nature

- **Event** - Disclosure, Interruption, Modification, Theft, Destruction, Ineffective Design, Ineffective Execution, External Business Drivers, Inappropriate Use
- **Asset/Resource** - People and Skills, Organizational Structures, Process, Facilities, IT Infrastructure, Information, Applications
- **Frequency** - How often an event might occur in a given environment
- **Loss Magnitude** - Potential financial impact or other consequences

The combination of these components helps estimate **frequency and impact**, which are the two key factors in determining overall risk.

Risk Assessment Process Phases

Risk assessment is foundational for determining how to protect business assets effectively. *It typically follows four phases:*

1. Risk Identification

- **Purpose:** Identify and document all potential risks the enterprise could face.
- **Focus:** Uncover assets, vulnerabilities, threats, and any relevant business processes or regulations.

2. Risk Analysis

- **Purpose:** Estimate the frequency and magnitude (impact) of identified IT risk scenarios.
- **Activities:**
 - Evaluate asset value (business impact, criticality, sensitivity).
 - Identify relevant threats and vulnerabilities.
 - Assess how often (probability/frequency) an event could occur.
 - Determine potential consequences (impact).
- **Outcome:** A quantitative or qualitative understanding of the organization's risk posture.

3. Risk Evaluation

- **Purpose:** Compare the results of the risk analysis against the organization's defined risk appetite and tolerance.
- **Criteria:** Operational, technical, financial, regulatory, legal, social, or environmental.
- **Focus:** Decide on appropriate risk responses (avoid, mitigate, transfer, accept) aligned with enterprise goals, internal policies, and procedures.

4. Risk Assessment

- **Purpose:** Formulate recommended actions based on the outcomes of risk analysis and evaluation.
- **Result:** A plan or strategy detailing which controls, countermeasures, or activities to implement to manage risks within acceptable levels.

Practical Application – Risk-Driven Approach

Let's go a layer deeper and step through application of the risk assessment process, and some of the questions and considerations at each step.

1. Identify

- Determine what sensitive data exists, where it resides, how it is processed or stored, who can access it, and if it is shared externally.

2. Assess

- For each location or process step involving sensitive data, analyze potential risks:
 - Are there vulnerabilities?
 - Are there threat actors capable of exploiting these vulnerabilities?

3. Decide if Risk is Within Defined Limits

- If **Yes**:
 - **Monitor**
 - * Continuously track residual risk.
 - * Regularly test and update controls to respond to changes in the threat landscape.
- If **No**:
 - Evaluate **What Responses** are available to deliver the most value in reducing risk:
 - * **Mitigate (Reduce Risk)**
 - **Technical Controls** (e.g., network segmentation, firewalls, encryption, vulnerability scanning, centralized logging)
 - **Organizational Measures** (e.g., data classification, handling procedures, training, governance)
 - * **Transfer (Insure)**
 - Shift certain risk impacts to a third party (insurance).
 - * **Avoid (Stop)**
 - Discontinue the activity if risk is unacceptable and cannot be mitigated.

4. Accept Risk?

- If implementing treatments brings risk to within accepted limits, **Accept** the residual risk.
- If residual risk exceeds the organization's appetite, **Re-assess** and escalate to leadership for further decisions or additional measures.

Key Takeaways:

- **Balance Frequency and Impact:** Understanding the likelihood of an event (frequency) and its severity (impact) is crucial for prioritizing resources.
- **Align with Business Objectives:** All risk decisions (avoid, mitigate, transfer, accept) should support the enterprise's overall strategic goals and meet regulatory or compliance obligations.
- **Control Selection:** Choose controls (technical and organizational) proportionate to the level of risk; avoid overprotection or underprotection.

Risk Assessment and Analysis Methodologies

Information security managers must understand various **risk management models** and **assessment approaches**. Your chosen approach depends on your enterprise context, regulatory environment, and risk profile. Notable methodologies include:

- COBIT
- OCTAVE
- NIST 800-39 / 800-30
- HB 158-2010
- ISO 27005:2018
- ISO/IEC 31000
- ITIL
- CRAMM
- FAIR (Factor Analysis of Information Risk)
- HARM (Holistic Approach to Risk Management)
- VAR (Value at Risk)

Each approach defines a systematic process for **identifying risks, analyzing their likelihood/impact, evaluating risk levels, and determining optimal response** (e.g., accept, mitigate, transfer, or avoid).

1. NIST Risk Assessment Methodology (SP 800-30)

According to NIST, the **risk assessment** involves **nine primary steps**, typically depicted as:

1. System (or general domain) Characterization

2. Threat Identification
3. Vulnerability Identification
4. Control Analysis
5. Likelihood Determination
6. Impact Analysis
7. Risk Determination
8. Control Recommendations
9. Results Documentation

Inputs and Outputs at Each Step

- **Step 1: System Characterization**
 - **Inputs:** Hardware, software, system interfaces, data, people, mission.
 - **Output:** System boundary, system functions, data criticality/sensitivity.
- **Step 2: Threat Identification**
 - **Inputs:** History of system attacks, intelligence data, mass media.
 - **Output:** Threat statement.
- **Step 3: Vulnerability Identification**
 - **Inputs:** Prior risk assessments, security test results, audit comments.
 - **Output:** List of potential vulnerabilities.
- **Step 4: Control Analysis**
 - **Inputs:** Current and planned controls.
 - **Output:** List of current and planned controls.
- **Step 5: Likelihood Determination**
 - **Inputs:** Threat-source motivation, capacity, vulnerabilities, existing controls.
 - **Output:** Likelihood rating (e.g., low, medium, high).
- **Step 6: Impact Analysis**
 - **Inputs:** Mission impact, asset criticality, data criticality/sensitivity.
 - **Output:** Impact rating (loss of integrity, availability, confidentiality).
- **Step 7: Risk Determination**
 - **Inputs:** Likelihood and magnitude of impact, adequacy of controls.
 - **Output:** Risk levels (e.g., critical, high, moderate, low).
- **Step 8: Control Recommendations**
 - **Output:** Recommended controls to reduce or manage risk.
- **Step 9: Results Documentation**
 - **Output:** Risk assessment report, capturing all findings and suggestions.

2. ISO/IEC 27005 Process Steps for Risk Assessment

ISO/IEC 27005 aligns closely with COBIT 5 for Risk. It breaks down into:

1. Context Establishment

- Define criteria, scope, boundaries, and an appropriate organizational structure for Information Security Risk Management (ISRM).

2. Risk Assessment

- Encompasses **Risk Identification**, **Risk Analysis**, and **Risk Evaluation**.
- Focuses on the value of information assets, relevant threats/vulnerabilities, controls in place, possible consequences, and ranking of risks.

3. Risk Identification

- Identify assets, threats, existing controls, vulnerabilities, and consequences.
- **Output:** List of incident scenarios and associated impacts on business processes.

4. Risk Analysis

- Assesses consequences, incident likelihoods, and determines the level of risk.

5. Risk Evaluation

- Compares identified risks against **evaluation criteria** and **acceptance criteria**.
- **Output:** A prioritized list of risks for treatment.

Risk Treatment Options

1. **Risk Modification** (Mitigation)
2. **Risk Retention** (Acceptance)
3. **Risk Avoidance**
4. **Risk Sharing** (Transfer)

Information Security Risk Acceptance

- Occurs after risk treatment planning and residual risk assessment.
- Management formally accepts risk levels and documents decisions.

Information Security Risk Communication and Consultation

- An ongoing, integrated process:
 - Share and communicate risk-related information with decision makers and stakeholders at every step.

Information Security Risk Monitoring and Review

- Continually review risks and influencing factors as organizational context changes.
- Maintain an overview of the **complete risk picture**.

3. COBIT 5 for Risk Alignment

- COBIT 5 for Risk focuses on **risk governance** and **risk response**.
- Key elements when identifying risk include **control**, **value**, and **threat conditions**.
- Supports **scenario-based** risk identification and uses a **risk map** (frequency vs. impact).

Cascading Risk

Cascading risk occurs when *one failure triggers a chain reaction* of failures, amplifying overall impact.

How It Happens:

- **Minor vulnerabilities**, each seemingly acceptable alone, can compound when *chained together*.
- Cascading risk can also arise from **non-technical** dependencies (e.g., supply chain, financial processes).

Real-World Example

A **fraudulent accounts payable process** allowed invoices below a certain threshold to be paid without a corresponding purchase order or appropriate reconciliation.

- **Technical controls** only flagged larger invoices.
- **Result:** Multiple smaller fraudulent invoices (exceeding \$250,000 total) went undetected.
- **Lessons:** Even well-designed individual controls can be **exploited in combination** if not reviewed holistically.

Key Takeaways for the CISM Exam

1. Focus on Risk Assessment Steps

- Identification of **threats**, **vulnerabilities**, **assets**, **controls**, and **risk levels** is foundational.

2. Prioritize and Treat Risks

- Use criteria for acceptance and decide if you **mitigate, transfer, avoid, or accept** the risk.

3. Communication and Documentation

- Document each phase and communicate with stakeholders.
- Formal acceptance of residual risk is crucial.

4. Beware of Cascading Failures

- Minor issues can combine into large-scale incidents.
- Holistic review of processes and controls is essential.

5. Scenarios and Practical Examples

- Be prepared to analyze real-world examples of how vulnerabilities chain together.
- Understand the difference between purely **technical** vs. **process** or **organizational** controls.

Other Risk Assessment Approaches

In recent years, we've seen significant advancements in how we assess risk. However, many of these new methods don't fully address the unique challenges of *information risk*. As the field of information security matures, we're starting to adopt and adapt these sophisticated techniques. *Some of the most relevant, mentioned by ISACA, include:*

Factor Analysis of Information Risk (FAIR)

FAIR is a widely recognized framework that helps break down information risk into its core components. It provides a structured approach to analyzing risk, acting as a valuable complement to other assessment methods.

- **Purpose:** Decomposes risk to enhance understanding and analysis.
- **Methodology:** Offers a detailed, logical framework for risk analysis.
- **Benefits:** Improves the accuracy of risk assessments.
- **Taxonomy:** FAIR provides a reasoned and logical framework that includes a taxonomy of the factors that make up information risk.
- **Measurement:** FAIR provides a method for measuring the factors that drive risk.
- **Computational Engine:** FAIR includes a computational engine that derives risk by mathematically simulating the relationships among the measured factors.
- **Simulation Model:** FAIR provides a simulation model that allows one to apply the taxonomy, measurement method and computational engine to build and analyze risk scenarios.

- **Threat Agent Characteristics:** FAIR identifies *four primary components* of risk taxonomy:
 - Frequency of contact between threat agents and assets
 - Probability of threat agents acting against assets
 - Probability of threat agent actions overcoming protective controls
 - Probable nature (type and severity) of impact to assets

Holistic Approach to Risk Management (HARM)

HARM builds upon FAIR, offering a methodology to standardize and refine an organization's approach to risk analysis.

- **Purpose:** To normalize and mature risk analysis practices.
- **Foundation:** Leverages the FAIR model.
- **Focus:**
 1. Refining estimation processes.
 2. Eliminating subjectivity.
 3. Ensuring appropriate levels of assurance.
 4. Establishing repeatable methods.
 5. Supporting defensible risk analysis.
- **Benefits:** Consistent results, demonstrable due care, reasonable assurance, informed decision-making, greater confidence in results, and defensible analyses.
- **Not a FAIR Replacement:** Enhances FAIR practices.

Probabilistic Risk Assessment (PRA)

PRA is gaining traction as a powerful tool for analyzing complex systems. It's especially useful for understanding risks across the entire lifecycle of technological assets. It was originally developed for the US National Aeronautics and Space Administration (NASA) and the nuclear power industry.

- **Purpose:** Evaluates risk across all phases of a system's life.
- **Methodology:** Systematic and comprehensive, involving detailed modeling and quantification.
- **Application:** Suitable for complex, high-risk environments.
- **Focus:** Answers three critical questions:
 1. What can go wrong?
 2. How likely is it?
 3. What are the consequences?
- **Approach:** Based on probability, statistical theory, reliability engineering, and decision theory.

Risk Analysis

Risk analysis is the phase where we calculate potential probabilities and their resulting outcomes. This involves assessing threat actor capabilities, motivations, the effectiveness of existing controls, and the extent to which these factors influence identified risks.

- **Purpose:** Calculate the probability and impact of potential risks.
- **Methodology:**
 - Thorough examination of risk sources (threats and vulnerabilities).
 - Evaluation of exposure to threats and their effect on likelihood.
 - Assessment of potential negative consequences (impact).
 - Analysis of the likelihood of consequences and influencing factors.
 - Inclusion of existing controls to mitigate negative risks or enhance positive outcomes.
- **Calculations:** Risk level estimation using statistical analysis and calculations combining impact and likelihood.
- **Business Impact Analysis (BIA):** Essential for understanding the financial impact of losing specific functions or assets.

Formulas and Methods

Consistent methods are essential for combining impact and likelihood. These should align with the criteria defined during the establishment of the risk management context.

- **Consistency:** Methods must align with the defined risk management context.
- **Approval:** Estimates lacking historical data must be communicated to and approved by decision-makers.
- **Information Sources:** Data comes from experience, records, industry practices, market research, experiments, models, and expert advice.

Analysis Techniques

Techniques vary and may include expert interviews, questionnaires, model simulations, and statistical analysis.

- **Variability:** Techniques depend on risk, purpose, and required protection levels.
- **Types:** Analyses can be qualitative, semi-quantitative (hybrid), or quantitative.
- **Consistency:** The chosen technique must align with the criteria defined in the risk management context.

Gap Analysis

Gap analysis identifies the delta between existing controls and desired control objectives.

- **Purpose:** Determine the gap between current controls and objectives.
- **Context:** Based on the outcome of developing an information security governance and management strategy.
- **Control Objectives:** Should lead to residual risk falling within acceptable levels.
- **Dynamic Nature:** Control objectives may change, necessitating periodic gap analysis.

Qualitative Analysis

Qualitative analysis describes the magnitude and likelihood of consequences in detail, often using descriptive scales.

- **Purpose:** Detailed description of potential consequences and their likelihood.
- **Scales:** Scales are tailored to the specific circumstances and risk, often with a low/medium/high scale.
- **Use Cases:**
 - Initial risk assessment.
 - Addressing nontangible risk aspects (e.g., reputation).
 - When lacking sufficient numerical data or resources.
- **Example:** Risk heat maps are a visual tool used in qualitative analysis.

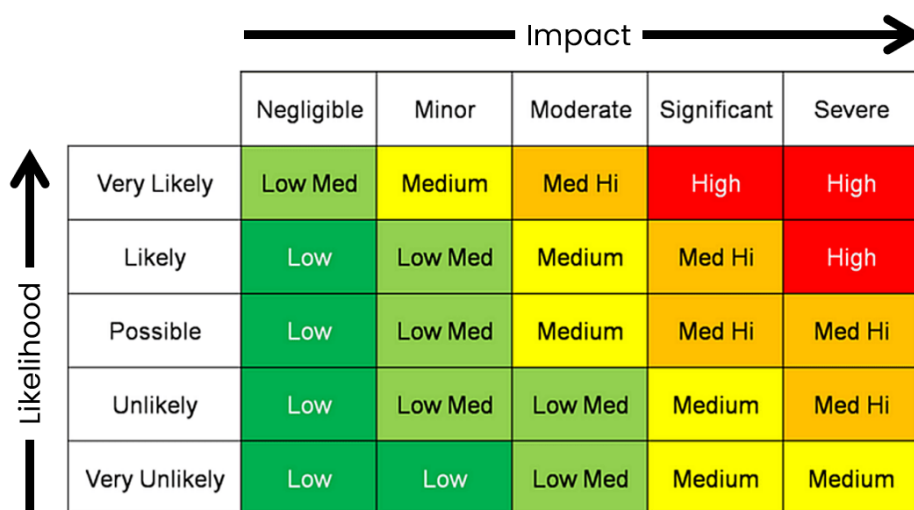


Figure 3.8. Risk Heat Map

Semi-quantitative (Hybrid) Analysis

This method assigns ranged values to qualitative descriptions, aiming to provide more consistent estimates and allow for better prioritization.

- **Purpose:** Combine qualitative descriptions with numerical ranges.
- **Objective:** Provide consistent estimations and better risk prioritization.
- **Mapping:** Qualitative terms are mapped to quantitative values.
- **Example Values for Likelihood:**
 - Rare (value = 1)
 - Unlikely (value = 2): Not seen within the last five years
 - Moderate (value = 3): Seen within the last five years but not within the last year
 - Likely (value = 4): Seen within the last year
 - Frequent (value = 5): Occurs on a regular basis
- **Example Values for Impact:**
 - Insignificant (value = 1): No meaningful impact or of limited consequence
 - Minor (value = 2): Impact on a small part of the business only or less than US \$1 million impact
 - Major (value = 3): Impact on the enterprise's brand or more than US \$1 million impact
 - Material (value = 4): Impact of more than US \$200 million and requiring external reporting
 - Catastrophic (value = 5): Failure or significant downsizing of the enterprise
- **Risk Calculation:** Risk = Impact x Likelihood

Quantitative Analysis

The CISM exam mentions the quantitative risk analysis formula, but with a different focus than more technically oriented exams like CISSP or Security+ exam.

EXAM TIP: The CISM will generally focus strictly on your ability to apply the formulas in the context of a scenario. The key quantitative risk formulas will be **single loss expectancy (SLE)** and **annual loss expectancy (ALE)**, as these represent meaningful loss estimates.

1. Asset Identification and Valuation:

- We begin by identifying all the valuable resources (assets) within our organization.
- Each asset is then assigned a monetary value (asset value) to represent the potential financial loss if compromised.

2. Threat Identification:

- Next, we focus on each asset and identify all potential threats it could face.
- This process creates a list of unique pairings between each asset and its potential threats.

3. Exposure Factor (EF) Calculation:

- For each asset-threat pairing, we calculate the exposure factor (EF).
- This factor represents the percentage of an asset's value that could be lost if the specific threat occurs.

4. Single Loss Expectancy (SLE) Calculation:

- We then calculate the single loss expectancy (SLE) for each asset-threat pairing.
- This value represents the average amount of financial loss we could expect from a single instance of the specific threat.

5. Annualized Rate of Occurrence (ARO) Calculation:

- To understand the frequency of threats, we perform a threat analysis.
- This analysis helps us estimate the annualized rate of occurrence (ARO) for each threat.
- The ARO represents the likelihood of a specific threat happening within a year.

6. Annualized Loss Expectancy (ALE) Calculation:

- With the EF and ARO values, we can calculate the annualized loss expectancy (ALE) for each threat.
- This value represents the average annualized financial loss we could expect to incur from a specific threat over a year.

7. Safeguard Evaluation:

- We then research and identify potential safeguards (countermeasures) for each threat.
- These countermeasures are actions or safeguards that can mitigate the threat's impact.
- We then analyze how each countermeasure would affect the ARO, EF, and consequently, the ALE.

8. Cost-Benefit Analysis and Selection:

- Finally, we perform a cost-benefit analysis for each countermeasure associated with each asset-threat pairing.

- This analysis compares the cost of implementing the countermeasure with the potential loss reduction it offers.
- Based on this analysis, we can select the most cost-effective and appropriate response to each threat.

By following these steps, we can gain a quantitative understanding of potential risks and make informed decisions about resource allocation for security controls.

Now, let's drill down on the risk formulas you need for exam day.

Quantitative Risk Analysis Formulas

The following are the key metrics and associated formulas used in performing quantitative risk analysis, in the order you'll need to use them:

- Exposure Factor (EF)
- Single Loss Expectancy (SLE)
- Annualized Rate of Occurrence (ARO)
- Annualized Loss Expectancy (ALE) <- Key for CISM!
- Cost/Benefit Analysis

Exposure Factor (EF)

The percentage of loss that an asset may experience due to a specific threat.

FORMULA: $EF = \text{Monetary loss due to threat} / \text{Value of asset}$

Examples:

- \$30,000 expected loss on \$100,000 asset
- $\$30,000 / \$100,000 = .30$ (30%) exposure factor

Single Loss Expectancy (SLE)

Represents the cost associated with a single realized risk against a specific asset

FORMULA: $SLE = \text{Asset Value (AV)} \times \text{Exposure Factor (EF)}$

Examples: EF of 30% on \$100,000 valuation, $SLE = \$30,000$

Annualized Rate of Occurrence (ARO)

The expected frequency with which a specific threat or risk will occur within a single year.

FORMULA: $ARO = (\text{Number of Events}) / (\text{Observation Time in Years})$

Examples:

- Risk occurs once every 2 years? $1 \div 2 = 0.5$
- Risk occurs once every 5 years? $1 \div 5 = 0.2$

Annualized Loss Expectancy (ALE)

The possible yearly cost of all instances of a specific realized threat against a specific asset.

FORMULA: $ALE = \text{single loss expectancy (SLE)} \times \text{annualized rate of occurrence (ARO)}$

EXAMPLES:

SLE of \$30,000 x ARO of 0.5 (once every two years) = \$15,000 ALE

Cost/Benefit Analysis

This step ensures the control is *cost-effective*.

FORMULA: $(ALE - ALE2) - ACS = \text{Value of the safeguard}$

- **ALE** - The expected annual financial loss from a specific risk *before* implementing the safeguard.
- **ALE2** - The revised annual loss expectancy *after* the safeguard is implemented.

Term	Formula	Description
Exposure Factor (EF)	$EF = \text{Monetary loss due to threat} / \text{Value of asset}$	Represents the percentage of potential loss an asset might experience if a threat occurs.
Single Loss Expectancy (SLE)	$SLE = AV \times EF$	Calculates the average expected loss from a single occurrence of a specific threat.
Annual Rate of Occurrence (ARO)	$ARO = (\text{Number of Events}) / (\text{Observation Time in Years})$	Estimates the frequency of a specific threat occurring within a year.
Annualized Loss Expectancy (ALE)	$ALE = SLE \times ARO$	Represents the average annualized loss expected from a specific threat over a year.
Cost/Benefit Analysis	$(ALE - ALE2) - ACS = \text{Value of the safeguard}$	Determines the value of the safeguard to ensure the solution is cost effective.

Figure 3.9. Quantitative Risk Analysis Formulas

Quantitative Risk Analysis Example

Here's an example of the QRA formulas in action in a scenario, much like you might expect on the exam.

Scenario:

- A company has a server that stores critical customer data.
- The server has a value of \$100,000.
- There's a 20% chance of a data breach per year.
- Expected loss of asset value per breach is 70%.

Formulas

- **Asset Value (AV):** The value of the asset at risk.
- **Exposure Factor (EF):** The percentage of the asset's value lost in a single occurrence of a risk.
- **Single Loss Expectancy (SLE):** The expected monetary loss from a single occurrence of a risk.
- **Annualized Rate of Occurrence (ARO):** The number of times a loss is expected to occur in a year.
- **Annualized Loss Expectancy (ALE):** The expected monetary loss from a risk over a year.
- **Safeguard Evaluation Cost/Benefit Analysis:** A formula to determine if a safeguard is cost-effective.

Calculations

We need to extract values from the scenario, just as you will be expected to do on the exam.

The first two values we need require no calculation. We can pull them directly from the scenario:

- **Asset Value (AV):** \$100,000
- **Exposure Factor (EF):** 70% (0.7)

1. Single Loss Expectancy (SLE):

- $SLE = AV * EF$
- $SLE = \$100,000 * 0.70 = \$70,000$

2. Annualized Rate of Occurrence (ARO):

- $ARO = 1 / \text{Average Occurrence Interval}$
- $\text{Average Occurrence Interval} = 1 / \text{Probability of Occurrence}$
- $\text{Average Occurrence Interval} = 1 / 0.20 = 5 \text{ years}$
- $ARO = 1 / 5 = 0.2$

3. Annualized Loss Expectancy (ALE):

- $ALE = SLE * ARO$
- $ALE = \$70,000 * 0.2 = \$14,000$

4. Safeguard Evaluation Cost/Benefit Analysis:

- **Pre-safeguard ALE:** \$14,000
- **Post-safeguard ALE:** Assuming a 50% reduction in ARO due to the safeguard, the post-safeguard ARO becomes 0.1. Therefore, the post-safeguard ALE is $\$70,000 * 0.1 = \$7,000$.
- **ACS:** Let's assume the annual cost of the safeguard is \$4,000.
- **Cost/Benefit Formula:** $(\text{Pre-safeguard ALE} - \text{Post-safeguard ALE}) - \text{ACS} = (\$14,000 - \$7,000) - \$4,000 = \$3,000$

In this scenario, we see a residual value greater than zero, so the control is cost effective!



You can watch an in-depth walkthrough demonstrating use of quantitative risk formulas in [Quantitative Risk Analysis: Just the Formulas](#).

Value at Risk (VaR)

VaR is a *quantitative* risk management tool used to estimate the potential loss in value of a portfolio or investment over a specific time horizon with a certain level of confidence.

How it works:

1. **Data Input:** VaR utilizes historical data or simulations to generate a range of possible outcomes for the portfolio's value.
2. **Probability Distribution:** This data is used to construct a probability distribution of potential losses.
3. **Confidence Level:** A confidence level is chosen (e.g., 95% or 99%).
4. **VaR Calculation:** VaR is the value that corresponds to the chosen confidence level on the loss distribution. This means there is a (1-confidence level)% chance of losing more than the VaR amount.

Example: If the 95% VaR for a portfolio is \$1 million, there is a 5% chance of losing \$1 million or more over the specified time horizon.

Key characteristics of VaR:

- **Numerical Output:** VaR provides a specific numerical value representing the potential loss.
- **Statistical Foundation:** It relies on statistical calculations and probability distributions to estimate risk.
- **Objective Measurement:** It aims to provide an objective and measurable estimate of potential losses.

Use Cases:

VaR is widely used in finance, investment, and risk management for:

- **Risk Assessment:** Measuring and managing market risk, credit risk, and operational risk.
- **Portfolio Management:** Optimizing portfolio allocation and diversification.
- **Compliance:** Meeting regulatory capital requirements.

Limitations:

- **Historical Data Dependence:** VaR relies on historical data, which may not accurately reflect future market conditions.
- **Extreme Events:** It may underestimate the potential for extreme losses, such as during financial crises.
- **Tail Risk:** VaR focuses primarily on the left tail of the loss distribution and may not fully capture the potential for large losses.

Other Risk Analysis Methods

Here are some additional techniques that can be used for risk assessment, though they tend to be more complex and less frequently used in most organizations.

- **Bayesian Analysis:** This method uses prior knowledge or beliefs (prior probability) to inform the analysis of new data. It updates the initial beliefs based on new evidence, resulting in a posterior probability.
- **Bow Tie Analysis:** This visual technique represents risks in a bow-tie shape. The “knot” of the bow tie represents the undesired event. The left side shows potential causes (threats), and the right side shows potential consequences (impacts). Controls and mitigation strategies are depicted as lines connecting the causes and consequences to the knot.
- **Delphi Method:** This iterative process involves a group of experts who provide anonymous opinions on a specific topic. The facilitator summarizes the responses and shares them with the group. The experts then revise their opinions based on the feedback, and the process is repeated until a consensus is reached.
- **Event Tree Analysis:** This forward-looking technique starts with an initiating event and analyzes the possible outcomes and their probabilities. It is a useful tool for predicting the consequences of different scenarios.
- **Fault Tree Analysis:** This top-down approach begins with an undesired event (top event) and works backward to identify the underlying causes. It helps to understand the root causes of failures and potential ways to prevent them.
- **Markov Analysis:** This method is used to model systems that transition between different states over time. It assumes that the probability of transitioning to a particular state depends only on the current state and not on the past history.
- **Monte Carlo Analysis:** This technique involves running simulations with random variables to estimate the distribution of possible outcomes. It can be used to assess the impact of uncertainty and risk in complex systems.



Remember that the choice of risk analysis method depends on the specific context and the goals of the assessment.

Risk Evaluation

Risk Evaluation involves comparing assessed risks against risk criteria (e.g., risk appetite, thresholds, or benchmarks). It determines which risks are acceptable, which need treatment (e.g., mitigate, transfer, accept, or avoid). Communication to executives often includes cost-benefit analysis, ranking which risks are critical vs. those that are tolerable (can be accepted).

*The goal of risk evaluation is to determine how the enterprise will **respond to and prioritize identified risks**. This is done in light of the organization's defined **risk appetite, tolerance, and capacity**.*

Deciding on Risk Treatment Options

1. Accept the Risk

- If the risk is **within the acceptable criteria** or tolerance levels.

2. Mitigate the Risk

- If the risk **exceeds** those criteria or is **not within** allowable variance.
- Mitigation can involve **adding or modifying controls, process redesign**, or other measures.

3. Transfer or Share the Risk

- Typically used for risk with **low likelihood but high impact** (e.g., through insurance or outsourcing).
- If controls are used as part of mitigation, remember that **control risk** (the probability a control will fail) must also be accounted for.

4. Accept Excessive Risk (under certain conditions)

- In rare cases, if **no cost-effective** mitigation exists but **benefits** of proceeding outweigh the potential adverse impact, management may still choose to accept the risk.

Further Analysis

If initial evaluation is **ambiguous** or is deemed **inaccurate/misleading**, the organization should consider further or more detailed risk analysis.

Risk Management Criteria

- Should align with:
 - **Organizational objectives**
 - **Stakeholder views**
 - **Scope and objectives** of the risk management process
 - Likely **margins of error** in the data

Determining Thresholds

When deciding how to respond to risk, thresholds are often defined in terms of:

- **Consequences (Impacts)** – The severity or magnitude of a negative outcome.
- **Likelihood of Events** – The probability of adverse events occurring.
- **Cumulative Impact** – Aggregate effect of multiple events occurring **simultaneously** or in quick succession.
- **Cascading Risks (Domino Effect)** – How one risk event can trigger or **magnify** another in **interdependent** systems.

Exam Tips:

- **Risk Acceptance Criteria:** The exam may test your knowledge of how organizations decide what level of risk is tolerable.
- **Decision-Making:** Remember that the final decision on risk acceptance or remediation often lies with senior management or the board.

Risk Ranking

Risk ranking is the process of *assigning relative priorities to identified risks* and is commonly used for resource allocation and action plans. It's often based on likelihood, impact, and urgency considerations. Risk ranking may also factor in "speed of onset" or how quickly a threat could materialize.

Exam Tip: Scenarios might show competing priorities, challenging you to determine how to justify which risks get top funding and which are monitored over time.

Domain 2B: Information Security Risk Response

Syllabus

2B. Information Security Risk Response

- 2B1. Risk Treatment/Risk Response Options
- 2B2. Risk and Control Ownership
- 2B3. Risk Monitoring and Reporting

Supporting Tasks

- 9. Compile and present reports to key stakeholders on the activities, trends, and overall effectiveness of the information security program.
- 22. Participate in and/or oversee the risk identification, risk assessment, and risk treatment process.
- 24. Identify, recommend, or implement appropriate risk treatment and response options to manage risk to acceptable levels based on organizational risk appetite.
- 25. Determine whether information security controls are appropriate and effectively manage risk to an acceptable level.
- 27. Monitor for internal and external factors that may require reassessment of risk.
- 28. Report on information security risk, including noncompliance and changes in information risk, to key stakeholders to facilitate the risk management decision making process.

2B1. Risk Treatment/Risk Response Options

These topics map to the various ways of handling risk: avoiding, accepting, transferring, and mitigating it—along with considerations for cost–benefit analysis, residual risk, and how legal/regulatory obligations factor into treatment choices.

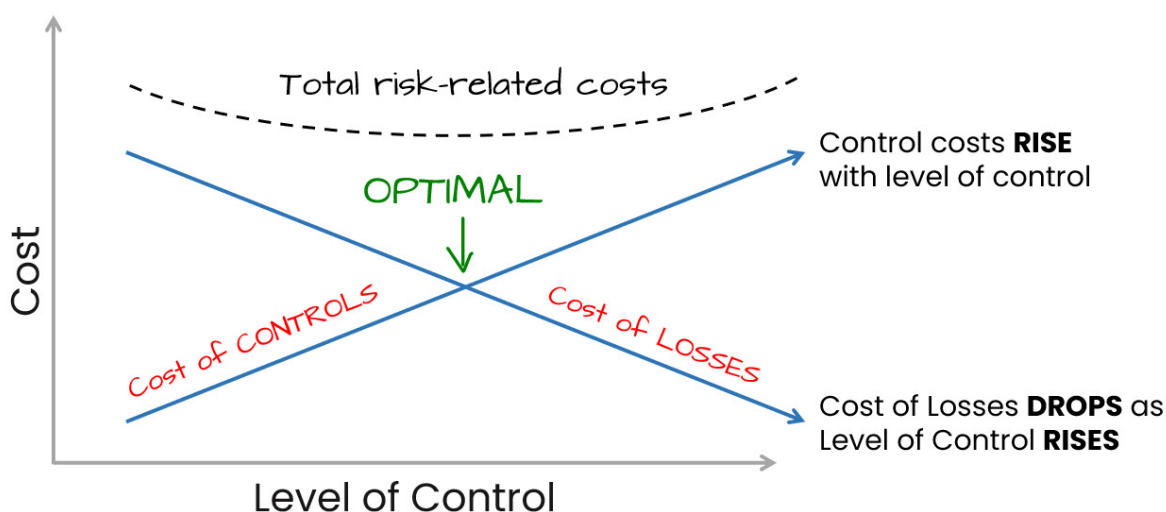


Figure 4.1. Cost vs Level of Control

Determining Risk Capacity and Acceptable Risk (Risk Appetite)

Every enterprise has a **risk capacity**, which is the maximum amount of potential loss it can withstand before its continued existence is threatened.

Within this boundary, the board of directors or owners establish the **risk appetite** - the amount and type of risk the organization is willing to accept in pursuit of its objectives or mission. In some cases, the board may delegate the task of defining risk appetite to senior management as part of strategic planning.

Once the risk appetite is set, it *guides decisions* about **risk acceptance**, where the organization deliberately chooses not to take further action on a risk, provided that risk remains within acceptable limits and clear accountability (a risk owner) is assigned.

If a risk approaches the upper boundary of the risk appetite (and possibly nears risk capacity), acceptance should only occur *when there is a compelling business need* and alternatives are too costly or impractical. If there is no compelling business need, the organization would generally choose **risk avoidance**.

Risk tolerance refers to the acceptable level of deviation from the stated risk appetite. It remains lower than the risk capacity, so the enterprise is never in danger of jeopardizing its survival. Tolerance is often expressed through operational metrics, processes, and policies (for example, IT procedures) that translate high-level objectives into day-to-day controls. A>

Example: The organization sets a maximum allowable downtime of 30 minutes for its critical e-commerce platform during peak hours. Any outage beyond this threshold automatically triggers a high-priority incident response to restore services

immediately.

Because risk appetite underpins strategic decisions, it influences how the enterprise allocates resources, approves investments, and makes operational changes. Ultimately, it is translated into standards and policies that must be communicated across the organization so each area can respond appropriately while still adhering to the enterprise-wide appetite.

Risk appetite can change with market conditions, organizational growth, or regulatory updates.



If you need a quick refresher on the basics of risk appetite, tolerance, and capacity, see “Important terms related to risk” at the beginning of chapter 3.

Risk Response Options

Risk Response entails determining how the organization will handle identified risks, guided by its risk appetite and capacity. *The core four options are:*

1. **Avoid (terminate):** Stop the activity that creates the risk (e.g., discontinue a risky product line).
2. **Transfer:** Shift some or all the risk to a third party (e.g., insurance, outsourcing).
3. **Mitigate:** Reduce the risk likelihood or impact by implementing controls and safeguards.
4. **Accept:** Recognize the risk but take no further action beyond monitoring, often because the cost of reducing it isn't justified.

Here are more detailed descriptions of risk response and treatment strategies you should know for the exam, along with some examples for context:

- **Avoidance** - Eliminating a risk by deciding not to proceed with the activity that introduced the risk. For example, avoiding the risk of a failed software project by deciding not to develop the software. Choosing to locate an office in Colorado instead of California to avoid earthquakes is another example of avoidance.
- **Mitigation** - Taking early action to reduce the probability or impact of a risk. For example, conducting frequent prototype reviews in a software project to mitigate the risk of building the wrong functionality.
- **Transference** - Shifting the risk to another party. For example, purchasing cyber insurance to transfer some financial risk of a data breach.

- **Acceptance** - Acknowledging the risk and deciding not to take action to affect it. For example, accepting the low risk that a minor bug exists in software rather than delaying release to fix it.
- **Exploitation** - Actively seeking to take on a risk you believe will have a positive outcome. For example, making a strategic business acquisition that has substantial upside potential despite some risk of overpaying.

Exam Tips:

- **Business Case Justification:** Be ready to justify choosing one response option over another based on cost-benefit and alignment with business objectives.
- **Residual Risk:** Remember, even after treatment, some portion of risk typically remains.
- **Most Appropriate Choice:** The exam often focuses on selecting the “most appropriate” response. Consider not just security effectiveness but also **cost-effectiveness** and **business impact**.

Risk Acceptance Framework

A **risk acceptance framework** defines when and how a risk can be accepted, including approval processes, documentation requirements, and reporting lines. It ensures that accepting risk is a conscious, well-governed decision rather than an ad hoc or unintentional one.

- **Definition and Rationale**
 - Risk acceptance occurs when an identified risk is within the organization’s tolerance level or when mitigating it is not cost-effective (or otherwise justified).
 - Acceptance must be formally documented, ensuring accountability for potential consequences.
- **Reassessment and Final Acceptance**
 - Final acceptance of residual risk considers factors such as:
 - * Cost and effectiveness of potential controls
 - * Acceptable levels of impact
 - * Organizational culture and maturity
 - * Regulatory and compliance requirements
 - * Risk appetite and stakeholder strategy
 - * Uncertainty in the threat or asset environment

- Even if a risk is below the acceptable level, it should be monitored to confirm that existing controls remain effective and that no new conditions arise that increase the risk.

- **Broader Considerations**

- Intangible impacts (e.g., reputational harm, lost opportunity) must be included.
- The strategic importance of the asset and potential obligations to external parties (business partners, regulators, etc.) should be factored into the acceptance decision.

Inherent and Residual Risk

Two types of risk you must be familiar with in order to make competent risk treatment decisions or *inherent* risk and *residual* risk.

- **Inherent Risk** is the level of risk in the absence of any controls or mitigation efforts.
- **Residual Risk** is the level of risk remaining after controls have been applied.

The objective is to ensure that the residual risk that remains after application of appropriate security controls is equal to or less than the organization's threshold for acceptable risk, allowing them to accept the risk that remains.

Impact

Impact refers to the potential magnitude of harm (financial, reputational, operational) that might result if a risk materializes. It is one half of the classic risk equation: Risk = Likelihood × Impact.

A few key considerations:

- **Multiple Impact Areas**

- A single risk can affect various aspects of the organization, including financial, operational, reputational, compliance, brand, goodwill, or image.
- Impacts can also be intangible or strategic in nature.

- **Scope and Layering of Controls**

- Different processes may have different levels and types of risk.
- Proper scoping is crucial to ensure controls address the right areas and to avoid redundancy or gaps.

- **Compliance Implications**

- When a process or environment is found to be noncompliant, the organization must evaluate potential consequences.

- If the cost of compliance is deemed too high, management may consider accepting the risk of noncompliance or adjusting operations—unless regulations are mandatory and non-negotiable.

Let's go a bit deeper and look at the facets of impact you should be familiar with for the CISM exam:

1. Impact Definition:

- Impact is the consequence of a successful threat exploiting a vulnerability.
- It represents the harm or loss resulting from a security incident.
- Impacts can be direct (e.g., financial loss) or indirect (e.g., reputational damage).

2. Quantifying Impact:

- Impact assessment can be qualitative (using terms like “minor,” “major,” “catastrophic”) or quantitative (assigning monetary values).
- Direct financial losses are often easier to quantify (e.g., lost revenue, legal costs).
- Indirect impacts, such as reputational damage or loss of customer trust, can be challenging to quantify but are still crucial to consider.

3. Types of Impacts:

- **Financial:** Direct loss of money, criminal or civil liability, reduction in share value.
- **Reputational:** Loss of reputation/goodwill/image, breach of confidence/privacy.
- **Operational:** Loss of business opportunity/competition, reduction in operational efficiency/performance.
- **Legal:** Noncompliance with laws and regulations, resulting in penalties.



Expect scenario-based questions that require you to weigh intangible impacts (e.g., reputation, regulatory trust) as well as direct financial losses.

4. Impact Analysis Methods:

- Business impact analysis (BIA) is a common method to identify and assess potential impacts.
- BIA considers factors like criticality of assets, sensitivity of information, and potential disruptions to business operations.

5. Impact and Risk Prioritization:

- Impact assessment is crucial for prioritizing risks.
- Higher impact risks require more attention and resources for mitigation.

Impact analysis also **informs business continuity planning**. It helps establish recovery time objectives (RTOs), recovery point objectives (RPOs), and other critical parameters.

Controls

A **control** is any procedure, process, practice, policy, standard, or technology that serves to regulate an activity or behavior. Controls are designed to reduce or eliminate risks. They can be preventive, detective, or corrective in nature.

Control Types

Controls can be categorized into various control types, including:

- **Administrative controls:** These involve policies, procedures, and guidelines for managing risk. *Examples include access control policies, security awareness training, and incident response plans.*
- **Technical controls:** These involve the use of technology to manage risk. *Examples include firewalls, intrusion detection systems, encryption, and antivirus software.*
- **Physical controls:** These involve physical measures to protect assets and personnel. *Examples include locks, security guards, and surveillance systems.*

Control Objectives

Controls are implemented to achieve specific objectives, such as:

- Preventing unauthorized access to systems and data.
- Ensuring the confidentiality, integrity, and availability of information.
- Detecting and responding to security incidents.
- Meeting compliance requirements.

Control Effectiveness

It's crucial to regularly assess the effectiveness of controls to ensure they are meeting their intended objectives. This can be done through various methods such as control self-assessments, independent audits, and vulnerability scans.

- **Implementation Strategy**

- Selecting controls should balance cost, complexity, and the degree of risk reduction.
- Over-controlling a risk can be wasteful; under-controlling can leave the organization vulnerable.

- **Alignment with Business Objectives**

- Controls must align with organizational goals, ensuring they do not hinder legitimate business processes unnecessarily.

Legal and Regulatory Requirements

Legal and regulatory considerations directly influence risk management decisions. Senior management must determine the necessary level of compliance and allocate resources accordingly. Organizations must comply with various laws and regulations, such as data privacy laws (e.g., GDPR, CCPA), industry-specific regulations (e.g., HIPAA, SOX), and cybersecurity frameworks (e.g., NIST CSF).

- **Evaluating Consequences**

- Regulations must be reviewed by legal experts to understand potential penalties for noncompliance.
- If the environment is noncompliant, the organization must decide whether to bear the risk, modify operations, or invest in compliance measures.

- **Mandatory Requirements**

- In some industries or regions, certain requirements are prescriptive and cannot be negotiated or accepted as risk.
- In these cases, compliance is compulsory.

Compliance as a Business Decision

ISACA describes evaluation of the consequences of noncompliance as a business decision. And it is true that there are *sometimes circumstances where noncompliance may be warranted*, such as:

- scenarios where compliance is not routinely enforced (often a political decision driven by a desire for deregulation)
- when compliance is much more expensive than the fines levied for noncompliance

Two obvious exceptions to this logic would be when human safety or user privacy would be at risk due to noncompliance, in which case professional ethics and protecting the reputation of the business would take precedence.

Cost-Benefit Analysis

Costs (direct or indirect) of implementing controls, transferring risks (insurance premiums), or halting activities must be weighed against the **benefits** of risk reduction. This forms the basis of a *business case* for security investments. *Key considerations include:*

- **Balancing Costs and Benefits**
 - Cost-benefit analysis weighs the expenses (financial or otherwise) of controls or compliance against the potential benefits or risk reduction.
 - It helps determine the appropriate level of controls based on the organization's risk appetite and tolerance.
- **Intangible Factors**
 - Costs may include inconvenience to users, reduced throughput, training in new procedures, compliance monitoring, and end-of-life decommissioning.
 - Benefits can also include reputational protection and avoidance of regulatory fines or legal action.

The analysis helps determine whether a control is justified. If the cost of a control outweighs its benefit, it may be more appropriate to accept the risk, provided it remains within acceptable tolerance levels.

Exam Tips: CISM questions may involve quantitative or qualitative evaluations of cost vs. risk reduction to confirm controls are cost-effective.

2B2. Risk and Control Ownership

The exam will test your knowledge of *risk ownership* and *control ownership*, key responsibilities reach role and ultimate accountability for risk treatment and management.

It's worth mentioning here that understanding the relationship between controls and risks is an important part of control selection.

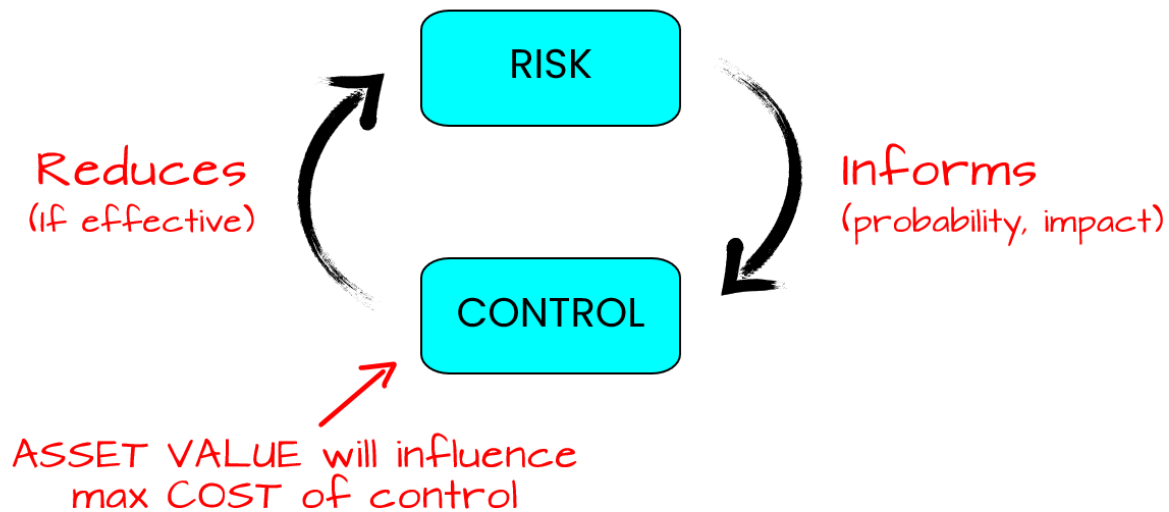


Figure 4.2. Risk/Control Relationship

Risk Ownership and Accountability

After a risk is identified, analyzed, and evaluated, a manager or senior official is named the “risk owner”.

- **Decision-Making Power:** This individual must have the authority to decide how the risk will be handled (e.g., mitigation, acceptance, or transfer).
- **Accountability:** *The risk owner is accountable* for the outcomes of those decisions and must ensure the risk is managed within the organization’s risk appetite.
- **Resources and Expertise:** Adequate knowledge, authority, and resources are crucial for the risk owner to effectively manage and communicate about the risk.

Risk Owner

The risk owner is the person ultimately responsible for ensuring a specific risk is managed appropriately. Typically, this role is held by a senior executive, manager, or director whose area of responsibility is most affected by the risk.

- **Key Responsibilities:**
 - Making key decisions about risk responses.
 - Allocating resources to manage the risk.
 - Accepting residual risk if it aligns with the organization’s risk appetite.
 - Ongoing monitoring of that risk and reports changes or updates as needed.

Exam Tips:

- **Governance Structure:** The exam may highlight boards, risk committees, or departmental heads as ultimate owners.
- **Business vs. IT:** The exam sometimes tests that *business* process owners (not necessarily IT) are typically the ultimate risk owners for processes within their domain.

Control Owner

The control owner has the authority and accountability for decisions about a control designed to address a particular risk. Sometimes, the control owner and the risk owner are the same person, especially for critical controls.

- **Implementation vs. Accountability:**
 - Technical staff (e.g., IT) may implement or maintain a control.
 - The control owner remains ultimately accountable for its effectiveness.
- **Control Ownership:**
 - The risk owner is also responsible for the controls associated with managing that risk.
 - Control owners are responsible for implementing, maintaining, and monitoring the controls they are assigned.
 - This includes ensuring the effectiveness of controls and monitoring their performance.
 - There may be multiple instances of some controls, and thus multiple control owners.
- **Key Responsibilities:**
 - Ensuring the control is properly designed, documented, tested, and aligned with the organization's risk appetite.
 - Monitoring the control's performance and taking corrective action when needed.
 - Coordinating with other stakeholders (IT, compliance, audit) to maintain a strong control environment.

Exam Tips:

- **Responsibility vs. Accountability:** Remember the difference: The risk owner is accountable for the risk outcome, while the control owner is responsible for operating or overseeing the specific control.
- **RACI:** The exam might reference RACI matrices to clarify roles and responsibilities.
- **Monitoring Controls Over Time:** Some exam questions highlight the control owner's duty to adapt or retire controls if they become obsolete or ineffective.

Important considerations in risk and control ownership

Be aware that the individuals responsible for risk, the owners of specific assets, and the owners of various controls *may all be different people* and could even be in separate departments or organizations. Identify each owner early on in your assessment and establish a clear plan for coordination and communication among them and other key stakeholders.

Having different types of ownership can trigger politically sensitive issues, ranging from resource allocation and accountability to the risk of blame. Carefully managing these relationships within the limits of your authority and the scope of the assessment is essential for a successful outcome.

2B3. Risk Monitoring and Reporting

There are several elements that are essential to *how* you track, measure, communicate, and document risk over time. Mastery of these is a key part of the information security manager's role in ensuring risk remains within limits of the organization's risk appetite.

Risk Monitoring

Risk monitoring involves continuous or periodic review of risks, controls, and the external environment (e.g., threat intelligence, regulatory changes). This ensures that new risks are identified promptly, and existing risks are evaluated in light of any changes.

Charts and visualizations can be helpful. Samples of risk reports are available in frameworks like COBIT.

Key Risk Indicators (KRIs)

KRIs are metrics used to signal increasing or decreasing levels of risk exposure (e.g., the number of phishing emails blocked, patch latency, system downtime frequency). They act as

early warning systems that signal when an enterprise is subject to risk that exceeds a tolerable level.

Benefits of KRIs include:

- **Proactive Risk Management:** KRIs enable organizations to proactively identify and address emerging threats rather than reacting to incidents after they occur.
- **Informed Decision-Making:** KRIs provide valuable information for risk assessments, allowing organizations to make informed decisions about risk mitigation strategies and resource allocation.
- **Continuous Monitoring:** KRIs facilitate continuous risk monitoring, enabling organizations to track changes in risk levels over time and adjust their risk management approach accordingly.

Selection Criteria for Effective KRIs:

The CISM exam stresses that metrics must be relevant and measurable.

Criteria for effective KRI selection include:

- **Impact:**
 - Prioritize indicators associated with risks that have a high potential impact on the organization.
 - This ensures that resources are focused on mitigating the most critical threats.
- **Effort to Implement, Measure, and Report:**
 - Select indicators that are relatively easy to measure and report.
 - This ensures that KRIs are practical and do not consume excessive resources for monitoring and analysis.
- **Reliability:**
 - Ensure that the chosen indicators have a strong correlation with the actual risk they represent.
 - Reliable indicators accurately predict or indicate changes in risk levels.
- **Sensitivity:**
 - Select indicators that are sensitive to changes in risk levels.
 - This allows for the early detection of emerging risks.
- **Relevance to Stakeholders:**
 - Involve relevant stakeholders in the selection of KRIs to ensure that the chosen indicators are relevant to their needs and concerns.
- **Balance:**
 - Maintain a balance between different types of indicators, such as leading indicators (predictive), lagging indicators (reactive), and trend-based indicators.

Exam Tips:

- **Alignment with Business:** KRIs should align with business goals and be actionable.
- **Thresholds:** Typically, KRIs have thresholds that trigger escalation or additional controls when exceeded.
- **Trend Analysis:** In exam scenarios, you may be challenged to interpret KRI trends and recommend proactive measures.

Reporting Changes in Risk

Risk reporting involves communicating updates in risk status, including new threats, control effectiveness, or incidents to stakeholders at the right level of detail.

Key considerations in reporting include:

- **Reporting Process:** A well-defined process should be in place for reporting and communicating risk changes. This may include:
 - Establishing clear reporting channels and procedures.
 - Defining the format and frequency of risk reports.
 - Using appropriate communication methods for your audience (e.g., meetings, reports, dashboards).
- **Importance of Continuous Monitoring:** Risk is a dynamic factor. Changes in the internal or external environment, new threats, or changes in business operations can significantly impact the risk landscape. Continuous monitoring and reporting of risk changes are essential for effective risk management.
- **Triggering Events:** Certain events can trigger a more immediate need for risk reporting and reassessment. *These include:*
 - Significant security breaches or incidents
 - Changes in internal or external environments
 - Changes in business operations or strategic direction
 - New or updated regulations or industry standards
- **Incident Response:** Security incidents require a thorough investigation and may necessitate a special report to senior management to inform them of the incident, its impact, and the steps being taken to mitigate the risk.
- **Responsibility of the Information Security Manager:** The information security manager plays a crucial role in monitoring and reporting risk changes. This includes:

- **Regular Risk Assessments:** Conducting periodic risk assessments to identify and evaluate new or changing risks.
- **Stakeholder Communication:** Regularly communicating risk information to relevant stakeholders, including risk owners, control owners, and senior management.
- **Risk Status Reporting:** Providing periodic reports on the overall risk status of the enterprise, including changes in risk levels and the status of any open (untreated) risks.

Risk Communication, Awareness, and Consulting

Effective risk management hinges on clear and consistent communication. It is necessary to communicate and create awareness of risk management issues across the enterprise at every stage of the process. This means more than just communication, but the right type of communication, appropriate cadence, medium, level of detail, and audience engagement.

A few effective techniques include:

- **Stakeholder Engagement:** Communication should involve consultation with all relevant stakeholders. This collaborative approach fosters a shared understanding of the objectives and requirements of the risk management program, leading to better alignment and support.
- **Addressing Variations:** By involving stakeholders, the risk management program can better address variations in stakeholder needs and perceptions. This ensures that the program is tailored to the specific requirements of the organization.
- **Risk Awareness Programs:** These programs are crucial for building a security-conscious culture. *They should aim to:*
 - Increase employee understanding of organizational risks.
 - Enhance the ability of employees to identify and report security threats.
 - Foster a sense of ownership and responsibility for security among employees.
- **Consulting** involves working with different departments or stakeholders to guide them in managing risk effectively.
- **Tailoring Awareness Programs:** Awareness programs should be tailored to the specific needs of different groups within the organization. Content and delivery methods should be adjusted to suit the characteristics and learning styles of various audiences.

Exam Tips:

- **Culture of Security:** CISM places emphasis on building a culture where risk management is recognized as everyone's responsibility.
- **Tailored Messaging:** Communication strategies might differ for technical, non-

technical, executive, and operational audiences.

- **Bidirectional Communication:** The exam may reference the importance of “two-way” communication, leadership providing updates *and* employees reporting observed risks or incidents.

Documentation

Effective risk management requires thorough, readily available documentation that covers policies, standards, procedures, and other risk-related information. This documentation ensures consistency, accountability, and clarity for all stakeholders.

Every step in the risk management process, along with the rationale behind each decision, should be recorded. *Key elements to include are:*

- **Objectives and Audience**
 - Clearly define what the organization aims to achieve with risk management.
 - Identify who needs this information (e.g., executive leadership, IT staff, auditors).
- **Information Resources**
 - Document the systems, applications, and infrastructure involved in risk management.
 - Maintain references for relevant standards or guidelines.
- **Assumptions and Decision Criteria**
 - Record any underlying assumptions (e.g., resource availability, regulatory constraints).
 - Clarify how decisions are made, including the metrics or thresholds used to determine risk responses.
- **Risk Management Policy and Process**

This is a formal document that should describe:

 - **Policy Objectives and Rationale:** Why the organization manages risk and the expected outcomes.
 - **Scope and Charter:** Which areas of the organization or types of risks are covered.
 - **Roles and Responsibilities:** Who is responsible for risk identification, assessment, and mitigation.
 - **Key Process Steps:** How risks are identified, analyzed, and treated.
 - **Risk Response Guidance:** Acceptable response options (avoid, mitigate, transfer, accept).

- **Documentation Requirements:** What records must be kept and how they should be maintained.
- **Communication and Training:** How staff will be informed and trained on risk management practices.
- **Timelines and Frequency:** When and how often risk assessments occur, and any triggers for reassessment.
- **Reporting and Escalation:** How risk information is reported to management and escalated when necessary.

- **Typical Supporting Documentation**

- **Risk Register:** A living document that lists each identified risk, risk owner, status, and planned actions.
- **Risk Management Framework:** Outlines overall governance, definitions, and the organization's risk appetite.
- **Assessment Reports, Logs, and Forms:** Detailed findings from risk analyses, including methods and results.
- **Communication Plan and Training Materials:** Ensures consistent messaging and education across the organization.
- **Risk Treatment Plans:** Describes the chosen mitigation strategies, cost/benefit considerations, and acceptance criteria.

- **Reviews and Audits**

- The risk management process should be periodically reviewed or audited (internally or externally) to confirm effectiveness.
- Proper documentation of risk acceptance decisions is crucial to demonstrate due diligence.
- Leadership should drive a strong risk management culture, ensuring everyone understands their role and the importance of adhering to established processes.

- **Version Control and Handling:** Effective version control and handling of documentation are crucial. This includes labeling with classification level, revision date, and number.



Ensuring that the risk management policy is *approved by the board of directors* is key to facilitate gaining support from all stakeholders in the enterprise.

Domain 3A: Information Security Program Development

Syllabus

3A. Information Security Program Development

- 3A1. Information Security Program Resources (e.g., people, tools, technologies)
- 3A2. Information Asset Identification and Classification
- 3A3. Industry Standards and Frameworks for Information Security
- 3A4. Information Security Policies, Procedures, and Guidelines
- 3A5. Information Security Program Metrics

Supporting Tasks

- 5. Establish and maintain information security policies to guide the development of standards, procedures, and guidelines.
- 10. Evaluate and report information security metrics to key stakeholders.
- 11. Establish and/or maintain the information security program in alignment with the information security strategy.
- 12. Align the information security program with the operational objectives of other business functions.
- 13. Establish and maintain information security processes and resources to execute the information security program.
- 14. Establish, communicate, and maintain organizational information security policies, standards, guidelines, procedures, and other documentation.
- 20. Establish and/or maintain a process for information asset identification and classification.

3A1. Information Security Program Resources

An information security program brings together the people, processes and technologies that safeguard an enterprise's information assets. Think of it as **the implementation plan** for an organization's information security strategy (covered in Chapter 2). A program typically involves designing, developing and integrating enterprise-wide controls and then continuously administering and managing them. These controls can be straightforward (such as policies and procedures) or highly sophisticated (such as advanced technical solutions).

Program leadership will be influenced by the organization's size and complexity, the program might be led by a single individual or by a chief information security officer (CISO) with a large, specialized team.

An information security manager may be responsible for **creating a new security program** from scratch or reviving one after organizational changes or even refining and enhancing an existing program. Regardless of the starting point, it's critical for an information security manager to understand the core principles of planning, implementing and managing an effective information security program.

Exam Tip: Be ready to demonstrate an understanding of *why* an information security program exists (strategic alignment, risk mitigation) and *what* it includes (policies, standards, resources).

Information Security Program Overview

Managing a security program is much like managing any business function. The main difference is that, despite its growing visibility, information security is still often misunderstood.

Many **information security managers** initially come from a technical background. They may have found themselves handling more and more managerial responsibilities as organizations recognized the need to justify security expenditures in terms of business benefits. Thus, security professionals often broaden their perspective beyond purely technical solutions and become well-versed in business processes and risk management.

Today, larger security teams and increased business interest in security have expanded the knowledge base that security managers need. These managers *act as a bridge between business goals and IT/security operations*, ensuring that security measures support organizational initiatives cost-effectively and appropriately.

Information Security Management Trends

In many organizations, the information security manager now holds a senior leadership role (e.g., VP of Security, CISO, or CSO). Often, security-related areas such as physical security,

privacy, compliance, and disaster recovery report to this senior role or even to a chief risk officer (CRO).

Regular communication with the board of directors is essential so that decision-makers maintain visibility into the organization's security posture. Over time, combining various assurance functions under a single umbrella makes sense: siloed approaches to security can be disjointed, inefficient, and more expensive.

Integrating IT risk with broader enterprise risk provides a holistic picture, helping senior leaders understand the full spectrum of risks, including those related to information security. Some organizations, however, still see security as purely technical and compliance-driven, especially in sectors like manufacturing, food services, and retail.

Additionally, as **more critical IT functions (including security) are outsourced**, managing third-party risk becomes increasingly important. Beyond technical expertise, information security managers now need skills in budgeting, business case development, resource management, and personnel management.

Essential Elements of an Information Security Program

Three elements are critical for a successful security program:

1. **Demonstrated execution of a security strategy aligned with organizational goals**
The strategy should directly support enterprise objectives and clearly show how security actions meet business needs.
2. **Active cooperation and support from management and stakeholders**
Program design and rollout should involve relevant stakeholders from the outset.
3. **Effective metrics to guide and measure performance**
Good metrics help track progress, identify gaps, and verify if security initiatives meet defined goals.

While some frameworks suggest **risk assessments** as the starting point for building a security strategy, a more **comprehensive approach** ensures strategic alignment, resource management, and measurable outcomes. This approach looks beyond risk, *tying information security objectives directly to business objectives* and optimizing security resource deployment.

If the organization isn't yet ready for a full governance model, frameworks like **COBIT** or **ISO/IEC 27001:2013**—combined with maturity models (like **CMMI**)—can help assess current capabilities, define realistic goals, and chart a course for improvement.

Once objectives and strategy are set, the security program aims to **achieve these objectives**. Program development might involve multiple long-term activities, each linked back to business value. Initiatives that **lack demonstrable benefit** (in business terms) should be carefully reviewed and potentially reevaluated.

Importance of the Information Security Program

A well-managed information security program:

- Protects information assets
- Ensures regulatory compliance
- Guides incident response
- Reduces legal and liability risks

Achieving **adequate security at reasonable cost** hinges on effective planning and management. A security program translates **strategic objectives** into **operational processes**—it ensures new and existing security controls are consistently designed, implemented, updated, and eventually retired.

A robust security program is adaptable, leveraging both in-house and third-party expertise (where appropriate) to meet changing risk conditions. When done well, it provides a **consistent security posture** across the enterprise, lowers costs, and simplifies maintenance over time.

Analogy: Think of a **security program as a well-built highway system**. It connects different parts of the business, allows for secure travel of data, and can be expanded or adapted as traffic (risk) patterns change.

Applying the Security Program Business Case

Major security initiatives should be anchored in a solid **business case**. This case clarifies:

- **Value proposition** or cost-benefit
- **Potential risk reduction** versus impact if not addressed
- **Feasibility and practical benefits** to daily operations

Budgeting, as a key aspect of security program management, often determines whether you'll have the resources and people required. *To prepare effectively*, the security manager needs to understand the organization's budgeting calendar, processes, and metrics for approval, ideally, well before budget cycles begin.

Link all expenditures to the security strategy and roadmap. Collaborate with project management offices (PMOs) and subject matter experts (SMEs) to accurately forecast resource needs (e.g., software, hardware, staff time, training). Make sure to anticipate **unexpected costs**, especially those tied to **incident response**, such as external forensic services, by examining historical data or peer industry benchmarks.

Outcomes of Information Security Program Management

A successful program should meet the **measurable objectives** set out in the information security strategy. *Typically, these objectives align with six main outcomes:*

- Strategic Alignment
- Risk Management
- Value Delivery
- Resource Management
- Performance Measurement
- Assurance Process Integration

Once the strategy and program attributes are defined conceptually and logically, the next step is to develop the **physical, functional, and operational components** needed to implement them. For significant initiatives, a comprehensive **security architecture** clarifies how all the moving parts fit together.

Below is a deeper look at each outcome:

Strategic Alignment

Effective alignment requires **regular engagement with business leaders** to understand their goals and risk tolerance. A **security steering committee** that includes business owners or their representatives can help ensure security activities consistently reflect evolving business objectives.

Maintaining day-to-day relationships across departments fosters **cooperation and accountability** for security measures. Regular reporting to executives on **progress and setbacks** keeps leadership aware of how well security aligns with organizational needs.

Analogy: Think of strategic alignment like a **compass**. Strategic alignment ensures everyone is heading in the same direction, even when unexpected changes occur.

Risk Management

Managing risk to information assets forms the core of an information security manager's role. This involves:

- Understanding and prioritizing **threats and vulnerabilities**
- Defining and communicating **acceptable risk levels**

- Continuously monitoring the **changing risk environment**

The enterprise's risk posture evolves over time, so the security program should incorporate ongoing risk assessment processes to **adapt** as threats emerge or business requirements change.

Value Delivery

Information security should *deliver measurable value* in a cost-effective way. Efficient planning and clear project management are key. Prioritizing resources based on **risk** and **potential impact** optimizes security investments.

To be sustainable, solutions must be **institutionalized**—integrated into day-to-day operations with standardized practices. This continuity enables **continuous improvement** and guards against complacency.

Resource Management

The security program depends on **people, processes, technology, and knowledge**. Effective resource management involves:

- **Documenting** core security processes and best practices
- **Project planning** and technology selection
- **Addressing skill gaps**, potentially via training or external hires
- **Developing a security architecture** that integrates with the broader enterprise infrastructure

By systematically identifying resource needs, organizations avoid shortfalls and capitalize on existing strengths.

Performance Measurement

Imagine trying to assess a car's performance without a speedometer or fuel gauge—you have no concrete way to measure how well it's running. Similarly, without measurable control points (or "gauges") in a security program, you cannot demonstrate that it's working as intended.

Metrics are essential for **guiding, monitoring, and verifying** security activities:

- **Strategic Metrics** help leadership gauge overall program alignment with objectives.
- **Tactical and Operational Metrics** track day-to-day performance and identify areas needing improvement.

Data from these metrics should be **aggregated** and shared with managers and executives so they can make **informed decisions**. As new security processes emerge, additional metrics may be defined, ensuring **continuous visibility**.

GOAL: to ensure that measurement practices *highlight failures and successes* so the program can *adapt and improve*.

Assurance Process Integration

The information security manager must collaborate with various assurance providers (e.g., physical security, privacy, audit, business continuity) because these areas often overlap and affect each other. *By aligning with enterprise governance practices, the information security manager helps ensure that:*

- The most critical **assets** are *well-protected*
- **Risk** is *reduced* to acceptable levels
- **Monitoring** and **auditing** are *consistent and transparent*

Approaches such as **business impact assessments** and **privacy impact assessments** help define and measure success criteria (e.g., acceptable downtime, data integrity thresholds, confidentiality levels).

Information Security Program Resources

To maintain **ongoing alignment** and **consistent oversight** of the security program, the information security manager typically leverages numerous organizational resources, including human, technology, and monetary. By using organizational resources effectively results in a foundation that aligns security with business priorities, ensuring the organization understands IT risk while remaining focused on strategic outcomes.

Information Security Program Objectives

An information security program should be based on a conceptual model that identifies the program's key components (e.g., policies, processes, controls) and how they interrelate. This model guides the design, implementation, and continuous management of security activities. *Key high-level characteristics of an effective program include:*

- **Flexible and Adaptable Approach**
 - Because each organization's structure, risk appetite, and technology landscape can vary significantly, the security program must remain flexible.
 - It should be open to adjusting priorities, reassigning resources, and revising strategies as business needs and risk conditions evolve.
- **Alignment with Organizational Requirements**

- The program must align with the organization's overarching governance framework and existing architectural standards (e.g., COBIT).
- Collaboration with stakeholders ensures that security measures support business objectives rather than obstruct them.

- **Ongoing Review and Stakeholder Engagement**

- Regular review of security objectives, controls, and outcomes is critical.
- Continuous communication with key stakeholders helps integrate security into everyday processes and maintain support across the organization.

Key Takeaways:

- **SMART Goals:** Objectives should be Specific, Measurable, Achievable, Relevant, and Time-bound.
- **Prioritization:** Objectives should be prioritized based on **risk** and **business impact**.
- **Ownership and Accountability:** Each objective should be tied to accountable and responsible parties, ensuring follow-through.

Information Security Program Concepts

From a program development perspective, there are a few characteristics and benefits the organization should consider from the outset, including:

1. Iterative Development Process

- Building and managing a security program is iterative: it includes planning, design, development, implementation, and ongoing refinement.
- Organizations often use frameworks like ISO 27001 or COBIT to structure these phases.

2. Risk Management is Foundational

- A thorough risk assessment underpins the entire program, identifying threats, vulnerabilities, and potential impacts.
- The results guide decisions about which controls to implement and how to allocate resources efficiently.

3. Defining Objectives and Scope

- Security objectives must reflect business priorities, legal requirements, and regulatory obligations.
- By clearly defining what the program must protect (e.g., data, infrastructure, processes), management can focus on the most critical areas first.

4. Technology and Process Integration

- A robust security program relies on various technologies, such as firewalls, intrusion detection systems, encryption, and identity management.
- Effective processes (e.g., incident response, business continuity, compliance management) ensure these tools are used consistently and properly.

5. Governance, Roles, and Responsibilities

- Clear governance structures (e.g., using RACI matrices) specify who is responsible, accountable, consulted, and informed for each security activity.
- Well-defined roles help avoid overlap or gaps in security coverage and foster accountability.

6. Implementation and Continuous Improvement

- After selecting and deploying security controls, the program must be monitored, tested, and updated regularly.
- Continuous improvement involves reviewing performance metrics, adapting to emerging threats, and refining policies and processes.

As with most aspects of security, monitoring, maintenance, and revision of the information security program are ongoing processes.

Scope and Charter of an Information Security Program

A **charter** is a formal, written document that defines:

1. **Objectives:** The overarching goals and purpose of the program.
2. **Timelines:** Major milestones and key dates.
3. **Funding:** Sources of financial support.
4. **Leadership:** The individuals responsible for leading and managing the program.
5. **Sponsorship:** The business executives who endorse the program.

In many organizations, a program charter is approved by a senior executive (e.g., the CEO). This approval grants the program leader or team the authority needed to execute their responsibilities. It also signals executive support for the program.

The **scope** determines the programs boundaries, and must be aligned with the organization's business objectives, risk tolerance, and legal requirements. It should account for all relevant information assets, systems, processes, and third-party relationships that could introduce risk.

- **Organizational Coordination**

- An effective security program requires coordination across various departments (e.g., IT, legal, HR) to address interrelated processes and shared responsibilities.
- Clarity on process ownership (which department manages specific assets or data) is essential for proper oversight.

- **Roles and Accountability**

- Implementing a RACI (Responsible, Accountable, Consulted, Informed) matrix helps clarify who does what, ensuring there are no ambiguities in security tasks.
- Assigning accountability at an appropriate management level promotes consistent support and enforcement of security measures.

- **Governance and Oversight**

- A governance framework defines how the security program aligns with broader enterprise goals.
- It establishes mechanisms for policy creation, risk reporting, and decision-making, ensuring security remains an integral part of organizational strategy.

- **Adaptability and Evolution**

- As the business changes—whether through new initiatives, mergers, or technological updates—the security program must adjust its scope accordingly.
- Ongoing assessment of emerging threats and regulatory changes helps keep the program relevant and effective.

Information Security Manager Role vs. Broader Responsibility

Even though the security manager is chartered to lead and coordinate the program, *success depends on collaboration and consensus across the organization*. The charter does not give the security manager free rein to unilaterally impose decisions. While the security manager is empowered to design and operate the information security program, *ultimate responsibility* for protecting information belongs to the executive leadership and the board of directors.

Common Information Security Program Challenges

There are a few common areas that challenge development of a strong information security program. Organizations who address these proactively can increase their odds of success, reduce cost, and avoid rework.

1. Organizational Resistance and Culture

- Changes to processes or the introduction of new security requirements often face pushback if they disrupt established workflows or priorities.

- Resistance may also stem from a lack of understanding about why security changes are necessary or beneficial.

2. Management and Governance Issues

- Inadequate executive support, weak sponsorship, or unclear responsibilities can hinder security initiatives.
- Delays in decision-making or a lack of direction from leadership create confusion and slow program progress.

3. Resource Limitations

- Budget and staffing constraints, coupled with a shortage of skilled personnel, impede timely and effective implementation.
- Insufficient or misallocated resources can lead to suboptimal security solutions.

4. Strategic Misalignment

- Security objectives may not align with broader organizational goals, causing friction in prioritization and funding.
- A lack of clear risk management strategies makes it difficult to justify security investments or measure return on investment (ROI).

5. Complex or Evolving Environments

- Rapid changes in technology, business processes, and regulatory requirements create moving targets for security efforts.
- Organizational restructuring or expansion can introduce new vulnerabilities or compliance obligations.

6. Ineffective Project Management

- Poor planning and oversight of security projects lead to cost overruns, missed deadlines, or incomplete solutions.
- Inconsistent or undefined project methodologies hamper collaboration among different teams.

7. Measurement and Justification Challenges

- Demonstrating the value of security to stakeholders can be difficult, especially if ROI is unclear.
- Cost-benefit analysis may be complicated by intangible benefits (e.g., reputation protection).

Common Information Security Program Constraints

Limitations will vary by organization and business units within the organization, but a few common areas include:

1. Staffing and Skill Gaps

- Limited availability of qualified security professionals and insufficient training for existing staff hinder program effectiveness.
- Underutilized staff or lack of clear role definitions can cause gaps in security coverage.

2. Budget and Financial Pressures

- Competition with other business priorities often leaves security underfunded.
- Justifying security spending can be challenging if management does not see immediate or tangible returns.

3. Organizational Structure and Culture

- Security may be siloed or lack integration with core business units.
- Cultural barriers, such as fear of change or resistance to external oversight, reduce program acceptance.

4. Technological Complexity

- The range of available security tools and rapidly evolving threats require continuous investment in technology and expertise.
- Legacy systems or fragmented infrastructures complicate security deployments and ongoing maintenance.

5. Regulatory and Compliance Demands

- Varying legal requirements (e.g., data protection, privacy laws) can add complexity and cost to security initiatives.
- Noncompliance risks, including fines and reputational damage, force organizations to prioritize certain controls over others.

6. Process and Governance Limitations

- Inconsistent policies or a lack of formalized procedures can undermine security efforts.
- Without clear metrics or accountability, it is difficult to track progress or demonstrate effectiveness.

7. Cost and Return on Investment (ROI)

- Implementing and maintaining security measures can be expensive, especially when factoring in ongoing support and potential downtime.

- A clear, consistent approach to calculating total cost of ownership (TCO) and potential loss from security incidents helps justify investments.

8. Strategic Integration

- Effective security requires alignment with the enterprise's overall strategy and risk appetite.
- Management must ensure that security objectives are woven into daily operations, not treated as a standalone function.

By addressing these challenges and constraints through stronger leadership support, clearer governance, adequate resources, and comprehensive risk management, organizations can build and maintain a more effective information security program.

Defining an Information Security Program Roadmap

A **roadmap** connects your overarching **information security strategy** to tangible actions and outcomes. It should address the six key goals of a mature security function discussed earlier in this chapter:

1. Strategic Alignment
2. Risk Management
3. Value Delivery
4. Resource Management
5. Assurance Process Integration
6. Performance Measurement

Because these concepts may be unfamiliar to some executives, you might roll out the roadmap in manageable phases. Early steps could focus on setting up an **information security steering committee** or drafting initial policies—gaining buy-in and showing quick wins. Subsequent phases can expand compliance checks, refine procedures, and integrate security deeper into business processes.

Example of a phased approach:

- **Stage 1:** Identify key stakeholders (e.g., HR, Finance, Legal) and pinpoint major issues.
- **Stage 2:** Form a security steering committee to create basic security policies aligned with business needs.
- **Stage 3:** Conduct internal security assessments to gauge policy compliance.
- **Stage 4:** Analyze gaps and develop a monitoring approach. Expand responsibilities, refine processes, and ensure alignment with executive management and business unit leaders.

Create a Program Roadmap Using Frameworks and Architectures

Leveraging recognized security frameworks and architectures *provides a strategic blueprint* for creating a comprehensive information security program roadmap, ensuring alignment with business objectives, clarity in control implementation, and continuous improvement.

1. Architecture Clarity Through Layering and Modularization

Break down the enterprise into manageable, interconnected components (e.g., applications, databases, networks) to define responsibilities, reduce complexity, and manage security effectively. *Benefits of this approach include:*

- **Simplified Design:** Divides the enterprise into layers (e.g., internet, application, database) for targeted security controls.
- **Defined Responsibilities:** Clarifies who is accountable for each layer, ensuring proper implementation of security measures.
- **Gap Identification:** Highlights security gaps in specific layers for focused improvement.
- **Policy Enforcement:** Ensures consistent security policies across layers, reducing vulnerabilities.

2. Architectural Focus Beyond Technical Domains

Security architecture isn't just about technology—it includes business, information, and organizational factors. *Key considerations in roadmap development include:*

- **Business Alignment:** Architecture must prioritize business goals, ensuring security supports operations without hindering them.
- **Information Flow:** Map how data moves across layers to secure it at every stage (e.g., encryption, access controls).
- **Organizational Structure:** Align security with business processes, roles, and responsibilities to ensure accountability.
- **Technical Integration:** Incorporate security into IT systems (e.g., networks, applications) while addressing non-technical aspects like user training and policy adherence.

3. Integration of Security into Frameworks

Leverage standards like COBIT, ISO/IEC 27001, or NIST to guide security program development, as these essentially provide a blueprint or template. *Integration goals include:*

- **Consistency:** Embed security into all enterprise processes (e.g., IT, HR, operations) for uniformity.

- **Measurable Outcomes:** Use frameworks to set clear security objectives and track progress.
- **Risk Management:** Address risks at each layer, ensuring comprehensive protection.
- **Adaptability:** Frameworks help adapt security to evolving threats and business needs that may change over time.

Roles and Responsibilities

In this process, the **information security manager** acts as a facilitator, ensuring security strategies support business goals. However, they must be familiar with leading frameworks and standards to select and adapt relevant components effectively. Once the roadmap is in place they have the responsibility for managing program activities to achieve the desired outcomes. It is the role of **senior management** to support these objectives and provide adequate resources and delegation of authority to ensure that they are achieved.

Practical Application

In practice, roadmap development might flow as follows:

- **Step 1:** Identify the enterprise's architecture (e.g., systems, networks, data flows).
- **Step 2:** Apply frameworks to define security controls for each layer.
- **Step 3:** Assign responsibilities to ensure accountability.
- **Step 4:** Monitor and adjust the roadmap to address gaps and emerging risks.

Example: For web-based applications, secure the internet layer with firewalls, the application layer with authentication, and the database layer with encryption, while ensuring policies and training support these measures.

Challenges and Considerations

There are some key considerations, that if addressed here, will ensure a successful outcome:

- **Complexity:** Large enterprises with diverse systems (e.g., legacy, cloud) require architectures tailored to the organization's needs. *The standards mentioned above can accelerate this process.*
- **Stakeholder Buy-In:** Ensure all departments (e.g., IT, HR, legal) align with the security roadmap. *A steering committee with key representatives from these business units can help.*
- **Continuous Improvement:** Plan to regularly review and update the roadmap to address new threats and business changes.

Developing an Information Security Program Roadmap

A structured plan that links security objectives to business goals will deliver the best results, guiding an organization from its current security posture to a desired future state.

The sequence of activities to develop the program roadmap could include:

1. Determine Strategic Alignment

- Identify the organization's business objectives and relevant international standards or frameworks (e.g., COBIT, ISO/IEC 27001 and 27002).
- Ensure security goals complement overall business strategies and priorities.

2. Assess Current Security Posture

- Review existing security policies, processes, and controls (e.g., threat monitoring, compliance monitoring, penetration testing).
- Evaluate how well current practices align with recognized best practices and standards.

3. Define Target Security State

- Outline the desired security capabilities, ensuring they meet both internal business needs and external regulatory requirements.
- Establish performance indicators and milestones to measure success.

4. Conduct Gap Analysis

- Compare current security capabilities with the desired future state.
- Identify specific areas needing improvement, such as policy updates, process enhancements, or additional controls.

5. Create an Action Plan

- Prioritize initiatives based on risk, business impact, and resource availability.
- Specify timelines, responsibilities, and budgets for implementing new or improved security measures.

6. Implement and Monitor

- Execute planned initiatives, integrating them into daily operations.
- Continuously measure performance against established objectives, adjusting as needed to address emerging threats or business changes.

Benefits

This approach should yield benefits across several areas:

- **Strategic Integration:** Aligns security efforts with business goals, ensuring that investments in security directly support organizational objectives.
- **Risk Management:** Identifies gaps and vulnerabilities early, allowing for targeted controls that reduce overall risk exposure.
- **Resource Allocation:** Prioritizes security projects based on impact and necessity, helping optimize budgets and staff.
- **Regulatory and Framework Compliance:** Ensures adherence to industry standards (e.g., COBIT, ISO/IEC 27001/27002), reducing compliance risks and potential legal penalties.
- **Continuous Improvement:** Establishes a structured approach for ongoing evaluation and refinement of the security program, keeping pace with evolving threats and business changes.

Life Cycle Principles Supporting the Roadmap

Using a structured life cycle, such as the **systems development life cycle (SDLC)**, ensures that security requirements are considered from project initiation through disposal, and risk management is continuous.

Phases of the SDLC

There's no single right answer for the systems development lifecycle, but here's a sensible iteration provided by ISACA, applicable in the CISM context.

- **1. Initiation:** Define and align high-level security requirements with business objectives.
- **2. Development/Acquisition:** Incorporate security controls into system design and code.
- **3. Implementation:** Test and validate these controls before going live.
- **4. Operations and Maintenance:** Monitor for vulnerabilities and update controls as needed.
- **5. Disposal:** Securely remove or archive data and decommission systems.

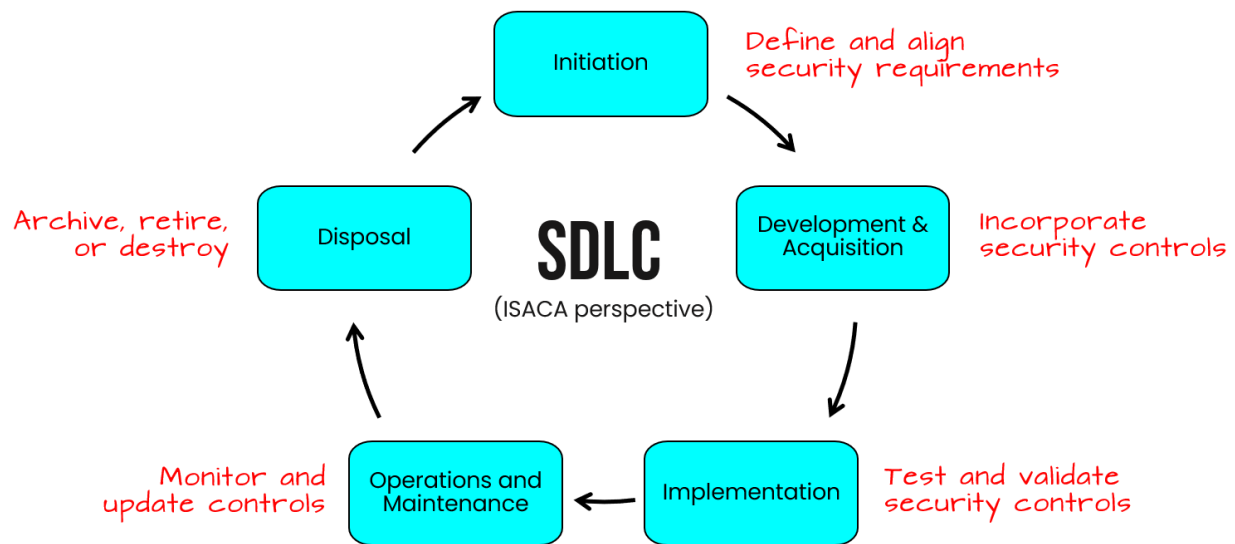


Figure 5.1. SDLC (ISACA perspective)

Within these phases are proactive activities that ensure the *security program remains effective and up to date*, such as:

- **Integrated Change Management:** Aligning life cycle activities with change management processes helps optimize resources and maintain security alignment with business goals.
- **Regular Updates:** Each phase of the system development life cycle (SDLC) includes specific security considerations, ensuring secure development, testing, operation, maintenance, and final disposal.
- **Risk Mitigation:** Applying consistent risk management practices throughout the life cycle minimizes disruptions and maintains data protection, supporting continuous improvement of the security program.

Benefits of a life cycle approach to the information security program include:

- Integrating security at each stage helps **avoid expensive, disruptive fixes** later.
- It also ensures **continuous risk management and compliance** with relevant regulations.
- By documenting and evaluating controls throughout the lifecycle, organizations can more **effectively communicate risk** and maintain a secure environment.

3A2. Information Asset Identification and Classification

Our focus in this section examines how to *identify, classify, and value* information assets.

- Information Asset Identification and Valuation

- Information Asset Valuation Strategies
- Information Asset Classification
- Methods to Determine Criticality of Assets and Impact of Adverse Events
- Asset Identification, Valuation, and Classification

Data protection throughout all stages of the information lifecycle is a critical aspect of risk mitigation. To prepare you for the exam, we'll focus on three areas:

- The Information Lifecycle
- Data Collection and Use
- Data Obfuscation Techniques

The Information Lifecycle

The CISM exam won't test you on a specific information lifecycle process. However, to succeed on questions related to data security, you should be familiar with the information lifecycle. Understanding the secure data lifecycle from a functional perspective will assist in questions related to control selection on the CISM exam.

Let's quickly step through the phases of this version secure data lifecycle.

1. Creation (Create). Data can be created by **users** (such as a file) or a **system** (e.g. logging access)

2. Classification (Classify). To ensure it is handled properly, it's important to ensure data is **classified** as soon as possible.

3. Storage (Store). Data should be protected **at rest** by adequate security controls based on its classification. Sensitive data should **never** be stored unencrypted.

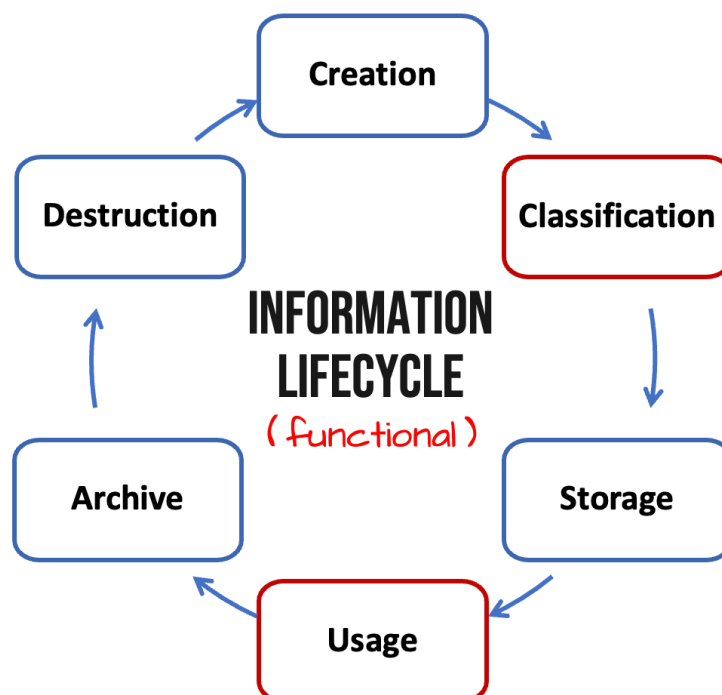


Figure 5.2. Functional perspective of the Information Lifecycle

4. Usage (Use). Data should be protected in transit using appropriate encryption. For data in motion, this is often TLS. Access controls and data security measures like data loss prevention (DLP) should be implemented to prevent data leaks, intentional or accidental, such as through oversharing.

5. Archival (Archive). Archival is sometimes needed to comply with laws or regulations requiring the retention of data. Even if there is no compliance requirement, it's a good idea to archive files and logs for a time in case the organization needs to recover for some reason, such as incident response.

6. Destruction (Destroy) When data is no longer needed, it should be destroyed in such a way that it is not readable. When properly destroyed, data will not be retrievable even with forensic tools and techniques.



Data should always be destroyed the moment it is no longer needed. Data retained longer than it's needed **increases risk**. Data you don't have is data that cannot be leaked, stolen, or produced in discovery for a legal proceeding.

Information Asset Identification and Classification

The **primary goal** of an information security program is to *protect valuable resources in a cost-effective way that aligns with stakeholder expectations*.

To achieve this, organizations must **identify** and **classify** all relevant assets—ranging from data and personnel to devices, systems, facilities, and any other resources that support business objectives. Classification should reflect each asset's relative importance to the organization's goals and risk strategy, ensuring the right level of protection is applied where it is needed most.

Information Asset Identification and Valuation

A key step is to *inventory all information assets and determine their business value*, which may be expressed as criticality (e.g., how essential they are to operations) or sensitivity (e.g., how damaging a breach might be). This valuation drives risk determination because risk is a product of **likelihood** and **consequences**.

- **Tangible vs. Intangible Assets:** Many assets are straightforward to value based on financial data, but *intangible assets* (e.g., brand reputation, intellectual property) may not appear on financial statements. Overlooking these can lead to incomplete risk assessments and insufficient security measures.
- **Valuation and Consequences:** Understanding an asset's value helps gauge the potential impact if it is compromised. Even if an asset lacks a direct financial figure, it should still be classified if its compromise could harm the organization.

Valuing hardware is straightforward - just check the replacement cost. But information's value often lies in the repercussions of a security breach. For instance, exposing trade secrets might devastate a competitive advantage, and leaking customers' personal data could lead to lawsuits, reputational harm, and regulatory fines. Even seemingly low-value marketing data might pose legal liabilities if it misrepresents products or influences investments improperly.

A few examples of information asset categories organizations might have to value/protect include:

- Proprietary data (trade secrets, business intelligence)
- Privacy-regulated data (PII, PHI)
- Payment card information (PCI)
- Current financial records and future projections
- Merger and acquisition plans
- Strategic marketing plans

Information Asset Valuation Strategies

Valuation methods can vary, but they should be **consistent** and **justifiable** to avoid underestimating risk. *Common considerations include:*

1. Market Capitalization vs. Book Value

- For publicly traded companies, intangible assets often appear as the difference between the market value and the recorded value of tangible assets. For example, if a company has a market capitalization of \$1.5 billion and only \$0.5 billion in tangible assets on its balance sheet, the remaining \$1 billion represents intangible assets (e.g., brand, goodwill).

2. Risks of Ignoring Intangible Assets

- Failing to account for intangible assets (like reputation or proprietary methods) can lead to major gaps in risk analysis. If a data breach or other event damages these assets, the costs can be significant (e.g., lawsuits, loss of consumer trust).

3. Consistency in Approach

- Security managers must adopt a **repeatable** process to identify and value intangible assets, ensuring that all significant assets—tangible or intangible—are included in risk assessments.

Many organizations struggle with asset valuation because it can be difficult or time-consuming to precisely assign numerical value—especially to intangible or sensitive data. However, complete accuracy isn't always necessary. Approximate valuations and thoughtful classification can still help focus security investments where they matter most.

A practical approach is to use well-defined loss scenarios. For each scenario (e.g., data breach, insider theft), estimate potential costs from downtime, regulatory penalties, or lost sales. *You can use:*

- **Quantitative methods:** Annualized loss expectancy (ALE), net present value (NPV), or other financial computations.
- **Qualitative methods:** Assign categories such as “High,” “Medium,” or “Low” for both impact and likelihood.
- **Hybrid approaches:** Blend financial estimates with business judgment.

Valuing intangible assets: In many cases, intangible assets (brand reputation, customer trust) might significantly exceed the book value of physical items. For example, a breach of 10,000 customer records can trigger millions of dollars in notification costs, legal expenses, and harm to public perception.

Integrating Asset Classification with Risk Structures

Once assets are identified and valued, they must be mapped to **business functions** and **risk structures**. Classification is about labeling resources according to sensitivity (risk if exposed) and criticality (risk if unavailable or corrupted). A standardized classification scheme ensures that more sensitive or vital data receive stronger protective measures. This alignment ensures that *risk assessments reflect how each asset supports critical business operations*:

- **Top-Down vs. Bottom-Up:** Some organizations use a top-down approach (starting with overall business objectives and working down to individual assets), while others use a bottom-up approach (aggregating vulnerabilities from specific assets upward). Both methods can reveal where threats are most severe.
- **Critical Function Layer:** Visual models (shown in the figure below), illustrate how assets relate to key business functions. By grouping assets under these functions, management can see vulnerabilities in context and prioritize remediation efforts accordingly.
- **Classification Benefits:** A structured classification system links the importance of an asset to the protection level it should receive. This helps direct resources efficiently—high-value or highly sensitive assets get stricter controls, while less critical assets might need fewer protections.

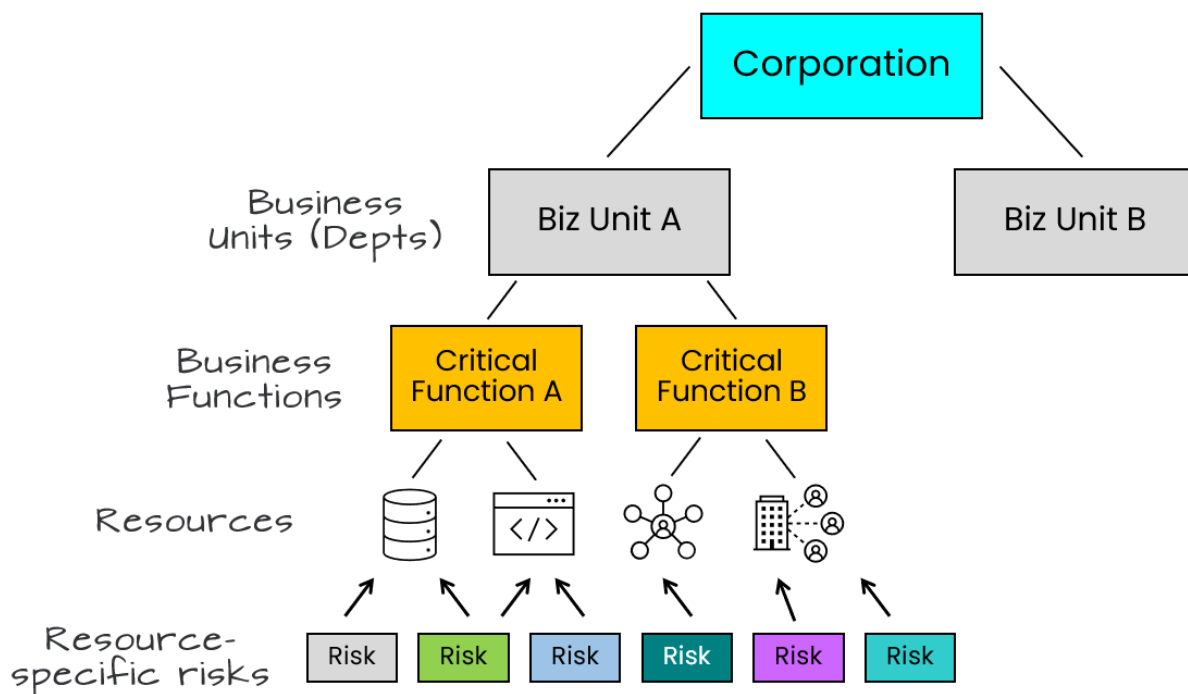


Figure 5.3. Mapping Business Functions to Risks

Key steps in classification:

1. **Inventory assets** (including those hosted externally by vendors or in the cloud).
2. **Identify data owners, custodians, and users**, which is a collaborative process, requiring input from business units. This step is critical for establishing accountability and ensuring that the right people are involved in the classification process.
3. **Assign classification levels** (e.g., Confidential, Internal, Public) in alignment with business impact.
4. **Mark or label** data according to classification.
5. **Outline handling, storage, transport, and destruction procedures** for each classification level.
6. **Define ownership and access rights** includes “access control levels” and ensuring appropriate business and IT stakeholders review and approve these guidelines.
7. **Ensure retention periods and disposal methods meet compliance.** There may be business and technical needs for retention, with legal and regulatory requirements generally taking priority.

Exam Tip: Avoid “over-classification”, where unnecessary or disproportionate controls inflate costs and hinder productivity. The goal is proportional protection aligned with actual risk.

Data Protection Technologies

While you won't be tested directly on data protection technologies, you are expected to be familiar with technologies for purposes of control selection. You will want to be familiar with data protection tools and solutions, how they work (at a high level), and scenarios where they fit in a layered data protection strategy.

- DRM (Digital Rights Management)
- DLP (Data Loss Prevention)
- CASB (Cloud Access Security Broker)
- Data Collection, Use, and Security
- Data Minimization Techniques

DRM (Digital Rights Management)

DRM is a set of access control technologies used to restrict the use, modification, and distribution of copyrighted works such as software, multimedia content, and documents. It focuses on protecting intellectual property and controls access, copying, and distribution of digital content. It is often used for media files, e-books, and software licensing. DRM may use watermarking for tracking and tracing unauthorized distribution of copyrighted works.

Example: When Kelly, a customer purchases an e-book, a bookseller's system generates a unique identifier associated with her account. Before delivering the e-book file to Kelly, the bookseller's system embeds this unique identifier into the file as a watermark.

DLP (Data Loss Prevention)

DLP refers to a set of tools and processes designed to detect and prevent breaches, exfiltration, or unwanted destruction of sensitive data. DLP monitors, detects, and blocks sensitive data in use, in motion, and at rest.

It helps organizations protect intellectual property and comply with regulations. DLP can be implemented in various parts of an organization's infrastructure, using different types of DLP tooling.

There are three flavors (types) of DLP you should be familiar with:

- **Cloud DLP** protects data stored in cloud services and SaaS applications. It monitors data movement between users and cloud services. It is ideal for organizations heavily reliant on cloud storage and applications.
- **Endpoint DLP** focuses on protecting data on end user devices like laptops, desktops, and mobile devices. It monitors activities such as file transfers, printing, and use of removable media. It's particularly useful for organizations with a large remote workforce and/or BYOD policies.
- **Network DLP** monitors data in transit across the organization's network. It inspects network traffic for sensitive data patterns. It is most effective for organizations with centralized network infrastructure.

Scenario: A medical research organization using a DLP solution to label and encrypt their research documents containing their confidential research (intellectual property), DLP policies to prevent it from being shared outside the research department.

CASB (Cloud Access Security Broker)

CASB (pronounced 'kaz-bee') is a security policy enforcement point placed between cloud service consumers and cloud service providers to combine and interject enterprise security policies as cloud-based resources are accessed.

It ensures compliance with data privacy regulations, protects against threats in cloud services, and provides visibility into cloud application usage.

Scenario: A multinational corporation using a CASB to monitor and secure access to various cloud services (like Office 365, Dropbox, and Salesforce) across its global workforce, ensuring consistent security policies and threat protection.



The CASB space was originally focused on detection and prevention of shadow IT but has matured well beyond this focus over the last several years.

Side-by-Side Comparison of DRM, DLP, and CASB

To help your understanding for exam day, here is a side-by-side comparison of these solutions in terms of focus, scope, primary users, and implementation.

1. Focus:

- **DRM:** Content protection and access control
- **DLP:** Data leak prevention and sensitive information protection
- **CASB:** Cloud service security and visibility

2. Scope:

- **DRM:** Primarily digital content and software
- **DLP:** All sensitive data within an organization
- **CASB:** Cloud services and applications

3. Primary users:

- **DRM:** Content creators, publishers, and distributors
- **DLP:** Organizations handling sensitive data (e.g., financial, healthcare)
- **CASB:** Organizations heavily utilizing cloud services

4. Implementation:

- **DRM:** Embedded in content or software
- **DLP:** Network, endpoint, and cloud-based
- **CASB:** As a cloud service or on-premises solution

Each of these technologies plays an important role in modern information security, often complementing each other to provide layers of data protection across an organization's digital ecosystem.

Data Collection, Use, and Security

Once data has been classified, it should be secured. It's important to remember that more data = more risk. Data protection begins at the beginning of the lifecycle with two important practices:

Purpose Limitation. Use collected data only for the specific purposes that were disclosed when collecting it. For instance, if customers provide their email for order notifications, don't use it for marketing unless they explicitly agreed to that purpose.

Data Minimization. Only collect and retain data that's absolutely necessary for specific business purposes. Think "less is more" - the less sensitive data you store, the lower your risk. For example, if you only need someone's age category for marketing, don't collect their exact birth date.

Anonymization, also called de-identification, is the process of removing relevant data so that it is impossible to identify original subject or person. However, this technique is only effective if you do not need to identify the original subject.

Data Obfuscation Techniques

Data obfuscation techniques are privacy-enhancing technologies that organizations use to protect sensitive information while maintaining data utility. Full anonymization (eliminating any connection to the original subject) is often not practical, in which case data obfuscation is the best approach.

There are multiple data obfuscation techniques, including:

- **Pseudonymization.** The process of using pseudonyms (aliases) to represent other data. It removes the privacy data so the remaining data can be shared, while sensitive data remains available in a separate dataset.
- **Tokenization.** A data security technique that replaces sensitive data with unique identification symbols that retain all the essential information about the data without compromising its security. The symbol (token) has no extrinsic or exploitable meaning or value. The original data is stored securely in a vault.
- **Data masking.** An obfuscation technique where only partial data is visible in a data field. For example, a credit card may be shown as **** * 1234. This technique is commonly implemented within the database tier, but also possible in code of frontend applications.

Determine Criticality of Assets, Impact of Adverse Events

After establishing a classification framework, organizations need to evaluate **how critical each asset is** and **what happens if it is compromised**:

1. Defining Sensitivity and Criticality

- Sensitivity often focuses on confidentiality, integrity, and availability requirements (i.e., how damaging would it be if data is exposed, altered, or unavailable?).
- Criticality focuses on how essential an asset is to **business continuity** and **core operations**.

2. Business Impact Analysis (BIA)

- A BIA helps measure the effect of disruptions on business processes. By identifying dependencies between assets and processes, an organization can estimate potential financial losses, regulatory consequences, and reputational harm.

3. Number of Classification Levels

- Although multiple classification tiers can provide granular protection, too many levels can become unwieldy. Striking a balance is important: enough levels to differentiate between truly critical vs. less important assets, but not so many that the system becomes too complex to manage.

4. Transport, Storage, and Handling Considerations

- Understanding how data is stored, accessed, and transferred informs the required security controls. Highly sensitive data may need encryption, restricted access, and specific handling procedures.

5. Ongoing Review and Adjustment

- As business objectives evolve and new threats emerge, asset classifications and valuations must be revisited to ensure the security program remains aligned with the organization's risk tolerance and strategic goals.

Key Takeaways:

A few of the key points to remember when it comes to asset identification and classification include:

- **Identify and classify** all assets, both tangible and intangible, to capture their full business value.
- **Valuation** of assets (especially intangible ones) is crucial for a complete risk assessment.
- **Align** assets with business functions and risk structures to prioritize security efforts effectively.
- **Determine criticality** by examining how each asset's compromise affects confidentiality, integrity, availability, and overall business operations.
- **Maintain** a flexible but consistent classification system, revisiting it as the business and threat landscapes change.

3A3. Industry Standards and Frameworks for Information Security

Various globally recognized standards and frameworks serve as reference points for establishing or enhancing an information security management program. *These frameworks provide authoritative guidance*; either **mandatory (normative)** or **advisory (informative)**, to help you design and operate a security program aligned with both general best practices and industry-specific requirements.

Organizations rely on recognized standards and frameworks to structure and manage their information security programs. These frameworks serve a couple of supporting purposes in the context of the information security program:

- Provide common terminology and guidance for designing, implementing, and maintaining security controls.

- Offer an integrated, coordinated approach so that different control requirements can be adopted more effectively and consistently.
- Help ensure that security efforts align with business objectives and regulatory demands.

By using well-established frameworks, security professionals can more easily communicate objectives, measure progress, and maintain a holistic view of security across the organization.

Framework Types

You may see mention of control frameworks, risk management frameworks, and security program frameworks, and it's important to know the difference between them. *Here are the key distinctions between these three types of frameworks:*

- **Control frameworks** are collections of security controls and starting points for implementing security controls. They provide detailed guidance on what controls should be implemented.

Examples: CIS CSC, ISO/IEC 27002, NIST SP 800-53, PCI DSS, etc.

- **Risk management frameworks** provide blueprints for a risk management life-cycle program and how to assess and manage risk over time. They guide organizations through the process of identifying, assessing and treating risks.

Examples: ISO/IEC 27005, ISO/IEC 31000, NIST CSF, NIST SP 800-37

- **Security program frameworks** are business process models that focus on how to develop and manage the overall security program. They describe the overall activities in an information security program and are risk-centric because risk identification drives other activities.

Examples: ISO/IEC 27001, NIST CSF, COBIT, ETSI TR 103 787-1

The key distinction is that control frameworks focus on what controls to implement, risk management frameworks focus on how to manage risk, and security program management frameworks focus on how to run the overall security program.



Bear in mind that some frameworks like NIST CSF *serve multiple purposes* and can be used as both a risk management framework and includes control mappings. As a result, some will be mentioned in multiple contexts.

Enterprise Information Security Architectures

An Enterprise Information Security Architecture (EISA) is a method for aligning security requirements, solutions, and processes with an organization's overall business and IT strategies. It is a core component of the broader enterprise architecture, ensuring that security is embedded at every level of the organization.

EISA addresses confidentiality, integrity, and availability by:

- Defining a conceptual design for the security program.
- Establishing an operating model that integrates people, processes, and technology.
- Helping to manage risk consistently across different domains (e.g., applications, infrastructure, data).

Why do some organizations fail to embrace security architecture?

- **Cost and Time:** Implementing a security architecture project can be expensive and require extensive time and effort. Many organizations lack awareness of its value.
- **Shortage of Skilled Architects:** Few professionals have the breadth and depth of expertise to address the full spectrum of security architecture needs.
- **Lack of Integration:** Over time, the absence of a unifying security architecture can result in siloed security solutions. While individual tools may become more sophisticated, fragmented security often increases the organization's overall vulnerability.
- **Increasing Complexity:** As systems expand and multiply, organizations find it increasingly difficult to unify and manage security effectively.



Because of this complexity, it's wise for the information security manager to seek support from enterprise architects. Their expertise helps ensure that intricate integration points remain both relevant and workable as the organization's needs evolve.

Objectives of Information Security Architecture Approaches

1. Provide an overarching structure and consistency.
2. Serve as a roadmap for program development.
3. Align security strategy with overall business goals.

4. Enable the business to succeed while implementing security controls.
5. Enforce security policies and strategies.
6. Maintain traceability from security measures back to business requirements.
7. Offer a technology-agnostic view that remains flexible for various implementations.
8. Establish common terminology within the enterprise.
9. Allow multiple stakeholders and contributors to coordinate toward shared objectives.

Types of Architectural Approaches

1. Process Approaches

Offer step-by-step guidance on how to design and implement each architectural element.

2. Frameworks

These describe the components of an architecture and define how they relate to each other, but they allow flexibility in how you actually build and maintain those components. Examples include COBIT, Zachman, SABSA, and TOGAF.

3. Reference Models

Smaller-scale representations that capture how the “real world” system or architecture should be structured.

Despite many possible approaches, they typically share the same fundamental aim: ensuring that security underpins and aligns with the enterprise’s mission. For instance, the Zachman framework’s method of asking who, what, why, where, when, and how is mirrored in both SABSA and E2AF.

Common Frameworks and Models

Several frameworks exist to structure an EISA. They typically break down enterprise security into multiple layers or domains, making it easier to handle the complexity of modern environments. Two prominent examples are:

1. SABSA (Sherwood Applied Business Security Architecture)

- Evolved from enterprise architecture methods (like the Zachman framework).
- Uses a six-layer matrix (contextual, conceptual, logical, physical, component, operational) aligned with questions of *why, what, how, who, where, and when*.
- *Ensures security requirements (e.g., business drivers) map clearly to technical controls and ongoing management processes.*

2. TOGAF (The Open Group Architecture Framework)

- Divides architecture into four domains: **business, data, application, and technology**.
- Provides the **Architecture Development Method (ADM)**, a cyclical process that guides organizations through defining an architectural vision, establishing a baseline, developing a target architecture, and then planning and governing its implementation.
- *Focuses on ensuring business needs drive the development of technology solutions.*

Alternative Enterprise Architecture Frameworks

Beyond SABSA and TOGAF, other frameworks and methodologies can be adapted to security architecture, such as:

- AGATE
- Open Security Architecture
- United States Federal Enterprise Architecture (FEA)
- UK Ministry of Defence Architecture Framework (MODAF)
- DoD Architecture Framework (DoDAF)
- Model-Driven Architecture (MDA)

Each has its own emphasis (e.g., industry-specific needs or government requirements), but all share a goal of *systematically aligning technical and business strategies*.

Enterprise Architecture Domains

To manage complexity, enterprise architecture is often grouped into domains, such as **business processes, organizational structure, data, applications, and technology**. By focusing on how these domains interrelate, an EISA ensures:

- A standardized, consistent approach to securing systems and data.
- Alignment of security controls with overall enterprise goals.
- A clear framework for addressing gaps and overlaps in security coverage.

Using an EISA within an established framework (like SABSA or TOGAF) helps security teams understand and communicate how specific controls, processes, and technologies serve the broader mission of the organization. This structured approach is crucial for managing complexity, ensuring regulatory compliance, and supporting continuous improvement of the security program.



Above all, make sure organizations should ensure their **security architecture** is closely *integrated* with your overall **enterprise architecture** so that security remains an essential design element rather than an afterthought.

Information Security Management Frameworks

An **information security management framework** provides a structured way to define, implement, and maintain security across an organization. It aligns security activities with business goals, risk tolerance, and regulatory requirements. Typically documented in policies,

procedures, and standards, this framework ensures consistent protection of information assets and supports continuous improvement as threats and business needs evolve.

Key Characteristics:

There are some common characteristics most common framework same to deliver:

- **Alignment with Business Objectives**
 - Ensures security efforts directly support the organization’s overall strategy and goals.
 - Balances protection needs with business priorities and risk appetite.
- **Defined Roles and Responsibilities**
 - Clarifies who is accountable for various security tasks.
 - Assigns clear authority for decision-making and policy enforcement.
- **Risk Management Focus**
 - Identifies, analyzes, and addresses security risks in a systematic way.
 - Helps select and apply the right security controls based on risk assessments.
- **Performance Measurement and Continuous Improvement**
 - Uses metrics and regular reviews to gauge effectiveness.
 - Adapts to emerging threats, changes in technology, and organizational growth.

Exam Tip: Per ISACA, The CISM exam will not test any specific framework or standard, but candidate should understand how to apply a framework in their enterprise.



Information security managers should be aware of frameworks applicable to their industries or specific enterprises.

Common Frameworks

There’s no single all-purpose framework. Each organization must tailor or combine elements from multiple frameworks to suit its needs. Some commonly referenced frameworks include:

- **COBIT**
- **ISO/IEC 27001/27002**
- **NIST Cybersecurity Framework**
- **NIST Risk Management Framework**
- **Industry-specific standards** (e.g., PCI DSS, HIPAA, NERC CIP)

Exam Tip: While each will be introduced briefly below; on the CISM exam, you won't be tested on any one framework in detail. However, ISACA advises you should understand how to apply a framework in your own environment.

COBIT

COBIT helps enterprises balance IT benefits, risk, and resources. Its principles guide how information and technology should be governed and managed holistically, offering alignment with business goals and stakeholders' interests. COBIT:

- Features two sets of principles guiding governance and the overall framework
- Maps information security within a broader enterprise context
- Helps assess and communicate risk effectively
- Offers **focus areas**, such as information security, digital transformation, risk, and privacy, where specialized guidance is needed

Major drivers for COBIT's information security focus area include:

- **Business Integration:** Recognizing that information security extends beyond IT and is an enterprise-wide responsibility
- **Risk Management:** Needing to achieve acceptable levels of risk, protect technology assets, ensure system availability, and comply with laws and regulations
- **Cost Management:** Keeping costs reasonable while managing security
- **Adaptability:** Integrating well with other frameworks and standards

ISO/IEC 27001

ISO/IEC 27001 and 27002 offer widely accepted best practices for establishing an information security management system (ISMS). They outline 114 controls organized into 14 domains, such as access control, cryptography, and physical security. While ISO/IEC 27001 can map to broader frameworks like COBIT, it's primarily a security-focused standard rather than a comprehensive IT governance model.

The 14 control domains are:

1. Information security policies
2. Organization of information security
3. Human resource security
4. Asset management

5. Access control
6. Cryptography
7. Physical and environmental security
8. Operations security
9. Communications security
10. System acquisition, development, and maintenance
11. Supplier relationships
12. Information security incident management
13. Information security aspects of business continuity management
14. Compliance

NIST Cybersecurity Framework (CSF)

Originally created to protect **critical infrastructure** in the United States, the NIST Cybersecurity Framework has broader applicability. *Rather than prescribing specific controls, it guides organizations to:*

1. Define the **current** cybersecurity posture
2. Describe the **desired** future state
3. Identify and prioritize gaps
4. Implement plans to reduce cybersecurity risk

Three Key Components:

1. **Framework Core:** Organized around five functions—Identify, Protect, Detect, Respond, Recover.
2. **Implementation Tiers:** Ranging from Partial (Tier 1) to Adaptive (Tier 4). Higher tiers indicate more mature and integrated practices.
3. **Profiles:** Descriptions of how an organization has implemented or plans to implement these five functions.

The NIST CSF is designed for non-government organizations and is **OPTIONAL**.

NIST Risk Management Framework (RMF)

The RMF integrates security, privacy, and supply chain risk into the system development life cycle. Although it originated for US federal agencies, it's widely used by many organizations. The process involves seven steps:

1. **Prepare**
2. **Categorize**
3. **Select** (controls)
4. **Implement**
5. **Assess**
6. **Authorize**
7. **Monitor**

This cyclical approach ensures controls remain effective as the technology and threat landscapes evolve.

The NIST RMF is designed for government agencies and is **MANDATORY** for those to which it applies.

Industry-Specific Standards

Many sectors have specialized standards, including:

- **PCI DSS**: Protects payment card data.
- **HIPAA**: Safeguards electronic protected health information (e-PHI).
- **NERC CIP**: Secures North America's bulk electric systems.

Additionally, local, regional, and national regulations provide more targeted requirements in certain jurisdictions.

Overall Value

By following a recognized **information security management framework**, organizations can:

- **Integrate** security into day-to-day operations.
- **Demonstrate** due diligence and regulatory compliance.
- **Optimize** resource use and align investments with prioritized risks.
- **Continuously refine** security practices in response to new threats and business changes.

In essence, these frameworks provide the foundation and roadmap for a robust, evolving security program that supports and protects the organization's mission.

Information Security Framework Components

Most frameworks begin with **risk assessment** and define **control objectives** that address identified risks. Although these frameworks offer guidance, every organization should tailor controls to its unique risk appetite, regulatory environment, and business objectives. Over time, evolving threats and changing business conditions may necessitate adjusting or replacing controls to maintain alignment with strategic goals.

To ensure comprehensive coverage, break down management framework components into **technical, operational, managerial, administrative, and educational** categories. This method helps confirm that each aspect of security receives due attention.



Remember, standard frameworks (e.g., NIST SP 800-53, COBIT 5, ISO/IEC 27002) often guide control selection but must be scoped and tailored to the enterprise's unique regulatory and operational requirements.

Technical Components

Technical components include the hardware and software that directly enforce security measures. These components are controls address specific threats and vulnerabilities, support policy enforcement, and automate monitoring and alerting processes.

Examples: Intrusion detection systems (IDS), intrusion prevention systems (IPS), security information and event management (SIEM) tools, firewalls, and other technical controls.

Operational Components

Operational components refer to the day-to-day activities and processes that maintain and support the security posture. Their purpose is to ensure continuous compliance, detect and respond to threats, and maintain protective measures on an ongoing basis.

Examples: Identity and access management, vulnerability management, patch management, security monitoring, and incident response.

Management Components

Management components include governance, strategic direction, and oversight responsibilities for the security program.

A few examples of management components include:

- **Risk Management:** Identifying and evaluating risks, determining acceptable risk levels, and aligning security initiatives with business objectives.
- **Resource Allocation:** Securing the necessary budget, tools, and personnel to implement and sustain the security program.
- **Performance Metrics:** Establishing and tracking KPIs to measure effectiveness, adjust strategies, and communicate results to senior leadership.
- **Coordination:** Maintaining open communication with business units, executive committees, and other stakeholders to ensure alignment and measure program effectiveness.

Administrative Components

Administrative components are formal structures and documentation that establish the security program's foundational requirements.

A few examples of administrative components include:

- **Policies, Standards, and Procedures:** Defining acceptable practices, mandatory controls, and step-by-step processes.
- **Roles and Responsibilities:** Clarifying ownership, accountability, and authority for security-related tasks.
- **Documentation:** Maintaining updated records, ensuring consistent application of policies, and demonstrating compliance with regulations and best practices.

Educational and Informational Components

Educational and informational initiatives promote security awareness, knowledge, and skills across the organization.

A few common methods include:

- **Orientation and Awareness Training:** Covering basic security principles, acceptable use policies, and role-specific responsibilities.
- **Interactive Techniques:** Role-playing, quizzes, and scenario-based exercises to improve engagement and retention.
- **Tracking and Reporting:** Monitoring attendance, quiz scores, and other metrics to assess effectiveness; reporting results to management and steering committees for continuous improvement.

Collaborating with HR and business unit leaders helps ensure that security education is relevant, timely, and reinforced throughout the organization.

By integrating technical, operational, management, administrative, and educational components, an information security program can comprehensively address risks, ensure alignment with business objectives, and maintain robust protection for the organization's information assets.

3A4. Information Security Policies, Procedures, and Guidelines

An effective information security program relies on **policies, standards, procedures, and guidelines** that align with organizational goals, regulatory requirements, and risk management objectives. These documents provide a structured approach to safeguarding assets and ensuring consistent, compliant practices across the enterprise.

You should be familiar with the purpose, scope, development, and maintenance of security policies, standards, procedures, and guidelines. In this section we're going to take a look at their purpose, attributes, as well as how each is typically developed and maintained. You'll also find examples of each, as well as exam tips specific to CISM to help you appreciate the contexts in which they might be raised.

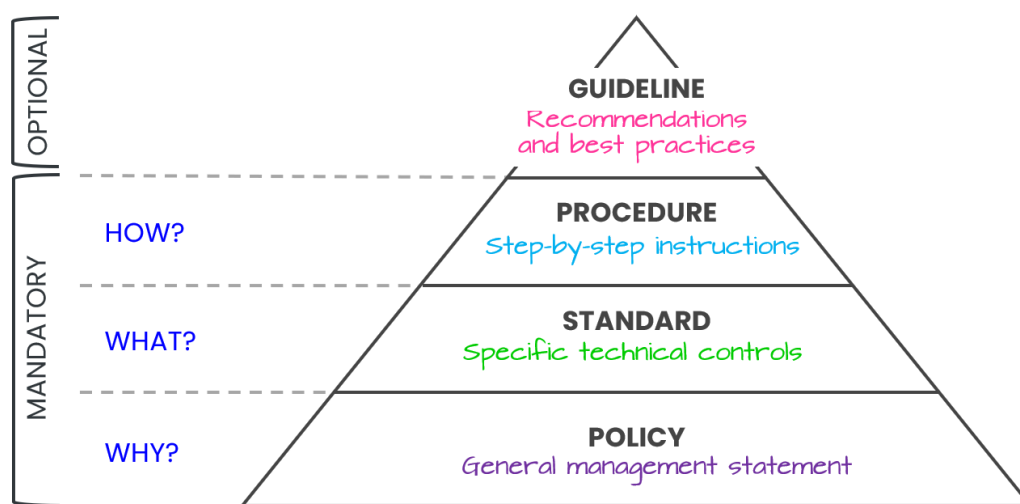


Figure 5.4. Policy, Standards, Procedures, Guidelines

Security Policy

- Definition and Purpose

- Policies are high-level statements of management's intent and expectations regarding information security.
- They define an organization's security objectives and establish the scope, responsibilities, and overall direction for protecting information assets.

- **Characteristics**

- Typically reference relevant laws, regulations, and business requirements.
- Outline enforcement or sanction measures for noncompliance.
- Serve as a foundation for developing standards, procedures, and guidelines.

- **Development:**

Usually drafted by senior leadership, security governance committees, or executive sponsors who have a clear understanding of the organization's risk appetite and strategic objectives. Policies typically go through a formal approval process involving top management or the board of directors.

- **Lifecycle and Exception Handling**

- Policies should be drafted, reviewed, approved, published, and regularly updated to reflect changes in the environment.
- An exception process must document requests for deviations, define risk acceptance or mitigating controls, and ensure a formal review and approval mechanism.

Example: "The organization is committed to protecting the confidentiality, integrity, and availability of its information assets."



Design and implementation of security policies will take business cases and budget restrictions into account to ensure policies are both effective and resource efficient.

Security Standard

- **Role and Scope**

- Standards translate policy directives into specific, mandatory requirements.
- They provide detailed rules and technical specifications (e.g., configuration baselines, password rules) that ensure consistent implementation of policies.

- **Key Attributes**

- Must be clear, unambiguous, and aligned with the intent of the policy.
- Require careful review and dissemination to all affected stakeholders.
- Are subject to periodic review and revision to maintain relevance and effectiveness.
- **Development:**
Typically created by subject matter experts (e.g., security architects, network administrators) who translate the high-level policy into actionable, enforceable technical requirements. Standards are often reviewed and approved by a security steering committee or a governance body to ensure consistency and feasibility.
- **Exception Process**
 - A formal procedure should exist for requesting and approving deviations from standards.
 - Mitigating controls or compensating measures are often required when exceptions are granted, to address any additional risk introduced.

Example: “All passwords must be at least 12 characters long and include a combination of uppercase and lowercase letters, numbers, and symbols.”

Security Procedure

- **Definition and Ownership**
 - Procedures are detailed, step-by-step instructions for operational tasks that support policy and standards.
 - They are generally created and maintained by functional or operational groups (e.g., IT operations, help desks, business units).
- **Purpose and Content**
 - Clearly describe how to perform specific activities (e.g., system configuration, incident response steps) in a consistent and secure manner.
 - Should specify roles, responsibilities, and escalation paths.
- **Development:**
Created by the operational teams or process owners who perform these tasks daily. They collaborate with security teams to ensure procedures align with standards. Management or department leads often approve procedures to confirm they meet policy and standard requirements.
- **Validation and Maintenance**
 - Must be tested for accuracy and feasibility.
 - Require periodic review and updates to stay aligned with changing technologies, business needs, and security objectives.

Example: “Procedure for Incident Response: Upon discovering a security incident, follow these steps: 1. Isolate the affected system. 2. Notify the security team. 3. Document the incident.”

Security Guideline

- **Function:**
 - Guidelines offer recommended (but not mandatory) best practices to help individuals follow policies, standards, and procedures.
 - They provide flexibility for different operational contexts while promoting consistent decision-making.
- **Specificity:**

Least specific, offering suggestions and recommendations that can be adapted to specific situations.
- **Application**
 - Serve as a reference or orientation to align organizational actions with recognized best practices.
 - Can be adapted as needed, ensuring they remain supportive rather than restrictive.
- **Development:**

Generally produced by security subject matter experts or industry professionals who identify helpful (but optional) practices. Guidelines are often published with minimal formal approval, since they are intended to be flexible enhancements rather than strict requirements.

Example: “Employees are encouraged to take advantage of security awareness training programs.”

How are policies, standards, procedures, and guidelines related?

These elements are interconnected and form a hierarchical structure:

1. **Security Policy** – Sets the overall vision and goals for information security.
2. **Security Standards** – Translate the policy into specific technical requirements and best practices.

3. **Security Procedures** – Provide detailed instructions on how to implement the standards.
4. **Security Guidelines** – Offer additional recommendations and best practices that can be adopted to further enhance security.

Analogy: Think of building a house

- **Policy:** The *blueprint* describing the vision and overall requirements for the house.
- **Standard:** The *building codes and mandatory specifications* (e.g., electrical wiring must meet certain safety criteria).
- **Procedure:** The *step-by-step instructions* that construction teams follow to pour the foundation, frame the walls, and install the roof.
- **Guidelines:** *Optional interior design tips* that can make the home more comfortable or efficient (e.g., suggestions for energy-saving light fixtures).



By following this hierarchy, organizations can ensure that their security measures are comprehensive, well-defined, and effectively implemented.

3A5. Information Security Program Metrics

When selecting and developing metrics for security program, you'll see several familiar themes that we've discussed in metrics for different areas of the effort, including:

1. Importance of Measurement

- You cannot manage what you cannot measure. Metrics are essential to gauge whether a security program is meeting its objectives, how well it is performing, and where improvements are needed.

2. Demonstrating Security Value

- Metrics help show the impact of security initiatives and justify security investments to stakeholders. They provide tangible evidence of effectiveness and return on investment (ROI).

3. Monitoring Control Objectives

- A formal procedure for monitoring and measuring the achievement of control objectives must be established. These measurements ensure that processes are fit for their intended purpose and meet defined goals.

4. Alignment with Business Objectives

- Effective metrics measure performance against the enterprise's broader business objectives and help assess how risk affects the organization.
- Metrics form the basis for key performance indicators (KPIs) that reflect how well the security program fulfills its mission and aligns with strategic aims.

5. Management-Level Concerns

Technical metrics alone do not answer high-level questions such as:

- "How secure is the enterprise overall?"
- "How much security is enough?"
- "How do we know we have achieved an adequate level of security?"
- "How do we determine or predict the degree of risk?"
- "Is the security program meeting its objectives?"
- "What if a catastrophe scenario occurs—how do we track and respond?"
- "How do security initiatives align with the organization's strategic plan?"

Meaningful answers to these questions will require risk assessments and security audits to gain a broader perspective.

Effective Security Metrics

If you want to identify meaningful, measurable metrics, there are a few considerations that will help you to identify them:

1. Purpose and Relevance

- Security metrics should reveal the organization's security posture, the nature of its risk environment, or the effectiveness of controls.
- Not everything that can be measured is necessarily relevant. Meaningful metrics should offer insights into actual security or risk conditions.

2. Frameworks and References

Widely recognized references for developing and evaluating security metrics include:

- NIST SP 800-55
- COBIT
- ISO/IEC 27004
- Balanced Scorecard
- Goal Question Metric (GQM)
- ITIL

These frameworks guide the selection and use of metrics but may not guarantee alignment with overarching business objectives or risk management strategies.

3. Limitations of Metrics

- Metrics may indicate policy compliance or whether certain impact thresholds are being met, but they do not always show whether the program is truly aligned with strategic goals or if risk is being managed optimally.

4. SMART Criteria

- Security metrics must be:
 - **Specific** – Clearly defined and focused.
 - **Measurable** – Quantifiable and objectively assessed.
 - **Achievable** – Realistic to gather and interpret.
 - **Relevant** – Aligned with business needs and stakeholder interests.
 - **Time-bound** – Collected and reviewed within meaningful intervals.

5. Additional Considerations

- **Actionable:** Metrics must enable decision-making or corrective action.
- **Audience-Specific:** Each metric should address the concerns of its intended audience (e.g., executives, technical teams, regulators).
- **Track Outcomes:** They should provide clear insights into how well security objectives are being met.
- **Reveal Trends:** Metrics should be tracked over time to detect improvements, declines, or emerging issues.

6. Ensuring Value to Management

Well-designed metrics help maintain alignment with organizational objectives and offer ongoing guidance for strategic and operational decisions in information security.

By focusing on the relevance, clarity, and practical application of metrics, these sections underscore how organizations can effectively measure and manage their information security programs to support overall business goals.

Security Program Metrics and Monitoring

Metrics should have a clear purpose, answering a meaningful question about the area program performance they intended to measure, but also continuously monitored over time.

1. Purpose of Metrics

- Metrics gauge how well a security program is meeting its goals at the **project**, **management**, and **strategic** levels.
- They demonstrate effectiveness, justify investments, and reveal whether the program reduces risk and maintains compliance.

2. Ongoing Measurement

- Once metrics are defined, they must be **monitored regularly** to show whether security efforts remain effective.
- Results help stakeholders see if controls and processes are working or if adjustments are needed.

3. Complex Security Environment

- Security involves multiple **policies, processes, and controls**, creating a need for **clear, consistent measurement**.
- Metrics should capture data that is both relevant and actionable so that decision-makers can interpret and use it for **continuous improvement**.

4. Different Levels of Metrics

- **Strategic:** Align with the organization's overall mission, objectives, and risk appetite.
- **Management:** Focus on the performance of security processes, compliance, and resource allocation.
- **Operational:** Address day-to-day security tasks, such as patch management, vulnerability scans, and incident response times.

Metrics Tailored to Enterprise Needs

Metrics are meaningful only if they are scoped and tailored to the organization's environment and business objectives. With the right question and consideration of the planning horizons, the organization can develop meaningful metrics to gauge performance.

1. Why Tailor Metrics?

- Every enterprise has unique **business goals, risk profiles, and regulatory requirements**. Metrics must be adapted to fit these specific needs.
- Tailored metrics ensure that the right people receive the right information at the right time.

2. Primary Parameters for Metrics Design

- **Who** needs the information?
- **What** do they need to know?
- **When** do they need to know it?

3. Strategic, Management, and Operational Metrics

- **Strategic:** Measure alignment with top-level objectives, governance effectiveness, and overall security posture.
- **Management:** Track policy compliance, risk management activities, budget use, and training effectiveness.

- **Operational:** Reflect the status of technical and procedural measures (e.g., vulnerability and patch management, incident handling, and system configuration).

4. Attributes of Effective Metrics

- **Predictive:** Offer leading indicators that help anticipate future events or trends.
- **Genuine:** Are difficult to manipulate and reliably represent actual conditions.
- **Actionable:** Provide insights that lead to meaningful improvements.

5. Common Areas Measured

- **Compliance** with standards and regulations.
- **User awareness** (e.g., training completion rates, phishing test outcomes).
- **Technical vulnerabilities** (e.g., open vulnerabilities, patch status).
- **Incident handling** (e.g., response times, resolution rates).

6. Frameworks and Standards

- These provide structured approaches for designing and evaluating metrics.
- Examples include **CMMI** maturity levels, **KPI** and **KRI** models, **balanced scorecards**, and **ISO 27001/27002**.

7. Monitoring Critical Areas

- Focus on areas with high impact or risk, such as **third-party providers**, **supply chain**, and **critical infrastructure**.
- The ultimate goal is to reduce operational risk, support business objectives, and maintain a strong security posture.

By defining clear, relevant, and actionable metrics, and aligning them with the organization's strategic, management, and operational goals—security teams can better measure their program's effectiveness, demonstrate value, and continuously improve their overall security posture.

Domain 3B: Information Security Program Management

Syllabus

3B. Information Security Program Management

- 3B1. Information Security Control Design and Selection
- 3B2. Information Security Control Implementation and Integrations
- 3B3. Information Security Control Testing and Evaluation
- 3B4. Information Security Awareness and Training
- 3B5. Management of External Services (e.g., providers, suppliers, third parties, fourth parties)
- 3B6. Information Security Program Communications and Reporting

Supporting Tasks

- 15. Establish, promote, and maintain a program for information security awareness and training.
- 16. Integrate information security requirements into organizational processes to maintain the organization's security strategy.
- 17. Integrate information security requirements into contracts and activities of external parties.
- 18. Monitor external parties' adherence to established security requirements.
- 19. Define and monitor management and operational metrics for the information security program.

3B1. Information Security Control Design and Selection

This section focuses on *how* to implement the security strategy defined in Part A. It's all about *controls* – the mechanisms that manage risk. Think of it as building the *defense* based on the *strategy*.

People, Process, Technology

The information security program relies on a balance of:

- **People:** The human element is crucial. Security programs help ensure people *strengthen* risk management.
- **Process:** Administrative and technical procedures.
- **Technology:** The technical tools.

This balance is key to achieving the goals outlined in the security program's business case.

What do I need to know from a technology perspective?

You will find that the official review manual from ISACA mentions the need to understand a long list of technologies. However, the manual does not cover these technologies in any way, but offers the following guidance to exam candidates:

- You will not be tested directly on these technologies
- You should understand when to recommend each (the use cases where they fit)
- You should know their features and benefits

BOTTOM LINE: If you've already passed the CISSP exam and remember these technologies, you have a BIG head start on CISM exam prep. If not, you'll find I've included info on relevant technologies throughout this book, including later in this chapter.

Controls are the core of risk management. They are the practical implementation of policies, procedures, and guidelines.

Control Objective Definition: A statement of the *desired result* or *purpose* to be achieved by implementing a control. It's *what* you want the control to accomplish.

Example Control Objectives (Access Control):

- **Logical Access:** "Only authorized users can access systems, and they can only do authorized things."
- **Physical Access:** "Only authorized personnel can physically access computer resources."

Key Takeaway: Control objectives should *always* align with the organization's overall business objectives. This ensures cost-effectiveness and balances IT value with risk.

Managing Risk Through Controls

Controls come in three main flavors:

1. **Physical:** Tangible barriers (locks, guards, fences).
2. **Technical:** Technology-based (firewalls, intrusion detection systems).
3. **Administrative:** Policies, procedures, and processes (security awareness training, incident response plans).

IT Controls vs. Non-IT Controls

- **IT Controls:** Most controls in modern organizations are IT-related, encompassing both technical and administrative aspects.
- **Non-IT Controls:** Essential for physical information (marking, handling, storage) and addressing social engineering threats. Also includes *environmental controls* (protecting against theft, natural disasters).

Layered Defenses, also called a “layered defense”, is the concept of protecting a company's data and other valuable assets with a series of protective layers. If one layer fails, another layer will already be in place to stop an attack.

It applies to all categories of security controls (physical, logical, admin). Defense in depth supports Zero Trust security.

Control Design Considerations

Controls should be designed based on the organization's *acceptable risk levels*. This means:

1. **Identify Risks:** Understand the threats and vulnerabilities.
2. **Define Acceptable Risk:** Determine how much risk the organization is willing to tolerate.
3. **Design Controls:** Create controls to reduce risk to the acceptable level.

Control Objectives = Design Goals = Effectiveness Metrics

The control objective is *both* the target *and* how you measure if the control is working. If the control meets its objective, it's effective.

Achieving Control Objectives: Multiple Control Types

Often, you'll need a *combination* of physical, administrative, and technical controls to achieve a single objective.

Example: A firewall (technical) needs physical protection (physical), configuration procedures (administrative), and monitoring (administrative).

Control Selection Criteria (beyond cost-effectiveness)

Cost-effectiveness is important, but consider these factors too:

- **Productivity Impact:** Will the control slow down users?
- **Costs:** Total costs, including acquisition, implementation, training, operation, maintenance.
- **User Acceptance:** Will users actually *use* the control?
- **Legal/Regulatory:** Are there compliance requirements?
- **Adaptability:** Can the control adapt to changing threats?
- **Scalability:** Can the control handle growth?
- **Monitoring/Notification:** Can the control be monitored, and can it alert you to problems?
- **Robustness/Resilience:** How well does the control withstand attacks or failures?

Physical and Environmental Controls: The Foundation

Physical security is the *base* for all other security efforts. *There is no security without physical security.*

- **Collaboration:** Information security managers often work with facilities management on physical security.
- **Responsibilities:** Clearly define roles and responsibilities for physical access controls.
- **Methods:** Controls include badges, biometrics, cameras, guards, fences, lighting, locks, sensors.

Control Technology Categories

Controls are often implemented and managed by different groups. For the exam, understand these three categories:

1. Native Control Technologies:

- **Definition:** Built-in security features of a system (e.g., web server authentication, OS access controls).
- **Management:** Usually configured and operated by IT, *not* the security team, to maintain segregation of duties and change control.

- **Examples:** Server, database, router, and switch built-in security features.

2. Supplemental Control Technologies:

- **Definition:** Add-on components that provide additional security functions (e.g., firewalls, intrusion prevention systems).
- **Management:** Often operated by security specialists, but may involve collaboration with IT.
- **Examples:** Federated identity management, single sign-on, IDS/IPS, firewalls, zero trust networks, device trust systems.

3. Management Support Technologies:

- **Definition:** Tools that automate security procedures or provide management information (e.g., SIEM, vulnerability scanners).
- **Management:** Primarily used by the security organization, often independently of IT.
- **Examples:** Compliance tools, access management workflow, vulnerability scanners, SIEM, SOAR, SASE, policy management systems.

Technical Control Components and Architecture

All technologies, native and supplemental combine to create the *technical security architecture*. Information security managers should take a holistic view, and understand how all the pieces work together. Avoid a “point solution” perspective.

Control Policy Review: Key Questions

- **Fail-Safe vs. Fail-Open:** What happens when the control fails? (Fail-secure is usually preferred).
- **Restrictive vs. Permissive:** Deny by default, or allow by default? (Restrictive is generally better).
- **Least Privilege:** Only grant the *minimum* necessary access.
- **Alignment:** Does the control’s configuration align with policy and business needs?

Control Implementation Review: Key Questions

- **Policy Compliance:** Is the control implemented according to policies and standards?
- **Self-Protection:** Can the control protect itself from tampering?
- **Alerting:** Does the control alert security personnel to failures or errors?
- **Testing:** Has the control been tested to ensure it works as intended?
- **Logging/Monitoring:** Are control activities logged and reviewed?
- **Control Objectives:** Does the control meet its defined objectives?
- **Mapping:** Are the control objectives mapped to organization goals?

Control Placement Review: Key Questions

- **Location:** Where are controls located within the enterprise?
- **Layering:** Are controls layered (defense in depth)?
- **Redundancy:** Is redundancy necessary (and appropriate)?
- **Perimeter Controls:** Are perimeter controls effective?
- **Uncontrolled Access:** Are there any ways to bypass controls? (Consider all access vectors: physical, network, system, application, message).

Control Effectiveness Review: Key Questions

- **Reliability:** Does the control work consistently?
- **Minimality:** Is the control the *minimum* necessary?
- **Productivity Impact:** Does the control hinder productivity unnecessarily?
- **Automation:** Is the control automated or manual? (Automated is generally better).
- **Monitoring:** Are key controls monitored, ideally in real time?
- **Circumvention:** Can the control be easily bypassed?

Control Efficiency Review: Key Questions

- **Breadth of Protection:** How widely does the control protect the environment?
- **Specificity:** Is the control specific to a single resource, or can it be used more broadly?
- **Single Point of Failure (Application):** Does the application fail if this control fails?
- **Single Point of Failure (Security):** Does the *entire security posture* fail if this control fails?
- **Unnecessary Redundancy:** Are there redundant controls that are not needed?

Control Measurement Review: Key Questions

- **Responsibility:** Who is responsible for measuring the control's effectiveness?
- **Reporting:** How, to whom, and how often should control outcomes be reported?
- **Testing:** Who will test the control (the owner or another team like compliance)?
- **Thresholds:** What are the thresholds for reporting errors or normal conditions?

Exam Tip: Be very familiar with the different types of controls, their purposes, and the considerations for selecting and implementing them. Understand the importance of a risk-based approach and the concept of defense in depth. The questions will likely focus on applying these concepts to practical scenarios.

Foundational Technologies

While the CISM exam is management-focused, there is an expectation of prior technical competence from your work experience. We'll cover a few important concepts here that may be helpful in support of decisions related to security control selections on the exam.

- Digital Certificates
- Cryptography
- Symmetric Cryptography
- Asymmetric Cryptography
- Hash Functions
- Digital Signatures

STUDY TIP: If you've consumed my content for the CISSP exam, you may recognize some familiar concepts. However, the technical level of the explanations here has been lightened a bit to better align with the focus of the CISM exam. So, if the concepts are still fresh in your mind from CISSP study, you should already be above the bar in terms of technical knowledge.

Digital Certificates

Public key infrastructure (PKI) is a system that manages digital certificates and public-key (asymmetric) encryption to secure communications over networks. It enables secure electronic transfer of information by:

- Providing a way to verify the identity of parties involved in digital transactions
- Ensuring the confidentiality and integrity of exchanged data

Certificate Authorities (CAs): Trusted entities that issue, sign, and revoke digital certificates.

Registration Authorities (RAs): Entities responsible for verifying the identity of certificate requesters and forwarding requests to CAs.

Digital certificate: an electronic file that verifies the identity of an entity (like a website or individual) and allows for secure online communication. A digital certificate binds a public key to an identity, and is signed by a trusted CA.

Common Uses: digital signatures, website security, secure e-mail, software signing, online transactions, as well as VPN and network security.

Certificate revocation: The process of invalidating a digital certificate before its expiration date due to compromise or change in circumstances (e.g., using Certificate Revocation Lists (CRLs) or Online Certificate Status Protocol (OCSP)).

Certificate Revocation List (CRL). A periodically published list of digital certificates that have been revoked by their issuing Certificate Authority (CA) before their scheduled expiration date. It's essentially a list of *invalid* certificates.

Online Certificate Status Protocol (OCSP). A real-time certificate verification protocol that allows applications to query the status of a specific certificate directly from a server hosting this role, which has access to the CAs. Instead of downloading a complete list of revoked certificates, it checks individual certificates on demand, providing performance and privacy advantages over a CRL.

Certificate Stapling: A method used with OCSP, which allows a web server to provide information on the validity of its own certificate. Done by the web server essentially downloading the OCSP response from the certificate vendor in advance and providing it to browsers.



If you're unfamiliar with PKI, watch this short YouTube video tutorial (~8 minutes) from my Security+ Exam Prep course to familiarize yourself with the concepts. Find it at [Security+ Exam Prep - PKI](#).

Cryptography

Cryptography focuses on creating secure methods to protect information. Its goal is to transform data into an unintelligible form using encryption algorithms and keys. Cryptography involves developing encryption techniques, algorithms, and protocols.

- **Encryption:** The process of transforming plain text (readable data) into ciphertext (unreadable data) using a secret code or algorithm. This is done to protect the data from unauthorized access.

- **Decryption:** The reverse process of encryption. It involves using the same secret code or algorithm to transform ciphertext back into its original plaintext form, making the data readable again.

Goals of Cryptography

At a high level, security practitioners employ cryptographic systems to achieve four fundamental goals.

1. Confidentiality
2. Integrity
3. Authentication
4. Non-repudiation

It's important to note that not all cryptosystems are designed to achieve all four goals simultaneously. The specific requirements and implementation details may vary depending on the intended use case and security needs of the system.

1. Confidentiality

Confidentiality ensures that information remains secret from unauthorized parties. It protects the privacy of data by making it unintelligible to anyone who doesn't have the proper decryption key. It aims to maintain confidentiality for data at rest, data in transit, and data in use. This may be achieved through symmetric crypto systems, which use a single shared key, or asymmetric (public key) cryptic systems, in which each party has a public private key.

GOAL: Ensure that information remains secret from unauthorized parties.

2. Integrity

Integrity ensures that data has not been altered during transmission or storage. It guarantees that the information received is exactly as it was sent, without any unauthorized modifications, additions, or deletions. Cryptographic hash functions and digital signatures are commonly used to maintain data integrity.

GOAL: Guarantees that information has not been altered during transmission or storage.

3. Authentication

Authentication verifies the identity of the parties involved in a communication. It ensures that the sender and receiver are who they claim to be, preventing impersonation attacks. Authentication can be achieved through various methods, including digital signatures, message authentication codes (MACs), and cryptographic protocols.

GOAL: Verify the identity of entities involved in communication or accessing resources.

4. Non-repudiation

Non-repudiation prevents a party from denying their involvement in a communication or transaction. It provides proof of the origin of data and the identity of the sender, making it impossible for them to later deny having sent the message. Digital signatures are a primary tool for achieving non-repudiation.

GOAL: Prevent entities from denying their involvement in a transaction or communication.

Symmetric Cryptography

Symmetric cryptography uses a single shared secret key for both encryption and decryption. It is fast and efficient for bulk encryption but requires an assist with secure key distribution.

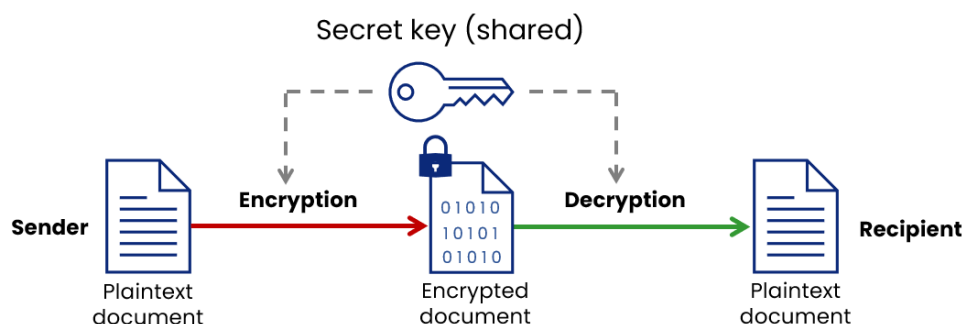


Figure 6.1. Symmetric Encryption and Decryption

Asymmetric Cryptography

Asymmetric cryptography, often referred to as *public key cryptography*, is a method of encrypting and decrypting data using two different keys: a **public key** and a **private key**.

- **Public Key:** This key is openly shared with anyone. It's used to *encrypt* messages or data. Think of it like a public mailbox where anyone can drop off a letter, but only you have the key to open it.
- **Private Key:** This key is kept secret by the owner. It's used to *decrypt* messages that were encrypted with the corresponding public key. Only the person with this key can read the message, ensuring privacy.

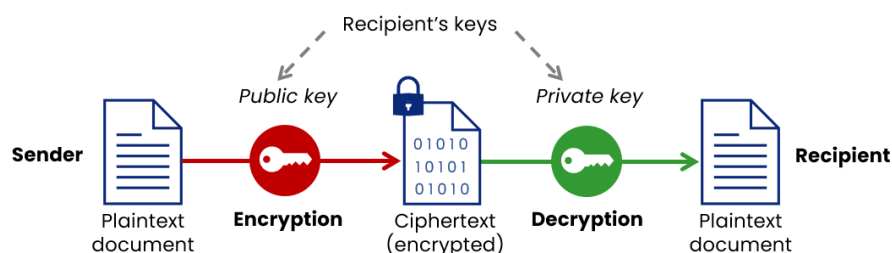


Figure 6.2. Asymmetric Encryption and Decryption

Hash Functions

A **hash function** is a mathematical function that converts data of any size into a fixed-size string of characters. Output is referred to as a hash value, hash code, or digest. Any minor change in the data results in a significantly different hash value. Hash functions are used for data integrity verification, digital signatures, and password hashing.

How is hashing different from encryption?

- **Encryption** is a *two-way function*; what is encrypted can be decrypted with the proper key.
- **Hashing** is a *one-way function* that scrambles plain text to produce a unique message digest. There is no way to reverse a hash if properly designed!

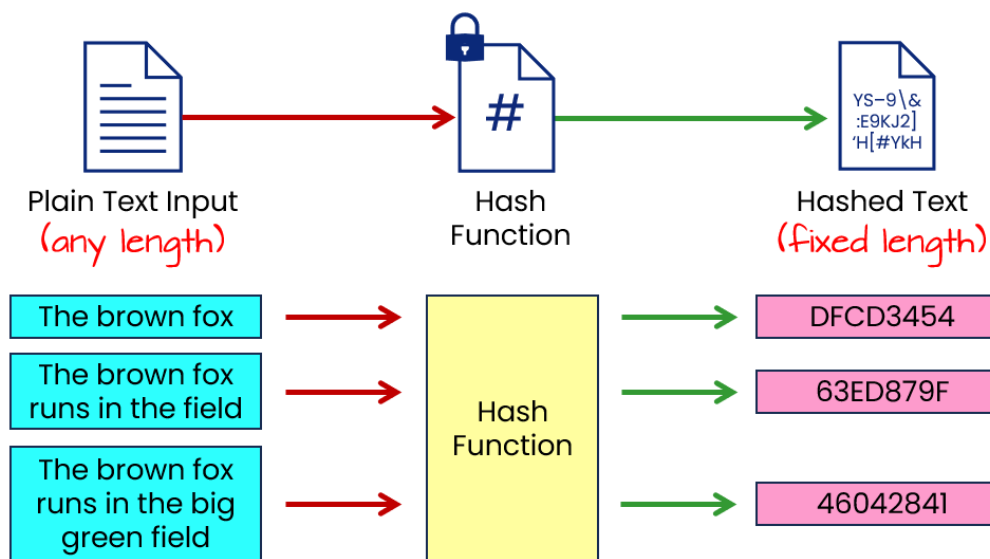


Figure 6.3. Hash Function (example)

Digital Signatures

Digital signatures and certificates are cryptographic tools used to ensure the *authenticity* and *integrity* of data.

How it works:

1. **Hashing:** The data to be signed is passed through a hash function, which produces a fixed-size digital fingerprint called a hash value or message digest.
2. **Signature Generation:** Using *their own private key*, the sender creates a digital signature based on the hash value.
3. **Signature Transmission:** The original data and the digital signature are sent to the recipient.

4. **Signature Verification:** The recipient calculates the hash value of the received data and uses the *sender's public key* to verify the digital signature. If the calculated hash value matches the verified signature, the data is considered authentic and intact.

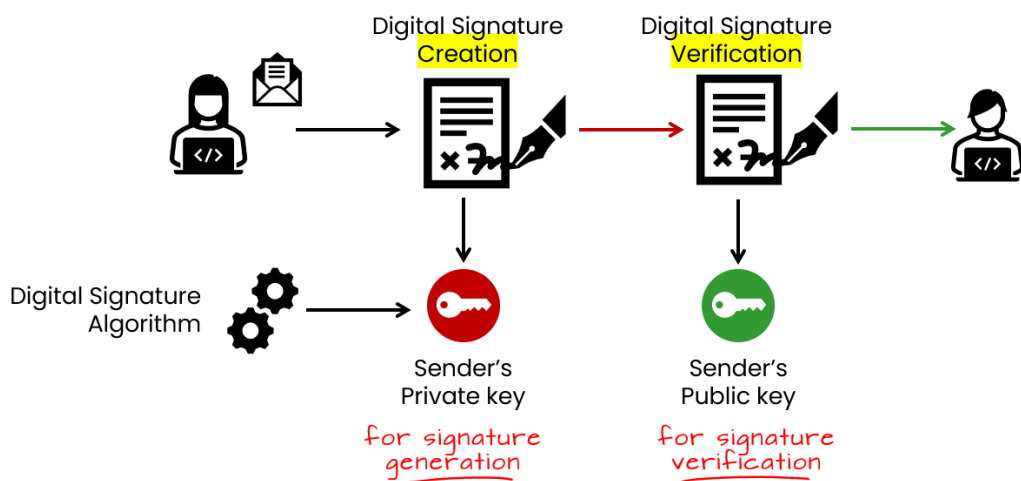


Figure 6.4. How Digital Signatures Work

3B2. Information Security Control Implementation and Integration

You should be familiar with the types and categories of security controls cited by ISACA, as well as their roles and function. They are very similar (though not identical) to similar standards called out in ISC2 and CompTIA exams.

Control Categories

There are *three categories* of security controls:

Administrative Controls - Policies, procedures, training that guide user behavior and support secure environments.

Examples: security policies, password policies, security training, personnel controls.

Technical/Logical Controls - System/software controls used to specify and regulate how systems are used.

Examples: authentication, access control lists, encryption, firewalls, antivirus software.

Physical Controls - Physical barriers and security measures protecting facilities and assets.

Examples: perimeter fencing, locked doors, security guards, video surveillance.



Exam questions may test your understanding that optimal security often requires **layered** controls across all categories.

Control Types

It's crucial to understand the *type* of control, not just the product name (like “firewall”). Think about the *function* a control performs. There are *six types* of security controls:

Preventive Controls - Stop security incidents before harm is done.

Examples: authorization, access control lists, encryption.

Deterrent Controls - Discourage actions that could lead to security incidents.

Examples: policies prohibiting certain behaviors, logon warning banners, security training.

Directive - is deployed to direct, constrain, or guide the actions of subjects. Intended to encourage or force compliance with the organizations security policies.

Examples: security guards, guard dogs, motion detectors, job rotation, mandatory vacations, audit trails, violation reports.

Detective Controls - Detect or expose security incidents as they happen.

Examples: audit logs, intrusion detection systems, antivirus software.

Corrective Controls - Contain or recover from security incidents after the fact.

Examples: incident response plans, system backups, disaster recovery plans.

Compensating Controls - Provide alternate security measures when primary controls cannot be implemented.

Example: additional training when something prevents deployment of new access control system.

The different categories protect information systems in layers according to where controls are implemented. The different types serve distinct purposes in detecting, reacting to, and preventing security issues. Organizations use controls from various categories and types to establish defense-in-depth.

Key Control Principles

Think of these as best practices for making controls *hard to bypass*:

- **Access Control (Logical):** Ensuring users are *who they say they are* (identification and authentication) and are only *allowed to do what they should* (authorization) *before* accessing information.
 - **Types:**

- * **Mandatory Access Control (MAC):** Restrictions based on data sensitivity (e.g., “Secret” clearance) and a user’s “need-to-know.” Common in military/government.
- * **Discretionary Access Control (DAC):** Access restrictions based on user identity/-group membership. Users can often grant access to others.
- **Secure Failure:** A system is designed to *shut down safely* if a security-critical malfunction occurs, preventing further compromise.

Important Consideration: Impacts *availability*. Must be balanced with safety concerns (e.g., physical access control failing “locked”).

- **Least Privilege:** Users (and processes) should only have the *minimum necessary* access rights to perform their jobs. Limits the damage from mistakes or malicious actions.
- **Compartmentalizing:** Limiting access to only particular subsets, by requiring separate authorizations for each section. *Example:* Restricting internet users from having admin functions through network port restrictions.
- **Segregation of Duties (SoD):** Preventing a *single person* from having control over *all* parts of a critical process. Prevents fraud and errors.

Example: The person who approves payments shouldn’t also be able to issue them.

- **Transparency:** Security mechanisms should be *understandable* by all stakeholders (users, admins, etc.). Simplicity aids in verification and reduces confusion.
- **Trust (and Trusted Third Parties):** Relying on a *verified identity provider* to authenticate users.

Example: Public Key Infrastructure (PKI) using a Certificate Authority (CA) to vouch for a user’s identity.

- **Zero Trust:** *Never trust, always verify.* No implicit trust based on location (internal network vs. internet) or device ownership. Every user, device, and connection must be authenticated and authorized.

Key Driver: Modern trends like remote work, mobile devices, and cloud computing.

- **SOAR (Security Orchestration, Automation, and Response):** A solution (or set of tools) that streamlines *incident response*, *security operations*, and *threat/vulnerability management*.

Key Benefits: Automates tasks, integrates data from multiple sources (like SIEM, EDR), and facilitates faster response to security incidents.

Baseline Controls

Baseline controls are a *minimum set of security controls* that should be applied to *all* new systems. These are predefined, documented security requirements (often in standards) that are considered *essential* for a given level of risk.

- **Examples:**
 - Authentication mechanisms
 - Logging and auditing
 - Role-Based Access Control (RBAC)
 - Data transmission confidentiality
- **Determining Baselines:**
 - Consider the organization's *risk appetite*.
 - Refer to *industry standards* and *regional regulations*.
 - May require *supplemental controls* based on specific vulnerabilities, threats, and risks.

Information Security Manager's Role in Baseline Controls:

1. **Evaluation:** Assess how well proposed solutions meet the baseline requirements and the organization's acceptable risk levels.
2. **Due Diligence:** Identify and communicate any deficiencies in proposed solutions. Develop *mitigating* or *compensating* controls.

3. **Code Review:** Review code (especially for critical systems) to ensure good security practices. May involve external experts.
4. **Testing:** Coordinate testing of security requirements and interfaces during the quality assurance (QA) and acceptance phases.
5. **Issue Resolution:** Work with project teams to prioritize and resolve any identified security issues.
6. **Risk Acceptance:** If issues cannot be resolved before deployment, ensure senior management reviews the risks and makes an informed decision. Document any accepted risks and plans for future resolution.
7. **Segregation of Duties:** Ensure SoD is considered throughout the entire System Development Life Cycle (SDLC).
8. **Testing and QA Plans** Ensure the security elements are thoroughly tested.
9. **Code Reviews** Needed for software developed for critical operations and is often outsourced to ensure independence.

Integration of the Security Program with IT Operations

The information security program must work in tandem with other areas of enterprise IT governance and management. The **information security manager** partners with the various stakeholders identified in Chapter 2 (who initially developed the security strategy) to ensure:

1. **Security measures** do not unduly impede operations.
2. Non-security personnel maintain a clear **understanding** and **commitment** to security processes.

Personnel, Roles, Skills, and Culture

Effective security depends on **well-defined roles**, necessary skill sets, and a culture that treats security as integral to operations, not an afterthought. The information security manager must **allocate and develop** personnel based on the skills needed for both technical and administrative tasks. Typical security positions include:

- Security engineers
- QA/testing specialists
- Access administrators
- Project managers
- Compliance liaisons
- Security architects
- Awareness coordinators

- Auditors
- Policy specialists

Small enterprises may combine these responsibilities in fewer positions. The security manager also ensures these individuals have **appropriate skills** through training or by contracting external service providers for specialized needs.

Example: If you only need specialized cryptography expertise once per year, hiring a full-time cryptography specialist might be excessive. Instead, contracting a consulting firm could be more efficient in terms of cost and timely expertise.

Roles and Responsibilities

A **role** defines who performs a function (e.g., security engineer), while a **responsibility** outlines what that role must do (e.g., configure firewalls). Role-based assignment reduces administrative overhead and ensures that responsibilities and access rights are attached to job functions rather than specific individuals.

Tools such as **RACI charts** (Responsible, Accountable, Consulted, Informed) help clarify which roles are involved in various activities in developing or running the security program.

Culture

Security culture refers to a set of values, beliefs, and behaviors that exhibit security consciousness in an organization's day-to-day operations. Because security activities often cross multiple departments, the information security manager must foster an organizational culture that values and **supports** security efforts.

Documentation

The security manager oversees **creation and maintenance** of key documentation, which often includes:

- Policies, standards, procedures, and guidelines
- Technical diagrams (infrastructure, architectures, data flows)
- Training and awareness materials
- Risk analyses and related documents
- Security system designs, configurations, and maintenance records
- Operational records (shift reports, incident logs)

- Process flows
- Organizational charts and RACI models

Each document needs an **owner**, version control, and defined update and approval processes. Sensitive security documentation must be properly **classified** and protected per organizational policies.

Information Security Liaison Responsibilities

Security liaisons serve as connectors between the security function and other departments, ensuring security requirements are understood and integrated into business processes. Effective security programs require **ongoing relationships** with many enterprise functions.

Common liaisons include:

- **Physical Security:** Ensures alignment on facility controls (e.g., electronic locks, guards, cameras).
- **IT Audit:** Addresses assurance of compliance, policy effectiveness, and collaborates on mitigation plans.
- **Information Technology:** Works with IT on security configuration, updates, performance requirements, and system deployments.
- **Business Unit Managers:** Integrates security with business goals, gathers feedback on emerging risk, and ensures alignment with operational needs.
- **Human Resources (HR):** Manages background checks, training, and enforcement of policies such as acceptable use.
- **Legal Department:** Advises on compliance, liability, and contractual issues.
- **Employees:** Serve as the **first line of defense**, requiring regular training on policies, standards, and reporting procedures.
- **Procurement:** Monitors technology acquisitions to ensure they meet security standards and do not introduce unnecessary risk.
- **Compliance Office or Privacy Office:** Addresses regulatory requirements, especially regarding data protection and privacy laws.
- **Training/Education Department:** Helps develop and deliver **awareness programs** and specialized security training.
- **Quality Assurance (QA):** Integrates security requirements into QA processes.
- **Insurance:** Coordinates coverage and aligns incident response, business continuity, and disaster recovery with insurance policy requirements.
- **Third-Party Management:** Manages **outsourced** security functions, ensuring vendors adhere to enterprise policies and meet risk thresholds.
- **Project Management Office (PMO):** Ensures security requirements and risk assessments are integrated into project life cycles.

Exam Tips:

- **Communication Challenges:** Look for scenario questions highlighting the need to bridge “technical vs. business” language gaps.
- **Escalation Paths:** Emphasize clear, well-documented paths for escalating security issues.
- **Distributed Accountability:** Expect questions on how departmental liaisons help embed security decisions across the organization.

Cross-Organizational Responsibilities

Because security touches multiple departments, **separation of duties (SoD)** must be considered to avoid conflicts of interest. Where SoD is impractical (e.g., in smaller enterprises), **compensating controls** should be employed.

Information Security Steering Committee

Many organizations form a **security steering committee** (or executive security council) to coordinate among key stakeholders (legal, IT, HR, risk, operations, etc.). *This committee:*

- Owns the **security strategy**.
- Approves changes to **policies** or **standards**.
- Ensures **alignment** of security with overall enterprise priorities.

Issue Resolution Through the Information Security Program

A robust **problem management** approach includes:

1. **Systematic investigation** into root causes of issues.
2. **Defined action plans** with assigned responsibility and due dates.
3. **Reporting and tracking** to confirm problem resolution.

When controls fail or become outdated, the security manager must:

- **Identify** the problem and its priority.
- **Deploy** mitigating controls (e.g., temporarily disconnecting a compromised system).
- **Communicate** escalation authority to senior management when business operations might be disrupted.

Vendor Management

Overseeing and monitoring **external providers** (hardware, software, and security services) helps ensure that any risk introduced by third parties is managed properly. *This includes verifying:*

- financial stability
- quality of service
- staffing
- security policy adherence
- right-to-audit
- alignment with the enterprise's overall security posture.

Key Takeaway: The vendor's policies and practices need to maintain their risk within the limits of the organization's risk appetite and tolerance.

Integration with IT Processes

Security must be embedded in core **IT processes** (change management, software development, service delivery) to ensure controls remain effective and vulnerabilities are minimized. This can also prevent overlaps, gaps, or contradictory efforts.

Key processes include:

1. System Development Life Cycle (SDLC)

- Incorporate security requirements from the **planning** through **maintenance** phases.
- Evaluate risk at each phase to avoid “bolting on” security at the end.
- **Waterfall vs. Agile:** Waterfall is more linear, while Agile involves iterative cycles with continuous collaboration.

2. DevOps and DevSecOps

- **DevOps** merges development and operations for rapid, frequent releases.
- **DevSecOps** integrates security into every stage of DevOps (continuous integration/-continuous deployment, or CI/CD).
- Emphasizes automating security checks to keep pace with fast development cycles.

3. Change Management

- Security must be part of **change requests**, assessing new or evolving vulnerabilities.
- **Risk analysis** of proposed changes helps maintain effective control.
- Decentralized enterprises may require additional effort to ensure consistent change management and policy compliance across departments.

4. Configuration Management

- **Misconfiguration** is a leading cause of security breaches.
- Ensure **clear standards** exist and that staff are trained to implement them correctly.
- Overburdened teams or poor documentation often lead to shortcuts—introducing vulnerabilities.

5. Release Management

- Verify new systems, devices, or software have **adequate security testing** prior to production.
- Follow standardized procedures to reduce the likelihood of operational failures and downtime.

Baseline Controls

Baseline controls are a minimum set of safeguards mandated for an environment, system, or data classification—serving as a starting point for security efforts. They can be customized or enhanced based on specific risk assessments.

Exam Tip: The exam may test your ability to justify deviating from a baseline (e.g., applying stricter measures for critical assets).

Public Cloud

Cloud environments introduce a shared responsibility model, where the provider handles certain controls (physical security, hypervisor, etc.), and the customer is responsible for securing their data and configurations.

Exam Tip: The exam may test how to manage risks associated with cloud providers (SLAs, right-to-audit clauses, exit strategies).

What is cloud computing?

According to NIST: “Cloud computing is a model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction.”

The five essential characteristics cited by NIST are:

1. **On-demand self-service:** Users can provision computing resources as needed automatically without requiring human interaction with each service provider.
2. **Broad network access:** Capabilities are available over the network and accessed through standard mechanisms that promote use by heterogeneous thin or thick client platforms.
3. **Resource pooling:** The provider’s computing resources are pooled to serve multiple consumers using a multi-tenant model, with different physical and virtual resources dynamically assigned and reassigned according to consumer demand.
4. **Rapid elasticity:** Capabilities can be elastically provisioned and released, in some cases automatically, to scale rapidly outward and inward commensurate with demand.
5. **Measured service:** Cloud systems automatically control and optimize resource use by leveraging a metering capability at some level of abstraction appropriate to the type of service.



While responsibility in the private cloud model (on-premises) is simple, you should ensure you are aware of how responsibility is shared between customer and CSP in the IaaS, PaaS, and SaaS cloud service models.

Cloud Service Models

The cloud **service model** refers to the type of service provided by a cloud provider. It determines the level of control and management that the customer has over the cloud resources.

Below are brief explanations of responsibility and ownership pictured in the preceding chart, along with a few examples of each service model.

IaaS (Infrastructure as a Service)

With IaaS, organizations get out of the datacenter business, handing over responsibility for hardware, facilities, and related operations to the CSP:

- Customer is responsible for management and security their apps, data, and operating system
- CSP provides building blocks, like networking, storage and compute
- CSP manages staff, HW, and datacenter

EXAMPLES: Azure Virtual Machines, Amazon EC2, GCP Compute Engine

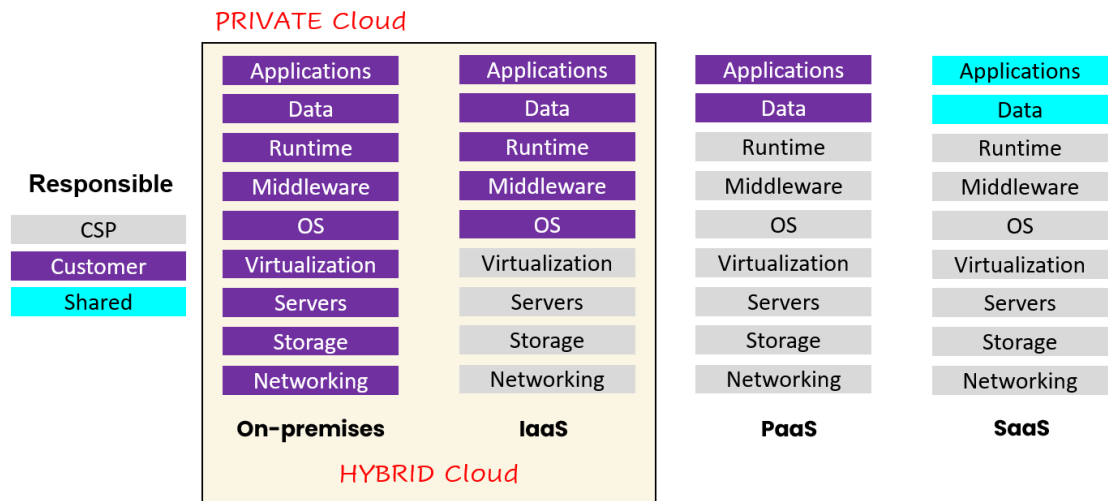


Figure 6.5. Cloud Shared Responsibility Model

PaaS (Platform as a Service)

With PaaS, organizations can focus delivering business value through their applications, while the CSP takes on additional responsibility compared to IaaS:

- Customer is responsible for deployment and management of apps
- CSP manages provisioning, configuration, hardware, and OS

EXAMPLES: Database as a service (DBaaS) offerings like Azure SQL Database, Amazon Relational Database Service, and Google Cloud SQL.

SaaS (Software as a Service)

With SaaS, organizations have only minimal responsibility beyond using the application:

- Customer just configures features
- CSP is responsible for management, operation, and service availability
- Customer has some responsibility in access management and data recovery

EXAMPLES: Office 365, ServiceNow, Salesforce

One more service model that might be mentioned:

FaaS (Function as a Service)

Applications are built, run, and managed as individual functions, and may be written in a variety of programming languages, as FaaS offerings typically support several languages. It is considered serverless because the service is stateless, scales automatically, and is generally pay-per-execution, with functions invoked by request. High availability and maintenance are all owned and implemented by the CSP.

EXAMPLES: AWS Lambda, Azure Functions, Google Cloud Functions

Cloud Deployment Models

The cloud **deployment model** refers to how the cloud infrastructure is physically deployed. It determines who owns and operates the cloud infrastructure.

There are *four cloud deployment models* you should be familiar with:

- **Private Cloud:** A cloud environment in your own datacenter. Advantages include legacy support, control, and compliance.
- **Public Cloud:** Everything runs on your cloud provider's hardware. Advantages include scalability, agility, pay-as-you-go, no maintenance, and low skills requirement.
- **Community Cloud:** A cloud infrastructure in which multiple organizations share resources and services based on common operational and regulatory requirements. Like a private cloud shared by a group of organizations, akin to the concept of a community garden.
- **Hybrid Cloud:** Combines public and private clouds, allowing you to run applications in the right location that provides the right security and control. Advantages include flexibility in legacy, compliance, and scalability scenarios.

Private and hybrid cloud are frequently used in legacy scenarios where a customer needs control. This may be control of application versions or compliance scenarios where the customer needs control of other elements of the environment to meet specific compliance requirements.



Some compliance standards will dictate that the customer must hold and manage their own encryption keys, which can make adoption of certain cloud platforms and services more difficult or even untenable. And there may be challenges with data sovereignty in some public cloud scenarios as well.

Cloud Model	Management	Ownership	Location	Advantages
Private Cloud	Customer	Customer	Your data center	Legacy support, control, compliance
Public Cloud	Cloud provider	Cloud provider	Cloud provider's data centers	Scalability, agility, pay-as-you-go, no maintenance, low skills requirement
Community Cloud	Shared by a group	Shared by a group	Shared data center	Cost-effective, shared resources, collaboration
Hybrid Cloud	Customer and cloud provider	Customer and cloud provider	Combination of customer and CSP data centers	Flexibility in legacy, compliance, and scalability scenarios

Figure 6.6. Cloud Deployment Models

Cloud Security Risks and Solutions

Geographic distribution and shared responsibility in the cloud bring additional considerations to protecting confidentiality, integrity, and availability of critical business services and sensitive data hosted there. *A few key concerns include:*

Application Security: To protect applications in modern cloud application architectures, solutions such include **API management (APIM)**, **next generation firewalls (NGFWs)** and **web application firewalls (WAFs)** provide specialized protection capabilities suited for cloud-based hosting scenarios.

Auditability: Traditionally, organizations have relied on physical audits to assess their service providers' security and compliance practices. However, directly auditing a Cloud Service Provider (CSP) presents unique challenges.

What is Right-to-Audit? Right-to-audit refers to a customer's contractual right to directly assess a service provider's security, compliance, and operational practices. This is especially important for highly regulated industries, where regulations may require direct audits to ensure the secure storage and handling of sensitive data.



If the vendor is a cloud service provider (AWS, Azure, GCP), you will generally not have the right-to-audit. However, most major CSPs have a portal where third-party audit reports (SOC 2 Type 2, etc.) available on demand.

Availability: Shared responsibility and geographic distribution are key considerations of availability in the cloud. While geographic distribution offers redundancy and resilience, it also introduces complexity. Regional outages or disruptions can still occur, and organizations must have well-tested disaster recovery plans to mitigate their impact.

Data Security: Due to shared responsibility in geographic distribution, data security comes with additional considerations in the cloud

- **Data Encryption:** Encrypting data at rest and in transit in cloud services is a must. Data storage in cloud repositories was a significant pain point in the early days of public cloud, where encryption was not always enabled by default.
- **Data Location:** A regulatory requirement to store and process certain data within specific geographical borders. It's often driven by privacy or security concerns and can impact how organizations manage their data infrastructure.
- **Data Sovereignty:** Focuses on a country's authority over data generated within its borders. Some types of data, such as financial data or personal information, collected or stored in a particular geographic location, such as a specific country or the European Union (EU), is subject to the laws of that location. In some cases, the laws of that country may require the data is stored within its borders. This affects how organizations handle data management and comply with local laws.
- **Key Management:** Storing keys securely using **hardware security modules (HSMs)** or encrypted key vaults. This protects keys from unauthorized access and ensures they are not stored in plaintext form on general-purpose systems.

Virtualization Security

The two primary security concerns with server virtualization (IaaS) you should be familiar with as you select security controls are:

- **VM Sprawl:** When unmanaged VMs have been deployed on your network. Because IT doesn't know it is there, it may not be patched and protected, and thus more vulnerable to attack.

Avoidance: Enforcement of security policies for adding VMs to the network, as well as periodic scanning to identify new virtualization hosts.

- **VM Escape:** Where an attacker gains access to a VM, then attacks either the host machine that holds all VMs, the hypervisor, or any of the other VMs.

Protection: Ensure patches and hypervisor and VMs are always up to date, guest privileges are low. Server-level redundancy and HIPS/HIDS protection also effective.



Policy-based security controls in the public cloud, such as Azure Policy and AWS Service Control Policies (SCPs), are considered essential for managing cloud security at scale. They provide a centralized, automated, and consistent way to enforce security and compliance, enabling security leaders to effectively protect their cloud environments.

Network Security

Several network security technologies are commonly used to enhance information security. They're described here to give you foundational knowledge of benefits as security controls.

Network Segmentation

Network segmentation divides a network into smaller, isolated subnets, enhancing security and performance by limiting the blast radius of security breaches and reducing network congestion. This approach enables granular control over traffic flow, enforcing specific security policies between segments and containing potential threats within defined boundaries.

Implementing network segmentation also minimizes lateral movement of attackers, simplifies compliance efforts, and optimizes network performance by isolating critical assets and sensitive data.

Virtual Local Area Network (VLAN)

Virtual Local Area Networks (VLANs) are a common approached network segmentation that *logically* divide a Layer 2 network based on broadcast domains, logically grouping switch ports based on communication needs (e.g., client VLAN, server VLAN, VoIP network, etc.).

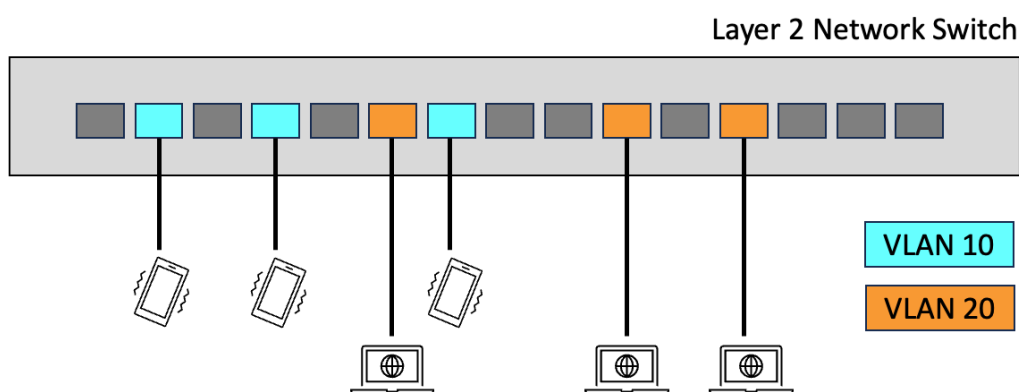


Figure 6.7. Virtual Local Area Network (VLAN) example

Firewalls

A common three-interface firewall design can provide basic network segmentation, separating trusted networks and resources from those accessible from the internet:

1. **External (Untrusted) Interface:** Connects to the Internet or another untrusted network. Systems on more trusted networks are typically allowed to initiate outbound connections, but most inbound attempts are blocked unless they meet the organization's security policy.
2. **Internal (Intranet) Interface:** Connects to the organization's main network, where most systems live. This intranet may be subdivided (e.g., endpoints, wireless networks, guests, data centers). The firewall enforces access controls between these segments, or additional firewalls may be used for further segmentation.
3. **DMZ Interface:** Connects to a "demilitarized zone", housing servers (e.g., customer-facing websites and applications) that must accept external connections. Because these systems face higher compromise risks, they are isolated in a separate security zone. Even if a DMZ server is compromised, the firewall still prevents access to the intranet. This configuration is also called a screened subnet.

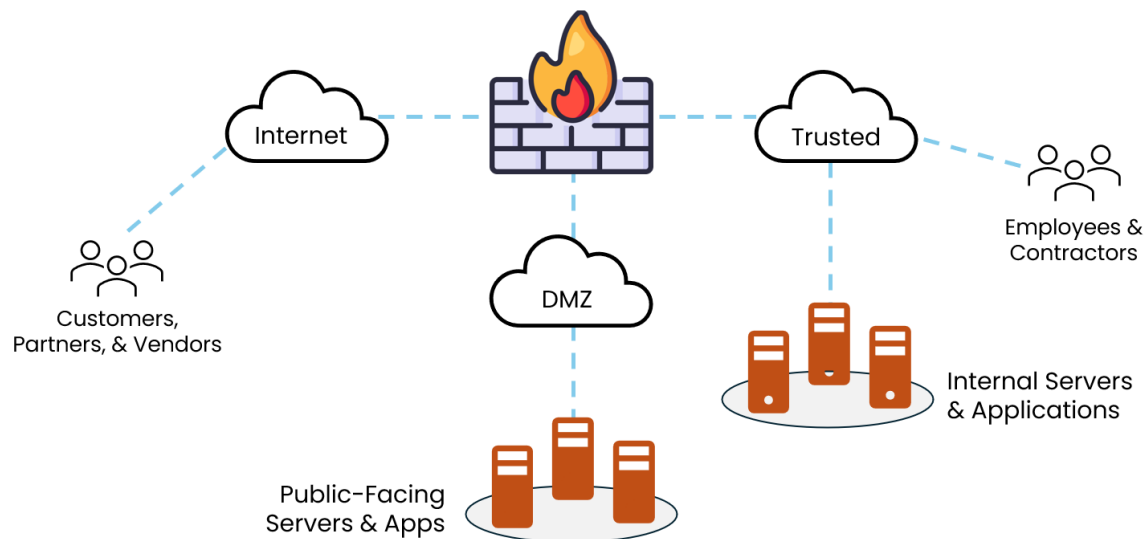


Figure 6.8. Segmentation via Three-Legged Firewall Configuration

Intrusion Detection/Prevention Systems (IDPS)

Intrusion detection systems (IDS) passively monitor network or system activity and generate alerts when suspicious behavior is detected, which make IDS a detective control. On the other hand, **intrusion prevention systems (IPS)** actively block or prevent potential threats in real time.

Network-based intrusion detection/prevention systems (NIDS/NIPS) monitor network traffic, with NIDS alerting and NIPS blocking. **Host-based intrusion detection/prevention systems (HIDS/HIPS)** monitor activity on individual hosts, providing visibility into system-level events.

Network Access Control (NAC)

Network access control (NAC) is a critical security layer that automates policy-driven access to network resources, *ensuring only authenticated and compliant devices gain entry*. It dynamically enforces access based on user identity, device MAC address, device security posture (configuration, security patches), and contextual factors, significantly mitigating risks associated with unauthorized access and non-compliant endpoints.

When implemented effectively, NAC Ensures unauthorized devices cannot connect to corporate networks.

Virtual Private Network (VPN)

A virtual private network (VPN) creates a secure, encrypted connection over a less secure network, like the internet, extending a private network across public infrastructure. It essentially establishes a secure tunnel for data transmission. SSL/TLS and IPsec are commonly used VPN protocols. IPsec is increasingly common in enterprise and hybrid cloud scenarios. *Common VPN configurations include:*

1. **Transport Mode:** This mode encrypts only the payload of the IP packet, leaving the original IP header intact. Transport mode is often used for client-to-site VPNs, where individual devices connect to a remote network. For this mode, there are two tunnel types:
 - **Split Tunnel**, in which only client traffic destined for the private network goes through the VPN tunnel. All other internet traffic is sent directly through the user's local internet connection.
 - **Full Tunnel**, in which all network traffic from the user's device is routed through the VPN tunnel, regardless of its destination.
2. **Tunnel Mode:** In this mode, IPsec encapsulates the entire IP packet and adds a new IP header. Tunnel mode is typically used for site-to-site VPNs, where entire networks communicate securely over an untrusted network (like the internet).

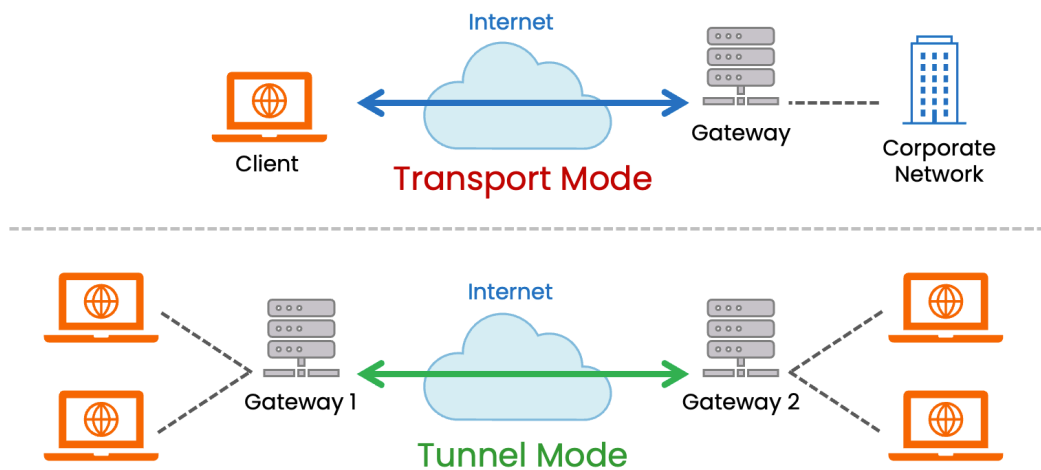


Figure 6.9. IPsec Modes

Zero Trust

Zero trust is an approach to security architecture in which no entity is trusted by default. Zero trust is based on three principles:

1. Assume breach
2. Verify explicitly
3. Least privilege access

Zero trust architecture is generally achieved through network segmentation, adaptive identity management, and policy-based access control.

3B3. Information Security Control Testing and Evaluation

After implementing information security controls, the next step is to evaluate their effectiveness. The goal is not to eliminate all risk, but rather to ensure that the implemented controls maintain risk at an acceptable level.

Security controls require ongoing testing and evaluation throughout their life cycle. Changes to risk objectives, the threat landscape, or system operations can alter control requirements, so the evaluation process must evolve to maintain cost-effectiveness and alignment with business objectives. Common methods for testing and evaluation include:

- **Periodic or routine assessments** to confirm control effectiveness
- **Internal and external audits** for independent validation
- **Continuous monitoring** for near real-time detection of issues
- **Penetration testing** to simulate malicious attacks and uncover hidden vulnerabilities

Analogy: Security Controls as Filters

Think of your security controls like multiple filters in a water purification system.

- Each filter reduces contaminants to an acceptable level, though no filter can promise 100% purity.
- In the same way, security controls aim to maintain an acceptable level of risk, not guarantee its complete removal.

Control Strength

Control strength refers to how effectively a security control resists or mitigates threats. When evaluating control strength, it is essential to consider both the control's inherent capabilities and the ways it can be bypassed or undermined in practice. *Below are the key considerations to keep in mind:*

1. Measurement of Control Strength

- Controls can be grouped by their type (e.g., preventive, detective, corrective) or by their method of enforcement (e.g., technical, procedural, physical).
- Stronger controls typically require more robust methods of enforcement, such as multi-factor authentication rather than a single password.
- A control's overall strength depends on how difficult it is for attackers to circumvent it, which may include analyzing factors such as cryptographic robustness or the complexity of an intrusion detection system.

2. Inherent vs. Practical Strength

- Some controls are inherently strong; for example, well-implemented encryption is intrinsically difficult to break.
- However, if a control is too cumbersome or costly to implement, people may create workarounds that weaken it in practice. Thus, a highly secure control can still fail if it is bypassed or misused.

3. Layered Approach

- No single control is sufficient to address all threats. Combining multiple controls (e.g., using intrusion detection along with strong authentication and proper logging) creates "defense in depth."
- Layering controls helps ensure that if one control fails or is bypassed, others can still mitigate or detect the threat.

4. Balance Cost, Complexity, and Security

- Security managers must weigh the benefits of stronger controls against their impact on usability, cost, and maintenance.
- Overly complex controls can reduce productivity and increase the likelihood of user circumvention, while too few controls leave systems vulnerable.
- The optimal solution is a balanced mix of controls that provides adequate security without overly burdening the organization.

EFFECTIVE Controls vs INEFFECTIVE Controls

While automated security controls are generally preferred over manual controls, automated does not necessarily mean more effective. Here are two examples, one of an **effective manual control**, and another of an **ineffective automated control**.

Effective Manual Control: Physical Security Rounds by Trained Guards

- **Description:** A company employs trained security guards to conduct regular, randomized patrols of a data center, checking for unauthorized access, suspicious behavior, or physical tampering with equipment. The guards use a checklist and log their observations in a tamper-proof system.
- **Why It's Effective:**
 - **Robust Enforcement:** The human element allows guards to adapt to unexpected situations (e.g., noticing a propped-open door or an unfamiliar individual) that an automated system might miss.
 - **Practical Strength:** Random timing and human judgment make it harder for attackers to predict or bypass the control compared to a static schedule.
 - **Layered Approach:** This complements technical controls like cameras or keycard systems, adding defense-in-depth by addressing physical threats that technology alone might not catch.
 - **Balanced Implementation:** While it requires personnel, it doesn't overly burden employees or systems, and the cost is justified for high-value assets like a data center.

Ineffective Automated Control: Password Expiration Policy Every 30 Days

- **Description:** An organization implements an automated system that forces all employees to change their passwords every 30 days, with no additional requirements beyond a minimum length (e.g., 8 characters).
- **Why It's Ineffective:**
 - **Inherent Weakness:** While the idea of frequent password changes seems strong, it lacks robust enforcement—users often choose predictable patterns (e.g., “Password1” to “Password2”) to cope with the frequent resets, reducing security.

- **Practical Failure:** The control's complexity and lack of usability lead to workarounds, like writing passwords down or reusing them across systems, undermining its strength in practice.
- **Poor Balance:** The frequent resets increase user frustration and IT support costs without significantly improving security, especially if attackers can exploit phishing or stolen credentials before the expiration.
- **Lack of Layering:** On its own, it doesn't integrate well with stronger controls (e.g., multi-factor authentication), leaving gaps that a more balanced approach could address.

Key Takeaway: Control strength isn't just about the control itself, but how it performs in real-world conditions. The manual guard patrol succeeds because it's adaptable and practical, while the automated password expiration fails due to poor usability and weak enforcement, illustrating the importance of balancing cost, complexity, and security.

Inherent Strength and Likelihood of Effectiveness

- **Inherent/design strength:** For instance, balancing a cash register and separating accounting duties among different staff members, or requiring dual control to access sensitive areas.
- **Likelihood of effectiveness:** Supported by consistent implementation, thorough testing, and alignment with business objectives.

Aligning risk mitigation with business needs helps justify costs and ensures governance requirements are met. Often, an independent reviewer—internal or external—provides greater objectivity. Guidance such as NIST Special Publication (SP) 800-37 Revision 2 (NIST RMF) and the RMF Assess steps outline how to define and assess control strength using standardized criteria.

Penetration Testing

Penetration tests simulate malicious attacks against networks, operating systems, and applications. These tests help identify unknown or underestimated vulnerabilities. They provide an independent, dynamic way to evaluate control effectiveness.

Continuous Monitoring

Some organizations implement **continuous monitoring** using automated tools to evaluate technical controls in near real-time. This allows rapid detection of changes in the environment or in control performance, enabling security teams to respond quickly.

Control Recommendations

When determining how to mitigate or eliminate a risk, security controls are selected and evaluated based on several characteristics and considerations:

1. Control Types

- **Preventive** vs. **Detective**: Does the control stop an incident or detect it after it occurs?
- **Manual** vs. **Automated**: Is it carried out by people or by technology?
- **Formal** vs. **Ad Hoc**: Is it documented with evidence of consistent operation, or is it applied in a more informal way?

When possible, *preventive, automated, and formalized* is preferred.

2. Key Factors for Recommending Controls

- **Effectiveness**: How well does the control reduce the risk?
- **Compatibility**: How does it integrate with existing systems, processes, and controls?
- **Compliance**: Does it meet relevant laws, regulations, policies, and standards?
- **Organizational Fit**: Is it suitable for the organization's structure, culture, and strategic objectives?
- **Operational Impact**: What effect does it have on day-to-day operations?
- **Safety & Reliability**: Does it maintain or improve safe and dependable operations?
- **Measurement**: How will you measure whether the control is successful?

3. Risk Assessment → Risk Treatment

- After conducting a **risk assessment** and analysis, the recommended procedural and technical controls are prioritized.
- A **cost-benefit analysis** justifies the expenses of implementing a control by comparing them to the anticipated reduction in risk and impact.
- Implementation should involve **input from relevant business units** to ensure the controls are practical, effective, and aligned with organizational needs.

Overall, these steps and considerations help ensure that proposed security controls not only address the identified risks but also align with the organization's overall goals, culture, and regulatory environment.

Exam Tip: Recommendations typically hinge on cost-benefit analyses. Avoid controls that hamper productivity; find the “just right” level of security.

Control Testing and Modification

Changes in technology or operations can weaken existing controls or introduce new vulnerabilities. To maintain effectiveness, organizations must implement:

1. Periodic Testing

- Mandatory in many publicly traded companies
- Confirms procedural controls are carried out consistently
- Ensures technical controls remain configured and functional as intended

2. Change Management

- Technical control changes must follow formal change control procedures with stakeholder approval.
- Analyze proposed updates to detect potential new or recurring vulnerabilities.
- Ensure updated controls are designed to self-protect, include a failure policy, and can be monitored.
- After implementation, acceptance testing confirms that policies are enforced correctly.

3. Operational Procedure Updates

- Reviewed and approved through the change management process.
- Update process inputs, steps, approvals, and outputs as needed.
- Coordinate changes with related processes and technologies.
- Consider workload impacts to prevent resource overload.
- Provide staff training before rollout, then conduct a walkthrough to confirm proper implementation.

Numerous resources detail how to develop and implement controls effectively, including **COBIT**, **NIST guidance**, and **ISO/IEC 27001 and 27002** standards. Proper use of these frameworks helps maintain strong and adaptive information security controls.

Exam Tips:

- **Testing Frequency:** Some controls (e.g., PCI-DSS scanning) are tested at mandated intervals.
- **Change Control Process:** Know that modifying a control must go through formal change management.
- **Post-Incident Revisions:** The exam might present an incident scenario requiring quick control updates based on root cause analysis.

3B4. Information Security Awareness and Training

A large portion of security incidents result from human error—often due to a lack of understanding of expected behavior or simple mistakes. The best way to address this risk is through a robust information security awareness and training program.

An ongoing awareness and training initiative should be part of every security strategy. Many organizations find that employees are unaware of existing security policies and standards, so it is crucial to train anyone affected by new or updated policies. Training should connect policies and standards to an individual's daily tasks, ensuring the information is relevant and clear.

For instance, introducing “server-hardening standards” would be unnecessary for the shipping department, but essential for IT operations. Similarly, personnel tasked with implementing strategy need specific guidance on:

- **KGI (Key Goal Indicators):** High-level objectives of the strategy.
- **KPI (Key Performance Indicators):** Metrics for measuring performance and processes.
- **CSF (Critical Success Factors):** Events or elements that must occur to achieve the KGIs.

An effective awareness program focuses on tailoring content by role or department, so everyone understands how their actions can contribute to (or jeopardize) the organization's security posture.

Analogy: Consider security policies like traffic rules—each driver needs to know the rules relevant to the roads they travel. Teaching someone who only commutes in a city about freeway merging tactics may not be immediately relevant, just as a server-hardening workshop won't resonate with someone from HR.

Security Awareness Training and Education

Technical security measures alone cannot fully address the risks inherent in using computing systems. A well-designed security awareness program educates users on behaviors that reduce risk—emphasizing consistent, practical steps everyone should take.

Common focus areas include:

- Password best practices
- Appropriate use of computing resources
- Safe email and web browsing
- Recognizing and countering social engineering

These programs should be role-specific. Additionally, employees are often the first line of defense for detecting threats that automated tools may miss (e.g., fraudulent activity or unusual social engineering attempts). Training should teach users when and how to escalate suspicious events.

Key considerations for implementation:

- Security awareness must start at onboarding and continue regularly.
- Vary training delivery methods (e.g., online courses, videos, posters) to keep content fresh.
- Reinforce learning with quizzes, reminders (posters, newsletters, screen savers), and refresher sessions.
- Specialized training may be necessary for middle and senior management to address information security awareness and operational issues.
- Everyone who has access to the enterprise's information—including third-party users—must regularly receive updates on security policies, standards, and procedures.

Exam Tip: Remember, different roles need different training depths. The exam may test how you gauge program success (e.g., relevant metrics like phishing click rates, incident metrics).

Developing an Information Security Awareness Program

When developing and implementing an awareness program, the information security manager should consider:

1. Audience

- Senior management
- Business managers
- IT staff
- End users

2. Message

- Policies and procedures
- Recent events and relevant updates

3. Intended Outcome

- Better policy compliance
- Behavioral change
- Adoption of best practices

4. Communication Method

- Computer-based training (CBT)
- All-hands meetings
- Intranet messages or newsletters

5. Organizational Structure and Culture

- Tailoring content to fit the existing culture
- Deciding on the appropriate tone or formality level

Methods for Raising Security Awareness include:

- Computer-based security awareness programs
- Email reminders and tips
- Written policies and procedures (with updates)
- Signed nondisclosure agreements
- Newsletters, web pages, videos, posters, login banners
- Visible enforcement of security rules
- Simulated security incidents for practice
- Employee rewards for reporting suspicious activity
- Role definitions in job descriptions
- Performance reviews that include security components

By using varied methods, employees and partners learn how to meet security expectations and reduce security incidents caused by human error or misconduct.



You may need to adjust awareness training topics based on emerging threats (e.g., ransomware tactics).

Role-Based Training

All personnel need general security training, but some roles require more specific instruction:

1. Executives, Leaders, and Managers

- Understand responsibilities for setting risk expectations (risk appetite, tolerance statements, key indicators).
- Recognize they set the tone for security objectives and ethics throughout the enterprise.
- Support the security program as part of overall enterprise risk management.

2. Roles with Elevated Privileges

- Administrative roles for critical assets or sensitive information.
- Focus on safeguarding valuable resources.
- Reinforce heightened responsibilities and potential consequences for noncompliance.

3. Physical Security Personnel

- Responsible for physical protection and environmental factors that ensure confidentiality, integrity, and availability of critical assets.



Role-specific modules help reduce careless errors or insider threats. Some positions may require more frequent updates due to high-risk tasks or regulatory compliance requirements (HIPAA, PCI-DSS).

Training and Education Metrics

To ensure that the right people receive the right training at the right time, a systematic approach to measuring and tracking is essential. Important considerations include:

- **Coverage**
 - Track how many people receive training (including external participants).
 - Define coverage targets (e.g., 90% completion) and measure progress toward them.
- **Grading**
 - While not always mandatory, consider follow-up for individuals who do not meet expected levels of competence.
 - Certain service-level agreements (SLAs) or regulations may require specific passing scores.
- **Automation and Deployment**

- A Learning Management System (LMS) can help create, deliver, track, and report on training initiatives.
- An LMS supports monitoring compliance with training requirements and contributes to continuous security improvement.

By systematically tracking these metrics, the organization can verify that training has been delivered effectively, identify areas that need improvement, and ensure ongoing compliance with security goals.



If training is effective, over time, metrics should show improving security behaviors (fewer incidents, quicker reporting, etc.).

3B5. Management of External Services

Enterprises increasingly rely on external partners not only for cloud services but also to supply, host, and operate their information and technology. This extended supply chain carries inherent risks that demand greater scrutiny from security personnel and regulators.

While these third-party relationships can provide significant benefits, the associated risks must be managed in alignment with stakeholder objectives.

Governance of Third-Party Relationships

Information security governance in the context of third-party relationships centers on the rules and processes used to manage service providers, and outsourced operations.

Managing security in these relationships is challenging, especially during mergers or acquisitions. *Potential issues include:*

- **Cultural differences** leading to incompatible security practices
- **Technology incompatibilities** that hinder integration
- Process or baseline security **misalignment**
- **Deficiencies or inconsistencies** in incident response, business continuity, and disaster recovery capabilities

To address these challenges:

1. Assess potential third-party security failures

- Understand how failures might impact your enterprise
- Have a plan to manage or mitigate these impacts to acceptable levels

2. Formalize responsibilities

- Document the information security manager's role in addressing risk
- Develop policies, standards, and procedures that define how and when security must be involved before new third-party relationships are established

3. Engagement model

- Create a clear framework for how the security team engages with departments responsible for evaluating and managing third-party relationships



The organization is still ultimately responsible for security, even if services are outsourced.

Third-Party Service Providers

Enterprises typically use a mix of internal and external resources to support their processes. Regardless of who provides the resources, the **information security manager** must ensure:

1. **Visibility of where data resides** and who can access it
2. **Protection of assets** in all environments—internal and external

When outsourcing, key considerations include:

- Establishing **appropriate controls and processes** before outsourcing
- Incorporating **risk management clauses** in contracts
- Conducting a **risk assessment** of the outsourcing arrangement
- Performing **due diligence** prior to contract signature
- **Managing day-to-day risks** of outsourced services
- **Reassessing risk** when material changes occur
- Following the correct **offboarding processes** when contracts end

Complexity in Outsourcing

Risk grows with critical functions, and vendor risk exposure must not exceed the organizations tolerance. These exposures should be addressed in contracts.

- **Control specification** (defined by the enterprise) and **control implementation** (performed by the provider) are separated. The contract acts as a bridge between these responsibilities.
- **Regulated industries** must explicitly address compliance in contracts.

- **Three risk areas** must be assessed:
 1. The business function itself
 2. The outsourcing provider
 3. The act of outsourcing
- **Risk management must adapt** over time, as business needs change.
- **Exit strategy** is as crucial as the initial transition and must be planned for at the beginning.

Outsourcing Challenges

Outsourcing arrangements can limit the transparency of a provider's technical controls. It is vital, therefore, to include **service level agreements (SLAs)** that specify:

- **Defined protection levels** (e.g., SOC 2 or ISO 27001:2013 certifications)
- **Right-to-audit** clauses and meaningful access to audit reports (e.g., SOC 2, vendor-provided compliance assessments)
- **Incident management and response protocols**
- **Business continuity and disaster recovery (BC/DR) plans**

For regulated industries (such as finance), **reporting suspicious events** within a specific time-frame is essential. Contracts should align third-party processes with regulatory obligations.

Other considerations:

- **Financial viability** of the outsourcing partner
- **Cultural and ethical differences**
- **Loss of essential in-house skills**
- **Lack of visibility** into the provider's security processes
- **Possible unanticipated costs** or service limitations

Privacy laws and cross-border data transfers must also be considered. A provider's staff may have different attitudes toward data classification and privacy, necessitating robust **training, awareness, and technical/administrative controls**.

Exam Tips:

- **Contractual Safeguards:** Use strong SLAs, data protection clauses, and periodic audits to mitigate risk.
- **Regulatory Complexities:** Some industries have stricter outsourcing rules (e.g., banking).

- **Contingency Planning:** You may see questions on how to pivot if a vendor fails or is breached.

Outsourcing Contracts

Contracts serve two main purposes:

1. To ensure each party understands their responsibilities and rights.
2. To provide a framework for resolving disagreements.

From an **information security** perspective, key contract provisions include:

1. **Confidentiality or nondisclosure** requirements

- Include how confidential data is handled, returned, or destroyed.

2. **Security control obligations**

- Clearly define what “appropriate” means (e.g., SOC reports, ISO/IEC 2700X compliance).

3. **Network connectivity responsibilities**

- Specify security mechanisms (e.g., firewalls, IDS/IPS, monitoring).

4. **Right to audit and inspect**

- For high-risk vendors, include a provision for unannounced inspections.
- Define the scope, frequency, notification terms, and cost responsibilities of audits.

5. **Incident response**

- Outline roles, notification procedures, remediation responsibilities, and timelines in case of a security breach.

6. **Indemnity clauses**

- Ensure you are compensated for the provider’s failures.
- Beware of providers limiting liability to the amount paid under the contract.

7. **Choice of law**

- Contracts often specify the jurisdiction for potential legal actions, which can affect your ability to recover losses.

Contracts should also address:

- **Detailed specifications** for outsourced services
- **Restrictions on data copying** and distribution
- **Access controls** (least privilege, need-to-know, etc.)
- **Incident response plans (IRPs)** and **business continuity plans (BCPs)**
- **Service quality levels**
- **Nondisclosure agreements (NDAs)** for the vendor's employees
- **Ownership and return/destruction of data**
- **Offboarding processes** (e.g., removing access upon contract termination)

Other Considerations:

- **Incident Response Obligations:** Both parties should know how to collaborate if a breach occurs.
- **Right-to-Audit Clause:** Often tested in scenarios ensuring the client can verify vendor compliance.
- **GDPR or Other Data Privacy Requirements:** Some regulations require explicit contractual terms for data processors.

Third-Party Access

Whenever a third party needs access to enterprise processing facilities, **risk assessment** should drive the decision, and the following must be clearly defined in an SLA:

- **Least privilege and need-to-know** access
- **Approved methods and levels** of functionality
- **Full logging and regular reviews** of access logs
- **Immediate revocation** of access upon contract expiration

Example: Suppose your marketing team hires a data analytics firm. They need direct access to your customer database for analysis. You would grant them only the bare minimum queries and read rights required, monitor their usage daily, and revoke all credentials once the project ends.

Network and information access should **never** be granted until a contract is signed, defining specific access terms and verification of necessary safeguards.

By incorporating these measures — clear governance, meticulous contract management, thorough due diligence, and ongoing oversight, you can better balance the benefits of external services against the associated risks.

Key Takeaway: Remember that *while you can outsource a process, you cannot outsource your accountability for securing it.*

3B6. Information Security Program Communications and Reporting

Effective communication and reporting are among the most critical outcomes of any information security program. They ensure that senior leaders, regulators, and other stakeholders remain informed about:

- Achievement of security and privacy objectives
- Ongoing risk status
- Opportunities for improvement

For some senior leaders, failing to remain current on risk factors could result in legal liability or financial penalties. By using effective monitoring and reporting, the information security manager can:

- Fulfill commitments stated in the business case
- Demonstrate successful implementation of the security strategy
- Keep stakeholders informed of monitoring results and emerging risks

Program Management Evaluation

When entering a new organization or when organizational demands change, information security managers should evaluate the current state of the existing security program. This evaluation should be shared with the steering committee and other stakeholders to determine if modifications are needed.

Program Objectives

1. Security Strategy and Roadmap

- Has the organization documented its security strategy and development roadmap?
- Are risk criteria and impact thresholds established?

2. Policies, Standards, and Procedures

- Are they complete, current, measurable, and realistic?

- Are they updated collaboratively with consensus among all stakeholders?

3. Alignment and Reviews

- Do program goals align with governance objectives, organizational initiatives, and compliance needs?
- Are there regular management reviews of objectives and accomplishments?

4. Metrics

- Have key performance indicators been defined to measure success or shortfalls?
- Is there a schedule to review these metrics?

Compliance Requirements

One of the most visible indicators of a security program's maturity is how well it meets regulatory and internal compliance needs.

- **Level of Compliance**

- Has management determined how much compliance the enterprise will undertake, with relevant timelines and milestones?

- **Integration**

- Are compliance requirements clearly defined and integrated into policies, standards, procedures, and success metrics?

- **Alignment**

- Do the technical, operational, and managerial components align with regulatory standards?

- **Audit and Tracking**

- What do recent audits reveal about compliance?
- Are deficiencies tracked, reported, and resolved promptly?
- Are compliance management technologies leveraged for efficiency?

Program Management

Evaluating program management helps gauge the breadth of the program and the extent of management support. Strategic, governance-driven programs typically have more comprehensive management activities than purely tactical ones.

- **Documentation**

- Is there thorough documentation of the overall security program?
- Are operating guidelines (policies, standards, procedures) accessible to those with assigned responsibilities?

- **Roles and Responsibilities**

- Are responsibilities clearly defined and understood, especially at the executive level?
- Are security roles included in business managers' objectives and performance reviews?

- **Authority and Oversight**

- To whom is the security program accountable?
- Does it have sufficient authority and visibility to meet its objectives?
- Is there a formal steering committee that offers guidance and support?

- **Administration**

- Does the program implement effective budgeting, financial management, HR management, and knowledge management?

- **Metrics and Review**

- Are meaningful metrics collected and reported regularly?
- Does management reassess the program's effectiveness on a routine basis?

Security Operations Management

The information security manager must also evaluate how effectively the program carries out day-to-day operations, both within the security organization and across business units.

- **Inclusion in SOPs**

- Are security processes included in technology and business unit standard operating procedures (SOPs)?
- Do these SOPs provide clear accountability and management oversight?

- **Documented Procedures**

- Are there SOPs for configuration management, access management, security system maintenance, event analysis, and incident response?
- Are scheduled tasks logged, tracked, and reviewed?
- **Separation of Duties (SoD)**
 - Is SoD enforced, especially among system implementers, security administrators, and compliance personnel?
- **Reporting**
 - Are operational, tactical, and strategic metrics reported effectively to management?
 - Is there a clear escalation forum for operational issues?

Technical Security Management

Managing the technical environment ensures that security mechanisms and processes are appropriately implemented.

- **Technical Standards**
 - Are there standards for configuring networks, systems, and applications?
 - Do they address architecture issues like topology, communication protocols, and compartmentalization of critical systems?
- **Implementation and Monitoring**
 - Is continuous monitoring of key controls performed?
 - Are controls capable of notifying staff upon failure?
 - Are development, test, and production environments separated?
- **Logging and Segregation**
 - Is there a reliable logging infrastructure to monitor configurations, accessibility, and security events?
 - Are decommissioning processes in place to protect against data leakage?

Resource Levels

The information security manager must assess whether financial, human, and technical resources are sufficient. Any gaps or shortfalls should be escalated to senior management.

1. Financial Resources

- Is there a comprehensive capital and operating budget for security initiatives?
- Are allocations linked to business objectives?

- Which functions risk underfunding?

2. Human Resources

- Are workloads managed effectively?
- Do staff have the right skills and training in place?
- Are low-value tasks being delegated or automated to free up skilled resources?

3. Technical Resources

- Which technologies currently support security objectives?
- Is capacity sufficient for present needs and scalable for the future?
- Does the program account for maintenance, updates, and eventual replacements?

Analogy: Think of this evaluation like a “health check” for the security program, much like a doctor who reviews vital signs, identifies any irregularities, and recommends a treatment plan.

The Plan-Do-Check-Act (PDCA) Cycle

Information security management closely aligns with Total Quality Management (TQM) philosophies, particularly the iterative four-step PDCA cycle (also called the Deming or Shewhart Cycle):

1. PLAN

- Design, plan, and initiate the security program (strategy, policies, objectives, and risk management).

2. DO

- Execute and maintain the security strategy by integrating it into routine organizational practices.

3. CHECK

- Monitor, audit, and review program effectiveness.
- Use metrics and performance indicators to gauge success.

4. ACT

- Address findings from audits and risk assessments.
- Create corrective, preventive, and continuous improvement actions.

- Present recommendations and resource requests to management for decision-making.

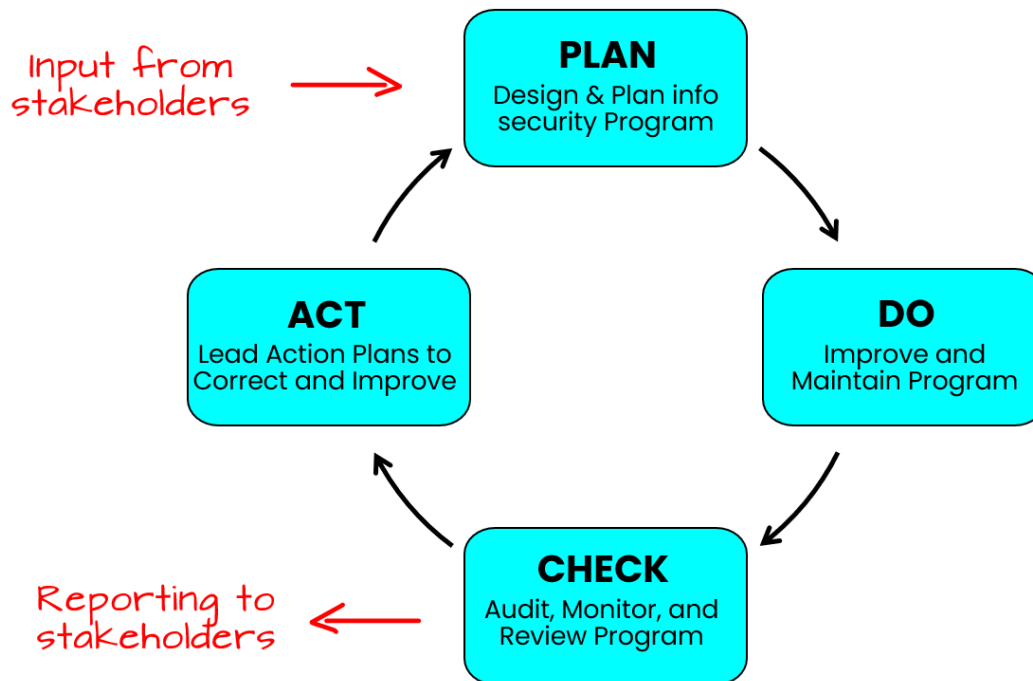


Figure 6.10. PDCA Cycle (for Info Security Program)

A strong governance approach supports PDCA by focusing on strategic alignment between security objectives and overall organizational goals. Elements such as a clear vision, key goals and initiatives (KGIs), critical success factors (CSFs), key performance indicators (KPIs), and tactical action plans collectively guide and reinforce continual improvement.

Security Reviews and Audits

A standardized, consistent approach to assessment not only provides valuable trend data but can also serve as a performance metric for the security program.

Security reviews typically include:

1. **Objective** – What is the primary question the review aims to answer (e.g., “Can external users exploit this system?”)?
2. **Scope** – Which systems, applications, or processes are assessed?
3. **Constraints** – Any limitations (e.g., no testing during business hours).
4. **Approach** – The set of activities to achieve the objective within constraints.
5. **Result** – Determining whether the objective is met.

Common types of reviews include control self-assessments, security architecture/design reviews, and spot checks. Each has specific objectives, scopes, constraints, and approaches, often summarized in a table or matrix.

Audits are similar but typically more formal, with auditors identifying and testing controls against established objectives (e.g., compliance with specific policies or external standards like COBIT or ISO/IEC 27001). Audit findings and work papers can be valuable in shaping the security program and garnering management support for security initiatives.



Cultivate a positive relationship with auditors. Their independent feedback often carries weight with senior management and can foster stronger organizational security culture.



Audits and assessments are covered in greater depth in Chapter 2 under “Assurance Provisions”.

Compliance Monitoring and Enforcement

Establish compliance enforcement early in program design to manage:

- **Policy Compliance**
 - Policies define security responsibilities and guide accountability.
 - Ensure no “orphan systems” exist without designated compliance owners.
 - Implement periodic reviews and a formal policy exception process with clear risk assessment, acceptance, and waiver timelines.
- **Standards Compliance**
 - Standards interpret policies in operational terms (consistent configurations, procedures, etc.).
 - Automate compliance where possible.
 - Maintain a formal process for exceptions, with thorough risk assessments.
- **Noncompliance Resolution**
 - Track and prioritize noncompliance items.
 - Assign responsibility and follow up.
 - Address issues discovered through monitoring, audits, or vulnerability scans in a timely, risk-based manner.

Example: If your policy mandates a specific password-reset procedure, you might have the help desk manager periodically review call recordings to confirm each technician followed the required identity verification steps. Violations trigger corrective measures.

Monitoring Approaches

Monitoring verifies that controls (technical or procedural) operate as intended. This often involves log reviews, alerts (e.g., from IDS/IPS or firewalls), and integration with change management.

- **Continuous Monitoring**
 - Ongoing security checks across infrastructure and applications.
 - Real-time alerts on suspicious activities or attempted breaches.
- **Risk Assessments**
 - Regularly perform to identify vulnerabilities and track remediation trends.
- **Penetration Testing and Scanning**
 - Internal and external scans provide insight into potential exploits and overall technical security posture.
 - Track repeat vulnerabilities and remediation efforts.
- **Metrics and Response**
 - Define escalation paths for anomalous events.
 - Develop action plans and respond quickly to adverse trends.

Measuring Information Security Management Performance

The security manager must implement processes to measure successes and identify improvement opportunities. *Common objectives include:*

1. **Manage Risk and Loss**
 - Track technical vulnerabilities: quantity, severity, time to resolve.
 - Monitor high/medium/low-risk items and their ALE (Annualized Loss Expectancy).
 - Track incident losses, discovery times, and containment times.
2. **Support Organizational Goals**

- Document alignment between security activities and enterprise objectives.
- Gauge consensus among stakeholders on security priorities.
- Assess whether security issues hindered any key organizational milestones.

3. Measure Compliance

- Measure adherence to internal policies and external regulations.
- Track resolution of noncompliance.
- Ensure compliance is a result of robust security, not the sole focus of security initiatives.

4. Assess Operational Productivity

- Evaluate the impact of automation.
- Track staffing efficiency and potential outsourcing of low-value tasks.
- Compare pre- and post-deployment productivity metrics.

5. Evaluate Cost-Effectiveness

- Use total cost of ownership (TCO) to factor in ongoing maintenance, training, and administrative costs.
- Track budget utilization vs. projections.
- Demonstrate cost-result ratios (e.g., cost per vulnerability assessed, cost per email scanned).

6. Gauge Organizational Awareness

- Maintain records of training, policy acceptance, and periodic refreshers.
- Use quizzes or surveys to measure retention of key concepts.
- Identify awareness gaps and address them promptly.

7. Review Technical Security Architecture

- Track attempted probes and attacks repelled.
- Monitor actual compromises and root causes.
- Quantify malware neutralization.
- Evaluate downtime caused by security flaws or unpatched systems.

8. Check Management Framework and Resources

- Monitor issue recurrence.
- Standardize processes and document roles.
- Verify that resources (personnel, budget, technology) are effectively utilized.

9. Monitor Operational Performance

- Measure time to detect, isolate, contain, and resolve incidents.
- Track patch deployment timelines.
- Identify changes released without proper change control approvals.

Ongoing Monitoring and Communication

Security managers must ensure regular, reliable communication of program status and emerging risks to stakeholders. *Key activities include:*

- **Centralized Monitoring**
 - Aggregate relevant security events in a central monitoring system or Security Operations Center (SOC).
 - Define severity and escalation processes.
- **Event Analysis and Response**
 - Train monitoring personnel and define clear response procedures.
 - Perform trend analysis (e.g., identify repeated attack vectors or frequently targeted assets).
- **Real-time vs. Detective Controls**
 - Real-time controls (e.g., IDS alerts) help *trigger rapid response*.
 - Detective controls (e.g., log reviews) help with *root-cause analysis* after the fact.
- **Management Assurance**
 - Summarize monitoring data to demonstrate operational assurance.
 - Provide actionable insights, not just raw metrics, so leaders can make informed decisions.

By designing clear objectives, continuously monitoring and evaluating controls, and communicating effectively with stakeholders, the information security manager can maintain a robust security program that ensures the enterprise *manages risk appropriately, meets its compliance obligations, and successfully aligns information security efforts with organizational goals*.

Domain 4A: Incident Management Readiness

Syllabus

4A. Incident Management Readiness

- 4A1. Incident Response Plan
- 4A2. Business Impact Analysis (BIA)
- 4A3. Business Continuity Plan (BCP)
- 4A4. Disaster Recovery Plan (DRP)
- 4A5. Incident Classification/Categorization
- 4A6. Incident Management Training, Testing, and Evaluation

Supporting Tasks

- 29. Establish and maintain an incident response plan, in alignment with the business continuity plan and disaster recovery plan.
- 30. Establish and maintain an information security incident classification and categorization process.
- 31. Develop and implement processes to ensure the timely identification of information security incidents.
- 32. Establish and maintain processes to investigate and document information security incidents in accordance with legal and regulatory requirements.
- 33. Establish and maintain incident handling process, including containment, notification, escalation, eradication, and recovery.
- 34. Organize, train, equip, and assign responsibilities to incident response teams.
- 35. Establish and maintain incident communication plans and processes for internal and external parties.
- 36. Evaluate incident management plans through testing and review, including tabletop exercises, checklist review, and simulation testing at planned intervals.

4A1. Incident Response Plan

Incident management is essentially part of an organization's risk management program. It focuses on the proactive planning, preparation, and identification of risks and abnormal events, with the overall aim of reducing negative impact on the business and helping it return to normal operations as quickly as possible.

The core elements of incident management:

- **Scope and Purpose:** Incident management aims to address a broad spectrum of potential disruptions (e.g., losing a critical staff member, IT outages, market changes, or major disasters).
- **Goals:**
 1. Minimize the harm the incident causes to the enterprise.
 2. Restore normal business operations promptly and efficiently.

Important consideration to developing incident management procedures include:

- **Variability Across Organizations:** Each organization tailors its incident management approach based on maturity, compliance requirements, size, industry, geography, and strategic goals. There is no universal one-size-fits-all model.
- **Collaboration and Support:** Developing and maintaining a solid incident management program requires the involvement of various stakeholders (including senior management) and adequate resource allocation.
- **Life Cycle of Activities:** Incident management addresses the full life cycle of an incident—before, during, and after it occurs—to ensure readiness, effective response, and proper recovery.

The Relationship Between Incident Management and Incident Response

While **incident management** is an overarching set of processes and activities that happen before, during, and after disruptive events, **incident response** is a more specific subset of activities triggered when an incident is declared.

Key distinctions and relationships:

- **Incident Management:** Encompasses everything required to plan for, handle, and recover from incidents. This includes understanding how tasks and processes interact, how information is shared, and ensuring the organization can quickly adapt to and manage unexpected events. *Think of it as the “big picture” approach to incident handling.*

- **Incident Response:** A focused portion of incident management that deals with the immediate actions of identifying, containing, eradicating, and recovering from an active incident to resume normal operations as soon as possible. *It's the "boots on the ground" work of dealing with a specific incident.*
- **Integration for Resilience:** Together, incident management and incident response form the operational dimension of emergency and risk management. They contribute to organizational resilience by making sure the enterprise is prepared to handle incidents efficiently and restore functionality in alignment with strategic objectives.
- **Senior Management's Role:** Executive endorsement and adequate commitment of resources are necessary to keep risk within acceptable tolerance levels and ensure the incident management framework aligns with the organization's strategic direction.

Goals of Incident Management and Incident Response

Incidents can arise from many sources (e.g., cyberattacks, natural disasters, loss of key personnel, workplace accidents) and involve any medium, logical, physical, or human. An organization's ability to respond effectively greatly influences how quickly it can recover and minimize impacts.

Stated simply, the primary goal of incident management and incident response is to minimize the impact of security incidents on the organization. *This includes:*

- Protecting human life and safety.
- Maintaining the confidentiality, integrity, and availability of information and systems.
- Minimizing downtime and business disruption.
- Preventing the recurrence of similar incidents.
- Complying with legal and regulatory requirements.
- Protecting the organization's reputation.

To go a bit deeper into the process, well-defined incident management and incident management and incident response establish several critical processes and procedures that support these goals, including:

1. Early Detection and Rapid Response

- **Identify incidents quickly** to reduce the time an attack or disruption can impact systems.
- **Contain threats** before they spread and escalate.

2. Minimize Adverse Impact

- **Limit damage** to critical assets, data, and operations.
- Maintain or restore **business continuity** so that essential functions keep running, even if on a reduced scale.

3. Preserve Evidence and Support Investigations

- **Gather and protect evidence** during an incident to support root-cause analysis and possible legal or regulatory inquiries.
- Ensure **chain of custody** is maintained so that collected evidence is admissible, if needed, in legal proceedings.

4. Meet Legal, Regulatory, and Contractual Obligations

- Comply with **relevant laws and regulations** (e.g., data protection laws).
- Fulfill any **contractual requirements** (e.g., service-level agreements) that specify incident reporting or notification.

5. Protect Reputation and Stakeholder Interests

- Maintain the organization's **public trust** and credibility by demonstrating a prompt and professional response.
- Keep **stakeholders informed** (e.g., executives, employees, customers) at appropriate levels of detail and frequency.

6. Establish Clear Roles and Responsibilities

- Define who does what during an incident, including **technical staff, management, and external resources** (e.g., law enforcement or third-party responders).
- Ensure **coordination** among all parties to avoid duplication of effort or conflicting actions.

7. Facilitate Continuous Improvement

- Conduct **post-incident reviews** to identify lessons learned, root causes, and areas for process improvement.
- Update **incident response plans** regularly based on insights from actual incidents and changing threat landscapes.

The last two on this list surface familiar themes we've touched on in other endeavors within this book:

8. Provide Adequate Funding and Resources

- Secure **budget** for the technologies, training, and personnel needed to implement and maintain an effective incident management program.
- Ensure **ongoing support** for continuous improvements, including testing and exercises.

9. Align with Business Objectives and Risk Appetite

- Tailor incident management strategies to the organization's **overall risk management framework** and tolerance levels.
- Balance **costs** of incident response measures with the **value** of assets being protected.

By aligning with business objectives, maintaining clear communication, and continually improving processes, an organization can ensure it remains resilient against a broad range of potential disruptions.

Incident Handling and the Incident Management Life Cycle

Incident handling encompasses all tasks involved in managing and responding to an event. The life cycle consists of several phases:

1. Planning and Preparation

- Create policies, obtain management support, and develop user awareness.
- Conduct research, build checklists, acquire tools, and ensure stakeholder buy-in.

2. Detection, Triage, and Investigation

- Define what qualifies as an event vs. an incident and determine notification processes.
- Detect and validate incidents, then prioritize them based on severity or risk.
- Use intrusion detection/prevention systems, security monitoring, and other tools.

3. Containment, Analysis, Tracking, and Recovery

- Execute containment strategies (e.g., isolating affected systems).
- Perform forensic analysis following evidence-handling procedures.
- Initiate recovery plans aligned with BC/DR to restore services.
- Identify the root cause of the incident to prevent recurrence.

4. Post-Incident Assessment

- Conduct a thorough review (postmortem) to determine what happened and when.
- Evaluate the effectiveness of staff response and documented procedures.
- Identify corrective measures to prevent similar incidents.
- Report on metrics (e.g., time to detect or recover) and lessons learned.

5. Incident Closure

- Complete any final analysis and submit incident reports to management and stakeholders.
- Incorporate lessons learned into continuous improvement of the incident management process.

By following this life cycle, organizations can detect incidents early, minimize damage, restore services swiftly, and implement improvements to reduce the likelihood of future incidents.

Incident Management vs Incident Response

For the exam, be sure you know the difference between incident management and incident response:

- **Incident Management** (*the overarching program*)
 - Governance, strategy, policy, resource allocation, continuous improvement.
 - Ensures the organization is **prepared** and that response activities are **aligned** with business goals.
- **Incident Response** (*the operational activities*)
 - Operational, hands-on activities for **detecting, containing, eradicating, and recovering** from an incident.
 - Goal is to **minimize** the impact of incidents and **quickly restore** normal business operations, reporting findings back to management for future improvements.

By distinguishing these two layers, the organization can ensure that security leaders not only **respond** effectively in a crisis but also **manage** the overarching program to continually strengthen the organization's incident-handling capabilities.

Incident Management and Incident Response Plans

Effective incident management ensures that all security incidents are quickly identified, recorded, and managed to minimize business impact. Recording these incidents is critical for several reasons:

- It provides a clear audit trail for planning and continuous improvement.
- It ensures no aspect of an incident is missed.
- It supplies potential forensics data (for legal or disciplinary actions).

Once incidents are recorded, they must be properly classified, prioritized, and routed to the appropriate teams. This includes an initial check against known issues to discover any existing workarounds or solutions. Incident management offers a structured lifecycle—encompassing investigation, diagnosis, resolution, and closure—so incidents are owned and tracked at every stage.

Major or complex incidents may demand escalations or special responses (e.g., activating disaster recovery plans), particularly if they surpass typical incident management capabilities.

Incident response is the final phase of incident handling, covering the coordination and execution of containment, eradication, and recovery actions. It can lead to further mitigation measures or improvements identified during post-incident reviews. Importantly, nontechnical incidents (such as social engineering attempts, theft of sensitive media, or natural disasters) must also be accounted for in the overall incident management strategy.

Importance of Incident Management

As organizations depend more on technology, disruptions in information systems can cause severe damage. Thus, effective incident management grows increasingly critical. Factors driving its importance include:

- **Rising frequency and severity** of security incidents.
- **Growing sophistication** of threat actors and their techniques.
- **New vulnerabilities** in software and infrastructure that affect large portions of the enterprise.
- **Failure of existing controls** to stop advanced threats (e.g., advanced persistent threats, zero-day exploits).
- **Regulatory and legal pressures** that demand robust incident management capabilities.
- **Poorly managed IT processes** that make exploitation easier.

In short, a comprehensive, well-planned incident management program enables organizations to cope with unexpected events effectively, safeguarding business operations and meeting both technical and regulatory obligations.

Outcomes of Incident Management

Comprehensive incident management and response yield multiple benefits, including:

- **Business continuity:** The organization can handle unexpected events and meet recovery time objectives (RTO) and recovery point objectives (RPO).
- **Timely detection:** Proper monitoring ensures that incidents are identified in time to reduce damage.
- **Clear escalation paths:** Well-defined severity and declaration criteria help teams know exactly whom to contact, when, and under which conditions.
- **Trained personnel:** Employees can recognize incidents, apply severity criteria, and follow correct reporting and escalation procedures.
- **Aligned response capabilities:** The organization can respond proportionately to protect critical resources.
- **Cost-effective risk management:** Integrating security functions and proactive risk analysis ensures resources are used optimally.
- **Monitoring and metrics:** The enterprise measures performance of incident management, tests response capabilities periodically, and ensures plans are updated regularly to remain current.

Monitoring and metrics should confirm (quantitatively, when possible) that:

- Information assets remain protected within acceptable risk thresholds.

- Properly trained and equipped response teams are in place.
- Incident response plans (IRPs) are well understood by relevant stakeholders (e.g., IT, management, end users, incident handlers).
- Incidents are quickly identified, correctly categorized, and contained, with root causes addressed.
- Communications to stakeholders and external parties follow a documented plan.
- Lessons learned inform improvements, enhance awareness, and influence policy updates.

Incident Management Resources

Several internal and external resources can assist in developing an incident management and response plan. *Typical resources may include:*

- **Internal:** compliance, facilities management, HR, internal audit, IT, legal, privacy officer, public relations, risk management, senior management, physical security.
- **External:** law enforcement, insurance providers, local government, industry emergency response teams, information sharing and analysis centers (ISACs), third-party providers, vendors, trusted advisors.

Successful incident management strategies begin with a well-defined scope and objectives to ensure both internal and external resources can be utilized effectively. The organization should articulate a plan to transition from the current state to the desired future state, confirming resource allocation and deployment methods.

Policies and Standards

An effective Incident Response Plan (IRP) must be anchored by *well-defined policies, standards, and procedures*. *This documentation framework is critical for:*

1. **IMT Mission Alignment**
Ensures all incident management activities directly support the objectives of the Incident Management Team (IMT).
2. **Setting Expectations**
Establishes what stakeholders can anticipate during the incident response process.
3. **Guidance for Operations**
Provides clear instructions that shape day-to-day response efforts, promoting a structured approach to incident handling.
4. **Consistency and Reliability**
Helps maintain uniform service quality and dependable response practices across the organization.

5. Defined Roles and Responsibilities

Clarifies who does what during an incident, reducing confusion and overlap among team members.

6. Contingency Personnel

Identifies backups for all critical functions to ensure coverage in the event key staff become unavailable.

GOAL: By documenting these elements, organizations create a robust foundation that supports *efficient, well-organized, and resilient incident response activities*.

Incident Management Objectives

In essence, incident management aims to handle unforeseen events that can severely disrupt enterprise operations. Once security controls fail, incident management is the next crucial line of defense to contain security incidents and restore normalcy quickly. If an incident expands beyond this scope, a disaster may be declared, necessitating more extensive recovery steps (e.g., relocating operations per BC/DR plans).

Key objectives of incident management include:

- **Containment and eradication:** Handle incidents swiftly to meet RTO and RPO targets.
- **Rapid recovery:** Restore systems and business processes to their normal state.
- **Learning from incidents:** Document lessons learned to prevent recurrence.
- **Proactive countermeasures:** Deploy safeguards to reduce the likelihood or impact of future incidents.

To be effective, the organization must maintain comprehensive monitoring of key controls and ensure the incident management team can swiftly act upon alerts. Well-trained personnel will classify, triage, and coordinate responses that safeguard continuity and minimize impact. Incident managers should also be prepared to enact disaster-recovery measures when criteria and authority dictate escalation.

Strategic Alignment

Incident management should align with the broader organizational strategy. Elements that support alignment include:

1. **Stakeholders:** Identify the IMT's primary stakeholders and understand their requirements.

2. **Mission:** Clearly define the team's purpose and objectives (e.g., "The IMT's mission is to provide timely and effective incident management to minimize risk and losses").
3. **Services:** Outline precisely which services (incident management, vulnerability management, situational awareness, knowledge transfer, etc.) the IMT will provide.
4. **Organizational structure:** Match the IMT's structure to the enterprise's geographical or subsidiary distribution for efficiency.
5. **Resources:** Ensure qualified staffing. Use virtual teams or external specialists if necessary.
6. **Funding:** Budget for specialized training, tools, and technology.
7. **Management support:** Secure senior leadership buy-in for adequate resources, reduced silos, and organizational cooperation.

Response and Recovery Plan

A formal, comprehensive approach to managing incidents is encapsulated in an **Incident Response Plan (IRP)**. While each IRP must address the enterprise's unique needs, its essential elements typically include:

- Mission, strategies, and goals
- Senior management approval
- Organizational approach and structure for incident response
- Roles, responsibilities, and communication channels
- Metrics to measure capability and effectiveness
- Roadmap for capability maturity
- Alignment with broader enterprise objectives

Once the IRP is created and approved, it should be *periodically reviewed, tested, and updated* to accommodate new risks and changes in the enterprise environment.

The Role of the Information Security Manager in Incident Management

The information security manager's involvement in business continuity (BC), disaster recovery (DR), and incident response varies depending on organizational size, industry, regulation, and maturity level.

Typical responsibilities include:

- Leading or participating in security-related incident response activities.
- Assisting with business impact analyses (BIAs).
- Coordinating with IT to identify and implement backup, redundancy, and recovery solutions.
- Acting as an internal consultant or advisor, depending on the size of the enterprise and existing dedicated BC/DR/incident response roles.

Regardless of the setting, the information security manager must understand BC, DR, and incident management requirements thoroughly so that security plans align well with broader continuity and recovery objectives.

Risk Management

Risk management and incident management are two sides of the same coin. One focuses on prevention, the other on response. Any materialized risk (i.e., an incident) calls for a coordinated response to contain damage and prevent escalation to disaster. In that sense, incident response capabilities reinforce the organization's overall risk posture.

- **Risk Management Sets the Stage:** You've identified potential risks (weaknesses in the castle walls) and implemented controls (guards, moats, etc.) to prevent them. This is your proactive risk management.
- **Controls Aren't Perfect:** Despite your best efforts, risks can still materialize. Think of it as a clever thief finding a way in. This is where incident management comes in.
- **Incidents Happen:** Any risk that slips past your controls becomes an "incident." This could be a data breach, a system failure, or a security vulnerability being exploited.

-Incident Management is the Response: You need a well-trained fire brigade (incident response team) ready to act quickly and efficiently.

- **Goal: Prevent Escalation:** The primary objective of incident management is to contain the incident and prevent it from becoming a disaster. Think of it as putting out the fire before it spreads and burns down the entire castle.

Effective incident management is crucial for *mitigating the impact of realized risks*. The ultimate goal is to minimize damage and ensure business continuity.

Assurance Process Integration

Assurance Process Integration is the practice of systematically connecting and coordinating various organizational functions (like physical security, HR, and legal) within incident response plans.

Its key value to the business is to *ensure smoother and more effective collaboration during high-pressure incidents* by:

- **Clearly defining departmental roles:** This eliminates confusion and overlaps during crises.
- **Testing interdepartmental linkages:** This proactively identifies and addresses potential communication or coordination breakdowns.
- **Facilitating a unified response:** This leads to more efficient and effective incident resolution.

Value Delivery

Incident management must be more than just a technical response to security events, it should be a fully integrated element of the organization's overall risk management strategy. It focuses not only on preventing incidents but also on containing them when they occur and restoring normal operations swiftly.

By aligning closely with core business processes, incident management serves as the last line of defense to protect the enterprise in a cost-effective manner.

To deliver maximum value, an effective incident management program should:

1. **Seamlessly integrate with business processes and structures**
Ensure that incident response plans fit naturally into day-to-day operations, minimizing disruption and maximizing efficiency.
2. **Strengthen the organization's risk management capabilities**
Provide clear, measurable ways to manage and reduce risk, offering assurance to stakeholders that security threats are being addressed responsibly.
3. **Align with the business continuity plan (BCP)**
Coordinate incident response with broader continuity efforts so that critical functions can keep running, or be restored quickly, even in adverse situations.
4. **Contribute to the enterprise's overall security strategy**
Support a cohesive, organization-wide effort to protect critical assets and functions, rather than functioning in isolation.
5. **Act as a backstop to optimize risk management efforts**
Serve as the final safeguard against threats, helping to contain damages and streamline recovery while continuously improving the risk posture of the organization.

Resource Management

Resource management, including time, personnel, budget, underpins the efficiency of any incident management effort. Effective triage is essential here: you deploy limited resources first to contain the incidents posing the greatest risk. This strategic allocation ensures the most critical business functions are protected and operations can resume quickly. *Resource management will be important across a number of response areas, including:*

- **Resource Identification:** First, understand what “resources” mean in an incident:
 - **Time:** How quickly must the incident be addressed to prevent further damage?
 - **Personnel:** Who are your incident responders? What are their skills and availability?
 - **Budget:** Are there funds for overtime, external consultants, or emergency equipment?
- **Triage:** Not all incidents are created equal. You need to quickly assess:
 - **Impact:** How critical are the affected systems or data? What is the potential damage?
 - **Urgency:** How quickly does the incident need to be addressed?
 - **Scope:** How widespread is the incident?
- **Prioritized Allocation:** Based on the triage, allocate resources strategically:
 - **Critical Incidents First:** Focus on the most severe incidents that pose the greatest risk to the business.
 - **Right Skills to the Right Task:** Assign personnel with the appropriate expertise to each incident.
 - **Efficient Resource Use:** Avoid wasting resources on low-priority incidents.
- **Business Continuity:** The goal is to minimize disruption and get critical business functions back online as quickly as possible. This requires:
 - **Focus on Core Systems:** Prioritize the restoration of systems that are essential for business operations.
 - **Communication:** Keep stakeholders informed of the situation and the steps being taken to resolve it.

Analogy: Think of resource management like emergency room triage.

A patient with life-threatening injuries is treated before someone with a minor cut. Similarly, an incident threatening core financial systems, the loss of which is life-threatening to the business, is prioritized over less critical disruptions.

Defining Incident Management Procedures

No universal approach to defining incident management procedures exists. Many organizations adapt established frameworks (e.g., NIST, SANS, CMU SEI) as a starting point or template and customize to create their own tailored procedures. The goal is to *match best practices* with the *enterprise's specific environment and risk profile*.

Plan of Action for Incident Management

Multiple methodologies guide the development of incident management plans and IRPs. ISACA cites one popular approach Carnegie Mellon University Software Engineering Institute (CMU SEI) breaks the incident management process into *five phases*:

1. Prepare (*Prepare/Improve/Sustain*)
2. Protect (*Reputation/Brand/Infrastructure/Data*)
3. Detect (*Events/Incidents/Anomalies*)
4. Triage
5. Respond

Each phase contains specific processes and actions to ensure that incidents are handled efficiently and effectively.

1. Prepare

Objective: Establish and maintain all foundational elements of an incident-handling program.

1. Coordinate Planning and Design

- **Identify requirements:** Determine what the organization needs from an incident management capability.
- **Establish vision and mission:** Define the overall goals and direction for incident handling.
- **Obtain funding and sponsorship:** Secure resources and management support.
- **Develop an implementation plan:** Lay out steps, timelines, and responsibilities.

2. Coordinate Implementation

- **Develop policies, processes, and plans:** Create formal procedures for incident handling.
- **Establish incident-handling criteria:** Clearly define what constitutes an incident and how it should be addressed.
- **Implement defined resources:** Ensure tools, technologies, and personnel are ready.

- **Evaluate incident management capability:** Assess whether existing processes effectively meet the identified requirements.
- **Conduct postmortem reviews:** Use lessons learned from previous incidents to refine procedures.
- **Determine and implement process changes:** Continuously improve and adapt your approach.

2. Protect

Objective: Safeguard the organization's reputation, brand, infrastructure, and data. *Primary objectives include:*

- **Business perspective:** Focus on protecting the brand and reputation.
- **Technology perspective:** Protect and secure critical data and infrastructure when responding to incidents.
- **Ongoing improvements:** Continuously enhance infrastructure and protective measures, guided by postmortem reviews and other feedback mechanisms.

More detailed processes in the Protect phase include:

- **Implementing changes to computing infrastructure** to mitigate current or potential incidents.
- **Incorporating postmortem recommendations** into future protection strategies.
- **Evaluating computing infrastructure** through proactive security assessments.
- **Providing input to the detect process** for timely and accurate threat identification.

3. Detect

Objective: Identify unusual, suspicious, or malicious activities that may disrupt critical business functions.

1. Proactive Detection

- Conduct regular monitoring through tools like vulnerability scanners, SIEM (Security Information and Event Management), DLP (Data Loss Prevention), and third-party alerts.

2. Reactive Detection

- Encourage reports from users, external entities, or partner organizations about observed suspicious behavior.

3. Communication Channels

- Provide multiple ways (phone, email, web-forms, automated alerts) for users and external teams to notify the Incident Management Team (IMT).

4. Triage

Objective: Sort, categorize, and prioritize incoming reports to optimize resource utilization and response effectiveness.

- **Categorization:** Classify all reports/events (e.g., denial of service, malicious code, unauthorized access, phishing) based on predefined criteria.
- **Correlation:** Cross-reference new events with other data sources to uncover patterns or relationships.
- **Prioritization:** Assign urgency levels based on potential impact on business functions, ensuring critical incidents are addressed first.
- **Assignment:** Direct incidents to the most appropriate IMT members or business units according to workload, expertise, and severity.

Triage provides a unified entry point for incident-related communication and ensures the IMT focuses on the right issues at the right time.

5. Respond

Objective: Take concrete steps to address, resolve, or mitigate incidents.

CMU/SEI identifies three types of response activities:

1. Technical Response

- **Collect data for analysis** (e.g., logs, system snapshots).
- **Research technical mitigation/recovery methods** such as patching or reconfigurations.
- **Consult (phone or email) for technical support** or onsite assistance.
- **Analyze logs** and other forensic data.
- **Deploy patches and workarounds** to contain or eliminate threats.

2. Management Response

- Involves supervision or management actions: notification, escalation, approvals, and reporting to business managers or senior executives.
- Ensures that necessary organizational support and resources are provided.

3. Legal Response

- Covers activities around investigation, prosecution, liability, privacy, and regulatory issues.
- May require legal expertise on laws, regulations, and nondisclosure agreements.
- Typically handled by the corporate legal team, especially when formal legal actions are necessary.

Key Takeaways:

A detailed **plan of action** provides a structured methodology for building and running an incident management capability. By systematically **preparing, protecting, detecting, triaging,** and **responding** to incidents, organizations can reduce risks, maintain business continuity, and continually improve their defenses.

Current State of Incident Response Capability

Before enhancing incident response, the information security manager should assess what is already in place. *Common assessment techniques include:*

- **Surveys of senior leaders, business managers, and IT** to measure past performance and perceptions.
- **Self-assessments** comparing existing capabilities against known best practices (easy but possibly limited).
- **External audits/assessments** providing a more thorough evaluation of strengths, weaknesses, and improvement areas.
- **History of Incidents:** Reviewing past incidents (internal and external) can highlight trends, common weaknesses, and impacts. All can be valuable for refining the IRP.



Infrequent but catastrophic threats (e.g., large-scale earthquakes) might be addressed through specialized insurance or advanced DR planning.

Incident Response Life Cycle

ISACA references a commonly accepted incident response lifecycle includes six phases. These steps roughly align to the process outlined in [NIST Special Publication 800-61, “Computer Security Incident Handling Guide”](#):

1. Preparation

- Develop an incident response plan, obtain management endorsement, and create training materials.
- Establish necessary tools and communication channels.

2. Identification

- Recognize potential incidents (e.g., user reports, automated alerts).
- Verify and prioritize them by severity and potential business impact.

3. Containment

- Limit further damage (e.g., isolate compromised networks, disable accounts).
- Work with relevant teams, preserve evidence, document actions, and manage stakeholder communications.

4. Eradication

- Find and remove the root cause (e.g., patch systems, remove malware).
- Strengthen defenses, apply lessons from vulnerability analysis.

5. Recovery

- Restore systems to normal or near-normal operation in line with RTO and RPO.
- Validate that restored systems are secure and stable.

6. Lessons Learned

- Post-incident, document what transpired, how it was handled, and improvements for the future.
- Incorporate feedback into refining the IRP.



Your objective for the exam is to understand the logical flow of activities regardless of the framework.

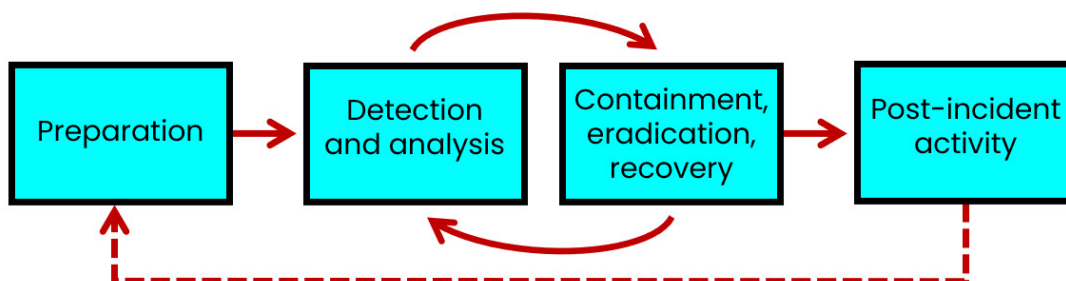


Figure 7.1. NIST SP 800-61 Incident Response Process

Gap Analysis

Performing a gap analysis compares the **current** versus **desired** incident response capability. *This exercise clarifies:*

- Which processes need improvement for efficiency and effectiveness.
- Any technology or skills required to meet response goals.
- What steps to prioritize, based on impact and cost-benefit considerations.

The findings of a gap analysis can provide direction on development or update of the incident response plan.

Logistics

Incident management plans should cover the logistics of continuing operations. This includes:

- Having **detailed, accessible, hard-copy procedures** in case electronic systems are down or staff is unavailable.
- Securing essential business forms and software offsite to enable alternate work locations if needed.
- Ensuring key **hardware and software dependencies** are documented, including backup availability.

Incident Management and Response Teams

Clear roles and responsibilities for each of these teams must be defined **before** an incident happens. The composition may vary by organization size and incident magnitude. Common teams include:

- **Emergency Action Team:** Manages immediate threats (e.g., fire, evacuation).
- **Damage Assessment Team:** Determines extent of damage and what can be salvaged.
- **Emergency Management Team:** Coordinates recovery teams and major decisions.
- **Relocation Team:** Handles moves to alternate sites.
- **Security Team or CSIRT:** Oversees security aspects, containment, and forensics.

Teams should have clarity on decisions such as service priorities, required staffing, and the location of alternate facilities. Together, these components ensure a smooth incident response, with minimal delays and confusion.

Organizing, Training, and Equipping the Response Staff

Training is critical for an effective incident response. The information security manager should:

- **Conduct scenario-based exercises** to test response steps.
- **Confirm resource adequacy** including tools, documentation, staff availability.
- **Mentor new IMT members** on processes, roles, responsibilities, and corporate standards.
- **Use on-the-job training** for continuous improvement in policies, standards, and tools.
- **Schedule formal training** when necessary for team members to achieve certifications or competencies relevant to their role.

Incident Notification Process

Timely notification is vital for reducing damage from security incidents. An effective approach should include **automated alerts** (email, SMS, etc.) and well-documented **escalation paths** help relevant stakeholders (e.g., application development, business process owners, cybersecurity, HR, legal, privacy, PR, senior management) respond quickly.

The information security manager should define and communicate notification responsibilities to the appropriate personnel and, if possible, work with HR to formalize these responsibilities within job descriptions or performance objectives.

Challenges in Developing an Incident Management Plan

Developing an incident management plan comes with challenges the information security manager should anticipate and address proactively. *Some common obstacles include:*

- **Lack of management buy-in:** Without senior leadership support, resources may be limited, and responses may be slow or inconsistent.
- **Misalignment with organizational goals:** Rapid organizational change can outpace updates to incident plans, leaving new or expanding areas unprotected.
- **IMT member turnover:** Losing key champions can stall plan development and maintenance.
- **Ineffective communication:** Either too little communication (leading to confusion), too much (leading to stakeholder fatigue), or failure to tailor the level of communication to the audience.
- **Overly complex plans:** If a plan is too broad or complicated, stakeholders might not commit to it fully.

Any of these can derail the project effort. Building contingencies from the start can ensure the project stays on track in spite of unavoidable difficulties.

4A2. Business Impact Analysis (BIA)

A **Business Impact Analysis** determines the effect on an organization's operations if critical processes or resources become unavailable or compromised. It serves as a foundation for risk management, business continuity (BC), and disaster recovery (DR) efforts, revealing how quickly a loss event escalates, the resources needed to recover, and the overall operational impact.

To provide a well-rounded assessment, a BIA must consider how disruptions could affect each dimension of information security: confidentiality, integrity, and availability.

1. Loss of Confidentiality

- **Definition:** Unauthorized or accidental disclosure of sensitive information.
- **Impact:** May lead to a loss of public confidence, legal repercussions, regulatory fines, and reputational damage.

2. Loss of Integrity

- **Definition:** Unauthorized or erroneous changes to data or IT systems, compromising accuracy and trustworthiness.
- **Impact:** Data corruption, fraud, and potentially broader security breaches that can undermine system availability or confidentiality.

3. Loss of Availability

- **Definition:** A critical system or process is out of service, blocking users from performing essential functions.
- **Impact:** Productivity disruptions, lost revenue opportunities, service failures, and reduced customer satisfaction.

The Three Primary Goals of a BIA

A BIA also focuses on three overarching objectives, which guide organizations in prioritizing tasks and resources during incidents.

1. Criticality Prioritization

- **Purpose:** Identify and rank critical business functions or units based on potential impacts if disrupted.
- **Benefit:** Ensures resources and recovery efforts target the most consequential processes first.

2. Downtime Estimation

- **Purpose:** Determine maximum tolerable downtime (MTD) or maximum tolerable outage (MTO) for each process or system.
- **Benefit:** Helps define the acceptable interruption window (AIW) and sets boundaries for how long a function can be non-operational.

3. Resource Requirement

- **Purpose:** Identify the personnel, technology, facilities, and other resources essential for restoration.
- **Benefit:** Clarifies the full scope of what is needed to achieve recovery objectives and maintain operations.

Key Considerations in a BIA

- **Scenario Analysis:** Avoid an overreliance on worst-case scenarios; consider a balanced range of likely and less likely outcomes.
- **Escalation of Loss:** Understand how losses accumulate over time if a function is disrupted, guiding realistic recovery time objectives (RTOs) and recovery point objectives (RPOs).
- **Tangible vs. Intangible Impacts:** Distinguish between measurable impacts (e.g., revenue) and those better evaluated qualitatively (e.g., reputation).
- **Alignment with Other Risk Assessments:** Ensure BIA findings can be compared with other business risk analyses, such as marketing or investment risks, for cohesive decision-making.



A common pitfall is focusing solely on worst-case outcomes, which can inflate perceived risks. Instead, a more effective approach is to analyze a manageable set of realistic scenarios with a broader group of key stakeholders.

Elements of a Business Impact Analysis

Although organizations may conduct BIAs differently, certain core steps and considerations are common to most approaches. In essence, a BIA aims to:

1. Identify Business Functions

- Clearly define each major function or process within the organization.

2. Characterize Function Activities

- Determine the tasks and activities that make up each function.

3. Determine Dependencies

- Identify both internal and external inputs required for the function to operate (e.g., resources, other processes).

4. Sequence Critical Operations

- Document the order in which these tasks or processes must occur and how they interrelate.

5. Establish Critical Timeframes

- Estimate how long each function can be offline before it causes significant harm (Recovery Time Objectives, or RTOs).

6. Define Resource and Activity Requirements

- Pinpoint what is needed—personnel, equipment, facilities—to restore each function to normal operations.

7. Determine Manual Workarounds and Recovery Point Objectives (RPOs)

- Outline the temporary procedures that can be used if systems are unavailable and identify how much data or transaction loss can be tolerated.

8. Assess Maximum Acceptable Downtime

- Decide the longest period the function can remain unavailable before the business suffers irreversible consequences.

9. Analyze Upstream and Downstream Impacts

- Recognize how a disruption in one function could affect other areas of the business.

10. Compile Findings for Business Continuity Planning

- Summarize all critical details in a way that informs the overall Business Continuity Plan (BCP).

Typical BIA Information Collected

By capturing these elements and information points, a BIA clarifies how critical each business function is, identifies the consequences of disruption, and sets priorities for recovery and continuity efforts.

1. Business Function Description

- Define the function's purpose and objectives.
- Clarify how it supports the organization and interacts with other processes.

2. Dependencies

- Identify all internal and external resources (e.g., other processes, services, or vendors) required to keep the function running.

3. Work Backlog

- Determine when and how tasks will accumulate if the function is disrupted.
- Assess how quickly this backlog could harm operations.

4. Technology and Resource Requirements

- List the software, hardware (e.g., servers, standalone PCs, workstations), and network dependencies (e.g., LAN, cloud) that the function relies on.
- Note how many servers or devices are needed.

5. Financial and Operational Impacts

- Establish when financial losses or operational disruptions become significant if the function is not performed.
- Consider both short-term and long-term consequences.

6. Restoration Procedures

- Outline how quickly and to what extent you can restore the function at an alternate site if the primary location is unavailable.
- Include details on partial or phased restorations.

7. Manual Workarounds

- Identify whether the function can be performed manually if IT systems are down.
- Determine feasibility, duration, and effectiveness of these workarounds.

8. Remote Work/From Home

- Assess whether the function can be performed remotely in the event of a site-specific disruption.
- Note any technological or security considerations.

9. Workload Considerations

- Examine potential shifts in workloads or tasks during disruptions.
- Determine how these shifts affect business operations and recovery priorities.

10. Critical Resources

- Highlight the essential people, equipment, and processes that must be available for the function to continue.
- Identify what happens if these resources become unavailable.

11. Creativity and Alternate Solutions

- Explore whether alternative methods or new solutions can substitute for unavailable resources.
- Determine the viability and speed of implementing these alternatives.

12. Business Disruption Sequence

- Document the order in which tasks must resume after a disruption.
- Clarify timelines and dependencies for each step to ensure smooth recovery.

13. Competitive Analysis

- Assess how quickly competitors might gain an advantage if the function remains offline.
- Factor in market share, customer loyalty, and overall reputation.

14. Impact on Customers

- Determine at what point the disruption significantly affects customer experience or satisfaction.
- Evaluate potential loss of customers and long-term brand damage.

Benefits of Conducting a Business Impact Analysis

Performing a thorough BIA delivers several major benefits to IT and business units, including:

1. **Increased Understanding of Potential Losses**

The organization gains clearer insight into the scale of losses—financial and otherwise—that could arise from specific disruption scenarios.

2. **Prioritized Restoration Activities**

By knowing the criticality of each function, teams can focus on restoring the most vital processes first, optimizing resources and reducing downtime.

3. **Dependency Visibility**

Documenting and analyzing interdependencies among functions ensures no critical upstream or downstream relationships are overlooked during recovery planning.

4. **Improved Awareness for Response Management**

The BIA process fosters a broader organizational understanding of disruption impacts and recovery strategies, leading to more coordinated incident management.

In essence, the BIA guides both strategic and tactical decisions by pinpointing where risks are most severe, how best to mitigate them, and how to allocate recovery resources effectively.

4A3. Business Continuity Plan (BCP)

Disruptions to business operations are inevitable. A **Business Continuity Plan (BCP)** outlines how an enterprise will continue delivering services or products—possibly at a reduced capacity—during unexpected interruptions. The core objective is to minimize overall impact, protect critical processes, and define roles and responsibilities. *A comprehensive plan considers:*

- **Key Processes and Personnel** – Identifies which processes and employees are essential to keep the business running.
- **Information and Technology Assets** – Ensures access to necessary systems, data, and infrastructure.
- **Third-Party Dependencies** – Accounts for vendors or partners whose unavailability could disrupt operations.

Integrating Incident Response with Business Continuity

Business continuity planning must be integrated with both incident response (IR) procedures and disaster recovery (DR) strategies. Although IR focuses on managing and mitigating the immediate effects of a security or system incident, and DR focuses on restoring IT services after a major disruption, all three processes overlap. *Key elements include:*

- **RTO and RPO Alignment** – Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) set targets for how quickly systems must be restored and how much data loss is acceptable. Both affect how incidents are handled and how continuity is maintained.
- **Consistent Planning** – Plans for IR, BCP, and DR should be coordinated so that declaring a disaster and moving operations to backup facilities or alternate sites happens seamlessly.
- **Incident Classification** – Not every disruption is necessarily a “security incident,” but any event requiring a major operational response might trigger aspects of the BCP or DR plan.

Methods for Providing Continuity of Network Services

A critical piece of business continuity involves ensuring continuous network connectivity.

Common approaches include:

1. Redundancy

- Provisioning extra capacity and backup components (e.g., additional cable paths) so if a primary connection fails, a secondary one takes over.
- Multiple paths between routers or data centers.

2. Diverse Routing

- Using alternate physical or logical routes that are not subject to the same outages.
- Avoids a single point of failure in network infrastructure.

3. Alternate Routing

- Having different or backup network carriers/routes that can be switched automatically if the primary route fails.

4. Last-Mile Protection

- Protecting the final leg of network connectivity into a facility.
- Often requires dual entrances or physically separated pathways from service providers.

Overall, the goal is to prevent a single failure from causing an extended network outage.

High-Availability Considerations

High availability ensures that critical systems and services remain accessible with minimal downtime. Key elements include:

- **Redundant Hardware/Software** – Clustering servers, using load balancers, or replicating data across multiple locations.

- **Rapid Failover** – Automated switchover to backup systems when primary systems fail.
- **Geographical Distribution** – Locating infrastructure in different regions to mitigate local disasters or major outages.
- **Network Reliability** – Ensuring that network devices (switches, routers) and connections have redundant paths and failover capabilities.

By incorporating these techniques, an enterprise reduces the likelihood and impact of system failures.

Foundational Terms, Concepts, and Examples

Here are relevant terms and concepts that surface in BCP discussions:

High availability aims to avoid single points of failure and ensure minimal downtime (e.g., RAID, clustering, virtualization).

Single Point of Failure (SPOF): A SPOF is any component that, if it fails, will cause the entire system to fail. Identifying and eliminating SPOFs is crucial for improving availability.

Example: A company has a single database server. If that server crashes, the entire application and all related services become unavailable.

System Resilience: This refers to a system's ability to maintain acceptable performance levels during and after disruptions. It involves designing systems to adapt to changing conditions and recover quickly from failures.

Examples:

- A network that automatically reroutes traffic around failed links.
- A cloud service provider distributes its data across multiple data centers in different geographic locations.

High Availability: This refers to a system's ability to continuously operate without experiencing significant downtime. It's achieved through redundancy and fault tolerance, ensuring that if one component fails, another can take over seamlessly. This often involves redundancy and rapid failover mechanisms.

Example: A website uses a load balancer to distribute traffic across multiple web servers.

Fault Tolerance: A fault-tolerant system continues to operate correctly even when one or more of its components fail. This typically involves redundancy and the ability to detect and isolate faults.

Example: RAID (Redundant Array of Independent Disks) storage systems: If one hard drive fails, the data can be reconstructed from the remaining drives.

A few examples of technologies that protect availability include:

Server Redundancy is achieved primarily through clustering or load balancing.

- **Clustering:** Multiple servers work together as a single system. Clustering is a strategy commonly used with database servers.
- **Load Balancing:** Distributes workloads across multiple servers. Load balancing is commonly used with web servers (HTTPS) but generally support other protocols. Load balancing is covered in depth in “4.1.10 Logical Segmentation”.

Network Redundancy involves creating alternate paths for network traffic, often using redundant switches, routers, and connections. Two sources of internet connectivity for a facility, entering the site at opposite ends of the facility, will reduce odds that both are impacted by a single event.

Power Redundancy includes using uninterruptible power supplies (UPS) and backup generators to ensure continuous power supply. Power redundancy at the facility level, as well as in servers and network devices, is important in eliminating single points of failure.

Hardware/Software Failure Management involves implementing monitoring systems, predictive maintenance, and rapid replacement procedures. Automated recovery (systems designed to self-heal or failover automatically) is generally preferable to manual recovery (human intervention to restore systems).

Insurance

The Incident Response Plan (IRP) should detail the enterprise’s insurance coverage as part of overall risk management. Insurance helps reduce the financial impact of interruptions or security incidents. Important points include:

- **General vs. Specialized Coverage**

- **Business Interruption Policies** – May reimburse lost profits due to outages.
- **Multi-Peril Policies** – Often required for IT operations, combining multiple coverage types.
- **Exclusions and Deductibles**
 - Typically, an organization cannot insure against legal or regulatory noncompliance.
 - Careful review is needed to understand what is and is not covered.
- **Types of Coverage**
 1. **IT Equipment and Facilities** – Covers physical damage or loss to the information processing facility and owned/leased equipment.
 2. **Media (Software) Reconstruction** – Covers costs to restore or replace damaged software, data media, and associated reproduction expenses.
 3. **Cybersecurity** – Covers damages from cyberattacks (e.g., ransomware, DDoS).
 4. **Professional and Commercial Liability** – Protects against claims from clients or third parties arising from the organization's actions or omissions.
 5. **Extra Expense** – Reimburses added costs of maintaining operations after a damaging event (e.g., renting backup facilities).
 6. **Business Interruption** – Covers lost profits due to disruptions caused by covered incidents.
 7. **Valuable Papers and Records** – Insures against physical loss or unauthorized disclosure of important documents.
 8. **Errors and Omissions** – Provides liability protection for professional mistakes or negligence.
 9. **Fidelity Coverage** – Protects against losses caused by dishonest acts of employees (e.g., fraud or embezzlement).
 10. **Media Transportation** – Covers data or media in transit to off-site facilities.

Careful evaluation of insurance policies helps ensure the enterprise understands its actual protections—and gaps *before* an incident occurs.

Cyber Insurance

Cyber insurance can play a critical role in an organization's overall security strategy. It is a common way to *transfer* risks that are rare, expensive, and high impact. However, simply having a policy is not enough; it is equally important to understand **why** it was purchased and **what** it actually covers.

Reasons an organization might purchase cyber insurance?

1. **Compliance:** Some organizations buy cyber insurance to meet legal, regulatory, or industry-standard requirements.

2. **Customer Requirements:** A key client or partner may mandate cyber insurance as part of doing business.
3. **Prior Incidents:** A past costly breach—or knowledge of a breach at a similar organization—often prompts the purchase of insurance to mitigate future financial loss.
4. **Risk Treatment:** Cyber risks that are identified but not accepted or mitigated in other ways might be transferred to an insurance provider.

Importance of Understanding Policy Terms

Even when the benefit amounts in a policy look attractive, **terms and conditions** are paramount. Organizations sometimes discover too late that their policy offers **little or no relief** due to exclusions or unmet requirements.

- Cyber-insurance policies **vary significantly**.
- Many policies require specific policies, controls, and security capabilities to be in place.
- Organizations that already have robust security controls are often at lower risk of major incidents—supporting the overall goal of reducing cybersecurity threats.

This mirrors other types of insurance—such as auto, homeowners, or renters—where it's crucial to **read the policy thoroughly** and understand exactly what is covered.

Key Coverage Considerations

When reviewing a cyber-insurance policy, it's essential to clarify the following:

1. **Ransomware:** Under what conditions will the policy pay a ransom?
2. **Third-Party Breaches:** Will the policy cover losses resulting from a breach at a service provider or partner?
3. **Proactive Support:** Does the insurer offer (or require) security assessments or assistance **before** an incident occurs?
4. **Incident Reporting and Assistance:** What notification is required to receive support? Does the insurer manage some aspects of the incident, or is the insured organization in control?

Meeting Insurance Requirements

Insurance carriers proactively identify risk factors for breaches. As a result, policies often **require** organizations to implement safeguards that reduce the likelihood or severity of incidents.

Security leaders should:

- **Review policy requirements** to ensure compliance.
- Confirm that all **controls and processes** are in place to maintain coverage validity.
- Understand that **effective security measures** help avoid serious incidents in the first place—supporting both the **insurance** and **overall risk management** objectives.

By thoroughly understanding **why** your organization has cyber insurance, what it **covers**, and the **conditions** under which it applies, you can ensure that the policy effectively supports your broader cybersecurity strategy.

Exam Tips:

- **Risk Transfer, Not Elimination:** Insurance covers losses but doesn't reduce the **likelihood** of incidents.
- **Link to Risk Strategy:** Insurance is often combined with other treatments (avoid, reduce, accept, transfer).

4A4. Disaster Recovery Plan (DRP)

Disaster recovery (DR) focuses on restoring IT systems and services after events such as system failures, security incidents, or natural disasters. It is part of a broader **business recovery** effort, which aims to resume *all* critical operations and processes as quickly as possible. The phases in the DR process will vary across standards, frameworks, and technical exams.

The phases of the DR process cited by ISACA are:

1. Conducting a risk assessment and business impact analysis (BIA)
2. Defining a response and recovery strategy
3. Documenting DR and business recovery plans
4. Training teams in these procedures
5. Updating and testing the plans regularly
6. Auditing the plans to ensure they remain appropriate and effective

Environmental issues, such as natural disasters (e.g., earthquakes, floods) and man-made threats (e.g., explosions, chemical spills), can significantly impact site and facility security.

Man-made disasters	Natural disasters
Explosions	Earthquakes
Electrical fires	Floods
Terrorist acts	Storms
Power outages	Tsunamis
Other utility failures	Volcanic eruptions

Figure 7.2. Types of Disasters

Business Continuity and Disaster Recovery Procedures

Business continuity (BC) is the overarching approach to preventing, mitigating, and recovering from disruptions; DR is a subset of BC that specifically addresses restoring operations after a disaster. When designing response and recovery procedures, organizations should consider:

- Available resources
- Expected services and service levels
- Types and severity of threats
- Monitoring and detection capabilities
- Overall risk appetite

Because DR focuses on reestablishing operations after a disaster has already occurred, it works hand in hand with BC, which provides continuous prevention and mitigation strategies.

Recovery Operations

Once a temporary or alternate DR site is operational, the BC team monitors the progress of restoring the primary site. They also conduct tests to determine if it is safe to switch back.

- **Returning to the primary site:** The same team that set up the DR site will coordinate and test the main data center. After confirming it can operate normally, they transition operations back.
- **If the primary site is destroyed:** The organization may move to a permanent alternate site or rebuild the original site, depending on long-term viability and cost considerations.
- **Security considerations:** Even during the chaos of a disaster, information security must remain in force to protect systems and data.

Evaluating Recovery Strategies

Organizations must choose a recovery approach that meets acceptable recovery times without imposing excessive costs or risks. Key factors include:

- The cost of preparing for disruptions (hardware, backup sites, training, etc.)
- The cost of activating these plans (e.g., relocating staff, restoring data)
- Potential insurance coverage (e.g., business interruption insurance)
- Trade-offs among capabilities, risk, and budget

A thorough analysis compares multiple strategies so management can make an informed decision that balances speed of recovery with overall cost and complexity.

Addressing Threats

Proactive measures to handle threats include:

1. **Elimination or neutralization:** Where feasible, remove the cause of the threat (e.g., disabling a risky service).
2. **Minimizing likelihood:** Implement safeguards (e.g., firewalls, intrusion detection, strong authentication) to reduce the chance of an incident.
3. **Minimizing impact:** If an incident does occur, minimize harm through effective incident response, redundant systems (automatic failover), insurance, and other compensating controls.

Every critical system needs its own plan for rapid restoration if disrupted.

Recovery site strategies

The need for alternate processing sites will surface in BCP development. However, the Focus of the site is to get infrastructure and other technology online to support the business, which is why it fits into the DRP. Recovery site strategies involve establishing alternate locations for processing and recovering critical systems and data in the event of a primary site failure. Important considerations of recovery site strategies include:

Choosing a recovery site involves many factors, including:

- **Business needs:** What are the critical systems and data that need to be recovered?
- **RTO/RPO:** How quickly do operations need to be restored, and how much data loss is acceptable?
- **Risk profile:** What are the most likely threats to the organization?
- **Budget:** What are the financial constraints?

- **Location:** Geographic separation is crucial to avoid a single event impacting both primary and recovery sites.

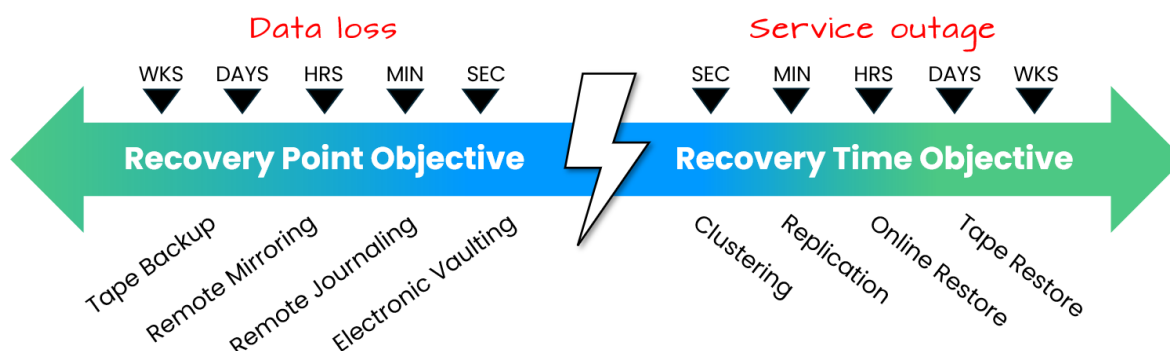


Figure 7.3. RPO/RTO and Recovery Methods

Key Considerations:

- **Compliance Constraints:** Laws or regulations may dictate where data can be stored and processed, influencing site selection.
- **Match Site Type to RTO:** A short RTO demands a hot site. Longer RTOs may allow for warm or cold sites.
- **Budget vs. Operational Need:** Be ready to analyze the trade-offs between cost and recovery speed when selecting a site type.

Exam Tip: The exam might present scenarios with specific constraints (budget, location, RTO) and ask you to choose the most appropriate site type.

Addressing Threats: Your disaster recovery plan must address various disaster scenarios, including:

- **Natural disasters:** Fires, floods, earthquakes, etc.
- **Cyber-attacks:** Ransomware, DDoS attacks, data breaches.
- **Hardware/software failures:** Server crashes, storage failures, application bugs.

Types of recovery sites

There are multiple types of recovery sites organizations can opt for based on their business needs and budget. These are the sites cited by ISACA:

- **Cold Site.** A “recovery” cold site is essentially just data center space, power, and network connectivity that’s ready and waiting for whenever you might need it. It’s essentially a standby facility with no preinstalled hardware or software.

TO RECOVER: If disaster strikes, your engineering and logistical support teams can readily help you move your hardware into the data center and get you back up and running.

- **Warm Site.** A “preventative” warm site allows you to pre-install your hardware and pre-configure your bandwidth needs.

TO RECOVER: If disaster strikes, all you have to do is load your software and data to restore your business systems.

- **Hot Site.** A “proactive” hot site allows you to keep servers and a live backup site up and running in the event of a disaster. You replicate your production environment in that data center.

TO RECOVER: This allows for an immediate cutover in case of disaster at your primary site. A hot site is a must for mission critical sites.

There are a number of ways these sites can be implemented:

- **Mobile sites** are alternatives to traditional recovery sites. They typically consist of self-contained trailers or other easily relocated units.
- **Mirror sites** is a specific type of duplicate site that is very similar or identical to the primary site and operates in real-time alongside it. They often work on a “load-sharing” basis, distributing workloads between the primary and mirror sites.
- **Duplicate sites** are recovery sites that are designed to be functionally similar or identical to the primary site. They can range from a standby “hot site” (fully operational and ready to go) to facilities available through a reciprocal agreement with another company.

- **Disaster Recovery as a Service (DRaaS)** is public cloud computing service that enables the full recovery of a system or data from disruptions at an on-premises infrastructure by replicating and restoring it within a cloud environment. Because of the clouds geographic distribution, it'll eliminate some of the traditional concerns, such as the backup site being impacted by the same disaster as the primary site.
- **Mutual assistance agreements (MAAs)**, sometimes called *reciprocal agreements*, provide an inexpensive alternative to disaster recovery sites. MAAs pose a risk to organizations participating, as multiple organizations may also be shut down by the same disaster. MAAs raise confidentiality concerns. They are also considered difficult to enforce. *For all these reasons, MAA's are relatively uncommon.*



For organizations adopting the public cloud, a **recovery site** for mission-critical services is an option. This will generally look much like a warm site or hot site, but without capital expense of hardware, just the operational expense of cloud consumption capacity and features.

Finally, any chosen solution must account for:

- **Ongoing resource availability** (e.g., bandwidth, staffing)
- **Hardware/software compatibility**
- **Regular testing** to confirm readiness
- **Geographic considerations** (avoid placing the backup site in the same disaster zone)
- **Third-party/contractual** provisions for support, service level agreements (SLAs), and security

By weighing cost, recovery speed, and the enterprise's tolerance for downtime, management can select the most appropriate offsite strategy and ensure effective disaster recovery.

Exam Tips:

- **Risk vs. Cost Analysis:** Be prepared to justify your recovery strategy choice based on a cost-benefit analysis and risk assessment. *For example, a hot site is expensive but offers the fastest recovery.*
- **SLAs in Recovery:** Understand the importance of Service Level Agreements (SLAs) with recovery providers, especially regarding Recovery Time Objective (RTO) and Recovery Point Objective (RPO).

Basis for Recovery Site Selections

Choosing the right recovery site (hot, warm, cold, or third-party) depends on several factors:

- **AIW (Acceptable Interruption Window):** How long business processes can be down before it becomes unacceptable.
- **RTO (Recovery Time Objective):** How quickly systems must be restored after an outage.
- **RPO (Recovery Point Objective):** The acceptable amount of data loss (how “old” restored data can be).
- **SDO (Service Delivery Objective):** The minimum level of services that must keep running until normal operations resume.
- **MTD (Maximum Tolerable Downtime):** The total time the enterprise can survive in alternate-mode operations.

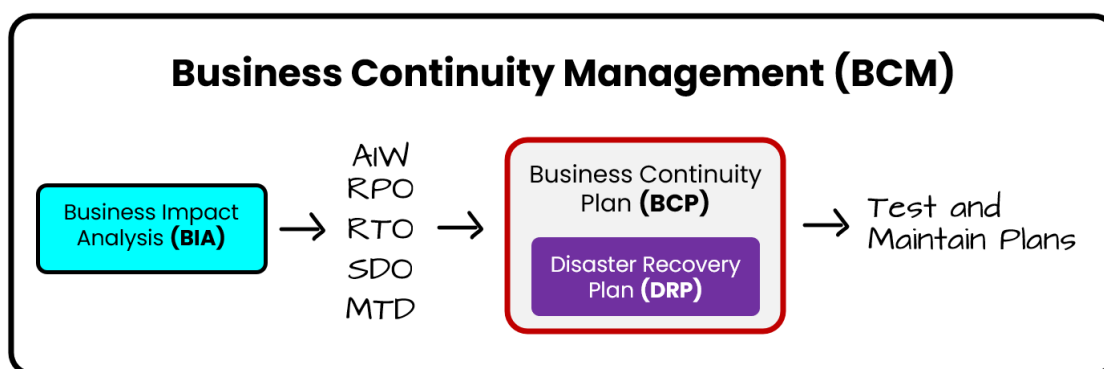


Figure 7.4. Relationship between BCM, BIA, BCP, and DRP

Additional considerations:

- **Proximity :** Distance from hazards (e.g., flood zones, hazardous materials facilities) that could disrupt a recovery site.
- **Geographic Location:** Sites should be sufficiently distant to avoid a single environmental event affecting both the primary and recovery facilities (e.g., hurricanes, earthquakes).
- **Probable Disruption Types:** Likely events in a region (earthquakes, tornados, etc.) determine how far apart sites must be and how resilient they should be.

Finally, cost and complexity rise as RTO and AIW get shorter:

- A very tight (short) interruption window often requires an expensive “hot” or mirrored site to resume operations quickly.
- A longer interruption window could allow for a less costly “cold” site, albeit with slower recovery.

Response and Recovery Strategy Implementation

A comprehensive recovery plan should be developed in clear, straightforward language. *It must address:*

- **Pre-incident readiness** (including preventive measures and resource staging)
- **Evacuation procedures** (protecting human safety)
- **Disaster declaration** guidelines
- **Transition to DR** if initial incident response fails
- **Critical business processes and IT resources** to be recovered
- **Decision authority** and roles/responsibilities
- **Contact information** for key personnel
- **Recovery options** (step by step)
- **Required resources** (technical, logistical, personnel)
- **Additional logistics** such as relocation, temporary housing, and team coordination

Copies of the plan should be kept offsite (e.g., the recovery site, media storage locations, and key decision-makers' homes) to ensure it is available in any emergency. The plan also often includes assigning specialized teams to handle system, application, network, and user recovery tasks.

Backup storage strategies

While you won't be tested directly on these technologies, ISACA assumes that you are familiar with some of these technologies for application in solving DR challenges. Backup storage strategies involve creating and maintaining copies of critical data and systems to enable recovery in case of loss or corruption.

Key considerations for backup storage strategies include:

- **Scope and requirements.** Identifying critical data and systems that require backup protection, which will influence the backup solutions selected.
- **Backup methodology.** Selecting appropriate backup methods (e.g., full, incremental, differential) based on recovery time objectives (RTO) and recovery point objectives (RPO).
- **Storage media.** Implementing secure and redundant backup storage solutions (e.g., disk, tape, cloud).
- **Periodic testing.** Testing backup integrity and recoverability regularly to ensure effectiveness.
- **Security.** Encrypting backup data to protect against unauthorized access or disclosure.

The following solutions are more common with *database workloads*:

Electronic vaulting is a backup strategy that automatically transfers data in bulk to an offsite storage facility over a network connection, typically used for critical data that needs frequent backups and provides quick recovery in case of data loss. *Due to the quantity of data, data may not be immediately available for recovery.*

Remote journaling continuously records changes made to data in real-time and transmits these changes to a remote backup site, allowing for point-in-time recovery and maintaining an up-to-date copy of data offsite.

Remote mirroring creates an exact copy of data at a remote location, either synchronously (in real-time) or asynchronously (with a slight delay), providing a fully functional duplicate of the primary system ideal for disaster recovery and high availability needs.

There are three fundamental backup strategies you should be familiar with, just in case they appear in a question on the exam - *full, incremental, and differential*.

1. Full Backup:

- A full backup copies all selected files and data from your system.
- **Frequency:** Typically done less frequently due to size and time.
- **Restore:** Restoring data requires only the most recent full backup.

2. Incremental Backup:

- Backs up only the data that has changed since the last backup, whether it was a full or another incremental backup.
- **Frequency:** Can be done more frequently because it's smaller in size.
- **Restore:** Requires the most recent full backup plus all subsequent incremental backups to restore data fully.

3. Differential Backup:

- Backs up all data that has changed since the last **full** backup.
- **Frequency:** More frequent than full but less than incremental in terms of data size growth.
- **Restore:** Needs only the most recent full backup and the latest differential backup to restore data, simplifying the restore process compared to incremental.



A note on backup media: Traditional tape media, which is sequential access and the slowest form of restore, has largely been replaced by disk-to-disk backups or cloud-based backup repositories.

4A5. Incident Classification/Categorization

Incident management often involves two related but distinct processes, categorization and **classification**, which serve different purposes in handling incidents:

Incident Categorization

- **Purpose:** This is about grouping incidents into predefined categories (and often sub-categories) based on their nature.
- **Focus:** It focuses on identifying the type of incident (e.g., network outage, software bug, hardware failure) to aid in routing the incident to the correct support team, enable accurate reporting, and support trend analysis.
- **Outcome:** A clear, standardized taxonomy that helps organizations understand *what kinds of incidents are occurring* and where to focus improvement efforts.

Incident Classification

- **Purpose:** This process involves assessing the incident's severity, impact, and urgency.
- **Focus:** It determines how the incident should be prioritized—often assigning it a priority level (such as Critical, High, Medium, or Low). This helps dictate the speed of response and escalation paths.
- **Outcome:** A clear priority that guides the resolution process and resource allocation, ensuring that incidents impacting the business most significantly are addressed first.

In short:

- **Categorization** is about identifying the type or nature of the incident for efficient handling and analysis
- **Classification** is about determining its priority based on business impact and urgency.

Escalation Process for Effective Incident Management

The incident escalation process defines *when*, *how*, and *to whom* to report security incidents, ensuring timely and appropriate responses. It bridges the gap between incident detection and full-scale incident response/disaster recovery.

1. Establishing an Escalation Process:

- The information security manager and senior management should define, in clear terms, the events that require escalation (e.g., telecom failures might be signs of a security breach).
- Even what appears routine, such as data corruption, could be a security event (like a virus).

2. Documenting Who Authorizes Actions:

- Clearly outline who must approve various recovery steps or a disaster declaration.
- Define responsibilities, backup personnel, and time estimates for each action in the escalation chain.

3. Executing the Escalation Steps:

- Each incident has an ordered list of actions with designated personnel.
- If a particular action fails or misses the time window, escalate to the next step without delay.

4. Alert Conditions:

- As time passes without resolution, the incident's severity may escalate from low to medium to high.
- This triggers notifications to specific groups or individuals who have authority to make decisions.

5. Notification Recipients:

- Potential recipients of alerts include backup facilities, business partners, customers, legal counsel, HR, public relations, and senior management, among others.
- The list should be predefined but flexible enough to add or remove stakeholders as the situation demands.

6. Ending the Emergency Phase:

- Once the incident is under control or resolved, the emergency team reviews damage, mitigation options, and decides if a disaster should be declared or if normal operations can resume.
- A communication plan must be in place to coordinate public relations, legal considerations, and senior management approvals.

7. Post-Escalation Tasks:

- These may involve activating backup sites, isolating threats, recovering data, arranging transport, and testing systems.
- The total response time should align with the organization's Recovery Time Objective (RTO).

8. Communication Methods:

- The organization should have various channels (email, phone, text, fax, websites, etc.) ready for incident notification.
- Because some methods (like email) may not be encrypted, the information security manager should implement safeguards (e.g., encryption) to protect sensitive updates.

Help/Service Desk Processes for Identifying Security Incidents

The service desk is often the front line for detecting anomalous user reports or system alerts.

1. First Point of Contact:

- Help/service desks often receive the earliest reports of potential security issues (e.g., user calls about system anomalies).
- They must be able to distinguish normal IT requests from possible security threats.

2. Defined Criteria and Training:

- The security manager should provide clear guidelines so that help desk staff can quickly spot red flags that signal a security incident.
- Proper training also helps prevent social engineering attacks—for example, someone impersonating a locked-out user who needs urgent access.

3. Prompt Escalation and Reporting:

- If help desk personnel suspect an incident, they should immediately escalate to the appropriate security or incident response team.
- Knowing correct procedures and escalation paths helps contain damage quickly.

By planning incident classification in advance, establishing a clear escalation process, and training frontline help/service desk staff, organizations can respond more effectively and minimize the impact of security events.

4A6. Incident Management Training, Testing, and Evaluation

Incident management training, testing, and evaluation ensure that the organization's incident response plan is effective and that personnel are prepared to handle security incidents.

Defining roles and responsibilities is part of the planning process. This clearly defines **who does what** during an incident (e.g., incident manager, forensic lead, communications officer).

1. Training

- All relevant personnel (including IT, help desk, and management) must be trained to recognize, report, and handle potential security incidents.
- Training should address the entire incident life cycle, from initial detection through resolution and recovery.

2. Testing

- Exercises (e.g., tabletop simulations, functional drills, or full-scale tests) confirm that incident response plans work as intended.

- Tests also verify that roles and responsibilities are well understood and that communication pathways function correctly.

3. Evaluation

- After each test—or real incident—organizations should perform a thorough review to capture lessons learned.
- Evaluations identify strengths, weaknesses, and areas for improvement, ensuring that the incident management process evolves over time.

Incident Management Metrics and Indicators

The purpose of metrics and indicators in this case is to measure how effective and efficient the incident management function is. They guide senior management on the performance of incident handling, identify needed improvements, and justify ongoing support or budget.

The two types of metrics in focus here are:

- **Key Performance Indicators (KPIs):** Quantifiable activity measures—e.g., “Number of incidents resolved within X minutes”. KPIs track progress against a specific target or service-level requirement.
- **Key Goal Indicators (KGIs):** Broader in scope, used to assess whether strategic or high-level goals are being met—e.g., “Reduce overall incident count by 10% annually.”

Common Criteria for Incident Management Metrics

A few common metrics leveraged in measuring incident management performance include:

1. **Number of reported incidents** – captures frequency.
2. **Number of detected incidents** – measures detection capabilities (though reported and detected may differ).
3. **Number of days without an incident** – helps track “clean” operational stretches.
4. **Average time to respond** – from incident detection to initial action; relates to RTO targets.
5. **Average time to resolve** – from detection to closure; also aligned with RTO.
6. **Total incidents successfully resolved** – measures how many incidents get fully remediated.
7. **Incidents not resolved successfully** – highlights areas needing more resources or process improvement.
8. **Proactive and preventive measures taken** – indicates maturity level of the overall security posture.

Value of Metrics in Reports:

- Offer the Incident Management Team (IMT) a self-assessment tool and highlight where performance can improve.
- Show trends over time and help in aligning resources or adjusting processes to meet business and regulatory requirements.

Performance Measurement

Performance measurement in incident management focuses on *how well-defined objectives and processes are being met*. This involves establishing Key Goal Indicators (KGIs) and Key Performance Indicators (KPIs) that reflect both strategic and operational targets.

Each of these metric types bring a unique perspective to measuring performance:

- **KGIs** typically measure the success of the overall incident-handling strategy (e.g., “Did we effectively handle simulated or real incidents without major losses?”).
- **KPIs** typically measure operational efficiency and effectiveness (e.g., “Time to detect,” “Time to respond,” or “Time to restore”).



KGIs and KPIs are discussed in depth in “Action Plan to Implement Strategy” in Chapter 2.

Exam Tips: *Remember why these measurements are important:*

- Demonstrating success in incident management (e.g., minimal downtime or rapid containment) is crucial for ongoing resource allocation and stakeholder confidence.
- Effective performance measurements drive continuous improvement and reflect how quickly and accurately the organization can respond to incidents under real or test conditions.

Updating Recovery Plans

Enterprises evolve constantly, as business priorities, strategies, applications, and threats change over time. Recovery and response plans must keep pace. During change management, the security manager ensures all relevant recovery plan updates happen promptly.

Key Factors Necessitating Updates:

Key elements of strategy, environment, and processes that trigger updates include:

1. **Strategy Shifts:** A previously acceptable strategy might not fit new business conditions or risk profiles.
2. **New Applications or Technologies:** Introducing new systems may require updated processes or recovery technologies.
3. **Changes in Business Strategy or Environment:** Whether due to mergers, acquisitions, or new regulatory demands, the recovery plan should reflect the current operational reality.
4. **Hardware/Software Updates:** Modernized infrastructure may make old processes obsolete or require new testing and documentation.
5. **Physical and Environmental Changes:** Data center relocations or new office sites can significantly affect recovery logistics.

Maintenance Activities:

Day-to-day operations can also trigger the need for updates, include:

- **Scheduled Reviews:** Regularly review the plan (e.g., every 30 days for revisions) and share deadlines with all relevant personnel.
- **Revisions for Major Changes:** Call for immediate updates when critical changes occur—e.g., new systems, major reorganizations, or fresh risk assessments.
- **Testing:** Both scheduled and unscheduled tests validate plan adequacy; incorporate lessons learned from any unsuccessful tests.
- **Training:** Ensure personnel understand recovery roles; schedule training within a set period after each plan update or test.
- **Record Keeping:** Maintain records of all plan maintenance tasks, including changes to contact lists, responsibilities, or operational procedures.

The goal is a recovery plan that aligns with current business operations, ensuring the organization can restore services and meet critical objectives when incidents occur.

Exam Tip: Know how **metrics** tie directly into **performance measurement**, and how **regular updates** ensure those metrics and performance expectations remain valid as the environment changes.

Testing Incident Response and BC/DR Recovery Plans

To ensure efficacy, all aspects of incident response and BC/DR plans should be tested regularly. *Important considerations include:*

1. Regular Testing

- All aspects of incident response, business continuity, and disaster recovery plans require scheduled testing.
- The primary goal is to validate readiness—of both personnel and processes—to handle real incidents.

2. Key Testing Activities

- **Identify Gaps:** Reveal missing procedures, unclear responsibilities, or unaddressed risks.
- **Verify Assumptions:** Confirm that presumed resources or processes (e.g., vendor support) function as intended.
- **Evaluate Strategies:** Assess whether existing recovery and response strategies remain effective.
- **Check Documentation:** Ensure plan documents are accurate, up to date, and easy to follow.

3. Coordination and Communication

- Effective collaboration among internal teams and external stakeholders (e.g., regulators, partners) is critical.
- Testing helps everyone understand their roles, fosters communication, and reduces confusion during real events.

4. Frequency

- Test frequency depends on the organization's risk profile, regulatory requirements, and any major changes in the environment.
- Each test generates insights that feed into plan improvements.

Periodic Testing of the Response and Recovery Plans

The scope, nature, and schedule of BC/DR test will vary by organization, but the full scope of incident management responsibilities need to be tested up to the point of a disaster declaration. *When establishing a test schedule, considerations include:*

1. Purpose

- Periodic testing ensures plans remain relevant and effective as conditions evolve (e.g., technology changes, new threats).
- Documenting test outcomes helps refine both the incident response plan and the recovery strategy.

2. Scope and Scale

- The extent of testing varies. It can range from targeted exercises (for a single system or department) to enterprise-wide drills simulating a large-scale incident.
- Each test scenario should be aligned with the most significant risks facing the organization.

3. Ongoing Improvement

- Management should be kept informed of test results, weaknesses discovered, and corrective actions taken.
- Plans must be revised based on lessons learned, ensuring continuous alignment with business needs.

The scope and schedule of tests will vary based on their nature, but the less effort intensive and invasive tests, such as a readthrough and walkthrough, will be conducted more frequently, often quarterly, or even monthly. Full interruption testing will be much less frequent, often once annually.

Now, we'll explore test scoping and test types.

Testing for Infrastructure and Critical Business Applications

The information security manager can identify critical business applications, and the infrastructure required to support them. Then, developing *a prioritized testing strategy based on criteria such as:*

1. Scope of Testing

- Testing must cover both infrastructure (e.g., networks, servers, storage) and critical applications.
- These tests may be separate or combined, depending on resource availability, potential for business disruption, and other organizational priorities.

2. Importance for IT-Dependent Enterprises

- Most enterprises rely heavily on IT; thus, ensuring systems can recover quickly and securely is essential.
- Tests validate backup procedures, failover capabilities, and interdependencies among systems.

3. Risk-Based Approach

- Prioritize testing for systems with the greatest potential business impact if disrupted.
- Testing intervals and methods should reflect each system's risk profile and regulatory requirements.

4. Timely Maintenance and Recovery

- To keep recovery processes current, the information security manager should schedule tests regularly.
- Results help confirm that infrastructure and applications can be restored within acceptable time frames (RTOs).

Types of Tests

You should be familiar with the following five disaster recovery tests for exam day:

Read-Through Test

The **read-through** is the simplest and least disruptive of the disaster recovery exercises in which you distribute copies of the disaster recovery plan to the members of the disaster recovery team. A read through will often involve team members reviewing the disaster recovery plan on their own and responding with any questions or feedback.

This exercise will ensure the team members are familiar with their responsibilities at a high level. The simple act of distributing the disaster recovery plan will also identify any roles that need to be filled due to personnel role changes or departures.

Walkthrough

The **walkthrough** (aka “table-top exercise”) will often vary in its scope and objectives from one iteration to the next. In a walkthrough, members of the disaster recovery team (and sometimes key stakeholders) gather in a large conference room and role-play a disaster scenario. It will definitely include IT staff, as well as those responsible for the communication plan. The team members refer to the document and discuss the appropriate responses to that particular type of disaster. Usually, the exact scenario is known only to the test moderator, who presents the details to the team at the meeting.

Walkthroughs will sometimes include participants taking at least some physical action or at least more deeply evaluating the impact of certain events and responses in a given scenario.

For example, users may be tasked with working remotely for a short time to verify work-from-home (WFH) resources are adequate to keep the business running.

Simulation Test

More active than tabletop walkthrough exercises, these can involve physically activating alternate locations, recovering partial data, and identifying bottlenecks in planned response actions. Similar to a walkthrough, except some response measures are then tested on non-critical functions.

Parallel Test

Parallel testing involves relocating personnel to the alternate recovery site and implementing site activation procedures. The employees relocated to the site perform their disaster recovery responsibilities just as they would for an actual disaster. The systems they work with to test will be backup systems running in parallel to production systems.

Full interruption Test

The full interruption test is similar to the parallel tests but involves actually shutting down operations at the primary site and shifting them to the recovery site. This is the **end-to-end test** that fully exercises and evaluates the efficacy of the disaster recovery plan. Not only does this verify the plan works as designed but will help to identify gaps or other problems in the plan.



For the exam, remember the most important test of a DRP is the full interruption test that *proves the plan actually works*.

There are three main categories of recovery testing cited by ISACA:

1. Paper Tests

- These are on-paper “walkthroughs” of the disaster-recovery plan.
- The major stakeholders talk through what might happen during a particular type of service disruption (or the entire plan).
- Paper tests generally occur before any more involved testing, helping the team refine the plan in theory before expending real resources.

2. Preparedness Tests

- These tests are smaller-scale or localized simulations of a real crash, using actual resources but limiting the scope.
- They are performed regularly, targeting specific parts of the plan in turn.
- This incremental approach helps gather evidence on how well the plan works and allows improvements without the cost or risk of a full test.

3. Full Operational Tests

- These are nearly a full “live” test—essentially one step away from deliberately causing a real-world disruption.
- They are carried out once the plan is proven solid on paper (and in localized preparedness tests).
- The goal is to ensure that the entire organization can execute the plan seamlessly under conditions that mimic an actual disaster.

Test Results

Each recovery test should produce an **expected set of outcomes** so that the organization can measure its performance against predefined objectives. *At a minimum, the following should be verified or evaluated:*

1. Completeness and Accuracy of the Response/Recovery Plan

- Confirm that all procedures and steps in the plan are properly documented and that they match the organization’s actual requirements.

2. Personnel Performance

- Assess how well staff carry out their assigned roles during the test and identify any gaps in skills or knowledge.

3. Training and Awareness

- Examine the effectiveness of training for personnel not directly involved in day-to-day operations, ensuring everyone understands their responsibilities.

4. Team and Supplier Coordination

- Evaluate the collaboration among internal teams and with external vendors or suppliers, verifying smooth communication and task execution.

5. Backup Site Capacity and Capability

- Measure the backup site’s resources (hardware, software, bandwidth, etc.) to ensure it can handle processing loads as planned.

6. Vital Records Retrieval

- Check how quickly and accurately essential documents and data can be recovered at the alternate location.

7. Equipment and Supplies

- Verify that any relocated equipment and materials meet the quantity and quality needed to maintain operations.

8. Overall Operational Performance

- Ensure that day-to-day business processes and information systems can continue or resume effectively under the tested conditions.

Recovery Test Metrics

To properly gauge the success and areas for improvement in a recovery test, **metrics** must be established and tracked. These metrics typically include:

- **Timing/Duration Metrics:** How long it takes to resume critical operations or restore systems to operational levels.
- **Accuracy Metrics:** The degree to which the recovered systems and data match expected states (e.g., data integrity, configuration settings).
- **Resource Utilization Metrics:** Usage levels for staffing, equipment, and other resources compared to availability.
- **Error/Issue Tracking:** The number and severity of problems encountered during testing, along with resolution times.
- **Communication Metrics:** The speed and clarity of internal and external communications, including escalation and coordination with third-party vendors.
- **User/Stakeholder Satisfaction:** Feedback from everyone involved on how well the recovery process worked and any improvements needed.

Key takeaway: By systematically collecting and analyzing these metrics, an organization can pinpoint weaknesses in its response and recovery plan, then refine the plan and its associated processes for better resilience.

Incident Management Metrics and Indicators

Metrics and key performance indicators (KPIs) measure the effectiveness of incident management and are presented to senior management. KPIs are quantifiable activity measures, while KGIs show progress toward a predefined goal.

Common metrics include:

- Average response time
- Average resolution time
- Number of days without an incident
- Number of detected incidents
- Total damage from incidents
- Total number of employees trained
- Total number of incidents resolved

- Total savings from resolved incidents

Metrics should be used to measure success quantitatively and improve the plan. The information security manager must understand RTOs, which are determined by the BIA and influenced by various factors.

Key Takeaways:

- **Relevant and Measurable:** Metrics should be meaningful and quantitatively measurable.
- **Alignment with Objectives:** Metrics should reflect organizational priorities (e.g., uptime, data protection, compliance).
- **Continuous Improvement:** Use metrics to refine policies, training, and resource allocation.

Updating Recovery Plans

Recovery plans must be updated due to evolving business and security landscapes. Factors triggering updates include:

- changes in business strategy
- new applications
- software/hardware changes
- physical/environmental changes.

Plan maintenance activities include scheduled reviews, revisions based on changes, plan testing, training, record keeping, and notification directory updates.

DOMAIN 4B: Incident Management Operations

Syllabus

4B. Incident Management Operations

- 4B1. Incident Management Tools and Techniques
- 4B2. Incident Investigation and Evaluation
- 4B3. Incident Containment Methods
- 4B4. Incident Response Communications (e.g., reporting, notification, escalation)
- 4B5. Incident Eradication and Recovery
- 4B6. Post-incident Review Practices

Supporting Tasks

- 37. Conduct post-incident reviews to facilitate continuous improvement, including root-cause analysis, lessons learned, corrective actions, and reassessment of risk.

Enterprises today rely heavily on technology and constant connectivity, which amplifies both the probability and the impact of information security incidents. Well-defined incident management processes, well-trained personnel, and effective monitoring are essential to reduce harm and enable a swift return to normal operations.

A robust incident management capability allows security teams to quickly **identify**, **contain**, **resolve**, and **recover** from incidents, minimizing damage and restoring business functions as soon as possible.

4B1. Incident Management Tools and Techniques

Enterprises often use a blend of commercial solutions, custom applications, or both to facilitate incident management. The **Incident Management Team (IMT)** relies on various tools to detect, track, and manage incidents effectively.

Modern systems and infrastructures generate vast amounts of data that can indicate potential or actual security incidents. Automated **incident management systems** help filter and correlate this data to alert the IMT about issues that require attention.

Some enterprises have a separate IMT, which decides how to manage incidents and incident response teams (IRT) which executes technical responses. In other cases, the **IMT and IRT** are the same group. For clarity, we refer to the IMT as the decision-making body and the IRT as the responders, though they may overlap.

Incident Management Systems

Modern IT environments produce **massive amounts of logs and security events**, making it impossible to manage them manually at scale. Automated **incident management systems** help filter, organize, and alert the right personnel to actual or potential security incidents. **Faster detection and response** reduce the overall impact of incidents on the business.

Without these systems, organizations face higher risks of prolonged outages, greater financial losses, and reputational damage. As a result, incident management systems have become a necessity and widely adopted by enterprises.

Solutions commonly implemented include:

Distributed incident management systems often involve multiple detection points—such as network intrusion detection systems (NIDS), host-based intrusion detection systems (HIDS), and various logs—feeding data into a central repository.

Centralized incident management systems are typically provided by Security Information and Event Management (SIEM) tools.

- SIEM combines logs from many devices and systems, normalizes this data in a single database, and performs correlation/analysis to identify incidents in near-real-time.
- SIEM can prioritize incidents based on potential severity, business impact, or other factors and issue alerts accordingly.
- SIEMs also track incidents throughout their life cycle, ensuring proper follow-up and closure.

An effective SIEM should:

- Consolidate and correlate data from multiple sources (log ingestion and event normalization to a common schema)
- Detect and notify staff of potential incidents
- Prioritize incidents based on business impact
- Track incidents until closure, providing status updates
- Integrate with major IT management systems
- Implement good practices (configurations, workflows, etc.)

Although **automated incident management systems** can offer efficiency and cost savings, proper configuration and tuning can be complex and time-consuming. Key considerations for the information security manager include:

- **Operating costs:**
Without a centralized system, security staff must manually monitor various logs and correlate events, which increases staffing needs and the risk of human error.
- **Recovery costs:**
Automated solutions often detect and escalate incidents faster than manual methods, mitigating damage sooner.
- **Endpoint Detection and Response (EDR)** collects and analyzes endpoint data (e.g., processes, file activity, registry changes) to detect suspicious behavior, respond to threats, and facilitate deeper investigation *on individual devices*.
 - Continuously monitors endpoint devices for threats
 - Collects and analyzes data from endpoints
 - Provides real-time threat detection and response
 - Offers forensic capabilities for incident investigation

Role: EDR focuses on detecting and responding to threats on individual endpoints, providing visibility into endpoint activity and enabling rapid response to potential breaches.

- **Extended Detection and Response (XDR)** extends EDR by correlating data across multiple layers (endpoints, networks, cloud) for a **holistic** threat view. Leverages automation and ML for advanced threat hunting.
 - Integrates data from multiple security layers (endpoints, network, cloud, etc.)
 - Provides a unified view of threats *across the entire IT environment*
 - Offers automated threat detection and response capabilities
 - Enables more comprehensive and context-aware security analysis

Role: XDR aims to provide a more holistic approach to threat detection and response by correlating data from various security tools and offering a centralized platform for analysis and action.

- **Managed Detection and Response (MDR)** is an outsourced service providing continuous monitoring and incident response by a third-party security provider. MDR includes expert staff and 24/7 oversight, not just software. Ensure well-defined SLAs, response times, and data privacy terms.

Outsourcing Considerations: Remember these considerations for when outsourcing incident response-related functions, such as the security operations center (SOC) function:

- **Accountability stays in-house:** Even if you outsource tasks, the organization remains responsible for overall security.
- **Contractual clarity:** Look for well-defined SLAs, response times, regulatory compliance, and data ownership.

Incident Response Technology Foundations

Security professional involved in **incident response** must be well-versed in key security concepts, including (but not limited to) the following list of baseline concepts and principles:

1. Security Principles

Understanding security principles helps identify potential problems that arise when security measures are inadequate or fail and highlights the impacts on enterprise systems.

- **Core Principles:**

- **Access Control:** Ensures only authorized users gain access.
- **Authentication:** Confirms the identity of users or systems.
- **Availability:** Guarantees systems and data are accessible when needed.
- **Compliance:** Aligns security measures with legal and regulatory requirements.
- **Confidentiality:** Protects information from unauthorized disclosure.
- **Integrity:** Safeguards data against unauthorized alteration.
- **Nonrepudiation:** Prevents parties from denying actions or transactions.
- **Privacy:** Maintains personal or sensitive information confidential.

2. Security Vulnerabilities/Weaknesses

Incident response teams (IRTs) need to understand how assets—people, processes, software, and hardware—can be exploited.

- **Common Types:**

- **Cloud Security Attacks:** Often caused by misconfigurations, weak encryption, and poor access control.
- **Configuration Weaknesses:** Incorrect or lax system configurations that attackers can exploit.
- **Implementation Flaws:** Includes buffer overflows and race conditions.
- **Malicious Code:** Viruses, worms, Trojan horses, and other forms of malware.

- **Operational Errors:** For example, phishing attacks exploiting user inattention or lack of security awareness.
- **Physical Security Issues:** Gaps in securing facilities, equipment, or physical access points.
- **Product Design Flaws:** Software or hardware lacking built-in security features.
- **Network Security Issues:** Involves firewall design, perimeter defenses, intrusion detection/prevention, remote access, DMZ configurations, and more.
- **Operating System Weaknesses:** Arise from misconfigurations, improper file permissions, and unpatched systems.
- **New Technologies:** Emerging technologies can introduce unknown vulnerabilities and require ongoing monitoring and evaluation.

Personnel (IRT Structure)

Typically led by an information security manager, overseen by a security steering committee or advisory board, and supported by technical experts. However, in large enterprises, there may be a separate **incident response manager** who focuses solely on incident response tasks. The steering committee, composed of senior management, sets policies and can approve exceptions.

Depending on the organization, **external expertise** may be brought in to bolster the team's capabilities.

Goal: The IRT's mission is to mitigate security incidents quickly and effectively, ensuring minimal impact on the organization.

IRT Models

Incident handlers analyze incidents, determine their impact, and recommend containment actions. Different IRT models include:

- **Central IRT:** A single team manages all incidents (typical for smaller or centralized enterprises).
- **Distributed IRT:** Multiple teams each handle a segment of the infrastructure (common in large or geographically dispersed organizations).
- **Coordinating IRT:** A central team sets standards, provides training, and coordinates response across distributed teams.
- **Outsourced IRT:** Some or all incident response functions may be outsourced to a third party.

Permanent team members might include incident handlers, investigators, forensic experts, and IT security specialists. Temporary members can include business representatives, legal, PR, HR, and risk management.

Roles and Responsibilities

A well-defined incident response plan outlines **who does what**, ensuring swift action and accountability. *Typical roles include:*

1. Security Steering Group (SSG)

- Sets overall incident management and response strategy.
- Approves budgets and critical decisions.

2. Information Security Manager

- IMT Team lead, liaison to senior leadership.
- Oversees the incident management process.
- Makes final decisions on major security measures.

3. Incident Response Manager (IRM)

- IRT team lead, coordinates IRT activities.
- Assigns tasks and ensures resources are available.
- Communicates with senior leadership and external parties as needed.

4. Incident Handler

- Executes the response plan.
- Identifies and contains security incidents.
- Reports findings to the IRM.

5. Investigator

- Gathers and analyzes evidence.
- Documents the incident thoroughly for legal or forensic purposes.

6. IT Specialist/Representatives

- Provides technical expertise (e.g., network, system, application).
- Implements containment, eradication, and recovery measures.

7. Risk Management Specialist

- Advises on risk mitigation strategies.
- Ensures incident response aligns with broader risk management policies.

8. Physical Security Liaison

- Addresses any on-site security issues.
- Coordinates with facilities and emergency response if needed.

9. Public Relations (PR) Area

- Manages external communication to media and stakeholders.
- Protects the organization's public image.

10. Subject Matter Expert (SME) in IR

- Provides specialized insight on technical or business-specific issues.
- Assists in refining or validating response strategies.

Skills

Effective IRT members typically need both **soft (personal)** skills and **technical** skills.

Soft (personal) skills

- **Communication:** Must clearly relay and gather information from team members, IT staff, users, management, law enforcement, and external parties.
- **Leadership:** Able to coordinate and motivate individuals across the organization.
- **Presentation:** Comfortable presenting technical or non-technical information to various audiences (including potential legal testimony).
- **Policy/procedure adherence:** Follows established incident response guidelines.
- **Teamwork:** Works collaboratively, shares information, and supports others' tasks.
- **Integrity:** Handles sensitive or newsworthy data with discretion.
- **Self-awareness:** Knows personal and skill limitations; seeks help when needed.
- **Stress management:** Maintains composure under pressure.
- **Problem solving:** Able to sift through large volumes of data and think outside the box.
- **Time management:** Balances multiple tasks, including analysis, incident coordination, meetings, and administrative duties.

Technical skills

- **Technical foundation:** Understanding of the systems and environments in use (network, OS, applications, security tools).
- **Incident handling:** Familiarity with detection, containment, eradication, and recovery methodologies, and with tools (e.g., SIEM, EDR) that support incident response.

Awareness and Education

End users are often the **first line of defense**. Ongoing security awareness programs should emphasize:

- Recognizing and reporting phishing attempts
- Safe web browsing
- Proper handling of sensitive data
- Secure use of devices (including personal or mobile devices)

Regular **skills assessments** can identify knowledge gaps within the enterprise. Training can help fill these gaps; alternatively, outside expertise may be contracted when in-house skills are insufficient.



Training should be conducted periodically (one or more times yearly) and updated to keep users abreast of the latest threats they should be aware of.

Audits

In the context of incident management, audits may range from internal assessments to formal audits conducted by an external firm. Regular security or compliance audits identify gaps in incident management processes, tools, or policies.

Both **internal** and **external** audits verify compliance with security policies and effectiveness of the incident management process.

- **Readiness:** Ensure enterprise is prepared to handle incidents without compromising security.
- **Compliance:** Confirm alignment with legal and regulatory requirements.
- **Process Definition:** Reveal the need for incident response process refinements or training needs.
- **Gap Identification:** Reveal gaps or weaknesses in existing processes and provide opportunities for improvement.

Outsourced Security Providers

Small or resource-limited enterprises may outsource some or all incident management functions to third parties. Even in fully outsourced IT operations, the enterprise still needs a **governance framework** and a clearly defined **incident response plan (IRP)**.

When outsourcing, ensure:

- **Incident reference alignment:** Match the vendor’s incident IDs with your own to accurately track recovery times.
- **Change management integration:** Wherever possible, coordinate change management processes between the enterprise and the vendor.
- **Regular incident reviews:** Schedule periodic reviews of incidents with the vendor to discuss root causes, remediation, and preventive measures.
- **Service Level Agreements (SLAs):** Define response times, indemnity clauses, and deliverables to ensure vendor accountability.

4B2. Incident Investigation and Evaluation

Not every **event** is an **incident**, and an effective information security manager must understand the difference. An **event** is simply something that happens at a specific place or time—such as an account logon, a door opening, or an automated process ending. Most events occur without causing concern. Whether an event requires attention depends on **context**.

For example, a user account logging in during standard business hours is a routine event when measured against a known baseline (see “Security Control Baselines” in Chapter 3). However, a user logging in after business hours might be abnormal and warrant further investigation. Additional details (e.g., user traveling abroad in a different time zone) may confirm the event is legitimate, or it might indicate malicious activity if the user’s credentials were stolen.

Until you gather and evaluate all relevant information, you cannot know whether the event is legitimate or malicious. After determining its legitimacy, the proper action can be taken. The decision to classify an event as an **incident** hinges on its potential impact to the enterprise.

Analogy: Think of a home motion sensor that triggers an alert. Is it a burglar or just the family pet? You need context, such as camera footage, your pet’s typical behavior, and the time of day—to know if it’s truly an incident requiring a response.

Executing Response and Recovery Plans

A **major incident** can lead to confusion and unexpected conditions, so it is vital that **incident management and response plans** are thoroughly tested under realistic circumstances. Unproven plans may fail when needed most. The more severe the incident, the more chaos and challenges the response teams will face (e.g., a cyberattack disabling IT systems or a natural disaster affecting the physical environment).

To ensure the enterprise remains resilient under various scenarios, all reasonably possible incidents should be anticipated, and the incident response plans must be well-prepared and **tested**.

Ensuring Execution as Required

- **Facilitator/Coordinator:** A designated person (not necessarily the information security manager) must oversee the execution of response and recovery tasks, communicate with senior management, and make timely decisions.
- **Strategies and Alternatives:** The information security manager must ensure that viable response and recovery strategies are in place. These strategies may vary based on the nature of the incident (e.g., cyber intrusion vs. physical disaster) but should always be clearly documented and practiced.

By having a well-coordinated response, the enterprise can mitigate damage, ensure continued operations, and maintain stakeholder confidence even in challenging circumstances.

Foundational Concepts

There are many concepts the CISM exam will not test you on directly, but you should be familiar with to best assess the questions you are presented on the exam. Below are a few concepts related to investigations associated with incident response that will be helpful foundational knowledge.

- Investigation Types
- Electronic Discovery (eDiscovery)
- Evidence
- Chain of Custody
- Admissibility of Evidence
- Digital Forensics

Investigation Types

You should also be familiar with the different types of investigations, as these guide the techniques and personnel that will be appropriate or necessary. Here's a breakdown of typical requirements and focus areas for different investigation types:

Administrative Investigations

Internal inquiries conducted by organizations to examine policy violations, employee misconduct, or other internal matters.

- **Requirements:** Conducted internally by an organization.
- **Focus:** Determine if policies were violated and recommend disciplinary actions if needed.

Criminal Investigations

Formal inquiries conducted by law enforcement agencies to determine if a crime has been committed and identify the perpetrator(s).

- **Requirements:** Conducted by law enforcement agencies and must follow strict procedural rules to ensure evidence admissibility in court.
- **Focus:** Gather admissible evidence to determine if a crime was committed and identify the perpetrator.

Civil Investigations

Fact-finding inquiries conducted by lawyers or private investigators to gather evidence relevant to a civil lawsuit.

- **Requirements:** Conducted by lawyers, private investigators, etc.
- **Focus:** Establish liability, assist in developing litigation strategy, and determine damages/liability amounts.

Regulatory Investigations

Examinations conducted by regulatory bodies to ensure compliance with industry regulations and enforce adherence.

- **Requirements:** Conducted by regulatory bodies with the authority to enforce industry regulations.
- **Focus:** Inspect records, facilities, etc. to identify regulatory violations and potentially initiate enforcement actions.

Some regulatory investigations are not mandated by the government, but rather are contractual obligations, such as Payment Card Industry Data Security Standard (PCI DSS). Contractual details may allow for third-party audits and investigations.

Industry Standards Investigations

Assessments conducted internally or by external groups to ensure adherence to industry codes of conduct or best practices.

- **Requirements:** Conducted internally or by outside groups.
- **Focus:** Examine if established industry standards and best practices are being followed appropriately.

Electronic Discovery (eDiscovery)

Organizations expecting lawsuit have a duty to preserve digital evidence in a process called eDiscovery. The eDiscovery process includes:

1. Information governance
2. Information identification
3. Preservation
4. Collection
5. Processing
6. Review
7. Analysis
8. Production
9. Presentation

These nine process steps come from the **Electronic Discovery Reference Model (EDRM)**, which describes standard for conducting eDiscovery.

The eDiscovery process often uses tagging, classification, targets specific custodians. In a tool or platform that supports eDiscovery, data collection and handling, will be gathered into a collection/case and given an ID.

eDiscovery vs Digital Forensics: What's the difference?

While these terms may seem interchangeable, there are a couple of significant differences. It's helpful to understand the difference as your interpreting questions for the exam.

eDiscovery. The process of identifying, preserving, collecting, processing, reviewing, and producing electronically stored information (ESI) in litigation. eDiscovery is about gathering the data and assessing its relevance to the request for production. eDiscovery custodians or outside firms typically do not analyze the data they collect beyond assessing its relevance to the request.

Digital Forensics. On the other hand, computer forensics involves the use of a forensic expert to protect data integrity and to copy/capture/recover the data stored on a device. Forensic investigators have specialized training enabling them to analyze data, protect data integrity, and recover missing or deleted data. For example, it may involve restoring a damaged or deleted partition and looking for traces of information which could reveal how and when the partition was used. Forensics experts may be working with computers which have been seeded with safety measures to prevent legal investigations, requiring special procedures.

eDiscovery works in conjunction with digital forensics; their functions are complementary.

Bottom line: With a little training, just about any IT professional or layperson can be trained to competently complete eDiscovery related tasks. On the other hand, digital

forensics requires specialized training and skills.



You can read more about the **EDRM electronic discovery reference model** at <https://edrm.net/edrm-model/current/>.

Evidence

Evidence refers to any data, information, or material—such as logs, files, emails, or digital records—that can be used to prove or disprove facts related to an incident or legal investigation. It serves as a basis for understanding what happened, who was involved, and supporting decision-making or compliance efforts.

There are *three major categories of evidence* that may be used in a criminal or civil trial:

- **Real evidence** consists of actual objects that can be brought into the courtroom.
- **Testimonial evidence** consists of verbal or written statements made by witnesses.
- **Documentary evidence** consists of written documents that provide insight into the facts.
- **Demonstrative Evidence** is evidence used to support testimonial evidence.

There are two rules of evidence that apply to documentary evidence you should be familiar with:

- **Best Evidence Rule:** Original documents must be presented in court, not copies or descriptions, unless specific exceptions apply.
- **Parol Evidence Rule:** When an agreement is written down, that document contains all terms - verbal agreements cannot modify it.

The **hearsay rule** prohibits witnesses from testifying in court about statements made by others outside the courtroom, to ensure the admissibility and reliability of evidence. There are several exceptions to this rule, such as past testimony under oath, statements made against one's own interest, dying utterances, and public records.

Chain of Custody

Chain of custody refers to the documentation and tracking of evidence from the moment it is collected until it is presented in court or disposed of. It ensures the integrity, security, and traceability of evidence. It involves:

1. **Chronological documentation:** A detailed record of where the evidence was, who handled it, and when, at every step from collection to final disposition.
2. **Preservation of evidence:** Ensuring that evidence is properly stored and protected from tampering or contamination.
3. **Transfer accountability:** Recording every time the evidence changes hands, including the reason for the transfer.
4. **Access control:** Limiting and documenting who has access to the evidence.
5. **Maintaining integrity:** Proving that the evidence presented in court is the same evidence that was initially collected, without alteration.



If there are gaps or irregularities in the chain of custody, it can cast doubt on the reliability of the evidence and potentially render it inadmissible in court.

Admissibility of Evidence

Requirements for evidence to be admissible in a court of law, evidence must be:

- **Relevant** to a fact at issue in the case (the legal proceeding)).
- **Material** (related) to the case.
- **Competent**, which means collected through legal means. Evidence obtained through an illegal act is generally inadmissible in court.

Digital Forensics

Digital forensics involves the collection, preservation, and analysis of digital evidence to support investigations and legal proceedings. It requires special skills and training, including:

- **Understanding the principles and best practices** of digital forensics, including data acquisition, analysis, and reporting
- **Familiarity with common digital forensic tools and techniques**, such as disk imaging, file carving, and memory analysis
- **Ensuring the admissibility and reliability of digital evidence** through proper handling and documentation

- **Staying current with emerging trends** and challenges in digital forensics, such as encryption and cloud computing

General principles include maintaining detailed logs of all actions, establishing a clear chain of custody, and ensuring all personnel involved in investigations are properly trained and certified in forensic procedures.

Important activities include skilled forensic investigators must master include:

- **Evidence Preservation:** The focus here is on maintaining the integrity of original evidence by working with copies and properly sealing originals. When preserving evidence, use write-blockers to prevent accidental modification, create bit-for-bit copies, and calculate hash values to verify integrity. Store original evidence in anti-static bags in a secure, climate-controlled environment.
- **Hardware/Embedded Device Analysis:** A specialized technique for investigating various devices, combining skills from both media and software analysis. When analyzing hardware, document the physical state of the device, photograph all connections before disconnecting, and consider the potential for anti-forensic measures like booby traps or remote wiping capabilities.
- **In-Memory Analysis:** This involves collecting and examining information from live system memory using trusted tools and working with verified copies of memory dumps. Perform memory acquisition as quickly as possible after the incident to capture volatile data. Use validated tools and document the system's state (running processes, network connections) at the time of acquisition.
- **Media Analysis:** A method of extracting information from various storage media by creating forensic images and analyzing copies while preserving the original. Use forensically sound tools to create images, verify the images with hash values, and analyze them in a controlled environment. Be aware of potential encryption, hidden partitions, or steganography that may conceal evidence.
- **Network Analysis:** A technique for reconstructing network activity during incidents by utilizing pre-existing logs, captures, and monitoring data. When performing network analysis, correlate data from multiple sources (e.g., firewall logs, IDS alerts, netflow data) to build a comprehensive picture. Be mindful of time synchronization across devices and potential log tampering.
- **Software Analysis:** If malicious activity is suspected, forensic analysis of applications, including their activities, and potentially examination of source code for potential security issues or malicious elements may be necessary to identify the presence of backdoors or other security vulnerabilities. When source code is not available, it may require dynamic testing in a controlled environment or reverse engineering to identify
- **Other considerations for evidence:** A few other considerations that may arise with regards to evidence:
 - **Preservation vs. Recovery:** Sometimes you must preserve evidence prior to full recovery actions.

- **Data sovereignty:** Different regions have varying rules on storing and sharing data.
- **Jurisdictional nuances:** Recognize that laws differ significantly among countries/states.



Always preserve original evidence, document everything, and work with copies when possible. Maintain a clear chain of custody and use validated forensic tools and techniques throughout the investigation.

Incident Investigation and Evaluation

Putting IR (Incident Response) and DR (Disaster Recovery) plans into **action** during an incident includes forensic analysis, containment strategies, system restoration.

- **Escalation Paths:** Distinguishing between urgent vs. routine incident workflows is necessary to ensure most effective use of resources.
- **Evaluating Plan Effectiveness:** Metrics like Mean Time to Detect (MTTD) and Mean Time to Contain (MTTC) measure plan success.

4B3. Incident Containment Methods

Incident containment focuses on *immediately limiting or reducing the impact* of a security incident. Because every incident is unique, you must tailor containment strategies to the specific situation. Before containing the incident, it is crucial to understand both the benefits and potential drawbacks—such as tipping off an attacker—so that senior management can make an informed decision about when and how to proceed.

Simply put, containment is a short-term, tactical action designed to “limit the damage”. It does **not** necessarily correct the root cause.

Analogy: Think of containment like applying a tourniquet to a bleeding wound. It won't heal the injury (the root cause of the incident), but it stops further damage until you can address the underlying problem.



Senior management must fully understand and approve containment efforts because once containment begins, the attacker may notice and escalate their actions.

Common Containment Activities

Typical containment tasks include:

1. Notification and Escalation

- Alert relevant stakeholders and escalate to higher-level teams or authorities as needed.

2. Memory Captures and Analysis

- Gather volatile data from impacted systems before shutting them down or disconnecting them from the network.

3. Enterprise-wide Password Resets

- Change passwords for all user accounts to prevent unauthorized access.

4. Updating Firewall Rule Sets

- Block, deny, or drop traffic from suspicious IP addresses or domains.

5. Updating IDS Signatures

- Add newly discovered indicators of compromise to intrusion detection systems.

6. Log Collection, Review, and Analysis

- Gather logs from various systems to identify the scope and nature of the incident.

7. Forensic Imaging

- Create a forensically sound image of impacted systems for evidence and deeper analysis.

8. Malware Reverse Engineering

- Examine malicious code to understand how it operates and identify indicators of compromise.

9. Removing the Device from the Network

- Isolate infected or compromised machines to prevent lateral movement of threats.

Scenario: System Compromise

If a malware-infected system is under active control by an attacker, possible containment steps could include:

- **Disconnecting the system** from the network to cut off the attacker's access.
- **Updating firewall rules** to block known malicious IP addresses and domains associated with the threat.
- **Scanning for indicators of compromise** on other systems to identify any additional infections.

The goal is to find and remove the adversary from all potentially compromised systems, preventing further damage while you plan and execute full remediation.

Decision to Initiate Containment

Initiating containment involves weighing immediate benefits (stopping ongoing damage) against risks (alerting the attacker and prompting retaliation). Senior management, in consultation with legal counsel, the information security manager, and the IMT, must decide:

1. **When** to initiate containment.
2. **How** to conduct containment measures effectively.
3. **Whether** the enterprise is fully prepared (i.e., has the necessary resources and approvals) to mitigate potential escalations once containment begins.

4B4. Incident Response Communications (e.g., reporting, notification, escalation)

Effective communication during disaster recovery ensures various stakeholders have the information they need to assist with recovery and ongoing business operations. As with security incident response, different internal and external audiences' different needs and preferred methods. A comprehensive communication plan will include:

- who should receive communications (internal and external to the organization)
- the method of communication (voice, SMS, email, chat, web dashboard)
- frequency of communication
- level of detail

An incident can affect multiple parts of an organization, so it is critical to define clear, authorized, and authoritative communication channels in advance. This approach helps minimize misunderstandings and misinformation. Remember that incident details can change as the situation unfolds, so initial statements may need to be corrected or updated later.

Establishing Authority and Accuracy

When many people are involved in an incident response, having a single authoritative source for updates is essential. Otherwise:

- **Speculation** may be mistaken for fact.

- **Facts** might be underplayed due to misunderstanding or lack of context.

All responders should know:

- **Who** is responsible for providing official updates
- **How** updates will be delivered
- **Where** to get reliable information

Communication Channels and Methods

Different communication channels may be necessary for different audiences (e.g., senior management, technical teams, external partners). These channels should be:

- **Documented:** Outlined in policies and procedures.
- **Conveyed:** Shared with all incident response team members.

Example: If a network is suspected of being compromised, normal email systems might be unsafe to use because attackers could be monitoring them. In such cases, the team could switch to a secure, out-of-band email platform (e.g., Google Business) instead of the standard enterprise email (e.g., Microsoft 365).



Communication plans for both testing and actual disasters should be integrated into the broader DR plan with pre-defined templates, approval chains, and contact information. The communication plan should be tested during DR exercises to ensure its effective when it's needed.

Notification Requirements

Notification requirements form a critical part of an Incident Response Plan (IRP). The plan should include:

- A **directory** of key decision-makers, IRT members, system owners, and end users involved in incident response.
- **Multiple contact methods** (phone, cellular, text, email, etc.) to ensure communication even if a channel fails.

Who to Notify

At a minimum, your notification directory should include:

- **Equipment and software vendors**
- **Suppliers** for hardware/software/services
- **Recovery facilities** (e.g., hot site providers, rerouting services)
- **Offsite media storage** contacts (and those authorized to retrieve media)
- **Insurance agents**
- **Regulatory bodies**
- **HR and contract personnel services**
- **Law enforcement contacts**

Law Enforcement Involvement

Only senior management should decide whether to contact law enforcement. Information security managers typically do **not** inform external organizations unless explicitly authorized. Some organizations outsource emergency communications to specialized vendors; if so, ensure the necessary processes are in place to make that service effective.

Notification requirements and timing Notification requirements define **who** must be notified, **when**, and **how** (e.g., internal executives, regulators, law enforcement, customers). Factors that determine requirements include:

- **Regulatory drivers:** GDPR, HIPAA, or other regulations may impose specific timelines.
- **Legal and Public Relations:** Often consulted regarding reputational damage and legal ramifications; know how to coordinate messaging.

Here's a breakdown from a slightly different perspective, addressing considerations across internal and external stakeholders, and an example of communication during a simulation.

Communication with internal stakeholders

- **DR Team:** Requires secure, reliable channels for real-time coordination, problem-solving, and decision-making. Tools like dedicated chat platforms, conference bridges, or even two-way radios (in extreme simulations) may be used.
- **Management:** Needs periodic updates on test progress, any identified issues, and the estimated impact on normal operations. Concise status reports and designated points of contact streamline this communication.
- **Wider Company:** General awareness of a scheduled test minimizes confusion. Pre-testing announcements and a clearly defined 'test mode' indicator (e.g., banners on restored systems, announcements) prevent panic or misunderstandings.

Communication with external stakeholders

- **Customers/Clients:** In large-scale tests or real scenarios, proactive, controlled communication about potential service disruptions (and ETAs for resolution) becomes vital for preserving trust and managing expectations.
- **Partners:** If your testing may impact joint systems or operations, inform partners with relevant timelines and agree on coordination channels.
- **Regulators:** Certain industries have reporting requirements. For tests triggering significant downtime of regulated systems, advance notification or post-test reports might be mandated. Involve compliance experts in plan creation and testing.

Communication considerations for testing

- **Accuracy:** Verified information is essential. Designate an “information source of truth” to avoid rumors and conflicting directives.
- **Tone:** Adapt to the audience. Technical updates for the DR team differ vastly from client-facing notifications.
- **Test Integrity:** Balance providing sufficient updates without revealing details that could undermine the simulation’s validity for participants.
- **Channel Diversity:** Leverage a mix of methods (email, designated status dashboards, phone trees) to ensure redundancy and reach stakeholders quickly despite potential outages during the test.
- **Security:** Secure channels for exchanging critical information (e.g., out-of-band communication, encrypted messaging, dedicated war rooms).

EXAMPLE: Communication during a simulated hot site failover test

- **DR Team:** Uses a secure chat channel to track real-time progress and escalate issues.
- **Management:** Receives scheduled updates from the DR team lead. Major setbacks could trigger an emergency decision-making call.
- **Customers:** A “maintenance notification” appears on the service dashboard, with proactive social media updates if the planned timeline changes.
- **Regulator:** If applicable, a post-test summary report is sent to prove adherence to established RTOs (recovery time objectives) and resilience practices.

Communication Networks

The IRP must detail how the organization will maintain or restore **telecommunications networks** during an incident. Because these networks are critical to business operations, continuity procedures should be a priority.

Telecommunications Vulnerabilities

In addition to natural disasters, telecommunication networks face unique threats, such as:

- Central switching office failures
- Cable cuts
- Communication software errors
- Security breaches (e.g., “phreaking”)
- Human errors

Local exchange carriers (LECs) typically back up main components, but the **enterprise** should also have its own backup and contingency plans rather than relying solely on the carrier.

Continuity Considerations

When planning for telecom continuity, consider:

- **Telephone voice circuits**
- **Wide Area Networks (WANs)** (e.g., connections to distributed data centers)
- **Local Area Networks (LANs)**
- **Third-party network providers**
- **Alternative links** (e.g., satellite, microwave, wireless, or single sideband radiotelephone)

Identify **critical capacity requirements** for different outage durations (e.g., two hours, eight hours, 24 hours). Ensure that **uninterruptible power supplies (UPSs)** can support both telecom and computing equipment to keep communications running during power outages.

Analogy: Think of each communication channel as a lane on a highway. If one lane is under construction (compromised), traffic (incident communication) must switch to another lane (alternative channel) to keep moving effectively.

4B5. Incident Eradication and Recovery

While **containment** focuses on quickly stopping an incident from spreading, **eradication** targets the underlying cause so the incident will not recur. This involves removing any malicious artifacts or backdoors left by attackers, applying patches, and making other necessary changes. Think of containment as putting out a fire, while eradication is fixing the faulty wiring that started it.

In this section, I'll outline the eradication and recovery phases of incident response, highlighting where root cause analysis plays a role. First, it helps to know the meaning of the terms used so frequently in incident management and response. You should know these terms and where they occur in the incident management process.

- **Triage** - The initial assessment and prioritization of an incident. Determining the severity and scope of the incident.
- **Containment** - Attempts to limit and control the incident from spreading. For example, disconnecting infected hosts from the network.
- **Mitigation** - Steps taken to reduce the severity of the incident. Mitigation is the phase where the organization begins to implement actions necessary to fix the incident. For example, blocking malicious IP addresses with a firewall.
- **Recovery** - Restoring affected systems and services *back to normal operations*. For example, restoring data from backups and bringing production systems back online.
- **Remediation** - Removing the underlying causes of the incident to *prevent reoccurrence*. For example, patching vulnerable software.
- **Eradication** - Removing artifacts of the incident like malware and backdoors. For example, completely wiping and reinstalling compromised systems.

In short:

- **Triage** is the *initial assessment*.
- **Containment** and **mitigation** are about *controlling the incident*.
- **Recovery** is about *restoring normal operations* after the incident.
- **Remediation** and **eradication** are about *removing the causes of the incident*.

Eradication Phase

The primary goal of the eradication phase is to remove all artifacts of the incident from the organization's network. *Common activities to eradicate a security incident include:*

- **Root cause analysis**
Determine why the incident occurred and document all contributing factors.
- **Cleanup and removal of artifacts**
Delete or neutralize any malicious files, configurations, or backdoors left behind.
- **Application of outstanding patches**
Update systems and apply security fixes to close vulnerabilities.

- **DNS null routing (sinkhole)**
Redirect malicious IP addresses and domains to prevent further communication with attacker-controlled infrastructure.
- **Adjustments to firewalls and IDSs**
Strengthen firewall and intrusion detection settings to block similar attacks in the future.
- **Scanning for additional indicators of compromise (IoCs)**
Continuously check for evidence of further intrusion across the environment.
- **Removing malicious software**
Eliminate any malware discovered on compromised systems.
- **Wipe/rebuilding impacted systems**
Erase and reinstall operating systems to ensure a clean, trusted environment.
- **Restoring from backups**
Recover from reliable backups taken before the incident to ensure integrity.
- **Secure media sanitation and disposal:** Some exam question may focus on secure disposition of media based on “NIST SP 800-88: Guidelines for Media Sanitization”, which defines three methods of media sanitation:
 - **Clear** applies logical techniques to sanitize data in all user-addressable storage locations for protection against simple noninvasive data recovery techniques; it is typically done through the standard Read and Write commands to the storage device, rewriting with a new value or resetting the device to the factory state.
 - **Purge** applies physical or logical techniques that render target data recovery infeasible using laboratory techniques, such as crypto-shredding, with the goal of rendering data unrecoverable, even through forensic techniques.
 - **Destroy** renders target data recovery (using state-of-the-art laboratory techniques) infeasible and results in the subsequent inability to use the media for storage of data.

Exam Tips:

- **Forensic Preservation:** Don't destroy evidence needed for legal or investigative purposes.
- **Comprehensive Cleanup:** Ensure all threat components (e.g., backdoors) are removed before restoration.

Recovery Phase

Recovery efforts begin only after successful containment and eradication. The primary goal is to bring systems back to normal operation, without reintroducing the vulnerabilities that

caused the incident in the first place. This step demands caution: rushing systems back online may unknowingly restore the same weaknesses or malicious tools that led to the original breach.

Typical recovery activities include:

- **Testing and validating the security baseline**
Confirm that all patches, configurations, and security controls meet organizational requirements.
- **Monitoring for known indicators of attack (IoAs) and indicators of compromise (IoCs)**
Keep a close watch on networks and systems for any signs of new attacks or lingering threats.
- **Searching for adversary artifacts across the enterprise**
Proactively hunt for malicious files, registry changes, or unusual processes.
- **Reintroducing impacted systems into production**
Only move restored systems back to normal operation after they have been thoroughly verified.

Note: Avoid the impulse to speed through recovery. Once a system is compromised, there is no guarantee that removing a few malicious artifacts addresses everything. Hidden backdoors or rootkits can remain undetected if the process is rushed.

CAUTION About Returning to Business as Usual

Simply returning to normal operations often means bringing back the same conditions that allowed the incident to happen in the first place. Properly addressing and remediating the **root cause** is essential for long-term risk management. Although resolving the immediate incident may seem like the finish line, the real work—strengthening defenses, improving processes, and preventing repeat incidents—begins now.

Key Takeaway: Root cause analysis is integral to both phases - it ensures thorough eradication by identifying all compromise vectors and enables secure recovery by preventing the reintroduction of vulnerabilities during system reconstruction. Without proper root cause analysis, organizations risk rebuilding systems that remain vulnerable to the same attack vectors.

4B6. Post-Incident Review Practices

Post-incident review is by some accounts the *most critical* phase of incident response. It offers a structured way to capture lessons learned, refine response processes, justify resource needs, and continually improve the organization's overall security posture.

Key post-incident activities include:

- **Documenting the Incident:** Capture all details of what happened and how it was handled.
- **Seeking Stakeholder Input:** Gather feedback from all involved parties, ensuring different perspectives are considered.
- **Final Report:** Produce a clear, concise report for senior management.
- **Identifying Process Issues and Required Changes:** Determine what failed or could be improved, and update processes or procedures accordingly.
- **Developing Remediation Plans:** Address the root cause to prevent future occurrences.
- **Securing Resources/Funding:** If improvements require new tools, training, or personnel, make a case for the necessary budget.

3. Benefits of Follow-Up

- **Lessons Learned:** Analyze what worked and what didn't to strengthen future incident handling.
- **Cost Calculation:** Assess and justify the cost of the incident (losses, labor, software/hardware), which can support budget requests and may serve as evidence if needed legally.
- **Proactive Focus:** By refining procedures and reducing reaction time, teams can spend more effort on prevention and other strategic initiatives.

The information security manager coordinates the entire post-incident review, potentially bringing in third-party forensic specialists if specialized expertise is required.



The most valuable part of incident response is often the follow-up. Lessons learned during containment and recovery help improve both security practices and the incident response process itself.

Identifying Causes and Corrective Actions

Security incidents can stem from a variety of sources:

- **External attacks** (e.g., cybercriminals, hacktivists)
- **Internal attacks** (e.g., malicious insiders)

- **Failures in existing security controls** (e.g., unpatched systems, misconfigurations)

A dedicated incident review team should analyze the root causes and recommend measures to prevent similar events. For example, a system compromise may reveal weak vulnerability assessment and patch management processes. *The review team typically asks questions such as:*

- Who was involved?
- What exactly happened?
- Where did the attack originate?
- When did it occur, and over what timeframe?
- Why did it happen?
- How was the system vulnerable?
- Was there a specific motivation behind the attack?

The answers to these questions will facilitate meaningful documentation of events and guidance on potential areas for improvement.

Documenting Events

Effective documentation is critical during and after an incident. A clear, detailed record of events helps:

- **Facilitate investigations** and serve as evidence if legal action is pursued
- **Provide clarity** on whether an event was accidental, a mistake, or malicious

In a serious incident, events can become chaotic. Having at least one individual in charge of documentation and evidence preservation ensures consistency and accuracy.

Analogy: Think of a security incident like a burglary at your facility. If everyone rushes in, moving objects and cleaning up immediately, crucial evidence can be lost or tainted. Assigning a specific person to document the scene preserves vital information for investigators.

Establishing Legal Procedures to Assist in Post-Incident Activities

Given the rise of cybercrime and increasing regulatory scrutiny, it is essential to involve legal counsel in preparing for and responding to security incidents. A comprehensive Incident Response Plan (IRP) should be:

- **Customized to the enterprise** and thoroughly tested
- **Developed with input** from legal counsel, security teams, and key stakeholders
- **Kept up to date** to reflect changes in laws, regulations, and business operations

A strong IRP details:

1. **Core team responsibilities** (who manages and coordinates the response).
2. **Documenting key events** before and after discovery of a compromise.
3. **Communication procedures** (internal, external, law enforcement, regulators, legal counsel, insurance, media).
4. **Decision-making milestones** (approval steps and escalation points).
5. **Pre-approved notification templates** to meet legally mandated notification deadlines.

In regulated environments, legal counsel should be engaged immediately when a breach is detected. They can advise on legal obligations, notification timelines, and help protect the confidentiality of the investigation under attorney-client privilege.

Requirements for Evidence

The ability to pursue legal action or conduct a thorough forensic examination often depends on preserving evidence correctly. Improper handling of data can:

- **Destroy critical leads**
- **Render evidence inadmissible** in court
- **Obscure how the attack occurred** and how to strengthen defenses

Typical Guidance: Law enforcement may recommend powering off a compromised system to preserve data on the hard drive and prevent further overwriting by swap files or malware. However, this practice remains controversial because it destroys data in memory—potentially losing evidence if the malware was only memory-resident.

Key Takeaway: The information security manager should define the most suitable approach for the enterprise and train staff accordingly.

Forensic Imaging:

If a system is secured for investigation, a bit-by-bit image of the hard drive(s) and other media must be created with forensically sound tools. To maintain admissibility:

- **Use write-protect** hardware (e.g., a cable with a write-protect diode).
- **Calculate and compare hash values** of the source and destination to verify exact copies.
- **Store the original media** in a secure location.
- **Maintain a chain of custody** to document who accessed the evidence and when.

Legal Aspects of Forensic Evidence

To be admissible in court, evidence must be collected in a forensically sound manner, with a documented chain of custody. The information security manager should have established procedures that specify:

1. Chain of custody forms

- Contact details for each custodian
- Dates and reasons for each transfer of the evidence
- Detailed evidence identification (serial numbers, model info, etc.)

2. Checklists for acquisition

- Legally acceptable forensic practices
- Step-by-step procedures for collecting data

3. Detailed activity logs

- Record of all investigator actions and observations

4. Nondisclosure/confidentiality forms

- Signed by all technicians and personnel involved

5. Comprehensive case logs

- Dates requests were received and assigned
- Investigator and requester contact details
- Case numbers, actions taken, and completion dates

6. Investigation report templates

- Investigator names, dates, and case numbers
- Interview details and communications with management/staff
- Tools used for acquisition/analysis (forensically validated)
- Findings and location of supporting data or evidence

All investigations should be fair, unbiased, and meticulously documented. The information security manager must work with legal counsel, HR, and other stakeholders to develop a legally sound approach that respects jurisdictional requirements and judicial standards.

Key Takeaway: Just as police carefully log every piece of evidence from a crime scene, digital evidence must be handled with equal diligence, never letting it out of sight without proper documentation and ensuring it remains unaltered.

Other Post-Incident Activities and Considerations

Other important post-incident activities and considerations include:

- **Evidence Retention**

Identify both internal and external evidence retention requirements. If legal action is a possibility, consult attorneys before discarding any evidence.

- **Post-Incident Review Practices**

- **Identifying Causes and Corrective Actions:** Using root cause analysis to determine what led to the incident and how to prevent recurrence.
- **Documenting Events:** Keeping an accurate log of **timelines, actions taken**, impacted systems, and involved personnel.
- **Legal procedures:** Involving legal counsel in evidence handling, breach notifications, or potential litigation.

By integrating post-incident reviews, thorough documentation, and legally sound forensic procedures, the information security manager helps ensure that each incident strengthens the security program. A clear, repeatable process for managing incidents and preserving evidence both protects the enterprise from future threats and provides a solid foundation for any subsequent legal or regulatory proceedings.

Exam Tips:

- **Lessons Learned:** ISACA frequently tests how organizations incorporate these into policy updates.
- **Continuous Improvement:** Link findings back to risk management and training programs.
- **Attorney-Client Privilege:** Certain communications may be privileged; watch for scenario questions about limiting exposure.
- **Regulatory Actions:** Understand the role of legal in shaping responses to possible compliance violations.

What's Next?

That's a wrap on CISM: The Last Mile"! I hope you're getting value from this book and feeling better equipped for the exam or at least have line-of-sight to the finish line. If you still have doubts in your mind, circle back to "Exam Prep Strategy" in the Preface at the beginning of this book and make a plan.

If you have questions, I'm here for you! Contact me at lastmilebooks@outlook.com and just ask.

Good luck!

Appendix A - Glossary (ISACA CISM Official)

These are the glossary terms ISACA says you should be familiar with for the exam, and many are not covered in their official study materials. Rather than simply listing them in alphabetical order, you'll see they are grouped here by functional areas tested by the CISM exam so you can consume them more easily.

Groupings are as follows:

1. **Governance and Management** - Terms related to organizational oversight, policies, and strategic direction (aligns with Information Security Governance).
2. **Risk Management** - Terms focused on identifying, assessing, and responding to risks (aligns with Information Risk Management).
3. **Security Program and Controls** - Terms about designing, implementing, and managing security measures (aligns with Information Security Program Development and Management).
4. **Incident Management and Recovery** - Terms related to handling incidents, disasters, and business continuity (aligns with Information Security Incident Management).
5. **Technical Security Mechanisms** - Terms covering encryption, authentication, and technical defenses.
6. **Network and Infrastructure Security** - Terms specific to network architecture, protocols, and infrastructure protection.
7. **Threats and Vulnerabilities** - Terms describing threats, attack methods, and system weaknesses.
8. **Data and Asset Management** - Terms related to managing and protecting data and assets.

1. Governance and Management

- **Acceptable use policy** - A policy that establishes an agreement between users and the enterprise that defines, for all parties, the ranges of use that are approved before gaining access to a network or the Internet.
- **Accountability** - The ability to map a given activity or event back to the party who must ultimately answer for the result.
- **Benchmarking** - A systematic approach to comparing enterprise performance against peers and competitors in an effort to learn the best ways of conducting business.

- **Business case** - Documentation of the rationale for making a business investment, used both to support a business decision on whether to proceed with the investment and as an operational tool to support management of the investment through its full economic life cycle.
- **Business Model for Information Security (BMIS)** - A holistic and business-oriented model that supports enterprise governance and management information security, and provides a common language for information security professionals and business management.
- **Capability Maturity Model Integration (CMMI)** - An integrated model of best practices that enable businesses to improve performance by improving their processes.
- **Change management** - 1. A holistic and proactive approach to managing the transition from a current to a desired organizational state, focusing specifically on the critical human or “soft” elements of change (ISACA). 2. A methodical approach for controlling and implementing changes in a planned and structured manner (CMMI).
- **Chief information officer (CIO)** - The most senior official of the enterprise who is accountable for IT advocacy, aligning IT and business strategies, and planning, resourcing and managing the delivery of IT services, information and the deployment of associated human resources.
- **Chief information security officer (CISO)** - The person in charge of information security within the enterprise.
- **Chief security officer (CSO)** - The person usually responsible for all physical and digital security matters in an enterprise.
- **Chief technology officer (CTO)** - The individual who focuses on technical issues in an enterprise.
- **COBIT** - 1. COBIT 2019: The current iteration of COBIT builds on and integrates more than 25 years of developments in the field of enterprise governance of information and technology (I&T), not only incorporating new insights from science, but also operationalizing these insights as practices. 2. COBIT 5: Formerly known as Control Objectives for Information and related Technology (COBIT); with this iteration used only as the acronym. 3. COBIT 4.1 and earlier: Formally known as Control Objectives for Information and related Technology (COBIT).
- **Configuration management** - The process of establishing and maintaining consistent security settings and controls across an organization’s systems and devices. This ensures that hardware and software are set up securely and that these secure configurations are maintained over time, reducing vulnerabilities and preventing unauthorized changes.
- **Corporate governance** - The system by which enterprises are directed and controlled.
- **Cost-benefit analysis** - An analysis that relies on the addition of positive factors and the subtraction of negative factors to determine a net result, and is a Message used to build a business case to support a risk response.
- **COSO** - Committee of Sponsoring Organizations of the Treadway Commission.

- **Due care** - The level of care expected from a reasonable person of similar competency under similar conditions.
- **Due diligence** - The performance of those actions that are generally regarded as prudent, responsible and necessary to conduct a thorough and objective investigation, review and/or analysis.
- **Enterprise governance** - A set of responsibilities and practices exercised by the board and executive management with the goal of providing strategic direction, ensuring that objectives are achieved, ascertaining that risk is managed appropriately and verifying that the enterprise's resources are used responsibly.
- **Guideline** - A description of a particular way of accomplishing something that is less prescriptive than a procedure.
- **Information security governance** - The set of responsibilities and practices exercised by the board and executive management with the goal of providing strategic direction, ensuring that objectives are achieved, ascertaining that risk is managed appropriately and verifying that the enterprise's resources are used responsibly.
- **IT governance** - The responsibility of executives and the board of directors; consists of the leadership, organizational structures and processes that ensure that the enterprise's IT sustains and extends the enterprise's strategies and objectives.
- **IT steering committee** - An executive-management-level committee that assists in the delivery of the IT strategy, oversees day-to-day management of IT service delivery and IT projects, and focuses on implementation aspects.
- **IT strategic plan** - A long-term plan (i.e., three- to five-year horizon) in which business and IT management cooperatively describe how IT resources will contribute to the enterprise's strategic objectives (goals).
- **IT strategy committee** - A committee at the level of the board of directors to ensure that the board is involved in major IT matters and decisions.
- **Key goal indicator (KGI)** - A measure that tells management, after the fact, whether an IT process has achieved its business requirements; usually expressed in terms of information criteria.
- **Key performance indicator (KPI)** - A performance indicator or key performance indicator is a type of performance measurement.
- **Monitoring policy** - Rules outlining or delineating the way in which information about the use of computers, networks, applications and information is captured and interpreted.
- **Net present value (NPV)** - Calculated by using an after-tax discount rate of an investment and a series of expected incremental cash outflows (the initial investment and operational costs) and cash inflows (cost savings or revenues) that occur at regular periods during the life cycle of the investment.
- **Outcome measure** - Represents the consequences of actions previously taken; often referred to as a lag indicator.
- **Policy** - A document that communicates required and prohibited activities and behaviors.

- **Procedure** - A document containing a detailed description of the steps necessary to perform specific operations in conformance with applicable standards.
- **Request for proposal (RFP)** - A document distributed to software vendors requesting them to submit a proposal to develop or provide a software product.
- **Return on investment (ROI)** - A measure of operating performance and efficiency, computed in its simplest form by dividing net income by the total investment over the period being considered.
- **Service level agreement (SLA)** - An agreement, preferably documented, between a service provider and the customer(s)/user(s) that defines minimum performance targets for a service and how they will be measured.
- **Standard** - A mandatory requirement, code of practice or specification approved by a recognized external standards organization, such as International Organization for Standardization (ISO).
- **Total cost of ownership (TCO)** - Includes the original cost of the computer plus the cost of: software, hardware and software upgrades, maintenance, technical support, training, and certain activities performed by users.

2. Risk Management

- **Annual loss expectancy (ALE)** - The total expected loss divided by the number of years in the forecast period yielding the average annual loss.
- **Business impact** - The net effect, positive or negative, on the achievement of business objectives.
- **Business impact analysis (BIA)** - Process of evaluating the criticality and sensitivity of information assets by determining the impact of losing the support of any resource to an enterprise.
- **Criticality** - The importance of a particular asset or function to the enterprise, and the impact if that asset or function is not available.
- **Criticality analysis** - An analysis to evaluate resources or business functions to identify their importance to the enterprise, and the impact if a function cannot be completed or a resource is not available.
- **Exposure** - The potential loss to an area due to the occurrence of an adverse event.
- **Impact analysis** - A study to prioritize the criticality of information resources for the enterprise based on costs (or consequences) of adverse events. In an impact analysis, threats to assets are identified and potential business losses determined for different time periods. This assessment is used to justify the extent of safeguards that are required and recovery time frames. This analysis is the basis for establishing the recovery strategy.
- **Key risk indicator (KRI)** - A subset of risk indicators that are highly relevant and possess a high probability of predicting or indicating important risk.
- **Residual risk** - The remaining risk after management has implemented a risk response.

- **Risk acceptance** - Decision to accept a risk, made according to the risk appetite and risk tolerance set by senior management where the enterprise can assume the risk and absorb any losses.
- **Risk analysis** - 1. A process by which frequency and magnitude of IT risk scenarios are estimated. 2. The initial steps of risk management: analyzing the value of assets to the business, identifying threats to those assets and evaluating how vulnerable each asset is to those threats.
- **Risk appetite** - The amount of risk, on a broad level, that an entity is willing to accept in pursuit of its mission.
- **Risk assessment** - A process used to identify and evaluate risk and its potential effects.
- **Risk avoidance** - The process for systematically avoiding risk, constituting one approach to managing risk.
- **Risk management** - The process of identifying, assessing, and responding to risk (not explicitly defined in the list, but implied through related terms).
- **Risk mitigation** - The management of risk through the use of countermeasures and controls.
- **Risk response** - Risk avoidance, risk acceptance, risk sharing/transfer, risk mitigation, leading to a situation that as much future residual risk (current risk with the risk response defined and implemented) as possible (usually depending on budgets available) falls within risk appetite limits.
- **Risk tolerance** - The acceptable level of variation that management is willing to allow for any particular risk as the enterprise pursues its objectives.
- **Risk transfer** - The process of assigning risk to another enterprise, usually through the purchase of an insurance policy or by outsourcing the service.
- **Security metrics** - A standard of measurement used in management of security-related activities.
- **Sensitivity** - A measure of the impact that improper disclosure of information may have on an enterprise.
- **Threat** - Anything (e.g., object, substance, human) that is capable of acting against an asset in a manner that can result in harm.
- **Threat agent** - Methods and things used to exploit a vulnerability.
- **Threat analysis** - An evaluation of the type, scope and nature of events or actions that can result in adverse consequences; identification of the threats that exist against enterprise assets.
- **Threat event** - Any event during which a threat element/actor acts against an asset in a manner that has the potential to directly result in harm.
- **Threat vector** - The path or route used by the adversary to gain access to the target.
- **Vulnerability** - A weakness in the design, implementation, operation or internal control of a process that could expose the system to adverse threats from threat events.

- **Vulnerability analysis** - A process of identifying and classifying vulnerabilities.

3. Security Program and Controls

- **Access control** - The processes, rules and deployment mechanisms that control access to information systems, resources and physical access to premises.
- **Access rights** - The permission or privileges granted to users, programs or workstations to create, change, delete or view data and files within a system, as defined by rules established by data owners and the information security policy.
- **Administrative control** - The rules, procedures and practices dealing with operational effectiveness, efficiency and adherence to regulations and management policies.
- **Application controls** - The policies, procedures and activities designed to provide reasonable assurance that objectives relevant to a given automated solution (application) are achieved.
- **Baseline security** - The minimum security controls required for safeguarding an IT system based on its identified needs for confidentiality, integrity and/or availability protection.
- **Compensating control** - An internal control that reduces the risk of an existing or potential control weakness resulting in errors and omissions.
- **Configuration management** - The process of establishing and maintaining consistent security settings and controls across an organization's systems and devices. This ensures that hardware and software are set up securely and that these secure configurations are maintained over time, reducing vulnerabilities and preventing unauthorized changes.
- **Continuous monitoring** - The process implemented to maintain a current security status for one or more information systems or for the entire suite of information systems on which the operational mission of the enterprise depends.
- **Control** - The means of managing risk, including policies, procedures, guidelines, practices or organizational structures, which can be of an administrative, technical, management or legal nature.
- **Countermeasure** - Any process that directly reduces a threat or vulnerability.
- **Defense in depth** - The practice of layering defenses to provide added protection. Defense in depth increases security by raising the effort needed in an attack. This strategy places multiple barriers between an attacker and enterprise computing and information resources.
- **Discretionary access control (DAC)** - Logical access control filters that may be configured or modified by the users or data owners.
- **Dual control** - A procedure that uses two or more entities (usually persons) operating in concert to protect a system resource so that no single entity acting alone can access that resource.

- **Guideline** - A description of a particular way of accomplishing something that is less prescriptive than a procedure.
- **Harden** - To configure a computer or other network device to resist attacks.
- **Identity and access management (IAM)** - Encapsulates people, processes and products to identify and manage the data used in an information system to authenticate users and grant or deny access rights to data and system resources. The goal of IAM is to provide appropriate access to enterprise resources.
- **Information security** - Ensures that, within the enterprise, information is protected against disclosure to unauthorized users (confidentiality), improper modification (integrity) and nonaccess when required (availability). Information security deals with all formats of information-paper documents, digital assets, intellectual property in people's minds, and verbal and visual communications.
- **Information security program** - The overall combination of technical, operational and procedural measures and management structures implemented to provide for the confidentiality, integrity and availability of information based on business requirements and risk analysis.
- **ISO/IEC 17799** - This standard defines information's confidentiality, integrity and availability controls in a comprehensive information security management system.
- **ISO/IEC 27001** - Information Security Management-Specification with Guidance for Use; the replacement for BS7799-2. It is intended to provide the foundation for third-party audit and is harmonized with other management standards, such as ISO/IEC 9001 and 14001.
- **Mandatory access control (MAC)** - Logical access control filters used to validate access credentials that cannot be controlled or modified by normal users or data owners.
- **Procedure** - A document containing a detailed description of the steps necessary to perform specific operations in conformance with applicable standards.
- **Security as a Service (SecaaS)** - The next generation of managed security services dedicated to the delivery, over the Internet, of specialized information-security services.

4. Incident Management and Recovery

- **Acceptable interruption window (AIW)** - The maximum period of time that a system can be unavailable before compromising the achievement of the enterprise's business objectives.
- **Alert situation** - The point in an emergency procedure when the elapsed time passes a threshold and the interruption is not resolved. The enterprise entering into an alert situation initiates a series of escalation steps.
- **Alternate facilities** - Locations and infrastructures from which emergency or backup processes are executed, when the main premises are unavailable or destroyed.
- **Alternate process** - Automatic or manual process designed and established to continue critical business processes from point-of-failure to return-to-normal.

- **Backup center** - An alternate facility to continue IT/IS operations when the primary data processing (DP) center is unavailable.
- **Blue team** - A group that proactively conducts systematic examinations of information systems or products to determine the adequacy of security measures, identify security deficiencies, respond to technical security incidents and confirm the adequacy of such measures after implementation.
- **Business continuity** - Preventing, mitigating and recovering from disruption.
- **Business continuity plan (BCP)** - A plan used by an enterprise to respond to disruption of critical business processes; depends on the contingency plan for restoration of critical systems.
- **Business dependency assessment** - A process of identifying resources critical to the operation of a business process.
- **Chain of custody** - The process of evidence handling from collection to presentation that is necessary to maintain the validity and integrity of evidence.
- **Contingency plan** - A plan used by an enterprise or business unit to respond to a specific systems failure or disruption.
- **Contingency planning** - Process of developing advance arrangements and procedures that enable an enterprise to respond to an event that could occur by chance or unforeseen circumstances.
- **Control center** - Hosts the recovery meetings where disaster recovery operations are managed.
- **Disaster declaration** - The communication to appropriate internal and external parties that the disaster recovery plan (DRP) is being put into operation.
- **Disaster notification fee** - The fee that the recovery site vendor charges when the customer notifies them that a disaster has occurred and the recovery site is required. The fee is implemented to discourage false disaster notifications.
- **Disaster recovery** - Activities and programs designed to return the enterprise to an acceptable condition. The ability to respond to an interruption in services by implementing a disaster recovery plan (DRP) to restore an enterprise's critical business functions.
- **Disaster recovery plan (DRP)** - A set of human, physical, technical and procedural resources to recover, within a defined time and cost, an activity interrupted by an emergency or disaster.
- **Disaster recovery plan (DRP) desk checking** - Typically a read-through of a disaster recovery plan (DRP) without any real actions taking place. Generally involves a reading of the plan, discussion of the action items and definition of any gaps that might be identified.
- **Disaster recovery plan (DRP) walk-through** - Generally a robust test of the recovery plan requiring that some recovery activities take place and are tested. A disaster scenario is often given, and the recovery teams talk through the steps that they would need to take to recover. As many aspects of the plan as possible should be tested.

- **Eradication** - When containment measures have been deployed after an incident occurs, the root cause of the incident must be identified and removed from the network.
- **Incident** - A violation or imminent threat of violation of computer security policies, acceptable use policies, guidelines or standard security practices.
- **Incident response** - The response of an enterprise to a disaster or other significant event that may significantly affect the enterprise, its people or its ability to function productively. An incident response may include evacuation of a facility, initiating a disaster recovery plan (DRP), performing damage assessment and any other measures necessary to bring an enterprise to a more stable status.
- **Incident response plan (IRP)** - The operational component of incident management.
- **Interruption window** - The time that the company can wait from the point of failure to the restoration of the minimum and critical services or applications. After this time, the progressive losses caused by the interruption are excessive for the enterprise.
- **Intrusion detection** - The process of monitoring the events occurring in a computer system or network to detect signs of unauthorized access or attack.
- **Intrusion detection system (IDS)** - Inspects network and host security activity to identify suspicious patterns that may indicate a network or system attack.
- **Intrusion prevention system (IPS)** - A system designed to not only detect attacks but also prevent the intended victim hosts from being affected by the attacks.
- **Maximum tolerable outages (MTO)** - Maximum time that an enterprise can support processing in alternate mode.
- **Paper test** - A walk-through of the steps of a regular test, but without actually performing the steps.
- **Passive response** - A response option in intrusion detection in which the system simply reports and records the problem detected, relying on the user to take subsequent action.
- **Reciprocal agreement** - Emergency processing agreement between two or more enterprises with similar equipment or applications.
- **Recovery action** - Execution of a response or task according to a written procedure.
- **Recovery point objective (RPO)** - Determined based on the acceptable data loss in case of a disruption of operations.
- **Recovery time objective (RTO)** - The amount of time allowed for the recovery of a business function or resource after a disaster occurs.
- **Red team** - A group authorized and organized to emulate bad actors using similar tactics, techniques, and procedures to provide feedback from an offensive perspective.
- **Root cause analysis** - A process of diagnosis to establish the origins of events, which can be used for learning from consequences, typically from errors and problems.
- **Service delivery objective (SDO)** - Directly related to the business needs, SDO is the level of services to be reached during the alternate process mode until the normal situation is restored.

5. Technical Security Mechanisms

- **Advanced Encryption Standard (AES)** - A public algorithm that supports keys from 128 bits to 256 bits in size.
- **Algorithm** - A finite set of well-defined, unambiguous rules for the solution of a problem in a finite number of steps; it is a sequence of operational actions that lead to a desired goal and is the basic building block of a program.
- **Antimalware** - A widely used technology to prevent, detect, and remove many categories of malware, including computer viruses, worms, Trojans, keyloggers, malicious browser plug-ins, adware, and spyware.
- **Antiphishing** - Software that identifies phishing content and attempts to block the content or warn the user about the suspicious nature of the content.
- **Antivirus software** - An application software deployed at multiple points in an IT architecture.
- **Asymmetric key (public key)** - A cipher technique in which different cryptographic keys are used to encrypt and decrypt a message.
- **Authentication** - 1. The act of verifying identity, i.e., user, system. 2. The act of verifying the identity of a user, the user's eligibility to access computerized information.
- **Certificate (Certification) authority (CA)** - A trusted third party that serves authentication infrastructures or enterprises and registers entities and issues them certificates.
- **Certificate revocation list (CRL)** - An instrument for checking the continued validity of the certificates for which the certification authority (CA) has responsibility.
- **Certification practice statement (CPS)** - A detailed set of rules governing the certificate authority's operations.
- **Challenge/response token** - A method of user authentication that is carried out through use of the Challenge Handshake Authentication Protocol (CHAP).
- **Checksum** - A checksum value is generated by an algorithm and associated with an input value and/or whole input file.
- **Cryptography** - The study of mathematical techniques related to aspects of information security, such as confidentiality, data integrity, entity authentication, and data origin authentication.
- **Cyclical redundancy check (CRC)** - A method to ensure that data have not been altered after being sent through a communication channel.
- **Decryption key** - A digital piece of information used to recover plaintext from the corresponding ciphertext by decryption.
- **Digital certificate** - Electronic credentials that permit an entity to exchange information securely via the Internet using the public key infrastructure (PKI).
- **Digital code signing** - The process of digitally signing computer code to ensure its integrity.

- **Encryption** - The process of taking an unencrypted message (plaintext), applying a mathematical function to it (encryption algorithm with a key), and producing an encrypted message (ciphertext).
- **Firewall** - A system or combination of systems that enforces a boundary between two or more networks, typically forming a barrier between a secure and an open environment such as the Internet.
- **Hash function** - 1. An algorithm that maps or translates one set of bits into another (generally smaller) so that a message yields the same result every time the algorithm is executed using the same message as input. 2. Fixed values derived mathematically from a text message.
- **Message authentication code** - An American National Standards Institute (ANSI) standard checksum that is computed using Data Encryption Standard (DES).
- **Message digest** - A cryptographic hash function takes an input of an arbitrary length and produces an output (also known as a message digest) that is a standard-sized binary string. The output is unique to the input in such a way that even a minor change to the input results in a completely different output.
- **Nonrepudiation** - The assurance that a party cannot later deny originating data; provision of proof of the integrity and origin of the data that can be verified by a third party.
- **Private key** - A mathematical key (kept secret by the holder) used to create digital signatures and, depending on the algorithm, to decrypt messages or files encrypted (for confidentiality) with the corresponding public key.
- **Public key** - In an asymmetric cryptographic scheme, the key that may be widely published to enable the operation of the scheme.
- **Split knowledge/split key** - A security technique in which two or more entities separately hold data items that individually convey no knowledge of the information that results from combining the items; a condition under which two or more entities separately have key components that individually convey no knowledge of the plain text key that will be produced when the key components are combined in the cryptographic module.
- **Symmetric key encryption** - System in which a different key (or set of keys) is used by each pair of trading partners to ensure that no one else can read their messages.
- **Token** - In security systems, a physical device that is used to authenticate a user, typically in addition to a username and password; in programming languages, a single element of the language.
- **Trusted system** - A system that employs sufficient hardware and software assurance measures to allow their use for processing a range of sensitive or classified information.
- **Two-factor authentication** - The use of two independent mechanisms for authentication (e.g., requiring a smart card and a password); typically the combination of something you know, are, or have.

6. Network and Infrastructure Security

- **Architecture** - Description of the fundamental underlying design of the components of the business system, or of one element of the business system (e.g., technology), the relationships among them, and the manner in which they support enterprise objectives.
- **Application service provider (ASP)** - Also known as managed service provider (MSP), it deploys, hosts, and manages access to a packaged application to multiple parties from a centrally managed facility.
- **Decentralization** - The process of distributing computer processing to different locations within an enterprise.
- **Demilitarized zone (DMZ)** - A small, isolated network that serves as a buffer zone between trusted and untrusted networks.
- **Disk mirroring** - The practice of duplicating data in separate volumes on two hard disks to make storage more fault tolerant. Mirroring provides data protection in the case of disk failure because data are constantly updated to both disks.
- **Dynamic Host Configuration Protocol (DHCP)** - A protocol used by networked computers (clients) to obtain IP addresses and other parameters such as the default gateway, subnet mask, and IP addresses of domain name system (DNS) servers from a DHCP server.
- **Fail-over** - The transfer of service from an incapacitated primary component to its backup component.
- **Fail-safe** - A system or component that automatically places itself in a safe operational mode in the event of a failure.
- **Hypertext Transfer Protocol (HTTP)** - A communication protocol used to connect to servers on the World Wide Web. Its primary function is to establish a connection with a web server and transmit hypertext markup language (HTML), extensible markup language (XML), or other pages to client browsers.
- **Hypertext Transfer Protocol Secure (HTTPS)** - A protocol for accessing a secure web server, whereby all data transferred are encrypted. Standard port number is 443.
- **Infrastructure as a Service (IaaS)** - Offers the capability to provision processing, storage, networks, and other fundamental computing resources, enabling the customer to deploy and run arbitrary software, which can include operating systems (OSs) and applications.
- **Internet service provider (ISP)** - A third party that provides individuals and enterprises with access to the Internet and a variety of other Internet-related services.
- **IP Security (IPSec)** - A set of protocols developed by the Internet Engineering Task Force (IETF) to support the secure exchange of packets.
- **Mail relay server** - An electronic mail (e-mail) server that relays messages so that neither the sender nor the recipient is a local user.
- **Media access control (MAC)** - Lower sublayer of the OSI Model Data Link layer.

- **Network address translation (NAT)** - A methodology of modifying network address information in IP datagram packet headers while they are in transit across a traffic routing device for the purpose of remapping one IP address space into another.
- **Packet** - Protocol data unit that is routed from source to destination in a packet-switched network.
- **Packet filtering** - Controlling access to a network by analyzing the attributes of the incoming and outgoing packets and either letting them pass or denying them based on a list of rules.
- **Packet switching** - The process of transmitting messages in convenient pieces that can be reassembled at the destination.
- **Platform as a Service (PaaS)** - Offers the capability to deploy onto the cloud infrastructure customer-created or -acquired applications that are created using programming languages and tools supported by the provider.
- **Port** - A process or application-specific software element serving as a communication endpoint for the transport layer IP protocols (UDP and TCP).
- **Proxy server** - A server that acts on behalf of a user.
- **Redundant array of inexpensive disks (RAID)** - Provides performance improvements and fault-tolerant capabilities via hardware or software solutions, by writing to a series of multiple disks to improve performance and/or save large files simultaneously.
- **Secure Shell (SSH)** - Network protocol that uses cryptography to secure communication, remote command line login, and remote command execution between two networked computers.
- **Software as a Service (SaaS)** - Offers the capability to use the provider's applications running on cloud infrastructure.
- **Tunneling** - Commonly used to bridge between incompatible hosts/routers or to provide encryption, a method by which one network protocol encapsulates another protocol within itself.
- **Uniform resource locator (URL)** - The string of characters that form a web address.
- **Virtual private network (VPN)** - A secure private network that uses the public telecommunications infrastructure to transmit data.
- **Voice-over Internet Protocol (VoIP)** - Also called IP Telephony, Internet Telephony, and Broadband Phone, a technology that makes it possible to have a voice conversation over the Internet or over any dedicated Internet Protocol (IP) network instead of over dedicated voice transmission lines.
- **Web hosting** - The business of providing the equipment and services required to host and maintain files for one or more websites and provide fast Internet connections to those sites.
- **Web server** - End-point hardware or software that serves web pages to users.
- **Wide area network (WAN)** - A computer network connecting multiple offices or buildings over a larger area.

- **Wi-Fi Protected Access II (WPA2)** - Wireless security protocol that supports 802.11i encryption standards to provide greater security.

7. Threats and Vulnerabilities

- **Advanced persistent threat (APT)** - An adversary that possesses sophisticated levels of expertise and significant resources, which allow them to create opportunities to achieve their objectives by using multiple attack vectors, e.g., cyber, physical, and deception.
- **Anomaly detection** - Detection on the basis of whether the system activity matches that defined as abnormal.
- **Attack vector** - A path or route used by the adversary to gain access to the target (asset).
- **Botnet** - A term derived from robot network; a large automated and distributed network of previously compromised computers that can be simultaneously controlled to launch large-scale attacks, such as a denial-of-service attack, on targeted victims.
- **Brute-force attack** - Methodically trying all possible combinations of passwords or encryption keys until the correct one is found.
- **Denial-of-service attack (DoS)** - An assault on a service from a single source that floods it with so many requests that it becomes overwhelmed and is either stopped completely or operates at a significantly reduced rate.
- **Distributed denial-of-service attack (DDoS)** - A denial-of-service (DoS) assault from multiple sources.
- **Honeypot** - A specially configured server, also known as a decoy server, designed to attract and monitor intruders in a manner so that their actions do not affect production systems.
- **Malware** - Short for malicious software. Designed to infiltrate, damage, or obtain information from a computer system without the owner's consent. Examples of malware include computer viruses, worms, Trojan horses, spyware, and adware.
- **Man-in-the-middle attack (MITM)** - An attack strategy in which the attacker intercepts the communication stream between two parts of the victim system and then replaces the traffic between the two components with the intruder's own, eventually assuming control of the communication.
- **Masqueraders** - Attackers that penetrate systems by using the identity of legitimate users and their logon credentials.
- **Nonintrusive monitoring** - The use of transported probes or traces to assemble information, track traffic, and identify vulnerabilities.
- **Password cracker** - A tool that tests the strength of user passwords by searching for passwords that are easy to guess.
- **Phishing** - A type of electronic mail (email) attack that attempts to convince a user that the originator is genuine, but with the intention of obtaining information for use in social engineering.

- **Rootkit** - A software suite designed to aid an intruder in gaining unauthorized administrative access to a computer system.
- **Sniffing** - The process by which data traversing a network are captured or monitored.
- **Social engineering** - An attack based on deceiving users or administrators at the target site into revealing confidential or sensitive information.
- **Spoofing** - Faking the sending address of a transmission in order to gain illegal entry into a secure system.
- **Virus signature** - The file of virus patterns that are compared with existing files to determine whether they are infected with a virus or worm.
- **Virus signature file** - The file of virus patterns that are compared with existing files to determine whether they are infected with a virus or worm.
- **Worm** - A programmed network attack in which a self-replicating program does not attach itself to programs but rather spreads independently of users' actions.
- **Zero-day exploit** - A vulnerability that is exploited before the software creator/vendor is even aware of its existence.

8. Data and Asset Management

- **Access path** - The logical route that an end user takes to access computerized information.
- **Application programming interface (API)** - A set of routines, protocols, and tools referred to as building blocks used in business application software development.
- **Asset** - Something of either tangible or intangible value that is worth protecting, including people, information, infrastructure, finances, and reputation.
- **Asset inventory** - A register that is used to record all relevant assets.
- **Asset value** - The value of an asset to both the business and to competitors.
- **Audit trail** - Data in the form of a logical path linking a sequence of events, used to trace the transactions that have affected the contents of a record.
- **Bit** - A contraction of the term binary digit, and the most basic and smallest unit of computing information.
- **Bit copy** - Provides an exact image of the original and is a requirement for legally justifiable forensics.
- **Bit-stream image** - Bit-stream backups, also referred to as mirror image backups, involve the backup of all areas of a computer hard disk drive or other type of storage media.
- **Chain of custody** - The process of evidence handling from collection to presentation that is necessary to maintain the validity and integrity of evidence.
- **Computer forensics** - The application of the scientific method to digital media to establish factual information for judicial review.

- **Confidentiality** - Preserving authorized restrictions on access and disclosure, including means for protecting privacy and proprietary information.
- **Data classification** - The assignment of a level of sensitivity to data (or information) that results in the specification of controls for each level of classification.
- **Data custodian** - The individual(s) and department(s) responsible for the storage and safeguarding of computerized data.
- **Data integrity** - The degree to which a collection of data is complete, consistent, and accurate.
- **Data leakage** - Unauthorized transmission of data from an organization either electronically or physically.
- **Data loss prevention** - Detecting and addressing data breaches, exfiltration, or unwanted destruction of data.
- **Data mining** - Generally, the use of computers to analyze large data sets to look for patterns that assist people in making business decisions.
- **Data normalization** - A structured process for organizing data into tables in such a way that it preserves the relationships among the data.
- **Data owner** - The individual(s) who has responsibility for the integrity, accurate reporting, and use of computerized data.
- **Data warehouse** - A generic term for a system that stores, retrieves, and manages large volumes of data.
- **Degauss** - The application of variable levels of alternating current for the purpose of demagnetizing magnetic recording media.
- **Electronic data interchange (EDI)** - The electronic transmission of transactions (information) between two enterprises.
- **Electronic funds transfer (EFT)** - The exchange of money via telecommunications.
- **External storage** - The location that contains the backup copies to be used in case recovery or restoration is required in the event of a disaster.
- **Fall-through logic** - An optimized code based on a branch prediction that predicts which way a program will branch when an application is presented.
- **Forensic examination** - The process of collecting, assessing, classifying, and documenting digital evidence to assist in the identification of an offender and the method of compromise.
- **Help desk** - A service offered via telephone/Internet by an enterprise to its clients or employees that provides information, assistance, and troubleshooting advice regarding software, hardware, or networks.
- **Integrity** - The guarding against improper information modification or destruction, and includes ensuring information nonrepudiation and authenticity.
- **Privacy** - The right of an individual to trust that others will appropriately and respectfully use, store, share, and dispose of their personal and sensitive information.

- **Sensitivity** - A measure of the impact that improper disclosure of information may have on an enterprise.
- **System owner** - Person or organization having responsibility for the development, procurement, integration, modification, operation, maintenance, and/or final disposition of an information system.

Appendix B - Acronyms (ISACA CISM Official)

These are the acronyms ISACA says you should be familiar with for the exam, and many are not covered in their official study materials. *Definitions are included here so you have additional context.*

Acronym	Term	Definition
AIW	Acceptable Interruption Window	The maximum amount of time a business process can be disrupted without causing significant harm to the organization.
ALE	Annual Loss Expectancy	The expected financial loss from a risk over a single year.
API	Application Programming Interface	A set of rules and specifications that allow one application to access the features or data of another application.
ASP	Application Service Provider	A third-party provider that offers software applications to customers over the Internet.
BCP	Business Continuity Plan	A plan that outlines how an organization will continue to operate in the event of a disruption.
BIA	Business Impact Analysis	A process of identifying and assessing the potential impacts of a disruption on business operations.
BYOD	Bring Your Own Device	A policy that allows employees to use their personal devices for work purposes.
CA	Certificate Authority	A trusted entity that issues digital certificates.
CEO	Chief Executive Officer	The highest-ranking executive in an organization.
CERT	Computer Emergency Response Team	A team of experts that responds to computer security incidents.
CFO	Chief Financial Officer	The executive responsible for an organization's finances.

Acronym	Term	Definition
CIO	Chief Information Officer	The executive responsible for an organization's information technology.
CIRT	Computer Incident Response Team	A team of experts that responds to computer security incidents.
CISO	Chief Information Security Officer	The executive responsible for an organization's information security.
CMMI	Capability Maturity Model Integration	A framework that helps organizations improve their processes.
CMU/SEI	Carnegie Mellon University Software Engineering Institute	A research and development center that focuses on software engineering.
COO	Chief Operating Officer	The executive responsible for an organization's day-to-day operations.
COSO	Committee of Sponsoring Organizations of the Treadway Commission	An organization that provides guidance on internal control.
CPO	Chief Privacy Officer	The executive responsible for an organization's privacy.
CPU	Central Processing Unit	The electronic circuitry within a computer that carries out the instructions of a computer program.
CSF	Critical Success Factor	A key area of activity that must be performed well for an organization to achieve its goals.
CSIRT	Computer Security Incident Response Team	A team of experts that responds to computer security incidents.
CSO	Chief Security Officer	The executive responsible for an organization's security.
CRO	Chief Risk Officer	The executive responsible for an organization's risk management.
CTO	Chief Technology Officer	The executive responsible for an organization's technology strategy.
CVE	Common Vulnerabilities and Exposures	A list of known security vulnerabilities.
DAC	Discretionary Access Controls	A type of access control that allows users to control access to their own files and resources.
DBMS	Database Management System	A software application that is used to create, maintain, and access a database.

Acronym	Term	Definition
DDoS	Distributed Denial of Service	An attack that floods a server with traffic from multiple sources to make it unavailable to users.
DHCP	Dynamic Host Configuration Protocol	A network protocol that is used to assign IP addresses to devices on a network.
DMZ	Demilitarized Zone	A network segment that is separated from the rest of the network and used to host publicly accessible servers.
DNS	Domain Name System	A system that translates domain names into IP addresses.
DoS	Denial of Service	An attack that makes a server unavailable to users.
DR	Disaster Recovery	The process of restoring business operations after a disaster.
DRP	Disaster Recovery Plan	A plan that outlines how an organization will recover from a disaster.
EDI	Electronic Data Interchange	The electronic exchange of business documents between organizations.
EGIT	Enterprise Governance of Information & Technology	A framework for governing information and technology.
EGRP	External Gateway Routing Protocol	A routing protocol that is used to exchange routing information between different autonomous systems.
FAIR	Factor Analysis of Information Risk	A quantitative risk assessment framework.
FAR	False-Acceptance Rate	The probability that a biometric system will incorrectly identify an unauthorized user as an authorized user.
HARM	Holistic Approach to Risk Management	A risk management approach that considers all aspects of risk.
HIDS	Host-Based Intrusion Detection System	A system that detects intrusions on a single host.
HIPAA	Health Insurance Portability and Accountability Act (USA)	A US law that protects the privacy of health information.
HR	Human Resources	The department of an organization responsible for managing employees.
HTML	Hypertext Markup Language	The language that is used to create web pages.

Acronym	Term	Definition
HTTP	Hypertext Transfer Protocol	The protocol that is used to transfer files over the web.
HTTPS	Secure Hypertext Transfer Protocol	A secure version of HTTP.
I/O	Input/Output	The communication between a computer and the outside world.
I&T	Information and Technology	The combination of information and technology.
IaaS	Infrastructure as a Service	A cloud computing service that provides access to computing resources such as servers, storage, and networking.
ICMP	Internet Control Message Protocol	A network protocol that is used to send error messages and other control information.
ID	Identification	The process of verifying the identity of a user.
IDS	Intrusion Detection System	A system that detects intrusions on a network.
IEC	International Electrotechnical Commission	An international organization that sets standards for electrical and electronic equipment.
IMT	Incident Management Team	A team of experts that responds to incidents.
IoT	Internet of Things	The network of devices that are connected to the Internet.
IP	Internet Protocol	The protocol that is used to route packets of data across the Internet.
IPF	Information Processing Facility	A facility that houses computer systems and data.
IPS	Intrusion Prevention System	A system that prevents intrusions on a network.
IPSec	Internet Protocol Security	A protocol that provides secure communication over the Internet.
IRP	Incident Response Plan	A plan that outlines how an organization will respond to incidents.
IRT	Incident Response Team	A team of experts that responds to incidents.
IS	Information Systems	The systems that are used to collect, store, process, and distribute information.

Acronym	Term	Definition
ISO	International Organization for Standardization	An international organization that sets standards for various products and services.
ISP	Internet Service Provider	A company that provides access to the Internet.
IT	Information Technology	The use of computers and other technology to manage information.
ITIL	Information Technology Infrastructure Library	A set of best practices for IT service management.
KCI	Key Control Indicator	A metric that is used to measure the effectiveness of a control.
KGI	Key Goal Indicator	A metric that is used to measure the achievement of a goal.
KPI	Key Performance Indicator	A metric that is used to measure the performance of an organization.
KRI	Key Risk Indicator	A metric that is used to measure the likelihood or impact of a risk.
LAN	Local Area Network	A network that connects devices in a small area.
MAC	Mandatory Access Control	A type of access control that restricts access based on the security clearance of the user.
MIME	Multipurpose Internet Mail Extension	A standard that is used to send attachments in email messages.
MitM	Man-in-the-Middle	An attack in which an attacker intercepts communication between two parties.
MTD	Maximum Tolerable Downtime	The maximum amount of time a system can be down without causing significant harm to the organization.
MTO	Maximum Tolerable Outage	The maximum amount of time a system can be unavailable without causing significant harm to the organization.
NAT	Network Address Translation	A technique that maps multiple private IP addresses to a single public IP address.
NCP	Network Control Protocol	A protocol that is used to establish and manage a network connection.
NDA	Nondisclosure Agreement	An agreement that prevents the disclosure of confidential information.

Acronym	Term	Definition
NIST	National Institute of Standards and Technology (USA)	A US government agency that sets standards for various technologies.
NPV	Net Present Value	The present value of future cash flows.
OS	Operating System	The software that controls the hardware of a computer.
OSI	Open System Interconnection	A reference model for network communication.
PaaS	Platform as a Service	A cloud computing service that provides a platform for developing and deploying applications.
PAN	Personal Area Network	A network that connects devices in a very small area.
PCI DSS	Payment Card Industry Data Security Standard	A set of security standards for organizations that process credit card payments.
PDCA	Plan-Do-Check-Act	A four-step cycle for continuous improvement.
PKI	Public Key Infrastructure	A system that is used to manage digital certificates.
POS	Point-of-Sale	A system that is used to process sales transactions.
PRA	Probabilistic Risk Assessment	A type of risk assessment that uses probabilities to estimate the likelihood and impact of risks.
QA	Quality Assurance	The process of ensuring that products and services meet quality standards.
RACI	Responsible, Accountable, Consulted, Informed	A matrix that is used to assign roles and responsibilities.
RAID	Redundant Array of Inexpensive Disks	A technology that stores data on multiple disks to improve performance and reliability.
ROI	Return on Investment	A measure of the profitability of an investment.
ROSI	Return on Security Investment	A measure of the profitability of a security investment.
RPO	Recovery Point Objective	The maximum amount of data that can be lost in the event of a disaster.
RTO	Recovery Time Objective	The maximum amount of time it can take to recover from a disaster.

Acronym	Term	Definition
SaaS	Software as a Service	A cloud computing service that provides access to software applications.
SABSA	Sherwood Applied Business Security Architecture	A framework for enterprise security architecture.
SCADA	Supervisory Control and Data Acquisition	A system that is used to control and monitor industrial processes.
SDLC	System Development Life Cycle	The process of developing and implementing a system.
SDO	Service Delivery Objective	A metric that is used to measure the performance of a service.
SEC	Securities and Exchange Commission (USA)	A US government agency that regulates the securities industry.
SIEM	Security Information and Event Management	A system that collects and analyzes security event data.
SIM	Security Information Management	The process of managing security information.
SLA	Service Level Agreement	An agreement between a service provider and a customer that defines the level of service provided.
SMART	Specific, Measurable, Achievable, Relevant, Time-bound	A set of criteria for setting goals.
SOAP	Simple Object Access Protocol	A protocol that is used to exchange structured information in a distributed environment.
SOP	Standard Operating Procedure	A set of step-by-step instructions that are used to perform a task.
SQL	Structured Query Language	A language that is used to access and manipulate data in a database.
SSH	Secure Shell	A protocol that provides secure remote access to a computer.
SSL	Secure Sockets Layer	A protocol that provides secure communication over the Internet.
SSO	Single Sign-On	A technology that allows users to access multiple applications with a single login.
SWOT	Strengths, Weaknesses, Opportunities, Threats	A strategic planning tool that identifies and analyzes an organization's strengths, weaknesses, opportunities, and threats.
TCO	Total Cost of Ownership	The total cost of owning and operating a system.

Acronym	Term	Definition
TCP	Transmission Control Protocol	A protocol that provides reliable communication between two devices on a network.
TLS	Transport Layer Security	A protocol that provides secure communication over the Internet.
UDP	User Datagram Protocol	A protocol that provides unreliable communication between two devices on a network.
URL	Uniform Resource Locator	The address of a resource on the web.
USB	Universal Serial Bus	A standard for connecting devices to a computer.
VAR	Value at Risk	A measure of the potential financial loss from a risk.
VoIP	Voice-over IP	A technology that allows voice calls to be made over the Internet.
VPN	Virtual Private Network	A technology that creates a secure connection between two networks over the Internet.
XML	Extensible Markup Language	A language that is used to store and exchange data.
XSS	Cross-Site Scripting	A vulnerability that allows an attacker to inject malicious scripts into a web page.

Appendix C - Frameworks Reference

ISACA explicitly states you won't be tested on the details of various information security, risk, or architecture frameworks, but does say that you should be familiar with their high-level function and when and where you'd use them in an enterprise. Here is a list of several popular frameworks from ISACA and elsewhere, with a brief description of each, as well as a link to the source on the website of the entity that maintains it.

NOTE: Some ISO standards require purchase for full access, so links point to official ISO pages with previews or purchase options. Where possible, links lead to official sources or downloadable PDFs; otherwise, they direct to informational pages.

- **CIS CSC** (Center for Internet Security Critical Security Controls) - A set of prioritized security controls designed to protect against common cyber threats; *More info at* [CIS CSC](#)
- **COBIT** (Control Objectives for Information and Related Technologies) - A framework for IT governance and management, aligning IT goals with business objectives; *More info at* [COBIT](#)
- **CSA CCM** (Cloud Security Alliance Cloud Controls Matrix) - A framework providing security controls for cloud service providers and customers to assess risk and compliance; *More info at* [CSA CCM](#)
- **ETSI TR 103 787-1** (European Telecommunications Standards Institute Technical Report) - A technical report providing guidance on cybersecurity practices, often for telecom and ICT systems; *More info at* [ETSI TR 103 787-1](#)
- **ISO/IEC 27001** (Information Security Management) - An international standard for establishing, implementing, and maintaining an information security management system (ISMS); *More info at* [ISO/IEC 27001](#)
- **ISO/IEC 27002** (Code of Practice for Information Security Controls) - A code of practice providing guidelines for implementing information security controls; *More info at* [ISO/IEC 27002](#)
- **ISO/IEC 27004** (Information Security Management Measurement) - A standard for measuring and evaluating the performance of an information security management system; *More info at* [ISO/IEC 27004](#)
- **ISO/IEC 27005** (Information Security Risk Management) - A standard providing guidelines for information security risk management processes; *More info at* [ISO/IEC 27005](#)

- **ISO/IEC 31000** (Risk Management Guidelines) - An international standard offering principles and guidelines for managing risk across organizations; *More info at* [ISO/IEC 31000](#)
- **ITIL** (Information Technology Infrastructure Library) - A set of practices for IT service management (ITSM) focused on aligning IT services with business needs; *More info at* [ITIL](#)
- **NIST CSF** (National Institute of Standards and Technology Cybersecurity Framework) - A voluntary framework for improving cybersecurity risk management across critical infrastructure; *More info at* [NIST CSF](#)
- **NIST RMF** (NIST Risk Management Framework, often referring to NIST SP 800-37) - A structured process for managing security and privacy risks in information systems; *More info at* [NIST RMF](#)
- **NIST SP 500-291** (Cloud Computing Standards Roadmap) - A document outlining standards and guidelines for cloud computing adoption and security; *More info at* [NIST SP 500-291](#)
- **NIST SP 500-292** (Cloud Computing Reference Architecture) - A reference model defining key components and capabilities for cloud computing systems; *More info at* [NIST SP 500-292](#)
- **NIST SP 800-30** (Guide for Conducting Risk Assessments) - A guide for assessing and managing risks to information systems; *More info at* [NIST SP 800-30](#)
- **NIST SP 800-37** (Risk Management Framework for Information Systems and Organizations) - A framework for integrating security and risk management into the system development lifecycle; *More info at* [NIST SP 800-37](#)
- **NIST SP 800-53** (Security and Privacy Controls for Information Systems and Organizations) - A catalog of security and privacy controls for federal information systems; *More info at* [NIST SP 800-53](#)
- **NIST SP 800-55** (Performance Measurement Guide for Information Security) - A guide for developing metrics to evaluate information security performance; *More info at* [NIST SP 800-55](#)
- **PCI DSS** (Payment Card Industry Data Security Standard) - A set of security standards for organizations handling credit card information to ensure data protection; *More info at* [PCI DSS](#)
- **SABSA** (Sherwood Applied Business Security Architecture) - A framework for developing risk-driven enterprise security architectures aligned with business needs; *More info at* [SABSA](#)
- **SOC 2** (Service Organization Control 2) - A framework for assessing service providers' controls related to security, availability, and confidentiality; *More info at* [SOC 2](#)
- **TOGAF** (The Open Group Architecture Framework) - An enterprise architecture framework for designing, planning, and implementing IT architecture; *More info at* [TOGAF](#)

Index

- acceptable use policy (AUP), 12
- accountability, 4
- administrative controls, 184
- advanced persistent threats (APTs), 59
- Annualized loss expectancy (ALE), 100
- Annualized rate of occurrence (ARO), 100
- application security, 198
- Assessment
 - defined, 39
- assets
 - determine criticality, 151
- assurance provisions, 38
- asymmetric (public key) cryptography, 182
- audit
 - characteristics, 41
 - defined, 39
 - external, 40
 - internal, 39
 - third-party, 40
- automated indicator sharing (AIS), 64
- availability, 52
- balanced scorecard, 34
- best evidence rule, 292
- board of directors, 18
- Business Model for Information Security (BMIS), 31
- Business records retention, 17
- CASB (Cloud Access Security Broker), 149
- certificate pinning, 179
- certificate revocation list (CRL), 179
- chief executive officer (CEO), 19
- chief information security officer (CISO), 19
- chief privacy officer (CPO), 19
- chief risk officer (CRO), 19
- cloud computing
 - defined, 195
- cloud security
 - application security, 198
- cloud security risks
 - auditability, 198
 - availability, 198
 - right-to-audit, 198
- cloud service models
 - PaaS, 196
 - SaaS, 196
- community cloud, 197
- compensating controls, 186
- compliance
 - approaches, 225
 - as a business decision, 114
 - monitoring and enforcement, 224
- compliance enforcement, 44
- compliance requirements, 14
 - contractual, 15
 - legal and regulatory, 114
 - organizational, 15
 - regulatory, 15
- confidentiality, 52
- control
 - owner, 115, 117
- control effectiveness, 113
- control objectives, 113
- control types, 113
 - physical, 113
 - technical, 113
- controls, 113
- corrective controls, 186
- critical success factors (CSFs), 48
- CRL, 179
- cryptography, 179
- cryptography, goals of, 180
 - authentication, 181
 - confidentiality, 180
 - integrity, 180
 - non-repudiation, 181
- cyber insurance, 256
- data encryption, 199
- data location, 199
- data protection technologies, 148
- data security, 150, 199
 - data minimization, 150
 - data obfuscation, 151
- data sovereignty, 199
- decryption, 180

- detective controls, 186
- deterrent controls, 185
- digital forensics, 291, 293
- digital signatures, 183
- directive controls, 185
- disaster recovery exercises
 - read-through, 275
- disaster recovery plan (DRP), 258
- disaster recovery tests
 - full interruption, 276
 - parallel, 276
 - simulation, 276
 - walkthrough, 275
- DLP (Data Loss Prevention), 148
- DRM (Digital Rights Management), 148
- due diligence, 14
- eDiscovery, 290
- EDR (Endpoint Detection and Response), 282
- electronic discovery, 290
- emerging threats, 64
- encryption, 179
- enterprise information security architecture
 - alternative frameworks, 156
 - approaches, 154
 - common frameworks and models, 155
 - types of approaches, 155
- Enterprise Information Security Architecture (EISA), 35
- enterprise information security architectures, 154
- enterprise Risk Management (ERM) Frameworks, 36
- Ethics, 13
- evidence, 292
 - admissibility, 293
 - chain of custody, 293
 - legal aspects, 308
 - preservation, 294
- Evidence categories
 - demonstrative evidence, 292
 - documentary evidence, 292
 - real evidence, 292
 - testimonial evidence, 292
- Exposure factor (EF), 99
- FaaS (Function as a Service), 197
- fault tolerance, 255
- framework types, 153
 - control frameworks, 153
 - risk management frameworks, 153
 - security program frameworks, 153
- Frameworks
 - NIST CSF, 36
 - NIST RMF, 36
- full interruption (recovery tests), 276
- Governance, 2
 - business alignment, 6
 - information security, 4
- governance
 - enterprise, 5
 - third-party relationships, 213
- governance frameworks and standards, 34
- hash functions, 182
- hearsay rule, 292
- high availability, 253, 254
- Hybrid cloud, 197
- IaaS (Infrastructure as a Service), 195
- incident containment
 - activities, 296
 - decision, 297
- incident eradication, 301
- incident investigation, 288
- incident management, 229
 - action plan, 241
 - classification/categorization, 267
 - escalation, 267
 - goals, 230
 - help desk processes, 269, 271
 - metrics and indicators, 270
 - objectives, 236
 - outcomes, 234
 - plans, 233
 - policies and standards, 235
 - relationship to incident response, 229
 - resources, 235
 - role of information security manager, 237
 - strategic alignment, 236
 - systems, 281
 - tools and techniques, 280
 - training and testing, 269
 - vs incident response, 233
- incident management systems
 - EDR, 282
 - IDPS, 281
 - SIEM, 281
- incident response

- assurance process integration, 239
- audits, 287
- awareness and education, 287
- communication channels and methods, 298
- communication networks, 300
- communications, 297
- documenting events, 306
- executing response plans, 288
- foundational concepts, 289
- legal procedures, 306
- models, 284
- notification requirements, 298
- outsourced security providers, 287
- personnel, 284
- resource management, 240
- roles and responsibilities, 285
- skills, 286
- technology foundations, 283
- value delivery, 239
- vs risk management, 238
- incident response plan (IRP), 237
- Information Asset
 - identification and classification, 141
- information asset
 - classification steps, 147
 - identification, 143
 - integration, 146
 - valuation, 144
 - valuation strategies, 144
- information lifecycle, 142
- information security frameworks, 161
 - administrative components, 162
 - educational components, 162
 - management components, 162
 - operational components, 161
 - technical components, 161
- Information Security Governance
 - charter, 11
- information security governance
 - scope, 11
- information security management
 - monitoring and communication, 227
 - performance, 225
- information security management frameworks,
 - 156
 - COBIT, 158
 - ISO/IEC 27001, 158
 - NIST CSF, 159
 - NIST RMF, 160
- Information security manager
 - role, 83
- information security manager
 - broader responsibility, 133
- information security program
 - business case, 127
 - common challenges, 133
 - communications and reporting, 218
 - compliance requirements, 219
 - concepts, 131
 - constraints, 135
 - essential elements, 126
 - evaluation, 218
 - importance of, 127
 - management outcomes, 128
 - metric characteristics, 167
 - metric efficacy, 168
 - metrics and monitoring, 169
 - objectives, 52, 130
 - operations management, 220
 - program management, 220
 - resources, 125, 130
 - roadmap, 136
 - scope and charter, 132
 - tailoring metrics, 170
- information security program outcomes
 - assurance process integration, 130
 - performance measurement, 129
 - resource management, 129
 - risk management, 128
 - strategic alignment, 128
 - value delivery, 129
- information security strategy, 32
- Inherent risk, 55
- inherent risk, 111
- insurance, 45, 255
- integrity, 52
- intrusion detection systems (IDS), 201
- intrusion prevention systems (IPS), 201
- investigation types, 289
- IPSec
 - transport mode, 202
 - tunnel mode, 202
- IS Management Frameworks and Models, 36
- ISACA code of professional ethics, 8
- ISO/IEC 27000 Series, 36
- IT risk management lifecycle, 79
- Key goal indicators (KGIs), 48
- key risk indicators (KRIs), 118

- logical/technical controls, 184
- Management, 2
- MDR (Managed Detection and Response), 282
- Mutual assistance agreements (MAAs), 263
- network security, 200
- OCSP, 179
- online certificate status protocol, 179
- Open Indicators of Compromise (OpenIOC), 65
- Open Source Intelligence (OSINT), 62
- organizational culture, 4, 12
- organizational structure, 18
 - steering committee, 20
- outsourcing, 82, 214
- PaaS (Platform as a Service), 196
- parallel (recovery tests), 276
- parole evidence rule, 292
- penetration testing, 70
- physical controls, 185
- physical Security, 82
- Plan-Do-Check-Act (PDCA), 222
- Planning horizons, 3
 - operational, 3
 - strategic, 3
 - tactical, 3
- post-incident activities
 - cause identification, 305
 - other considerations, 309
- preventive controls, 185
- Private cloud, 197
- program management
 - security reviews, 223
- Public cloud, 197
- quantitative risk analysis
 - annualized loss expectancy (ALE), 100
 - annualized rate of occurrence (ARO), 100
 - exposure factor (EF), 99
 - safeguard evaluation, 98
 - single loss expectancy (SLE), 99
- RACI Matrix, 22
- Read-through/tabletop exercises, 275
- recovery site strategies, 260
- recovery sites, 261
 - cold site, 262
 - DRaaS, 263
 - hot site, 262
 - mirror site, 262
 - mobile site, 262
 - mutual assistance agreements (MAAs), 263
 - warm site, 262
- recovery test categories
 - full operational tests, 276
 - paper tests, 276
 - preparedness tests, 276
- recovery tests
 - categories, 276
- Residual risk, 55, 75
- residual risk, 111
- Responsibility, 4
- right-to-audit, 198
- risk
 - analysis, 75
 - appetite, 54
 - characteristics, 86
 - communication and awareness, 121
 - cost-benefit analysis, 115
 - documentation, 122
 - evaluation, 75, 77
 - impact, 111
 - inherent, 55
 - monitoring, 118
 - owner, 116
 - reporting, 118, 120
 - residual, 55, 75
 - scenarios, 84
 - tolerance, 54
- risk acceptance, 108, 110
- Risk analysis, 76
- risk analysis, 95
 - formulas, 99
 - formulas example, 101
 - gap analysis, 96
 - other methods, 104
- risk analysis techniques, 95
- risk appetite, 54, 108
- Risk assessment, 76
- risk assessment, 45
 - process, 87
 - scenario, 86
- risk assessment methodologies
 - COBIT 5, 92
 - FAIR, 93
 - HARM, 94
 - ISO/IEC 27005, 91
 - NIST 800-30, 89

- PRA, 94
- risk assessment process, 86
- risk avoidance, 108, 109
- risk capacity, 108
- risk categories, 57
 - compliance, 58
 - data, 58
 - human resources, 59
 - operational, 57
 - reputational, 58
 - strategic, 57
 - technology, 58
- risk evaluation, 77, 104
- risk factors, 66
- risk identification, 76
- risk Management, 75
- risk management
 - continuous, 83
- risk management framework, 62
- risk mitigation, 109
- risk ranking, 106
- risk register, 67
- risk response
 - acceptance, 110
 - acceptance framework, 110
 - avoidance, 109
 - mitigation, 109
 - transference, 109
- risk thresholds, 106
- risk tolerance, 54, 108
- risk transference, 109
- risk treatment, 105, 109
- roadmap
 - for information security program, 139
 - for information security strategy, 33
- SaaS (Software as a Service), 196
- SDLC (Systems development life cycle), 140
- security awareness training
 - metrics, 212
 - program, 210
- Security control baselines, 71
- security control categories
 - administrative, 184
 - physical, 185
 - technical/logical, 184
- security control types
 - Compensating, 186
- security controls
 - categories, 184
 - types, 185
- security governance
 - importance of, 9
 - principles, 6
 - six basic outcomes, 9
- security guideline, 166
- security policy, 163
- security procedure, 165
- security standard, 164
- simulation (recovery tests), 276
- Single loss expectancy (SLE), 99
- single point of failure (SPOF), 254
- SOC 1, 41
- SOC 2, 41
- SOC 2 reports
 - Type I, 41
 - Type II, 41
- SOC 3, 41
- span of control, 4
- STIX (Structured Threat Information eXpression), 65
- strategic planning, 37
- Strategy, 2
- structured Threat Information eXpression (STIX), 65
- supply chain risk management, 61
- symmetric cryptography, 181
- System and Organization Controls (SOC), 41
- TAXII (Trusted Automated eXchange of Intelligence Information), 65
- threat actors, 60
- threat classification, 60
- threat feed, 64
- threat intelligence, 62
- threat vectors, 61
- threats, 59
- trusted Automated eXchange of Intelligence Information (TAXII), 65
- Value at Risk (VAR), 102
- virtualization security, 199
- VM escape, 199
- VM sprawl, 199
- vulnerability assessment, 68
- vulnerability categorization, 69
- vulnerability management, 69
- walkthrough (recovery tests), 275
- XDR (Extended Detection and Response), 282
- zero trust, 203